



Information Security Baseline

Security Measure Plan for Microsoft Windows Server 2016

Current release

Authors	Cornelius Moucha
Owner	Siemens CYS GRS PR
Version Number	2.0
Approved By	Jose Antonio Rubio Tora
Status	Release
Document Release Date	2021-10-08
Classification	Restricted
Document ID	BL968
Reference Source	https://sfera.siemens.com

Document History

Version	Author	Date	Description
2.0	Cornelius Moucha	2021-10-08	Update to version 2.0
1.1	Kai Yorck	2019-07-01	See detailed Change Log.
1.0	Kai Yorck	2019-03-15	Initial release

Change Log in the Current Version

Following changes have been submitted during review:

- **Modified [BL968-0003](#) (Configure 'Intel AMT Login Bypass')**: Changed during review: Added exemption for cloud instances. Adapted the Windows 10 MP/Windows Server 2016 rule; not part of CIS Server 2016 Baseline.
- **Revised [BL968-0442](#) (Configure 'Secure Built-in Remote Management Interface')**: Changed during review: Rephrased rule to emphasize existing remote management interfaces. Adapted the Windows Server 2016 rule; not part of CIS Server 2019 Baseline.
- **Modified [BL968-0172](#) (Install Windows using UEFI mode)**: Changed during review: Added exemption for cloud instances where UEFI is currently beta feature.
- **Modified [BL968-1181](#) (Ensure 'Access this computer from the network' is configured)**: Added Backup Operators as allowed value, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Textual rephrasing of whitelist note in rule.
- **Modified [BL968-3021](#) (Ensure 'Adjust memory quotas for a process' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE')**: Changed during review: Added exemption E01. Textual rephrasing of whitelist note in rule, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- **Modified [BL968-1226](#) (Ensure 'Allow log on locally' is configured):** Added exemption for additional, dedicated group, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Textual rephrasing of whitelist note in rule. Rephrased exemption E02.
- **Revised [BL968-2181](#) (Ensure 'Allow log on through Remote Desktop Services' is configured):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Textual rephrasing of whitelist note in rule.
- **Modified [BL968-1251](#) (Ensure 'Deny access to this computer from the network' is configured):** Moved exemption 02 to Rule Note, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Textual rephrasing of blacklist note in rule.
- **Modified [BL968-2586](#) (Ensure 'Generate security audits' is set to 'LOCAL SERVICE, NETWORK SERVICE'):** Changed during review: Added exemption E01. Textual rephrasing of whitelist note in rule, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-3166](#) (Ensure 'Impersonate a client after authentication' is configured):** Changed during review: Added exemption E01. Textual rephrasing of whitelist note in rule. Added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-5032](#) (Ensure 'Log on as a batch job' is configured):** Changed during review: Added exemption for mandatorily required additional service accounts. Textual rephrasing of whitelist note in rule, added Backup Operators as allowed value, added Check section. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-3136](#) (Ensure 'Replace a process level token' is set to 'LOCAL SERVICE, NETWORK SERVICE'):** Changed during review: Added exemption E01. Textual rephrasing of whitelist note in rule, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-3111](#) (Ensure 'Devices: Allowed to format and eject removable media' is set to 'Administrators'):** Changed during review: Removed planned exemption as Microsoft only provides configuration possibilities for pre-defined options, but no dedicated groups providing a secure alternative option. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-2021](#) (Ensure 'Microsoft network client: Digitally sign communications (always)' is set to 'Enabled'):** Changed during review: Added exemption E01. Added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-2936](#) (Ensure 'Microsoft network server: Digitally sign communications (always)' is set to 'Enabled'):** Changed during review: Added exemption E01. Added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-3631](#) (Ensure 'Microsoft network server: Digitally sign communications (if client agrees)' is set to 'Enabled'):** Changed during review: Added exemption E01. Added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- **Modified [BL968-2351](#)** (Ensure 'Network access: Restrict clients allowed to make remote calls to SAM' is set to 'Administrators: Remote Access: Allow' (MS only)): Added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Added exemption E02 for PAM accounts.
- **Modified [BL968-1186](#)** (Ensure 'Hardened UNC Paths' is set to 'Enabled, with "Require Mutual Authentication" and "Require Integrity" set for all NETLOGON and SYSVOL (DC only) shares'): Changed during review: Corrected title and rule with (DC only) for SYSVOL. Added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-4849](#)** (Disable IPv6 (Ensure TCPIP6 Parameter 'DisabledComponents' is set to '0xff (255)')): This rule is consistent with the CIS recommendation. Changed during review: Added exemption E02.
- **Created [BL968-4850](#)** (Ensure 'Turn off notifications network usage' is set to 'Enabled'): Changed during review: Fixed wrong GPO UI path. This rule is consistent with the CIS recommendation.
- **Modified [BL968-2036](#)** (Ensure 'Require pin for pairing' is set to 'Enabled'): Changed during review: Fixed value in compliance with 1607, added Check section. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-0077](#)** (Ensure 'Application: Back up log automatically when full' is set to 'Enabled'): Changed during review: Added exemption for server backup including log files. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-0088](#)** (Ensure 'Application: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'): Changed during review: Added exemption for server backup including log files. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-2599](#)** (Ensure 'Security: Back up log automatically when full' is set to 'Enabled'): Changed during review: Added exemption for server backup including log files. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-0098](#)** (Ensure 'Security: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'): Changed during review: Added exemption for server backup including log files. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-4888](#)** (Ensure 'Setup: Back up log automatically when full' is set to 'Enabled'): Changed during review: Added exemption for server backup including log files. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-4860](#)** (Ensure 'Setup: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'): Changed during review: Added exemption for server backup including log files. This rule is not consistent with the CIS recommendation.
- **Created [BL968-0020](#)** (Ensure 'System: Back up log automatically when full' is set to 'Enabled'): Changed during review: Added exemption for server backup including log files. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

- Created [BL968-6125](#) (Ensure 'System: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'): Changed during review: Added exemption for server backup including log files. Added exemption 01. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-0616](#) (Ensure 'Check for the latest virus and spyware definitions before running a scheduled scan' is set to 'Enabled'): Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696). Changed during review: Aligned GPO UI path to Windows Server 2016 v1607.
- Revised [BL968-2931](#) (Ensure 'WinRM Service: Allow Basic authentication' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Added 'Policies' to the UI path in the Implementation.
- Modified [BL968-2596](#) (Ensure 'WinRM Service: Allow remote server management through WinRM' is set to 'Disabled'): Combined exemption 02 and 03. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Added 'Policies' to the UI path in the Implementation.
- Created [BL968-0325](#) (Configure TLS Cipher Suite Ordering): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115). Changed during review: Added 'Policies' to the UI path in the Implementation.
- Modified [BL968-0177](#) (Permissions on Shared Folders): Changed during review: Rephrased rule text. Rephrased exemption 01. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- Modified [BL968-1066](#) (Use Domain User Accounts): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Added exemption E03 for PAM solutions.

Changes in version 2.0:

- With this version of the Security Measure Plan, the Windows Server 2016 and Windows Server 2019 Security Measure Plans are aligned as much as possible. The last four digits of the rule number are kept identical for both Security Measure Plans as well as the text is kept in sync as much as possible.
- Deleted BL968-2742 (Configure 'Maximum password age' for enabled administrator accounts): Rule combined with BL968-2741.
- Deleted BL968-8186 (Configure 'Minimum password length' for enabled administrator accounts): Rule combined with BL968-2261.
- Deleted BL968-5816 (Configure 'Accounts: Rename administrator account'): Removed as only very limited benefit due to login via well-known SID: Security-By-Obscurity.
- Deleted BL968-4006 (Configure 'Accounts: Rename guest account'): Removed as only very limited benefit due to login via well-known SID: Security-By-Obscurity.
- Deleted BL968-0176 (Configure 'Audit: Audit the access of global system objects'): Removed as not relevant from security perspective: rule demands disabled (default value), but if anyone wants to set enabled, it is better from security perspective.
- Deleted BL968-0311 (Configure 'Devices: Allow undock without having to log on'):

Removed as servers in docking stations are very rarely in place.

- **Deleted BL968-0496 (Configure 'Devices: Restrict CD-ROM access to locally logged-on user only')**: Removed as inserting CD-ROM requires physical access and according rationale, sharing requires manual configuring a share for this. Too less security benefit for too much attackers work.
- **Deleted BL968-0676 (Configure 'Devices: Restrict floppy access to locally logged-on user only')**: Removed as inserting floppy requires physical access and according rationale, sharing requires manual configuring a share for this. Too less security benefit for too much attackers work.
- **Deleted BL968-0591 (Configure 'Interactive logon: Require smart card')**: Removed rule as alternative two factor authentication solutions (e.g., PAM solutions) and fallback solutions (e.g., broken or lost smart cards) are not possible if the setting is activated. Removal of the rule does not imply that authentication to an ACP 3 system is allowed without second factor.
- **Deleted BL968-5076 (Ensure 'Network security: Force logoff when logon hours expire' is set to 'Enabled')**: Removed as there are no logon hours at Siemens, a global company with rotating business hours.
- **Deleted BL968-0306 (Configure 'Shutdown: Clear virtual memory pagefile')**: Removed due to only very few security benefit: rule for encryption exists and if not encrypted, there's much more data to steal than only that in cache/pagefile.
- **Deleted BL968-0631 (Configure 'System cryptography: Use Certificate Rules on Windows Executables for Software Restriction')**: Removed as there are no Software Restriction policies used at Siemens and if, there would be much more to configure than just this setting: Too less security benefit at the moment.
- **Deleted BL968-5306 (Ensure 'Windows Firewall: Domain: Outbound connections' is set to 'Allow (default)')**: Removed: Outbound is more operational topic. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Deleted BL968-2961 (Ensure 'Windows Firewall: Domain: Settings: Display a notification' is set to 'No')**: Removed as this is just a user experience and operational topic.
- **Deleted BL968-2431 (Configure 'Windows Firewall: Domain: Settings: Apply local connection security rules')**: Removed this rule which is not part of CIS Windows Server 2016 as we would increase the risk level for the complete domain if we open dedicated ports required only for few servers.
- **Deleted BL968-4541 (Configure 'Windows Firewall: Domain: Settings: Apply local firewall rules')**: Removed this rule which is not part of CIS Windows Server 2016 as we would increase the risk level for the complete domain if we open dedicated ports required only for few servers.
- **Deleted BL968-5231 (Ensure 'Windows Firewall: Private: Outbound connections' is set to 'Allow (default)')**: Removed as outbound is more operational topic. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Deleted BL968-3271 (Ensure 'Windows Firewall: Private: Settings: Display a notification' is set to 'No')**: Removed as this is an operational topic.
- **Deleted BL968-2386 (Configure 'Windows Firewall: Private: Settings: Apply local connection security rules')**: Removed this rule which is not part of CIS Windows Server 2016 as administrators in non-domain environment shall open dedicated

ports only in 'Private' but not in 'Public' Profile.

- **Deleted BL968-3056 (Configure 'Windows Firewall: Private: Settings: Apply local firewall rules')**: Removed this rule which is not part of CIS Windows Server 2016 as administrators in non-domain environment shall open dedicated ports only in 'Private' but not in 'Public' Profile.
- **Deleted BL968-3816 (Ensure 'Windows Firewall: Public: Settings: Display a notification' is set to 'No')**: Removed as this is an operational topic.
- **Deleted BL968-0166 (Configure: 'Audit Process Termination')**: Removed this rule which is not part of CIS Windows Server 2016 as Security benefit vs. log volume is low; not in MS baseline anymore and field-test shows significant reduction of events.
- **Deleted BL968-3811 (Ensure 'Audit Logoff' is set to 'Success')**: Removed this rule which is not part of CIS Windows Server 2016 as Security benefit vs. log volume is low; not in MS baseline anymore and field-test shows significant reduction of events.
- **Deleted BL968-3147 (Configure 'Audit User / Device Claims')**: Removed this rule which is not part of CIS Windows Server 2016 as Security benefit vs. log volume is low; not in MS baseline anymore and field-test shows significant reduction of events.
- **Deleted BL968-2501 (Ensure 'Audit Authorization Policy Change' is set to 'Success')**: Removed in alignment with Windows 10 and in alignment with Basic Domain Policy.
- **Deleted BL968-0101 (Configure 'Encryption oracle remediation')**: Rule has been combined with BL968-0100.
- **Deleted BL968-3142 (Configure 'Boot-Start Driver Initialization Policy')**: Rule has been combined with BL968-3141.
- **Deleted BL968-1696 (Configure 'Untrusted Font Blocking')**: Removed this rule as Microsoft deprecated this setting. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Deleted BL968-3901 (Configure 'Let Windows apps *')**: Removed: Divided into separate rules.
- **Deleted BL968-1271 (Configure 'Block launching Windows Store apps with Windows Runtime API access from hosted content.')**: Removed according MS recommendation. This rule is consistent with the CIS recommendation for Windows Server 2016.
- **Deleted BL968-1721 (Configure 'Disable pre-release features or settings')**: This setting does not exist anymore and has been replaced with more granular settings (BL968-5871 and BL968-006).
- **Deleted BL968-5911 (Configure 'Allow Extensions')**: Microsoft decided to remove Microsoft Edge from the system.
- **Deleted BL968-2611 (Configure 'Allow InPrivate Browsing')**: Microsoft decided to remove Microsoft Edge from the system.
- **Deleted BL968-1751 (Configure 'Configure cookies')**: Microsoft decided to remove Microsoft Edge from the system.
- **Deleted BL968-2921 (Configure 'Configure Password Manager')**: Microsoft decided to remove Microsoft Edge from the system.
- **Deleted BL968-3341 (Configure 'Configure Pop-up Blocker')**: Microsoft decided to remove Microsoft Edge from the system.
- **Deleted BL968-1301 (Configure 'Prevent using Localhost IP address for WebRTC')**: Microsoft decided to remove Microsoft Edge from the system.
- **Deleted BL968-4861 (Configure 'Configure search suggestions in Address bar')**: Microsoft decided to remove Microsoft Edge from the system.

- **Deleted BL968-0116 (Configure 'SMBv1 Protocol')**: Replaced by CIS-Rules BL968-4843 / 4844.
- **Deleted BL968-0076 (Configure 'DES and 3DES Cipher' in Schannel)**: Rule divided in two separate rules.
- **Deleted BL968-0052 (Configure 'TLS 1.2' Protocol in WinHTTP)**: Windows Server 2019 (and 2016) already natively support TLS 1.2 for client-server communications over WinHTTP.
- **Deleted BL968-2743 (Additional Rules for all Passwords)**: Removed as all requests are already part of the Siemens Information Security Framework.
- **Deleted BL968-0104 (Password for the Guest Account)**: Removed as Guest account is already disabled by rule and must not be used.
- **Deleted BL968-0321 (Registry Access for Corporate Scan Service)**: Removed rule as this functionality is now covered by Endpoint Detection & Response
- **Deleted BL968-0716 (Configure 'Maximum application log size')**: Rule deleted as those setting will be overwritten by corresponding setting in UI path `Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service`.
- **Deleted BL968-0396 (Configure 'Maximum security log size')**: Rule deleted as those setting will be overwritten by corresponding setting in UI path `Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service`.
- **Deleted BL968-0466 (Configure 'Maximum system log size')**: Rule deleted as those setting will be overwritten by corresponding setting in UI path `Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service`.
- **Deleted BL968-0316 (Configure 'Retain application log')**: Rule deleted as those setting will be overwritten by corresponding setting in UI path `Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service`.
- **Deleted BL968-0681 (Configure 'Retain security log')**: Rule deleted as those setting will be overwritten by corresponding setting in UI path `Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service`.
- **Deleted BL968-0126 (Configure 'Retain system log')**: Rule deleted as those setting will be overwritten by corresponding setting in UI path `Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service`.
- **Deleted BL968-0009 (Configure 'Retention method for application log')**: Rule deleted as those setting will be overwritten by corresponding setting in UI path `Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service`.
- **Deleted BL968-0082 (Configure 'Retention method for security log')**: Rule deleted as those setting will be overwritten by corresponding setting in UI path `Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service`.
- **Deleted BL968-0220 (Configure 'Retention method for system log')**: Rule deleted as those setting will be overwritten by corresponding setting in UI path `Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service`.

Log Service.

- **Modified [BL968-0031](#) (Require TPM 2.0):** Moved the TPM requirements from Implementation to Rule section. Extended the Check to handle systems where the data is unavailable.
- **Modified [BL968-0249](#) (Update BIOS/UEFI Firmware):** Adapted the Windows 10 MP/Windows Server 2016 rule; not part of CIS Server 2019 Baseline. Added exemption for systems without BIOS configuration capabilities.
- **Modified [BL968-0452](#) (Disable Compatibility Support Module):** Adapted the Windows 10 MP/Windows Server 2016 rule; not part of CIS Server 2016 Baseline. Added two exemptions for existing BIOS installed systems and cloud instances.
- **Modified [BL968-0362](#) (Enable UEFI Secure Boot):** Adapted the Windows 10 MP/Windows Server 2016 rule; not part of CIS Server 2016 Baseline. Added exemption for cloud instances.
- **Created [BL968-0988](#) (Enable Virtualization Technology):** Adapted the Windows 10 MP rule; not part of CIS Server 2016 Baseline. Added exemption for systems with BIOS/UEFI not offering virtualizations.
- **Created [BL968-4812](#) (Enable IOMMU Technology):** Adapted the Windows 10 MP rule; not part of CIS Server 2016 Baseline.
- **Revised [BL968-0986](#) (Set a BIOS/UEFI Boot Password):** Adapted the Windows 10 MP/Windows Server 2016 rule; not part of CIS Server 2019 Baseline.
- **Modified [BL968-0620](#) (Set a Password to Access BIOS/UEFI Setup):** Adapted the Windows 10 MP/Windows Server 2016 rule; not part of CIS Server 2019 Baseline. Added exemption for systems without BIOS configuration capabilities.
- **Revised [BL968-0003](#) (Configure 'Intel AMT Login Bypass'):** Adapted the Windows 10 MP/Windows Server 2016 rule; not part of CIS Server 2016 Baseline.
- **Revised [BL968-0442](#) (Configure 'Secure Built-in Remote Management Interface'):** Adapted the Windows Server 2016 rule; not part of CIS Server 2019 Baseline.
- **Revised [BL968-0172](#) (Install Windows using UEFI mode):** Adapted the Windows 10 MP/Windows Server 2019 rule; not part of CIS Server 2016 Baseline.
- **Revised [BL968-0017](#) (Limit Additional Server Roles):** Adapted the Windows Server 2012/Windows Server 2019 rule; not part of CIS Server 2016 Baseline.
- **Revised [BL968-0032](#) (Configure 'Windows Server Features'):** Adapted the Windows Server 2012/Windows Server 2019 rule; not part of CIS Server 2016 Baseline.
- **Revised [BL968-0110](#) (Configure 'Active Directory Domain Membership'):** Adapted the Windows Server 2012/Windows Server 2019 rule; not part of CIS Server 2016 Baseline.
- **Revised [BL968-0747](#) (No Direct Remote Access from the Internet):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-0769](#) (Subscribe to the Cybersecurity Governance Announcement Service):** Adapted the Windows 10 MP rule; not part of CIS Server 2016 Baseline.
- **Revised [BL968-2896](#) (Ensure 'Enforce password history' is set to '24 or more password(s)'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-2741](#) (Ensure 'Maximum password age' is configured):** Added Check section, added different account types. Combined with previous rule BL968-2742. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- **Modified [BL968-5266](#)** (Ensure 'Minimum password age' is set to '1 or more day(s)'): Added PAM exemption, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-2261](#)** (Ensure 'Minimum password length' is configured): Added Check section, added different account types. Combined with previous rule BL968-8186. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-3756](#)** (Ensure 'Password must meet complexity requirements' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-2411](#)** (Ensure 'Store passwords using reversible encryption' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-5216](#)** (Ensure 'Account lockout duration' is configured): Added Check section, removed 0 as allowed value. This rule is not consistent with the CIS recommendation as it uses a different minimum duration of 30.
- **Revised [BL968-5041](#)** (Ensure 'Account lockout threshold' is set to '10 or fewer invalid logon attempt(s), but not 0'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-5241](#)** (Ensure 'Reset account lockout counter after' is set to '30 or more minute(s)'): Added Check section, no need to set an EVAL flag. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1606](#)** (Ensure 'Access Credential Manager as a trusted caller' is set to 'No One'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-1181](#)** (Ensure 'Access this computer from the network' is configured): Added Backup Operators as allowed value, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-5526](#)** (Ensure 'Act as part of the operating system' is set to 'No One'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-3986](#)** (Ensure 'Add workstations to domain' is set to 'Administrators' (DC only)): Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-3021](#)** (Ensure 'Adjust memory quotas for a process' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE'): Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-1226](#)** (Ensure 'Allow log on locally' is configured): Added exemption for additional, dedicated group, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-2181](#)** (Ensure 'Allow log on through Remote Desktop Services' is configured): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- **Modified [BL968-5841](#) (Ensure 'Back up files and directories' is configured):** Textual rephrasing of whitelist note in rule, added Backup operators as allowed value, added Check section. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-5246](#) (Ensure 'Change the system time' is set to 'Administrators, LOCAL SERVICE'):** Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-3046](#) (Ensure 'Change the time zone' is set to 'Administrators, LOCAL SERVICE'):** Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1406](#) (Ensure 'Create a pagefile' is set to 'Administrators'):** Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-3231](#) (Ensure 'Create a token object' is set to 'No One'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-5831](#) (Ensure 'Create global objects' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE'):** Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1281](#) (Ensure 'Create permanent shared objects' is set to 'No One'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-3541](#) (Ensure 'Create symbolic links' is set to 'Administrators'):** Textual rephrasing of whitelist note in rule, also allowed special group Virtual Machines, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1221](#) (Ensure 'Debug programs' is set to 'Administrators'):** Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-1251](#) (Ensure 'Deny access to this computer from the network' is configured):** Moved exemption 02 to Rule Note, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1156](#) (Ensure 'Deny log on as a batch job' is set to 'Guests'):** Textual rephrasing of blacklist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1831](#) (Ensure 'Deny log on as a service' is set to 'Guests'):** Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-4186](#) (Ensure 'Deny log on locally' is set to 'Guests'):** Textual rephrasing of blacklist note in rule, added Check section, no need to set an EVAL

flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- **Modified [BL968-2561](#) (Ensure 'Deny log on through Remote Desktop Services' is configured):** Textual rephrasing of blacklist note in rule, moved exemption 01 to Rule Note, added Check section. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-5881](#) (Ensure 'Enable computer and user accounts to be trusted for delegation' is configured):** Removed inappropriate note in rule, added second CIS crossreference, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1756](#) (Ensure 'Force shutdown from a remote system' is set to 'Administrators'):** Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-2586](#) (Ensure 'Generate security audits' is set to 'LOCAL SERVICE, NETWORK SERVICE'):** Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-3166](#) (Ensure 'Impersonate a client after authentication' is configured):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-4146](#) (Ensure 'Increase scheduling priority' is set to 'Administrators, Window Manager\Window Manager Group'):** Textual rephrasing of whitelist note in rule, also allowed Window Manager Group, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-4031](#) (Ensure 'Load and unload device drivers' is set to 'Administrators'):** Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1441](#) (Ensure 'Lock pages in memory' is set to 'No One'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-5032](#) (Ensure 'Log on as a batch job' is configured):** Textual rephrasing of whitelist note in rule, added Backup Operators as allowed value, added Check section. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-5031](#) (Configure 'Log on as a service'):** Not part of CIS Windows Server 2016. Adapted from Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1701](#) (Ensure 'Manage auditing and security log' is configured):** Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-2716](#) (Ensure 'Modify an object label' is set to 'No One'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-3861](#) (Ensure 'Modify firmware environment values' is set to**

- 'Administrators'**): Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-5176](#)** (Ensure **'Perform volume maintenance tasks'** is set to **'Administrators'**): Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-5136](#)** (Ensure **'Profile single process'** is set to **'Administrators'**): Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-2221](#)** (Ensure **'Profile system performance'** is set to **'Administrators, NT SERVICE\WdiServiceHost'**): Textual rephrasing of whitelist note in rule, added WdiServiceHost in alignment with CIS and feedback, added Check section. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-3136](#)** (Ensure **'Replace a process level token'** is set to **'LOCAL SERVICE, NETWORK SERVICE'**): Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-2811](#)** (Ensure **'Restore files and directories'** is configured): Textual rephrasing of whitelist note in rule, added Backup Operators as allowed value, added Check section. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-5236](#)** (Ensure **'Shut down the system'** is set to **'Administrators'**): Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-4801](#)** (Ensure **'Synchronize directory service data'** is set to **'No One'**): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-4176](#)** (Ensure **'Take ownership of files or other objects'** is set to **'Administrators'**): Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-3116](#)** (Ensure **'Accounts: Administrator account status'** is set to **'Disabled' (MS only)**): Rule is only valid for Member servers. Added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-5281](#)** (Ensure **'Accounts: Block Microsoft accounts'** is set to **'Users can't add or log on with Microsoft accounts'**): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-1081](#)** (Ensure **'Accounts: Guest account status'** is set to **'Disabled' (MS only)**): Rule is only valid for Member servers. Added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-4126](#)** (Ensure **'Accounts: Limit local account use of blank passwords to**

- console logon only' is set to 'Enabled'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1716](#) (Ensure 'Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings' is set to 'Enabled'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-3301](#) (Ensure 'Audit: Shut down system immediately if unable to log security audits' is set to 'Disabled'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0621](#) (Configure 'DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax'):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0181](#) (Configure 'DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax'):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-3111](#) (Ensure 'Devices: Allowed to format and eject removable media' is set to 'Administrators'):** Added exemption for additional, dedicated group, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-5566](#) (Ensure 'Devices: Prevent users from installing printer drivers' is set to 'Enabled'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-1036](#) (Ensure 'Domain controller: Allow server operators to schedule tasks' is set to 'Disabled' (DC only)):** Changed scope to DC only, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-1206](#) (Ensure 'Domain controller: LDAP server signing requirements' is set to 'Require signing' (DC only)):** Changed scope to DC only, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-1126](#) (Ensure 'Domain controller: Refuse machine account password changes' is set to 'Disabled' (DC only)):** Changed scope to DC only, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-4151](#) (Ensure 'Domain member: Digitally encrypt or sign secure channel data (always)' is set to 'Enabled'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-1886](#) (Ensure 'Domain member: Digitally encrypt secure channel data (when possible)' is set to 'Enabled'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-2266](#) (Ensure 'Domain member: Digitally sign secure channel data (when possible)' is set to 'Enabled'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens

Windows Server 2019 (BL942).

- Revised [BL968-4266](#) (Ensure 'Domain member: Disable machine account password changes' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3476](#) (Ensure 'Domain member: Maximum machine account password age' is set to '30 or fewer days, but not 0'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2756](#) (Ensure 'Domain member: Require strong (Windows 2000 or later) session key' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-0471](#) (Configure 'Interactive logon: Display user information when the session is locked'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3941](#) (Ensure 'Interactive logon: Do not require CTRL+ALT+DEL' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2796](#) (Ensure 'Interactive logon: Do not display last user name' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Modified [BL968-5071](#) (Ensure 'Interactive logon: Machine inactivity limit' is set to '900 or fewer second(s), but not 0'): Added PAM exemption, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5072](#) (Configure 'Interactive logon: Machine account logout threshold'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- Modified [BL968-1571](#) (Ensure 'Interactive logon: Number of previous logons to cache (in case domain controller is not available)' is set to '0' (MS only)): Added exemption, added Check section. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942), added an exemption.
- Revised [BL968-2311](#) (Ensure 'Interactive logon: Require Domain Controller Authentication to unlock workstation' is set to 'Enabled' (MS only)): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3401](#) (Ensure 'Interactive logon: Smart card removal behavior' is configured): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2021](#) (Ensure 'Microsoft network client: Digitally sign communications (always)' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5611](#) (Ensure 'Microsoft network client: Digitally sign communications

- (if server agrees)' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4441](#) (Ensure 'Microsoft network client: Send unencrypted password to third-party SMB servers' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-4521](#) (Ensure 'Microsoft network server: Amount of idle time required before suspending session' is set to '15 or fewer minute(s)'): Removed the limitation to not set 0, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-0051](#) (Configure 'Microsoft network server: Attempt S4U2Self to obtain claim information'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-2936](#) (Ensure 'Microsoft network server: Digitally sign communications (always)' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-3631](#) (Ensure 'Microsoft network server: Digitally sign communications (if client agrees)' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-2486](#) (Ensure 'Microsoft network server: Disconnect clients when logon hours expire' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Modified [BL968-4531](#) (Ensure 'Microsoft network server: Server SPN target name validation level' is set to 'Required from client' (MS only)): Fixed wrong value name, removed exemption 01, added Check section. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-1931](#) (Ensure 'Network access: Allow anonymous SID/Name translation' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-5726](#) (Ensure 'Network access: Do not allow anonymous enumeration of SAM accounts' is set to 'Enabled' (MS only)): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-5631](#) (Ensure 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' is set to 'Enabled' (MS only)): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-5016](#) (Ensure 'Network access: Do not allow storage of passwords and credentials for network authentication' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-5501](#) (Ensure 'Network access: Let Everyone permissions apply to

- anonymous users' is set to 'Disabled'**): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-3091](#) (Configure 'Network access: Named Pipes that can be accessed anonymously')**: Merged DC and MS setting, removed exemption 01. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-5421](#) (Configure 'Network access: Remotely accessible registry paths')**: Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-3316](#) (Configure 'Network access: Remotely accessible registry paths and sub-paths')**: Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-4041](#) (Ensure 'Network access: Restrict anonymous access to Named Pipes and Shares' is set to 'Enabled')**: Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-2351](#) (Ensure 'Network access: Restrict clients allowed to make remote calls to SAM' is set to 'Administrators: Remote Access: Allow' (MS only))**: Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-5681](#) (Ensure 'Network access: Shares that can be accessed anonymously' is set to 'None')**: Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-4796](#) (Ensure 'Network access: Sharing and security model for local accounts' is set to 'Classic - local users authenticate as themselves')**: Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-1106](#) (Ensure 'Network security: Allow Local System to use computer identity for NTLM' is set to 'Enabled')**: Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-5996](#) (Ensure 'Network security: Allow LocalSystem NULL session fallback' is set to 'Disabled')**: Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-4311](#) (Ensure 'Network Security: Allow PKU2U authentication requests to this computer to use online identities.' is set to 'Disabled')**: Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-5821](#) (Ensure 'Network security: Configure encryption types allowed for Kerberos' is configured)**: Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-5406](#) (Ensure 'Network security: Do not store LAN Manager hash**

- value on next password change' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2161](#) (Ensure 'Network security: LAN Manager authentication level' is set to 'Send NTLMv2 response only. Refuse LM & NTLM'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-1296](#) (Ensure 'Network security: LDAP client signing requirements' is set to 'Require signing'): Added Check section, no need to set an EVAL flag. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-4901](#) (Ensure 'Network security: Minimum session security for NTLM SSP based (including secure RPC) clients' is set to 'Require NTLMv2 session security, Require 128-bit encryption'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-4791](#) (Ensure 'Network security: Minimum session security for NTLM SSP based (including secure RPC) servers' is set to 'Require NTLMv2 session security, Require 128-bit encryption'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-0281](#) (Configure 'Network security: Restrict NTLM: Add remote server exceptions for NTLM authentication'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-0636](#) (Configure 'Network security: Restrict NTLM: Add server exceptions in this domain'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-0646](#) (Configure 'Network security: Restrict NTLM: Audit Incoming NTLM Traffic'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-0056](#) (Configure 'Network security: Restrict NTLM: Audit NTLM authentication in this domain' (DC only)): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - Modified [BL968-0686](#) (Configure 'Network security: Restrict NTLM: Incoming NTLM traffic'): Added exemption for PAM solutions using local pool accounts.
 - Revised [BL968-0981](#) (Configure 'Network security: Restrict NTLM: NTLM authentication in this domain'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-0456](#) (Configure 'Network security: Restrict NTLM: Outgoing NTLM traffic to remote servers'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-0421](#) (Configure 'Recovery console: Allow automatic administrative logon'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-0571](#) (Configure 'Recovery console: Allow floppy copy and access to all drives and all folders'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-4576](#) (Ensure 'Shutdown: Allow system to be shut down without

having to log on' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- **Modified [BL968-0931](#)** (Configure 'System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing'): Removed exemption 01. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-0381](#)** (Configure 'System cryptography: Force strong key protection for user keys stored on the computer'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-2676](#)** (Ensure 'System objects: Require case insensitivity for non-Windows subsystems' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1486](#)** (Ensure 'System objects: Strengthen default permissions of internal system objects (e.g. Symbolic Links)' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-0081](#)** (Configure 'System Settings: Optional subsystems'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-4942](#)** (Ensure 'User Account Control: Admin Approval Mode for the Built-in Administrator account' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
- **Created [BL968-4943](#)** (Ensure 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' is set to 'Prompt for consent on the secure desktop'): This rule is consistent with the CIS recommendation.
- **Created [BL968-4944](#)** (Ensure 'User Account Control: Behavior of the elevation prompt for standard users' is set to 'Automatically deny elevation requests'): This rule is consistent with the CIS recommendation.
- **Created [BL968-4945](#)** (Ensure 'User Account Control: Detect application installations and prompt for elevation' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
- **Created [BL968-4946](#)** (Ensure 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
- **Created [BL968-4947](#)** (Ensure 'User Account Control: Run all administrators in Admin Approval Mode' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
- **Created [BL968-4948](#)** (Ensure 'User Account Control: Switch to the secure desktop when prompting for elevation' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
- **Created [BL968-4949](#)** (Ensure 'User Account Control: Virtualize file and registry write failures to per-user locations' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
- **Modified [BL968-3226](#)** (Ensure 'Windows Firewall: Domain: Firewall state' is set to 'On (recommended)'): Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-1741](#)** (Ensure 'Windows Firewall: Domain: Inbound connections' is

- set to 'Block (default)'): Added exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3446](#) (Ensure 'Windows Firewall: Domain: Logging: Name' is configured): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-5486](#) (Ensure 'Windows Firewall: Domain: Logging: Size limit (KB)' is configured): Added Check section, no need to set an EVAL flag. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-5971](#) (Ensure 'Windows Firewall: Domain: Logging: Log dropped packets' is set to 'Yes'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-5291](#) (Ensure 'Windows Firewall: Domain: Logging: Log successful connections' is set to 'Yes'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Modified [BL968-5576](#) (Ensure 'Windows Firewall: Private: Firewall state' is set to 'On (recommended)'): Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Modified [BL968-3486](#) (Ensure 'Windows Firewall: Private: Inbound connections' is set to 'Block (default)'): Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-1901](#) (Ensure 'Windows Firewall: Private: Logging: Name' is configured): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-5121](#) (Ensure 'Windows Firewall: Private: Logging: Size limit (KB)' is configured): Added Check section, no need to set an EVAL flag. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-1646](#) (Ensure 'Windows Firewall: Private: Logging: Log dropped packets' is set to 'Yes'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-5141](#) (Ensure 'Windows Firewall: Private: Logging: Log successful connections' is set to 'Yes'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Modified [BL968-5086](#) (Ensure 'Windows Firewall: Public: Firewall state' is set to 'On (recommended)'): Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Modified [BL968-2696](#) (Ensure 'Windows Firewall: Public: Inbound connections' is set to 'Block (default)'): Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server

2019 (BL942).

- Revised [BL968-5656](#) (Ensure 'Windows Firewall: Public: Outbound connections' is set to 'Block'): Added Check section, no need to set an EVAL flag. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1431](#) (Ensure 'Windows Firewall: Public: Settings: Apply local firewall rules' is set to 'No'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5446](#) (Ensure 'Windows Firewall: Public: Settings: Apply local connection security rules' is set to 'No'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5061](#) (Ensure 'Windows Firewall: Public: Logging: Name' is configured): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4526](#) (Ensure 'Windows Firewall: Public: Logging: Size limit (KB)' is configured): Added Check section, no need to set an EVAL flag. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2706](#) (Ensure 'Windows Firewall: Public: Logging: Log dropped packets' is set to 'Yes'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4911](#) (Ensure 'Windows Firewall: Public: Logging: Log successful connections' is set to 'Yes'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5866](#) (Ensure 'Audit Credential Validation' is set to 'Success and Failure'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-0361](#) (Ensure 'Audit Kerberos Authentication Service' is set to 'Success and Failure' (DC Only)): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-0511](#) (Ensure 'Audit Kerberos Service Ticket Operations' is set to 'Success and Failure' (DC Only)): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1736](#) (Ensure 'Audit Computer Account Management' is set to 'Success' (DC only)): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4741](#) (Ensure 'Audit Distribution Group Management' is set to 'Success' (DC only)): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2956](#) (Ensure 'Audit Other Account Management Events' is set to

- 'Success' (DC only):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-5391](#) (Ensure 'Audit Security Group Management' is set to 'Success'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-4016](#) (Ensure 'Audit User Account Management' is set to 'Success and Failure'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-1591](#) (Ensure 'Audit PNP Activity' is set to 'Success'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-2511](#) (Ensure 'Audit Process Creation' is set to 'Success'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-4586](#) (Ensure 'Audit Directory Service Access' is set to 'Failure' (DC only)):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-1611](#) (Ensure 'Audit Directory Service Changes' is set to 'Success' (DC only)):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-3146](#) (Ensure 'Audit Account Lockout' is set to 'Failure'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-3366](#) (Ensure 'Audit Group Membership' is set to 'Success'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-4261](#) (Ensure 'Audit Logon' is set to 'Success and Failure'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-5431](#) (Ensure 'Audit Other Logon/Logoff Events' is set to 'Success and Failure'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-5251](#) (Ensure 'Audit Special Logon' is set to 'Success'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0346](#) (Ensure 'Audit File Share' is set to 'Success and Failure'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0347](#) (Ensure 'Audit Detailed File Share' is set to 'Failure'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-7474](#) (Ensure 'Audit Other Object Access Events' is set to 'Success and Failure'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0441](#) (Ensure 'Audit Removable Storage' is set to 'Success and Failure'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- Revised [BL968-2916](#) (Ensure 'Audit Audit Policy Change' is set to 'Success'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3381](#) (Ensure 'Audit Authentication Policy Change' is set to 'Success'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-0776](#) (Ensure 'Audit MPSSVC Rule-Level Policy Change' is set to 'Success and Failure'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-0956](#) (Ensure 'Audit Other Policy Change Events' is set to 'Failure'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3361](#) (Ensure 'Audit Sensitive Privilege Use' is set to 'Success and Failure'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3481](#) (Ensure 'Audit Other System Events' is set to 'Success and Failure'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2211](#) (Ensure 'Audit Security State Change' is set to 'Success'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2381](#) (Ensure 'Audit Security System Extension' is set to 'Success'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4281](#) (Ensure 'Audit System Integrity' is set to 'Success and Failure'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1506](#) (Ensure 'Prevent enabling lock screen camera' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5111](#) (Ensure 'Prevent enabling lock screen slide show' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4681](#) (Ensure 'Allow Input Personalization' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-0612](#) (Ensure LAPS AdmPwd GPO Extension / CSE is installed (MS only)): This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Modified [BL968-4626](#) (Ensure 'Do not allow password expiration time longer than required by policy' is set to 'Enabled' (MS only)): Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Modified [BL968-2851](#) (Ensure 'Enable Local Admin Password Management' is set to 'Enabled' (MS only)): Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- **Modified [BL968-3176](#)** (Ensure 'Password Settings: Password Complexity' is set to 'Enabled: Large letters + small letters + numbers + special characters' (MS only)): Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-5551](#)** (Ensure 'Password Settings: Password Length' is set to 'Enabled: 15 or more' (MS only)): Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-5341](#)** (Ensure 'Password Settings: Password Age (Days)' is set to 'Enabled: 45 or fewer' (MS only)): Rephrased exemption 01, added Check section. Aligned value with password policy. This rule is relaxed from the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1191](#)** (Ensure 'Apply UAC restrictions to local accounts on network logons' is set to 'Enabled' (MS only)): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-4843](#)** (Ensure 'Configure SMB v1 client driver' is set to 'Enabled: Disable driver (recommended)'): This rule is consistent with the CIS recommendation.
- **Created [BL968-4844](#)** (Ensure 'Configure SMB v1 server' is set to 'Disabled'): This rule is consistent with the CIS recommendation.
- **Created [BL968-0063](#)** (Ensure 'Enable Structured Exception Handling Overwrite Protection (SEHOP)' is set to 'Enabled'): This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-4845](#)** (Ensure 'Extended Protection for LDAP Authentication (Domain Controllers only)' is set to 'Enabled: Enabled, always (recommended)' (DC Only)): This rule is consistent with the CIS recommendation.
- **Modified [BL968-5741](#)** (Ensure 'NetBT NodeType configuration' is set to 'Enabled: P-node (recommended)'): Removed Implementation 02, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-4076](#)** (Ensure 'WDigest Authentication' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-4171](#)** (Ensure 'MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-5706](#)** (Ensure 'MSS: (DisableIPSourceRouting IPv6) IP source routing protection level (protects against packet spoofing)' is set to 'Enabled: Highest protection, source routing is completely disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-2131](#)** (Ensure 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' is set to 'Enabled: Highest protection, source routing is completely disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- Revised [BL968-3251](#) (Ensure 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Modified [BL968-1456](#) (Ensure 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds' is set to 'Enabled: 300,000 or 5 minutes (recommended)'): Removed exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-4847](#) (Ensure 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
- Revised [BL968-1346](#) (Ensure 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2496](#) (Ensure 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-4846](#) (Ensure 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended)' is set to 'Enabled: 5 or fewer seconds'): This rule is consistent with the CIS recommendation.
- Revised [BL968-2498](#) (Ensure 'MSS: (TcpMaxDataRetransmissions IPv6) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2497](#) (Ensure 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-4848](#) (Ensure 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' is set to 'Enabled: 90% or less'): This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1586](#) (Ensure 'Turn off multicast name resolution' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5046](#) (Ensure 'Enable Font Providers' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4466](#) (Ensure 'Enable insecure guest logons' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1071](#) (Ensure 'Turn on Mapper I/O (LLTDIO) driver' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2246](#) (Ensure 'Turn on Responder (RSPNDR) driver' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS

recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- Revised [BL968-5956](#) (Ensure 'Turn off Microsoft Peer-to-Peer Networking Services' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5966](#) (Ensure 'Prohibit installation and configuration of Network Bridge on your DNS domain network' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1561](#) (Ensure 'Prohibit use of Internet Connection Sharing on your DNS domain network' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5491](#) (Ensure 'Require domain users to elevate when setting a network's location' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1186](#) (Ensure 'Hardened UNC Paths' is set to 'Enabled, with "Require Mutual Authentication" and "Require Integrity" set for all NETLOGON and SYSVOL shares' (DC only)): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-4849](#) (Disable IPv6 (Ensure TCPIP6 Parameter 'DisabledComponents' is set to '0xff (255)')): This rule is consistent with the CIS recommendation.
- Revised [BL968-2791](#) (Ensure 'Configuration of wireless settings using Windows Connect Now' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5051](#) (Ensure 'Prohibit access of the Windows Connect Now wizards' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1386](#) (Ensure 'Minimize the number of simultaneous connections to the Internet or a Windows Domain' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2816](#) (Ensure 'Prohibit connection to non-domain networks when connected to domain authenticated network' is set to 'Enabled' (MS only)): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-4850](#) (Ensure 'Turn off notifications network usage' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
- Revised [BL968-5126](#) (Ensure 'Include command line in process creation events' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942). The advantage of exact auditing is assessed higher by Siemens CYS Protection Services than the possible risk of password loss in the specific case of entering a clear text password in the command line.

- **Modified [BL968-0100](#)** (Ensure 'Encryption Oracle Remediation' is set to 'Enabled: Force Updated Clients'): Removed relaxed ACP12 setting and merged both rules with appropriate value. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-0581](#)** (Configure 'Allow delegating default credentials'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-0566](#)** (Configure 'Allow delegating default credentials with NTLM-only server authentication'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-0567](#)** (Configure 'Restrict delegation of credentials to remote servers'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-0445](#)** (Ensure 'Turn On Virtualization Based Security' is set to 'Enabled'): This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-0846](#)** (Ensure 'Turn On Virtualization Based Security: Select Platform Security Level' is set to 'Secure Boot'): This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-1444](#)** (Ensure 'Turn On Virtualization Based Security: Virtualization Based Protection of Code Integrity' is set to 'Enabled with UEFI lock'): This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-0529](#)** (Ensure 'Turn On Virtualization Based Security: Credential Guard Configuration' is set to 'Enabled with UEFI lock' (MS Only)): This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-3141](#)** (Ensure 'Boot-Start Driver Initialization Policy' is set to 'Enabled: Good only'): Removed relaxed ACP12 rule, merged both rules and set appropriate value. This rule is consistent, but strengthened, to the CIS recommendation.
- **Revised [BL968-2656](#)** (Ensure 'Configure registry policy processing: Do not apply during periodic background processing' is set to 'Enabled: FALSE'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-5461](#)** (Ensure 'Configure registry policy processing: Process even if the Group Policy objects have not changed' is set to 'Enabled: TRUE'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-5851](#)** (Ensure 'Continue experiences on this device' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-3256](#)** (Ensure 'Turn off background refresh of Group Policy' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-2216](#)** (Configure 'Turn off access to the Store'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-0896](#)** (Configure 'Turn off Automatic Root Certificates Update'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-4236](#)** (Ensure 'Turn off downloading of print drivers over HTTP' is set

- to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2326](#) (Ensure 'Turn off handwriting personalization data sharing' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-1276](#) (Ensure 'Turn off handwriting recognition error reporting' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-1046](#) (Ensure 'Turn off Internet Connection Wizard if URL connection is referring to Microsoft.com' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-2271](#) (Ensure 'Turn off Internet download for Web publishing and online ordering wizards' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-2901](#) (Ensure 'Turn off printing over HTTP' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-5476](#) (Ensure 'Turn off Registration if URL connection is referring to Microsoft.com' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-3576](#) (Ensure 'Turn off Search Companion content file updates' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-5226](#) (Ensure 'Turn off the "Order Prints" picture task' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-4166](#) (Ensure 'Turn off the "Publish to Web" task for files and folders' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-1321](#) (Ensure 'Turn off the Windows Messenger Customer Experience Improvement Program' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-1841](#) (Ensure 'Turn off Windows Customer Experience Improvement Program' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-2571](#) (Ensure 'Turn off Windows Error Reporting' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- Revised [BL968-0156](#) (Configure 'KDC support for claims, compound authentication and Kerberos armoring' (DC only)): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-0211](#) (Configure 'Kerberos client support for claims, compound authentication and Kerberos armoring'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4696](#) (Ensure 'Support device authentication using certificate' is set to 'Enabled: Automatic'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5151](#) (Ensure 'Disallow copying of user input methods to the system account for sign-in' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4136](#) (Ensure 'Block user from showing account details on sign-in' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5006](#) (Ensure 'Do not display network selection UI' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5211](#) (Ensure 'Do not enumerate connected users on domain-joined computers' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Modified [BL968-1666](#) (Ensure 'Enumerate local users on domain-joined computers' is set to 'Disabled' (MS only)): Restricted scope to MS only, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3776](#) (Ensure 'Turn off app notifications on the lock screen' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-4854](#) (Ensure 'Turn off picture password sign-in' is set to 'Enabled'): This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2841](#) (Ensure 'Turn on convenience PIN sign-in' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1461](#) (Ensure 'Allow network connectivity during connected-standby (on battery)' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1462](#) (Ensure 'Allow network connectivity during connected-standby (plugged in)' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3416](#) (Ensure 'Require a password when a computer wakes (on battery)' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This

rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- Revised [BL968-3417](#) (Ensure 'Require a password when a computer wakes (plugged in)' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5771](#) (Ensure 'Configure Offer Remote Assistance' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1621](#) (Ensure 'Configure Solicited Remote Assistance' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3291](#) (Ensure 'Enable RPC Endpoint Mapper Client Authentication' is set to 'Enabled' (MS only)): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1516](#) (Ensure 'Restrict Unauthenticated RPC clients' is set to 'Enabled: Authenticated' (MS only)): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3371](#) (Ensure 'Microsoft Support Diagnostic Tool: Turn on MSDT interactive communication with support provider' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2836](#) (Ensure 'Enable/Disable PerfTrack' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-4857](#) (Ensure 'Turn off the advertising ID' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
- Created [BL968-4858](#) (Ensure 'Enable Windows NTP Client' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
- Created [BL968-4859](#) (Ensure 'Enable Windows NTP Server' is set to 'Disabled' (MS only)): This rule is consistent with the CIS recommendation.
- Revised [BL968-4906](#) (Ensure 'Allow a Windows app to share application data between users' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-5901](#) (Ensure 'Let Windows apps access account information' is set to 'Enable: Force Deny'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.
- Created [BL968-5902](#) (Ensure 'Let Windows apps access call history' is set to 'Enable: Force Deny'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.
- Created [BL968-5903](#) (Ensure 'Let Windows apps access contacts' is set to 'Enable: Force Deny'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.
- Created [BL968-5904](#) (Ensure 'Let Windows apps access email' is set to 'Enable: Force Deny'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server

2019 (BL942), but divided into separate rules.

- Created [BL968-5905](#) (Ensure 'Let Windows apps access location' is set to 'Enable: Force Deny'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.
- Created [BL968-5906](#) (Ensure 'Let Windows apps access messaging' is set to 'Enable: Force Deny'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.
- Created [BL968-5907](#) (Ensure 'Let Windows apps access motion' is set to 'Enable: Force Deny'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.
- Created [BL968-5908](#) (Ensure 'Let Windows apps access the calendar' is set to 'Enable: Force Deny'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.
- Created [BL968-5909](#) (Ensure 'Let Windows apps access the camera' is set to 'Enable: Force Deny'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.
- Created [BL968-5910](#) (Ensure 'Let Windows apps access the microphone' is set to 'Enable: Force Deny'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.
- Created [BL968-5923](#) (Ensure 'Let Windows apps access trusted devices' is set to 'Enable: Force Deny'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.
- Created [BL968-5912](#) (Ensure 'Let Windows apps control radios' is set to 'Enable: Force Deny'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.
- Created [BL968-5914](#) (Ensure 'Let Windows apps make phone calls' is set to 'Enable: Force Deny'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.
- Created [BL968-5915](#) (Ensure 'Let Windows apps access notifications' is set to 'Enable: Force Deny'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.
- Revised [BL968-2316](#) (Ensure 'Allow Microsoft accounts to be optional' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4926](#) (Ensure 'Disallow Autoplay for non-volume devices' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1966](#) (Ensure 'Set the default behavior for AutoRun' is set to 'Enabled: Do not execute any autorun commands'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4501](#) (Ensure 'Turn off Autoplay' is set to 'Enabled: All drives'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3876](#) (Ensure 'Use enhanced anti-spoofing when available' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-7367](#) (Ensure 'Prevent memory overwrite on restart' is set to

- 'Disabled'):** Not part of CIS Windows Server 2016 and Siemens Windows Server 2019 (BL942). Rule has been copied from Siemens Windows 10 (BL696).
- **Created [BL968-0226](#) (Configure the policy 'Provide the unique identifiers for your organization'):** Not part of CIS Windows Server 2016 and Siemens Windows Server 2019 (BL942). Rule has been copied from Siemens Windows 10 (BL696).
 - **Modified [BL968-0326](#) (Configure 'Choose drive encryption method and cipher strength (Windows 10 [Version 1511] and later)'):** Removed the option 'AES-CBC 256 bit' for fixed and operating system drives. Not part of CIS Windows Server 2016. Aligned with Windows Server 2019 (BL942).
 - **Created [BL968-1636](#) (Ensure 'Choose how BitLocker-protected fixed drives can be recovered' is set to 'Disabled'):** Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).
 - **Modified [BL968-0336](#) (Configure 'Enforce drive encryption type on fixed data drives'):** Combined both exemptions into one. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0491](#) (Configure 'Allow network unlock at startup'):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Created [BL968-1871](#) (Ensure 'Choose how BitLocker-protected operating system drives can be recovered' is set to 'Disabled'):** Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).
 - **Modified [BL968-0331](#) (Configure 'Configure minimum PIN length for startup'):** Changed required PIN length to 8 chars. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-0291](#) (Configure 'Enforce drive encryption type on operating system drives'):** Combined both exemptions into one. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0841](#) (Configure 'Require additional authentication at startup'):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Created [BL968-9206](#) (Ensure 'Choose how BitLocker-protected removable drives can be recovered' is set to 'Disabled'):** Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).
 - **Created [BL968-1101](#) (Configure the policy 'Configure use of passwords for removable data drives'):** Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).
 - **Created [BL968-1671](#) (Configure the policy 'Control use of BitLocker on removable drives'):** Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).
 - **Revised [BL968-0626](#) (Configure 'Enforce drive encryption type on removable data drives'):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-5171](#) (Ensure 'Allow Use of Camera' is set to 'Disabled'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-4451](#) (Ensure 'Turn off Microsoft consumer experiences' is set to 'Enabled'):** Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-2036](#) (Ensure 'Require pin for pairing' is set to 'Enabled: Always'):**

Changed value in compliance with 1607, added Check section. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- Revised [BL968-3081](#) (Ensure 'Do not display the password reveal button' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1991](#) (Ensure 'Enumerate administrator accounts on elevation' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4046](#) (Ensure 'Allow Telemetry' is set to 'Enabled 0 - Security [Enterprise Only]'): Added Check section, no need to set an EVAL flag. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4646](#) (Ensure 'Do not show feedback notifications' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5871](#) (Ensure 'Toggle user control over Insider builds' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-0077](#) (Ensure 'Application: Back up log automatically when full' is set to 'Enabled'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-0088](#) (Ensure 'Application: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'): This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-0007](#) (Ensure 'Application: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'): Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-2599](#) (Ensure 'Security: Back up log automatically when full' is set to 'Enabled'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-0098](#) (Ensure 'Security: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'): This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-0044](#) (Ensure 'Security: Specify the maximum log file size (KB)' is set to 'Enabled: 524,288 or greater'): Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-4888](#) (Ensure 'Setup: Back up log automatically when full' is set to 'Enabled'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-4860](#) (Ensure 'Setup: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'): This rule is not consistent with the CIS recommendation.
- Created [BL968-7113](#) (Ensure 'Setup: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'): This rule is nearly consistent with the CIS recommendation. Increased size from 32,768 KB to 131,072 kb. Aligned with Siemens Windows Server 2019 (BL942).

- Created [BL968-0020](#) (Ensure 'System: Back up log automatically when full' is set to 'Enabled'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-6125](#) (Ensure 'System: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'): Added exemption 01. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-4701](#) (Ensure 'System: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'): Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-1421](#) (Ensure 'File Explorer: Configure Windows Defender SmartScreen' is set to 'Disabled'): Not consistent with CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).
- Revised [BL968-5766](#) (Ensure 'Turn off Data Execution Prevention for Explorer' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5496](#) (Ensure 'Turn off heap termination on corruption' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2881](#) (Ensure 'Turn off shell protocol protected mode' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4191](#) (Ensure 'Turn off location' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4936](#) (Ensure 'Prevent the usage of OneDrive for file storage' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4686](#) (Ensure 'Do not allow passwords to be saved' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-4826](#) (Ensure 'Restrict Remote Desktop Services users to a single Remote Desktop Services session' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3746](#) (Ensure 'Do not allow COM port redirection' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-4864](#) (Ensure 'Do not allow drive redirection' is set to 'Enabled'): Added exemption from review feedback. This rule is consistent with the CIS recommendation.
- Revised [BL968-1291](#) (Ensure 'Do not allow LPT port redirection' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-4865](#) (Ensure 'Do not allow supported Plug and Play device redirection' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
- Modified [BL968-4546](#) (Ensure 'Always prompt for password upon connection' is set to 'Enabled'): Rephrased exemption 01 for PAM exemption. This rule is consistent

- with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-2466](#)** (Ensure 'Require secure RPC communication' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0436](#)** (Ensure 'Require use of specific security layer for remote (RDP) connections' is set to 'Enabled: SSL'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-0586](#)** (Ensure 'Require user authentication for remote connections by using Network Level Authentication' is set to 'Enabled'): Added PAM exemption. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-4776](#)** (Ensure 'Set client connection encryption level' is set to 'Enabled: High Level'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-0256](#)** (Configure 'Server Authentication Certificate Template'): Update in alignment with Siemens Windows Server 2019 (BL942). Not part of CIS Windows Server 2016.
 - **Revised [BL968-5191](#)** (Ensure 'Set time limit for active but idle Remote Desktop Services sessions' is set to 'Enabled: 12 hours or less'): Added Check section, no need to set an EVAL flag. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-3211](#)** (Ensure 'Set time limit for disconnected sessions' is set to 'Enabled: 18 hours or less'): Added Check section, no need to set an EVAL flag. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-1416](#)** (Ensure 'Do not delete temp folders upon exit' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-1417](#)** (Ensure 'Do not use temporary folders per session' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-1971](#)** (Ensure 'Prevent downloading of enclosures' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-5781](#)** (Configure 'Allow Cortana'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-4891](#)** (Configure 'Allow Cortana above lock screen'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-1376](#)** (Ensure 'Allow indexing of encrypted files' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-2046](#)** (Configure 'Allow search and Cortana to use location'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-2286](#)** (Configure 'Disable all apps from Windows Store'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-1641](#)** (Configure 'Turn off Automatic Download and Install of

- updates'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-1941](#) (Configure 'Turn off the offer to update to the latest version of Windows'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-1161](#) (Configure 'Turn off the Store application'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - Created [BL968-4866](#) (Ensure 'Turn off KMS Client Online AVS Validation' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
 - Created [BL968-4870](#) (Ensure 'Configure local setting override for reporting to Microsoft MAPS' is set to 'Disabled'): This rule is consistent with the CIS recommendation.
 - Revised [BL968-1051](#) (Ensure 'Join Microsoft MAPS' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Created [BL968-0541](#) (Ensure 'Scan all downloaded files and attachments' is set to 'Enabled'): Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).
 - Created [BL968-4871](#) (Ensure 'Turn on behavior monitoring' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
 - Revised [BL968-3616](#) (Ensure 'Configure Watson events' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Created [BL968-0616](#) (Ensure 'Check for the latest virus and spyware security intelligence before running a scheduled scan' is set to 'Enabled'): Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).
 - Created [BL968-0746](#) (Ensure 'Scan archive files' is set to 'Enabled'): Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).
 - Created [BL968-4872](#) (Ensure 'Scan removable drives' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
 - Created [BL968-4873](#) (Ensure 'Turn on e-mail scanning' is set to 'Enabled'): This rule is consistent with the CIS recommendation.
 - Created [BL968-4869](#) (Ensure Windows Defender as Fallback): This rule is not consistent with the CIS recommendation as we use Windows Defender AV only as Fallback; added an exemption in case WDAV must be used as primary AV product.
 - Created [BL968-4877](#) (Ensure 'Explorer: Configure Windows SmartScreen' is set to 'Disabled'): Modified GPO path to comply with 1607. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows 10 (BL696).
 - Revised [BL968-0005](#) (Configure 'Use Windows Hello for Business'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-2306](#) (Ensure 'Allow suggested apps in Windows Ink Workspace' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
 - Revised [BL968-4511](#) (Ensure 'Allow Windows Ink Workspace' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- Revised [BL968-3761](#) (Ensure 'Allow user control over installs' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Created [BL968-4878](#) (Ensure 'Computer Configuration: Always install with elevated privileges' is set to 'Disabled'): This rule is consistent with the CIS recommendation.
- Revised [BL968-5066](#) (Ensure 'Prevent Internet Explorer security prompt for Windows Installer scripts' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3651](#) (Ensure 'Sign-in last interactive user automatically after a system-initiated restart' is set to 'Disabled'): Added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3516](#) (Ensure 'Turn on PowerShell Script Block Logging' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2071](#) (Ensure 'Turn on PowerShell Transcription' is set to 'Disabled'): This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-0936](#) (Configure 'PowerShell: Turn on Script Execution'): Added note for compliance of more restrictive setting. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5106](#) (Ensure 'WinRM Client: Allow Basic authentication' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3596](#) (Ensure 'WinRM Client: Allow unencrypted traffic' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3921](#) (Ensure 'WinRM Client: Disallow Digest authentication' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-0911](#) (Configure 'WinRM Client: Allow CredSSP authentication'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-2931](#) (Ensure 'WinRM Service: Allow Basic authentication' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Modified [BL968-2596](#) (Ensure 'WinRM Service: Allow remote server management through WinRM' is set to 'Disabled'): Combined exemption 02 and 03. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-3126](#) (Ensure 'WinRM Service: Allow unencrypted traffic' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- Revised [BL968-5411](#) (Ensure 'WinRM Service: Disallow WinRM from storing RunAs credentials' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

- **Modified [BL968-3514](#)** (Ensure 'Allow Remote Shell Access' is set to 'Disabled'): Combined exemption 02 and 03. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-1011](#)** (Ensure 'Enable screen saver' is set to 'Enabled'): Added PAM exemption. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-3326](#)** (Ensure 'Password protect the screen saver' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-4456](#)** (Ensure 'Screen saver timeout' is set to 'Enabled: 900 seconds or fewer, but not 0'): Added PAM exemption. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1936](#)** (Ensure 'Turn off toast notifications on the lock screen' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-3506](#)** (Ensure 'Turn off Help Experience Improvement Program' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-2421](#)** (Ensure 'Do not preserve zone information in file attachments' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-4885](#)** (Ensure 'Notify antivirus programs when opening attachments' is set to 'Enabled'): This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-2206](#)** (Ensure 'Configure Windows spotlight on lock screen' is set to 'Disabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-5581](#)** (Ensure 'Do not suggest third-party content in Windows spotlight' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-3666](#)** (Ensure 'Turn off all Windows spotlight features' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-4706](#)** (Ensure 'Prevent users from sharing files within their profile.' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Created [BL968-4886](#)** (Ensure 'User Configuration: Always install with elevated privileges' is set to 'Disabled'): This rule is consistent with the CIS recommendation.
- **Revised [BL968-1076](#)** (Ensure 'Prevent Codec Download' is set to 'Enabled'): Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1001](#)** (Configure 'Maximum log size (KB) of PowerShell'): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Revised [BL968-1000](#)** (Configure 'Maximum log size (KB) of TerminalServices-

- LocalSessionManager**): Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
- **Modified [BL968-0991](#) (Configure 'Access-based Enumeration')**: Added exemption 01. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0261](#) (Configure 'Default Share Permissions')**: Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-5981](#) (Configure 'IPv6 Site-to-Site Static Tunnels')**: Added exemption 01. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0531](#) (Configure 'Sharing Wizard')**: Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0117](#) (Configure 'SMBv3 protocol encryption')**: Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-0118](#) (Do Not Allow Unencrypted SMB Sessions)**: Removed exemption. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0641](#) (Configure 'Additional LSA Protection')**: Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0596](#) (Disable 'SSL 2.0' Protocol)**: Added PowerShell Implementation and Check. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Revised [BL968-0891](#) (Disable 'SSL 3.0' Protocol)**: Added PowerShell Implementation and Check. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Revised [BL968-0312](#) (Disable 'TLS 1.0' Protocol)**: Added PowerShell Implementation and Check. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Revised [BL968-0313](#) (Disable 'TLS 1.1' Protocol)**: Added PowerShell Implementation and Check. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Created [BL968-0314](#) (Enable 'TLS 1.2' Protocol)**: Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Created [BL968-0315](#) (Disable 'NULL' Cipher Suites)**: Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Created [BL968-3906](#) (Disable 'DES' Cipher Suites)**: Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Revised [BL968-0821](#) (Disable 'RC2' Cipher Suites)**: Added PowerShell Implementation and Check. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Revised [BL968-0131](#) (Disable 'RC4' Cipher Suites)**: Added PowerShell Implementation and Check. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Created [BL968-0317](#) (Disable 'Triple DES' Cipher Suites)**: Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS

- 10 (BL115).
- **Created [BL968-0318](#) (Enable 'AES 128/128' Cipher Suites):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Created [BL968-0319](#) (Enable 'AES 256/256' Cipher Suites):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Created [BL968-0320](#) (Disable 'MD5' Hashing Algorithm):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Created [BL968-0323](#) (Disable 'SHA-1' Hashing Algorithm):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Revised [BL968-0484](#) (Ensure sufficient 'Modulus Size in the DHE Key Exchange'):** Added PowerShell Implementation and Check. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Created [BL968-0325](#) (Configure TLS Cipher Suite Ordering):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).
 - **Modified [BL968-0322](#) (Enable the Corporate Scan Service Agent):** Rephrased exemption to clarify standalone systems with Siemens Corporate Network access. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0066](#) (Enable an Endpoint Detection and Response Agent):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-0422](#) (Install a Virus Scanner):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942); simplified *Exemption* and *Implementation* as the required settings are now part of separate rules.
 - **Modified [BL968-0771](#) (Kerberos Delegation):** Added Note to the Rule. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0004](#) (Reset Password of kbrtgt Account Regularly (DC only)):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-0177](#) (Permissions on Shared Folders):** Rephrased exemption 01. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0271](#) (Special Protection of High-Value Accounts):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-1066](#) (Use Domain User Accounts):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0416](#) (Users allowed for Remote Desktop):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Modified [BL968-0049](#) (Domain Controller Hardening):** Aligned implementation. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).
 - **Revised [BL968-0516](#) (Configure 'Auditing Privileged Group Members Logons'):** Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

- **Modified [BL968-0486](#) (Configure 'Audit User Mailbox Attribute' (DC only)):** Specified more precisely in the Implementation which Audit policies need to be configured. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942); linked to corresponding audit rules.
- **Modified [BL968-0180](#) (Check Windows Service Paths):** Changed script in Implementation and Check section. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens Windows 10 (BL696).
- **Modified [BL968-0002](#) (Configure 'DACLS for Windows Services'):** Aligned implementation. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Table of Contents

Current release	2
Document History	2
Change Log in the Current Version	2
Table of Contents	42
Introduction	69
Objectives	69
Scope and Applicability	69
Roles and Responsibilities	70
Information Security Policy Framework	70
Readability	70
Hardware Security	72
BL968-0031 - Require TPM 2.0	72
BL968-0249 - Update BIOS/UEFI Firmware	75
BL968-0452 - Disable Compatibility Support Module	77
BL968-0362 - Enable UEFI Secure Boot	79
BL968-0988 - Enable Virtualization Technology	81
BL968-4812 - Enable IOMMU Technology	83
BL968-0986 - Set a BIOS/UEFI Boot Password	84
BL968-0620 - Set a Password to Access BIOS/UEFI Setup	86
BL968-0003 - Configure 'Intel AMT Login Bypass'	87
BL968-0442 - Configure 'Secure Built-in Remote Management Interface'	89
System Setup	91
BL968-0172 - Install Windows using UEFI mode	91
BL968-0017 - Limit Additional Server Roles	93
BL968-0032 - Configure 'Windows Server Features'	95
BL968-0110 - Configure 'Active Directory Domain Membership'	96
BL968-0747 - No Direct Remote Access from the Internet	98
BL968-0769 - Subscribe to the Cybersecurity Governance Announcement Service	99
Account Policies	100
Password Policy	100
BL968-2896 - Ensure 'Enforce password history' is set to '24 or more password(s)'	100
BL968-2741 - Ensure 'Maximum password age' is configured	102
BL968-5266 - Ensure 'Minimum password age' is set to '1 or more day(s)'	104
BL968-2261 - Ensure 'Minimum password length' is configured	106
BL968-3756 - Ensure 'Password must meet complexity requirements' is set to 'Enabled'	108
BL968-2411 - Ensure 'Store passwords using reversible encryption' is set to 'Disabled'	110
Account Lockout Policy	111

BL968-5216 - Ensure 'Account lockout duration' is configured	111
BL968-5041 - Ensure 'Account lockout threshold' is set to '10 or fewer invalid logon attempt(s), but not 0'	113
BL968-5241 - Ensure 'Reset account lockout counter after' is set to '30 or more minute(s)'	115
Local Policies	117
User Rights Assignment	117
BL968-1606 - Ensure 'Access Credential Manager as a trusted caller' is set to 'No One'	117
BL968-1181 - Ensure 'Access this computer from the network' is configured	119
BL968-5526 - Ensure 'Act as part of the operating system' is set to 'No One'	121
BL968-3986 - Ensure 'Add workstations to domain' is set to 'Administrators' (DC only)	122
BL968-3021 - Ensure 'Adjust memory quotas for a process' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE'	124
BL968-1226 - Ensure 'Allow log on locally' is configured	126
BL968-2181 - Ensure 'Allow log on through Remote Desktop Services' is configured	128
BL968-5841 - Ensure 'Back up files and directories' is configured	130
BL968-5246 - Ensure 'Change the system time' is set to 'Administrators, LOCAL SERVICE'	132
BL968-3046 - Ensure 'Change the time zone' is set to 'Administrators, LOCAL SERVICE'	134
BL968-1406 - Ensure 'Create a pagefile' is set to 'Administrators'	136
BL968-3231 - Ensure 'Create a token object' is set to 'No One'	137
BL968-5831 - Ensure 'Create global objects' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE'	139
BL968-1281 - Ensure 'Create permanent shared objects' is set to 'No One'	141
BL968-3541 - Ensure 'Create symbolic links' is set to 'Administrators'	142
BL968-1221 - Ensure 'Debug programs' is set to 'Administrators'	144
BL968-1251 - Ensure 'Deny access to this computer from the network' is configured	146
BL968-1156 - Ensure 'Deny log on as a batch job' is set to 'Guests'	148
BL968-1831 - Ensure 'Deny log on as a service' is set to 'Guests'	150
BL968-4186 - Ensure 'Deny log on locally' is set to 'Guests'	152
BL968-2561 - Ensure 'Deny log on through Remote Desktop Services' is configured	154
BL968-5881 - Ensure 'Enable computer and user accounts to be trusted for delegation' is configured	156
BL968-1756 - Ensure 'Force shutdown from a remote system' is set to 'Administrators'	158
BL968-2586 - Ensure 'Generate security audits' is set to 'LOCAL SERVICE, NETWORK SERVICE'	160
BL968-3166 - Ensure 'Impersonate a client after authentication' is configured	162
BL968-4146 - Ensure 'Increase scheduling priority' is set to 'Administrators, Window Manager\Window Manager Group'	164

BL968-4031 - Ensure 'Load and unload device drivers' is set to 'Administrators'	166
BL968-1441 - Ensure 'Lock pages in memory' is set to 'No One'	168
BL968-5032 - Ensure 'Log on as a batch job' is configured	169
BL968-5031 - Configure 'Log on as a service'	171
BL968-1701 - Ensure 'Manage auditing and security log' is configured	172
BL968-2716 - Ensure 'Modify an object label' is set to 'No One'	174
BL968-3861 - Ensure 'Modify firmware environment values' is set to 'Administrators'	175
BL968-5176 - Ensure 'Perform volume maintenance tasks' is set to 'Administrators'	177
BL968-5136 - Ensure 'Profile single process' is set to 'Administrators'	179
BL968-2221 - Ensure 'Profile system performance' is set to 'Administrators, NT SERVICE\WdiServiceHost'	181
BL968-3136 - Ensure 'Replace a process level token' is set to 'LOCAL SERVICE, NETWORK SERVICE'	183
BL968-2811 - Ensure 'Restore files and directories' is configured	185
BL968-5236 - Ensure 'Shut down the system' is set to 'Administrators'	187
BL968-4801 - Ensure 'Synchronize directory service data' is set to 'No One'	189
BL968-4176 - Ensure 'Take ownership of files or other objects' is set to 'Administrators'	191
Security Options	193
Accounts	193
BL968-3116 - Ensure 'Accounts: Administrator account status' is set to 'Disabled' (MS only)	193
BL968-5281 - Ensure 'Accounts: Block Microsoft accounts' is set to 'Users can't add or log on with Microsoft accounts'	195
BL968-1081 - Ensure 'Accounts: Guest account status' is set to 'Disabled' (MS only)	197
BL968-4126 - Ensure 'Accounts: Limit local account use of blank passwords to console logon only' is set to 'Enabled'	199
Audit	201
BL968-1716 - Ensure 'Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings' is set to 'Enabled'	201
BL968-3301 - Ensure 'Audit: Shut down system immediately if unable to log security audits' is set to 'Disabled'	203
DCOM	205
BL968-0621 - Configure 'DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax'	205
BL968-0181 - Configure 'DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax'	

Devices	206
BL968-3111 - Ensure 'Devices: Allowed to format and eject removable media' is set to 'Administrators'	207
BL968-5566 - Ensure 'Devices: Prevent users from installing printer drivers' is set to 'Enabled'	207
Domain controller	209
BL968-1036 - Ensure 'Domain controller: Allow server operators to schedule tasks' is set to 'Disabled' (DC only)	211
BL968-1206 - Ensure 'Domain controller: LDAP server signing requirements' is set to 'Require signing' (DC only)	211
BL968-1126 - Ensure 'Domain controller: Refuse machine account password changes' is set to 'Disabled' (DC only)	213
Domain member	215
BL968-4151 - Ensure 'Domain member: Digitally encrypt or sign secure channel data (always)' is set to 'Enabled'	217
BL968-1886 - Ensure 'Domain member: Digitally encrypt secure channel data (when possible)' is set to 'Enabled'	217
BL968-2266 - Ensure 'Domain member: Digitally sign secure channel data (when possible)' is set to 'Enabled'	219
BL968-4266 - Ensure 'Domain member: Disable machine account password changes' is set to 'Disabled'	221
BL968-3476 - Ensure 'Domain member: Maximum machine account password age' is set to '30 or fewer days, but not 0'	223
BL968-2756 - Ensure 'Domain member: Require strong (Windows 2000 or later) session key' is set to 'Enabled'	225
Interactive logon	226
BL968-0471 - Configure 'Interactive logon: Display user information when the session is locked'	228
BL968-3941 - Ensure 'Interactive logon: Do not require CTRL+ALT+DEL' is set to 'Disabled'	228
BL968-2796 - Ensure 'Interactive logon: Do not display last user name' is set to 'Enabled'	229
	231

BL968-5071 - Ensure 'Interactive logon: Machine inactivity limit' is set to '900 or fewer second(s), but not 0'	233
BL968-5072 - Configure 'Interactive logon: Machine account lockout threshold'	235
BL968-1571 - Ensure 'Interactive logon: Number of previous logons to cache (in case domain controller is not available)' is set to '0' (MS only)	236
BL968-2311 - Ensure 'Interactive logon: Require Domain Controller Authentication to unlock workstation' is set to 'Enabled' (MS only)	238
BL968-3401 - Ensure 'Interactive logon: Smart card removal behavior' is configured	240
Microsoft network client	242
BL968-2021 - Ensure 'Microsoft network client: Digitally sign communications (always)' is set to 'Enabled'	242
BL968-5611 - Ensure 'Microsoft network client: Digitally sign communications (if server agrees)' is set to 'Enabled'	244
BL968-4441 - Ensure 'Microsoft network client: Send unencrypted password to third-party SMB servers' is set to 'Disabled'	246
Microsoft network server	248
BL968-4521 - Ensure 'Microsoft network server: Amount of idle time required before suspending session' is set to '15 or fewer minute(s)'	248
BL968-0051 - Configure 'Microsoft network server: Attempt S4U2Self to obtain claim information'	250
BL968-2936 - Ensure 'Microsoft network server: Digitally sign communications (always)' is set to 'Enabled'	251
BL968-3631 - Ensure 'Microsoft network server: Digitally sign communications (if client agrees)' is set to 'Enabled'	253
BL968-2486 - Ensure 'Microsoft network server: Disconnect clients when logon hours expire' is set to 'Enabled'	255
BL968-4531 - Ensure 'Microsoft network server: Server SPN target name validation level' is set to 'Required from client' (MS only)	257
Network access	259
BL968-1931 - Ensure 'Network access: Allow anonymous SID/Name translation' is set to 'Disabled'	259

BL968-5726 - Ensure 'Network access: Do not allow anonymous enumeration of SAM accounts' is set to 'Enabled' (MS only)	261
BL968-5631 - Ensure 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' is set to 'Enabled' (MS only)	263
BL968-5016 - Ensure 'Network access: Do not allow storage of passwords and credentials for network authentication' is set to 'Enabled'	265
BL968-5501 - Ensure 'Network access: Let Everyone permissions apply to anonymous users' is set to 'Disabled'	267
BL968-3091 - Configure 'Network access: Named Pipes that can be accessed anonymously'	269
BL968-5421 - Configure 'Network access: Remotely accessible registry paths'	271
BL968-3316 - Configure 'Network access: Remotely accessible registry paths and sub-paths'	273
BL968-4041 - Ensure 'Network access: Restrict anonymous access to Named Pipes and Shares' is set to 'Enabled'	276
BL968-2351 - Ensure 'Network access: Restrict clients allowed to make remote calls to SAM' is set to 'Administrators: Remote Access: Allow' (MS only)	278
BL968-5681 - Ensure 'Network access: Shares that can be accessed anonymously' is set to 'None'	280
BL968-4796 - Ensure 'Network access: Sharing and security model for local accounts' is set to 'Classic - local users authenticate as themselves'	282
Network security	284
BL968-1106 - Ensure 'Network security: Allow Local System to use computer identity for NTLM' is set to 'Enabled'	284
BL968-5996 - Ensure 'Network security: Allow LocalSystem NULL session fallback' is set to 'Disabled'	286
BL968-4311 - Ensure 'Network Security: Allow PKU2U authentication requests to this computer to use online identities.' is set to 'Disabled'	288
BL968-5821 - Ensure 'Network security: Configure encryption types allowed for Kerberos' is configured	290
BL968-5406 - Ensure 'Network security: Do not store LAN Manager hash value on next password change' is set to 'Enabled'	292

BL968-2161 - Ensure 'Network security: LAN Manager authentication level' is set to 'Send NTLMv2 response only. Refuse LM & NTLM'	294
BL968-1296 - Ensure 'Network security: LDAP client signing requirements' is set to 'Require signing'	296
BL968-4901 - Ensure 'Network security: Minimum session security for NTLM SSP based (including secure RPC) clients' is set to 'Require NTLMv2 session security, Require 128-bit encryption'	298
BL968-4791 - Ensure 'Network security: Minimum session security for NTLM SSP based (including secure RPC) servers' is set to 'Require NTLMv2 session security, Require 128-bit encryption'	300
BL968-0281 - Configure 'Network security: Restrict NTLM: Add remote server exceptions for NTLM authentication'	302
BL968-0636 - Configure 'Network security: Restrict NTLM: Add server exceptions in this domain'	303
BL968-0646 - Configure 'Network security: Restrict NTLM: Audit Incoming NTLM Traffic'	304
BL968-0056 - Configure 'Network security: Restrict NTLM: Audit NTLM authentication in this domain' (DC only)	305
BL968-0686 - Configure 'Network security: Restrict NTLM: Incoming NTLM traffic'	307
BL968-0981 - Configure 'Network security: Restrict NTLM: NTLM authentication in this domain'	308
BL968-0456 - Configure 'Network security: Restrict NTLM: Outgoing NTLM traffic to remote servers'	310
Recovery console	312
BL968-0421 - Configure 'Recovery console: Allow automatic administrative logon'	312
BL968-0571 - Configure 'Recovery console: Allow floppy copy and access to all drives and all folders'	313
Shutdown	314
BL968-4576 - Ensure 'Shutdown: Allow system to be shut down without having to log on' is set to 'Disabled'	314
System cryptography	316
BL968-0931 - Configure 'System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing'	316

BL968-0381 - Configure 'System cryptography: Force strong key protection for user keys stored on the computer'	
System objects	317
	319
BL968-2676 - Ensure 'System objects: Require case insensitivity for non-Windows subsystems' is set to 'Enabled'	319
BL968-1486 - Ensure 'System objects: Strengthen default permissions of internal system objects (e.g. Symbolic Links)' is set to 'Enabled'	
System settings	321
	323
BL968-0081 - Configure 'System Settings: Optional subsystems'	
User Account Control	323
	325
BL968-4942 - Ensure 'User Account Control: Admin Approval Mode for the Built-in Administrator account' is set to 'Enabled'	325
BL968-4943 - Ensure 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' is set to 'Prompt for consent on the secure desktop'	327
BL968-4944 - Ensure 'User Account Control: Behavior of the elevation prompt for standard users' is set to 'Automatically deny elevation requests'	329
BL968-4945 - Ensure 'User Account Control: Detect application installations and prompt for elevation' is set to 'Enabled'	331
BL968-4946 - Ensure 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' is set to 'Enabled'	333
BL968-4947 - Ensure 'User Account Control: Run all administrators in Admin Approval Mode' is set to 'Enabled'	335
BL968-4948 - Ensure 'User Account Control: Switch to the secure desktop when prompting for elevation' is set to 'Enabled'	337
BL968-4949 - Ensure 'User Account Control: Virtualize file and registry write failures to per-user locations' is set to 'Enabled'	339
Windows Firewall with Advanced Security	341
Domain Profile	341
BL968-3226 - Ensure 'Windows Firewall: Domain: Firewall state' is set to 'On (recommended)'	341
BL968-1741 - Ensure 'Windows Firewall: Domain: Inbound connections' is set to 'Block (default)'	343
BL968-3446 - Ensure 'Windows Firewall: Domain: Logging: Name' is configured	345
BL968-5486 - Ensure 'Windows Firewall: Domain: Logging: Size limit (KB)' is configured	347

BL968-5971 - Ensure 'Windows Firewall: Domain: Logging: Log dropped packets' is set to 'Yes'	349
BL968-5291 - Ensure 'Windows Firewall: Domain: Logging: Log successful connections' is set to 'Yes'	351
Private Profile	353
BL968-5576 - Ensure 'Windows Firewall: Private: Firewall state' is set to 'On (recommended)'	353
BL968-3486 - Ensure 'Windows Firewall: Private: Inbound connections' is set to 'Block (default)'	355
BL968-1901 - Ensure 'Windows Firewall: Private: Logging: Name' is configured	357
BL968-5121 - Ensure 'Windows Firewall: Private: Logging: Size limit (KB)' is configured	359
BL968-1646 - Ensure 'Windows Firewall: Private: Logging: Log dropped packets' is set to 'Yes'	361
BL968-5141 - Ensure 'Windows Firewall: Private: Logging: Log successful connections' is set to 'Yes'	363
Public Profile	365
BL968-5086 - Ensure 'Windows Firewall: Public: Firewall state' is set to 'On (recommended)'	365
BL968-2696 - Ensure 'Windows Firewall: Public: Inbound connections' is set to 'Block (default)'	367
BL968-5656 - Ensure 'Windows Firewall: Public: Outbound connections' is set to 'Block'	369
BL968-1431 - Ensure 'Windows Firewall: Public: Settings: Apply local firewall rules' is set to 'No'	371
BL968-5446 - Ensure 'Windows Firewall: Public: Settings: Apply local connection security rules' is set to 'No'	373
BL968-5061 - Ensure 'Windows Firewall: Public: Logging: Name' is configured	375
BL968-4526 - Ensure 'Windows Firewall: Public: Logging: Size limit (KB)' is configured	377
BL968-2706 - Ensure 'Windows Firewall: Public: Logging: Log dropped packets' is set to 'Yes'	379
BL968-4911 - Ensure 'Windows Firewall: Public: Logging: Log successful connections' is set to 'Yes'	381
Advanced Audit Policy Configuration	383
Account Logon	383
BL968-5866 - Ensure 'Audit Credential Validation' is set to 'Success and Failure'	383
BL968-0361 - Ensure 'Audit Kerberos Authentication Service' is set to 'Success and Failure' (DC Only)	385
BL968-0511 - Ensure 'Audit Kerberos Service Ticket Operations' is set to 'Success and Failure' (DC Only)	387
Account Management	389
BL968-1736 - Ensure 'Audit Computer Account Management' is set to 'Success' (DC only)	389
BL968-4741 - Ensure 'Audit Distribution Group Management' is set to 'Success' (DC only)	391

BL968-2956 - Ensure 'Audit Other Account Management Events' is set to 'Success' (DC only)	393
BL968-5391 - Ensure 'Audit Security Group Management' is set to 'Success'	395
BL968-4016 - Ensure 'Audit User Account Management' is set to 'Success and Failure'	397
Detailed Tracking	399
BL968-1591 - Ensure 'Audit PNP Activity' is set to 'Success'	399
BL968-2511 - Ensure 'Audit Process Creation' is set to 'Success'	401
DS Access	403
BL968-4586 - Ensure 'Audit Directory Service Access' is set to 'Failure' (DC only)	403
BL968-1611 - Ensure 'Audit Directory Service Changes' is set to 'Success' (DC only)	405
Logon/Logoff	407
BL968-3146 - Ensure 'Audit Account Lockout' is set to 'Failure'	407
BL968-3366 - Ensure 'Audit Group Membership' is set to 'Success'	409
BL968-4261 - Ensure 'Audit Logon' is set to 'Success and Failure'	411
BL968-5431 - Ensure 'Audit Other Logon/Logoff Events' is set to 'Success and Failure'	413
BL968-5251 - Ensure 'Audit Special Logon' is set to 'Success'	415
Object Access	417
BL968-0346 - Ensure 'Audit File Share' is set to 'Success and Failure'	417
BL968-0347 - Ensure 'Audit Detailed File Share' is set to 'Failure'	419
BL968-7474 - Ensure 'Audit Other Object Access Events' is set to 'Success and Failure'	421
BL968-0441 - Ensure 'Audit Removable Storage' is set to 'Success and Failure'	423
Policy Change	425
BL968-2916 - Ensure 'Audit Audit Policy Change' is set to 'Success'	425
BL968-3381 - Ensure 'Audit Authentication Policy Change' is set to 'Success'	427
BL968-0776 - Ensure 'Audit MPSSVC Rule-Level Policy Change' is set to 'Success and Failure'	429
BL968-0956 - Ensure 'Audit Other Policy Change Events' is set to 'Failure'	431
Privilege Use	433
BL968-3361 - Ensure 'Audit Sensitive Privilege Use' is set to 'Success and Failure'	433
System	435
BL968-3481 - Ensure 'Audit Other System Events' is set to 'Success and Failure'	435
BL968-2211 - Ensure 'Audit Security State Change' is set to 'Success'	437
BL968-2381 - Ensure 'Audit Security System Extension' is set to 'Success'	439
BL968-4281 - Ensure 'Audit System Integrity' is set to 'Success and Failure'	441
Administrative Templates (Computer)	443
Control Panel	443
Personalization	443
BL968-1506 - Ensure 'Prevent enabling lock screen camera' is set to 'Enabled'	443
BL968-5111 - Ensure 'Prevent enabling lock screen slide show' is set to 'Enabled'	443
Regional and Language Options	445
	447

BL968-4681 - Ensure 'Allow Input Personalization' is set to 'Disabled'	
LAPS	447
BL968-0612 - Ensure LAPS AdmPwd GPO Extension / CSE is installed (MS only)	449
BL968-4626 - Ensure 'Do not allow password expiration time longer than required by policy' is set to 'Enabled' (MS only)	449
BL968-2851 - Ensure 'Enable Local Admin Password Management' is set to 'Enabled' (MS only)	451
BL968-3176 - Ensure 'Password Settings: Password Complexity' is set to 'Enabled: Large letters + small letters + numbers + special characters' (MS only)	453
BL968-5551 - Ensure 'Password Settings: Password Length' is set to 'Enabled: 15 or more' (MS only)	455
BL968-5341 - Ensure 'Password Settings: Password Age (Days)' is set to 'Enabled: 45 or fewer' (MS only)	457
MS Security Guide	459
BL968-1191 - Ensure 'Apply UAC restrictions to local accounts on network logons' is set to 'Enabled' (MS only)	461
BL968-4843 - Ensure 'Configure SMB v1 client driver' is set to 'Enabled: Disable driver (recommended)'	461
BL968-4844 - Ensure 'Configure SMB v1 server' is set to 'Disabled'	463
BL968-0063 - Ensure 'Enable Structured Exception Handling Overwrite Protection (SEHOP)' is set to 'Enabled'	465
BL968-4845 - Ensure 'Extended Protection for LDAP Authentication (Domain Controllers only)' is set to 'Enabled: Enabled, always (recommended)' (DC Only)	467
BL968-5741 - Ensure 'NetBT NodeType configuration' is set to 'Enabled: P-node (recommended)'	469
BL968-4076 - Ensure 'WDigest Authentication' is set to 'Disabled'	471
MSS (Legacy)	473
BL968-4171 - Ensure 'MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)' is set to 'Disabled'	475
BL968-5706 - Ensure 'MSS: (DisableIPSourceRouting IPv6) IP source routing protection level (protects against packet spoofing)' is set to 'Enabled: Highest protection, source routing is completely disabled'	475
BL968-2131 - Ensure 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' is set to 'Enabled: Highest protection, source routing is completely disabled'	477
BL968-3251 - Ensure 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' is set to 'Disabled'	479
BL968-1456 - Ensure 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds' is set to 'Enabled: 300,000 or 5 minutes (recommended)'	481
BL968-4847 - Ensure 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers' is set to 'Enabled'	483
BL968-1346 - Ensure 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)' is set to 'Disabled'	485
BL968-2496 - Ensure 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)' is set to 'Enabled'	487
	489

BL968-4846 - Ensure 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended) is set to 'Enabled: 5 or fewer seconds'	491
BL968-2498 - Ensure 'MSS: (TcpMaxDataRetransmissions IPv6) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3'	493
BL968-2497 - Ensure 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3'	495
BL968-4848 - Ensure 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' is set to 'Enabled: 90% or less'	497
Network	499
DNS Client	499
BL968-1586 - Ensure 'Turn off multicast name resolution' is set to 'Enabled'	
Fonts	499
	501
BL968-5046 - Ensure 'Enable Font Providers' is set to 'Disabled'	
Lanman Workstation	501
	503
BL968-4466 - Ensure 'Enable insecure guest logons' is set to 'Disabled'	
Link-Layer Topology Discovery	503
	505
BL968-1071 - Ensure 'Turn on Mapper I/O (LLTDIO) driver' is set to 'Disabled'	
	505
BL968-2246 - Ensure 'Turn on Responder (RSPNDR) driver' is set to 'Disabled'	
Microsoft Peer-to-Peer Networking Services	507
	509
BL968-5956 - Ensure 'Turn off Microsoft Peer-to-Peer Networking Services' is set to 'Enabled'	
Network Connections	509
	511
BL968-5966 - Ensure 'Prohibit installation and configuration of Network Bridge on your DNS domain network' is set to 'Enabled'	
	511
BL968-1561 - Ensure 'Prohibit use of Internet Connection Sharing on your DNS domain network' is set to 'Enabled'	
	513
BL968-5491 - Ensure 'Require domain users to elevate when setting a network's location' is set to 'Enabled'	
Network Provider	515
	517
BL968-1186 - Ensure 'Hardened UNC Paths' is set to 'Enabled, with "Require Mutual Authentication" and "Require Integrity" set for all NETLOGON and SYSVOL (DC only) shares'	
TCPIP Settings	517
	519
Parameters	
	519

BL968-4849 - Disable IPv6 (Ensure TCPIP6 Parameter 'DisabledComponents' is set to '0xff (255)')	
Windows Connect Now	519
	521
BL968-2791 - Ensure 'Configuration of wireless settings using Windows Connect Now' is set to 'Disabled'	
	521
BL968-5051 - Ensure 'Prohibit access of the Windows Connect Now wizards' is set to 'Enabled'	
Windows Connection Manager	523
	525
BL968-1386 - Ensure 'Minimize the number of simultaneous connections to the Internet or a Windows Domain' is set to 'Enabled'	
	525
BL968-2816 - Ensure 'Prohibit connection to non-domain networks when connected to domain authenticated network' is set to 'Enabled' (MS only)	
Start Menu and Taskbar	527
Notifications	529
	529
BL968-4850 - Ensure 'Turn off notifications network usage' is set to 'Enabled'	
System	529
Audit Process Creation	531
	531
BL968-5126 - Ensure 'Include command line in process creation events' is set to 'Enabled'	
Credentials Delegation	531
	533
BL968-0100 - Ensure 'Encryption Oracle Remediation' is set to 'Enabled: Force Updated Clients'	
	533
BL968-0581 - Configure 'Allow delegating default credentials'	
	535
BL968-0566 - Configure 'Allow delegating default credentials with NTLM-only server authentication'	
	536
BL968-0567 - Configure 'Restrict delegation of credentials to remote servers'	
Device Guard	537
	539
BL968-0445 - Ensure 'Turn On Virtualization Based Security' is set to 'Enabled'	
	539
BL968-0846 - Ensure 'Turn On Virtualization Based Security: Select Platform Security Level' is set to 'Secure Boot'	
	541
BL968-1444 - Ensure 'Turn On Virtualization Based Security: Virtualization Based Protection of Code Integrity' is set to 'Enabled with UEFI lock'	
	543
BL968-0529 - Ensure 'Turn On Virtualization Based Security: Credential Guard Configuration' is set to 'Enabled with UEFI lock' (MS Only)	

Early Launch Antimalware	545
	547
BL968-3141 - Ensure 'Boot-Start Driver Initialization Policy' is set to 'Enabled: Good only'	
Group Policy	547
	549
BL968-2656 - Ensure 'Configure registry policy processing: Do not apply during periodic background processing' is set to 'Enabled: FALSE'	
	549
BL968-5461 - Ensure 'Configure registry policy processing: Process even if the Group Policy objects have not changed' is set to 'Enabled: TRUE'	
	551
BL968-5851 - Ensure 'Continue experiences on this device' is set to 'Disabled'	
	553
BL968-3256 - Ensure 'Turn off background refresh of Group Policy' is set to 'Disabled'	
Internet Communication Management	555
	556
Internet Communication settings	
	556
BL968-2216 - Configure 'Turn off access to the Store'	
	556
BL968-0896 - Configure 'Turn off Automatic Root Certificates Update'	
	558
BL968-4236 - Ensure 'Turn off downloading of print drivers over HTTP' is set to 'Enabled'	
	559
BL968-2326 - Ensure 'Turn off handwriting personalization data sharing' is set to 'Enabled'	
	561
BL968-1276 - Ensure 'Turn off handwriting recognition error reporting' is set to 'Enabled'	
	563
BL968-1046 - Ensure 'Turn off Internet Connection Wizard if URL connection is referring to Microsoft.com' is set to 'Enabled'	
	565
BL968-2271 - Ensure 'Turn off Internet download for Web publishing and online ordering wizards' is set to 'Enabled'	
	567
BL968-2901 - Ensure 'Turn off printing over HTTP' is set to 'Enabled'	
	569
BL968-5476 - Ensure 'Turn off Registration if URL connection is referring to Microsoft.com' is set to 'Enabled'	
	571
BL968-3576 - Ensure 'Turn off Search Companion content file updates' is set to 'Enabled'	
	573
BL968-5226 - Ensure 'Turn off the "Order Prints" picture task' is set to 'Enabled'	

	575
BL968-4166 - Ensure 'Turn off the "Publish to Web" task for files and folders' is set to 'Enabled'	
	577
BL968-1321 - Ensure 'Turn off the Windows Messenger Customer Experience Improvement Program' is set to 'Enabled'	
	579
BL968-1841 - Ensure 'Turn off Windows Customer Experience Improvement Program' is set to 'Enabled'	
	581
BL968-2571 - Ensure 'Turn off Windows Error Reporting' is set to 'Enabled'	
KDC	583
	585
BL968-0156 - Configure 'KDC support for claims, compound authentication and Kerberos armoring' (DC only)	
Kerberos	585
	586
BL968-0211 - Configure 'Kerberos client support for claims, compound authentication and Kerberos armoring'	
	586
BL968-4696 - Ensure 'Support device authentication using certificate' is set to 'Enabled: Automatic'	
Locale Services	587
	589
BL968-5151 - Ensure 'Disallow copying of user input methods to the system account for sign-in' is set to 'Enabled'	
Logon	589
	591
BL968-4136 - Ensure 'Block user from showing account details on sign-in' is set to 'Enabled'	
	591
BL968-5006 - Ensure 'Do not display network selection UI' is set to 'Enabled'	
	593
BL968-5211 - Ensure 'Do not enumerate connected users on domain-joined computers' is set to 'Enabled'	
	595
BL968-1666 - Ensure 'Enumerate local users on domain-joined computers' is set to 'Disabled' (MS only)	
	597
BL968-3776 - Ensure 'Turn off app notifications on the lock screen' is set to 'Enabled'	
	599
BL968-4854 - Ensure 'Turn off picture password sign-in' is set to 'Enabled'	
	601
BL968-2841 - Ensure 'Turn on convenience PIN sign-in' is set to 'Disabled'	
Power Management	603
	605
Sleep Settings	

BL968-1461 - Ensure 'Allow network connectivity during connected-standby (on battery)' is set to 'Disabled'	605
BL968-1462 - Ensure 'Allow network connectivity during connected-standby (plugged in)' is set to 'Disabled'	605
BL968-3416 - Ensure 'Require a password when a computer wakes (on battery)' is set to 'Enabled'	607
BL968-3417 - Ensure 'Require a password when a computer wakes (plugged in)' is set to 'Enabled'	609
Remote Assistance	611
BL968-5771 - Ensure 'Configure Offer Remote Assistance' is set to 'Disabled'	613
BL968-1621 - Ensure 'Configure Solicited Remote Assistance' is set to 'Disabled'	613
Remote Procedure Call	615
BL968-3291 - Ensure 'Enable RPC Endpoint Mapper Client Authentication' is set to 'Enabled' (MS only)	617
BL968-1516 - Ensure 'Restrict Unauthenticated RPC clients' is set to 'Enabled: Authenticated' (MS only)	617
Troubleshooting and Diagnostics	619
Microsoft Support Diagnostic Tool	621
BL968-3371 - Ensure 'Microsoft Support Diagnostic Tool: Turn on MSDT interactive communication with support provider' is set to 'Disabled'	621
Windows Performance PerfTrack	623
BL968-2836 - Ensure 'Enable/Disable PerfTrack' is set to 'Disabled'	623
User Profiles	625
BL968-4857 - Ensure 'Turn off the advertising ID' is set to 'Enabled'	625
Windows Time Service	627
Time Providers	627
BL968-4858 - Ensure 'Enable Windows NTP Client' is set to 'Enabled'	627
BL968-4859 - Ensure 'Enable Windows NTP Server' is set to 'Disabled' (MS only)	629
Windows Components	631
App Package Deployment	631

BL968-4906 - Ensure 'Allow a Windows app to share application data between users' is set to 'Disabled'	
App Privacy	631
	633
BL968-5901 - Ensure 'Let Windows apps access account information' is set to 'Enable: Force Deny'	633
BL968-5902 - Ensure 'Let Windows apps access call history' is set to 'Enable: Force Deny'	635
BL968-5903 - Ensure 'Let Windows apps access contacts' is set to 'Enable: Force Deny'	636
BL968-5904 - Ensure 'Let Windows apps access email' is set to 'Enable: Force Deny'	637
BL968-5905 - Ensure 'Let Windows apps access location' is set to 'Enable: Force Deny'	638
BL968-5906 - Ensure 'Let Windows apps access messaging' is set to 'Enable: Force Deny'	639
BL968-5907 - Ensure 'Let Windows apps access motion' is set to 'Enable: Force Deny'	640
BL968-5908 - Ensure 'Let Windows apps access the calendar' is set to 'Enable: Force Deny'	641
BL968-5909 - Ensure 'Let Windows apps access the camera' is set to 'Enable: Force Deny'	642
BL968-5910 - Ensure 'Let Windows apps access the microphone' is set to 'Enable: Force Deny'	643
BL968-5923 - Ensure 'Let Windows apps access trusted devices' is set to 'Enable: Force Deny'	644
BL968-5912 - Ensure 'Let Windows apps control radios' is set to 'Enable: Force Deny'	645
BL968-5914 - Ensure 'Let Windows apps make phone calls' is set to 'Enable: Force Deny'	646
BL968-5915 - Ensure 'Let Windows apps access notifications' is set to 'Enable: Force Deny'	647
App runtime	648
BL968-2316 - Ensure 'Allow Microsoft accounts to be optional' is set to 'Enabled'	

AutoPlay Policies	648
BL968-4926 - Ensure 'Disallow Autoplay for non-volume devices' is set to 'Enabled'	650
BL968-1966 - Ensure 'Set the default behavior for AutoRun' is set to 'Enabled: Do not execute any autorun commands'	650
BL968-4501 - Ensure 'Turn off Autoplay' is set to 'Enabled: All drives'	652
Biometrics	654
Facial Features	656
BL968-3876 - Ensure 'Use enhanced anti-spoofing when available' is set to 'Enabled'	656
BitLocker Drive Encryption	656
BL968-7367 - Ensure 'Prevent memory overwrite on restart' is set to 'Disabled'	658
BL968-0226 - Configure the policy 'Provide the unique identifiers for your organization'	659
BL968-0326 - Configure 'Choose drive encryption method and cipher strength (Windows 10 [Version 1511] and later)'	660
Fixed Data Drives	662
BL968-1636 - Ensure 'Choose how BitLocker-protected fixed drives can be recovered' is set to 'Disabled'	662
BL968-0336 - Configure 'Enforce drive encryption type on fixed data drives'	663
Operating System Drives	664
BL968-0491 - Configure 'Allow network unlock at startup'	664
BL968-1871 - Ensure 'Choose how BitLocker-protected operating system drives can be recovered' is set to 'Disabled'	665
BL968-0331 - Configure 'Configure minimum PIN length for startup'	666
BL968-0291 - Configure 'Enforce drive encryption type on operating system drives'	667
BL968-0841 - Configure 'Require additional authentication at startup'	668
Removable Data Drives	670

BL968-9206 - Ensure 'Choose how BitLocker-protected removable drives can be recovered' is set to 'Disabled'	670
BL968-1101 - Configure the policy 'Configure use of passwords for removable data drives'	672
BL968-1671 - Configure the policy 'Control use of BitLocker on removable drives'	674
BL968-0626 - Configure 'Enforce drive encryption type on removable data drives'	676
Camera	677
BL968-5171 - Ensure 'Allow Use of Camera' is set to 'Disabled'	677
Cloud Content	679
BL968-4451 - Ensure 'Turn off Microsoft consumer experiences' is set to 'Enabled'	679
Connect	681
BL968-2036 - Ensure 'Require pin for pairing' is set to 'Enabled'	681
Credential User Interface	683
BL968-3081 - Ensure 'Do not display the password reveal button' is set to 'Enabled'	683
BL968-1991 - Ensure 'Enumerate administrator accounts on elevation' is set to 'Disabled'	685
Data Collection and Preview Builds	687
BL968-4046 - Ensure 'Allow Telemetry' is set to 'Enabled 0 - Security [Enterprise Only]'	687
BL968-4646 - Ensure 'Do not show feedback notifications' is set to 'Enabled'	689
BL968-5871 - Ensure 'Toggle user control over Insider builds' is set to 'Disabled'	691
Event Log Service	693
Application	693
BL968-0077 - Ensure 'Application: Back up log automatically when full' is set to 'Enabled'	693
BL968-0088 - Ensure 'Application: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'	695
BL968-0007 - Ensure 'Application: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'	697
Security	699

BL968-2599 - Ensure 'Security: Back up log automatically when full' is set to 'Enabled'	699
BL968-0098 - Ensure 'Security: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'	701
BL968-0044 - Ensure 'Security: Specify the maximum log file size (KB)' is set to 'Enabled: 524,288 or greater'	703
Setup	705
BL968-4888 - Ensure 'Setup: Back up log automatically when full' is set to 'Enabled'	705
BL968-4860 - Ensure 'Setup: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'	707
BL968-7113 - Ensure 'Setup: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'	709
System	711
BL968-0020 - Ensure 'System: Back up log automatically when full' is set to 'Enabled'	711
BL968-6125 - Ensure 'System: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'	713
BL968-4701 - Ensure 'System: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'	715
File Explorer (formerly Windows Explorer)	717
BL968-1421 - Ensure 'File Explorer: Configure Windows Defender SmartScreen' is set to 'Disabled'	717
BL968-5766 - Ensure 'Turn off Data Execution Prevention for Explorer' is set to 'Disabled'	719
BL968-5496 - Ensure 'Turn off heap termination on corruption' is set to 'Disabled'	721
BL968-2881 - Ensure 'Turn off shell protocol protected mode' is set to 'Disabled'	723
Location and Sensors	725
BL968-4191 - Ensure 'Turn off location' is set to 'Enabled'	725
OneDrive (formerly SkyDrive)	727
BL968-4936 - Ensure 'Prevent the usage of OneDrive for file storage' is set to 'Enabled'	

Remote Desktop Services (formerly Terminal Services)	727
	729
Remote Desktop Connection Client	729
BL968-4686 - Ensure 'Do not allow passwords to be saved' is set to 'Enabled'	729
Remote Desktop Session Host (formerly Terminal Server)	731
Connections	731
BL968-4826 - Ensure 'Restrict Remote Desktop Services users to a single Remote Desktop Services session' is set to 'Enabled'	731
Device and Resource Redirection	733
BL968-3746 - Ensure 'Do not allow COM port redirection' is set to 'Enabled'	733
BL968-4864 - Ensure 'Do not allow drive redirection' is set to 'Enabled'	735
BL968-1291 - Ensure 'Do not allow LPT port redirection' is set to 'Enabled'	737
BL968-4865 - Ensure 'Do not allow supported Plug and Play device redirection' is set to 'Enabled'	739
Security	741
BL968-4546 - Ensure 'Always prompt for password upon connection' is set to 'Enabled'	741
BL968-2466 - Ensure 'Require secure RPC communication' is set to 'Enabled'	743
BL968-0436 - Ensure 'Require use of specific security layer for remote (RDP) connections' is set to 'Enabled: SSL'	745
BL968-0586 - Ensure 'Require user authentication for remote connections by using Network Level Authentication' is set to 'Enabled'	747
BL968-4776 - Ensure 'Set client connection encryption level' is set to 'Enabled: High Level'	749
BL968-0256 - Configure 'Server Authentication Certificate Template'	751
Session Time Limits	753
BL968-5191 - Ensure 'Set time limit for active but idle Remote Desktop Services sessions' is set to 'Enabled: 12 hours or less'	753

BL968-3211 - Ensure 'Set time limit for disconnected sessions' is set to 'Enabled: 18 hours or less'	755
Temporary folders	757
BL968-1416 - Ensure 'Do not delete temp folders upon exit' is set to 'Disabled'	757
BL968-1417 - Ensure 'Do not use temporary folders per session' is set to 'Disabled'	759
RSS Feeds	761
BL968-1971 - Ensure 'Prevent downloading of enclosures' is set to 'Enabled'	763
Search	763
BL968-5781 - Configure 'Allow Cortana'	763
BL968-4891 - Configure 'Allow Cortana above lock screen'	764
BL968-1376 - Ensure 'Allow indexing of encrypted files' is set to 'Disabled'	765
BL968-2046 - Configure 'Allow search and Cortana to use location'	767
Store	768
BL968-2286 - Configure 'Disable all apps from Windows Store'	768
BL968-1641 - Configure 'Turn off Automatic Download and Install of updates'	769
BL968-1941 - Configure 'Turn off the offer to update to the latest version of Windows'	770
BL968-1161 - Configure 'Turn off the Store application'	771
Software Protection Platform	772
BL968-4866 - Ensure 'Turn off KMS Client Online AVS Validation' is set to 'Enabled'	772
Windows Defender	774
MAPS	774
BL968-4870 - Ensure 'Configure local setting override for reporting to Microsoft MAPS' is set to 'Disabled'	774
BL968-1051 - Ensure 'Join Microsoft MAPS' is set to 'Disabled'	776
Real-time Protection	778
BL968-0541 - Ensure 'Scan all downloaded files and attachments' is set to 'Enabled'	

	778
BL968-4871 - Ensure 'Turn on behavior monitoring' is set to 'Enabled'	779
Reporting	
	781
BL968-3616 - Ensure 'Configure Watson events' is set to 'Disabled'	781
Scan	
	783
BL968-0616 - Ensure 'Check for the latest virus and spyware definitions before running a scheduled scan' is set to 'Enabled'	783
BL968-0746 - Ensure 'Scan archive files' is set to 'Enabled'	784
BL968-4872 - Ensure 'Scan removable drives' is set to 'Enabled'	785
BL968-4873 - Ensure 'Turn on e-mail scanning' is set to 'Enabled'	787
BL968-4869 - Ensure Windows Defender as Fallback	
Windows Defender SmartScreen	788
	790
Explorer	
	790
BL968-4877 - Ensure 'Explorer: Configure Windows SmartScreen' is set to 'Disabled'	
Windows Hello for Business	790
	792
BL968-0005 - Configure 'Use Windows Hello for Business'	
Windows Ink Workspace	792
	793
BL968-2306 - Ensure 'Allow suggested apps in Windows Ink Workspace' is set to 'Disabled'	
	793
BL968-4511 - Ensure 'Allow Windows Ink Workspace' is set to 'Disabled'	
Windows Installer	795
	796
BL968-3761 - Ensure 'Allow user control over installs' is set to 'Disabled'	
	796
BL968-4878 - Ensure 'Computer Configuration: Always install with elevated privileges' is set to 'Disabled'	
	798
BL968-5066 - Ensure 'Prevent Internet Explorer security prompt for Windows Installer scripts' is set to 'Disabled'	
Windows Logon Options	800
	802
BL968-3651 - Ensure 'Sign-in last interactive user automatically after a system-initiated restart' is set to 'Disabled'	
Windows PowerShell	802

	804
BL968-3516 - Ensure 'Turn on PowerShell Script Block Logging' is set to 'Disabled'	804
BL968-2071 - Ensure 'Turn on PowerShell Transcription' is set to 'Disabled'	806
BL968-0936 - Configure 'PowerShell: Turn on Script Execution'	808
Windows Remote Management (WinRM)	810
WinRM Client	810
BL968-5106 - Ensure 'WinRM Client: Allow Basic authentication' is set to 'Disabled'	810
BL968-3596 - Ensure 'WinRM Client: Allow unencrypted traffic' is set to 'Disabled'	812
BL968-3921 - Ensure 'WinRM Client: Disallow Digest authentication' is set to 'Enabled'	814
BL968-0911 - Configure 'WinRM Client: Allow CredSSP authentication'	816
WinRM Service	817
BL968-2931 - Ensure 'WinRM Service: Allow Basic authentication' is set to 'Disabled'	817
BL968-2596 - Ensure 'WinRM Service: Allow remote server management through WinRM' is set to 'Disabled'	819
BL968-3126 - Ensure 'WinRM Service: Allow unencrypted traffic' is set to 'Disabled'	821
BL968-5411 - Ensure 'WinRM Service: Disallow WinRM from storing RunAs credentials' is set to 'Enabled'	823
Windows Remote Shell	825
BL968-3514 - Ensure 'Allow Remote Shell Access' is set to 'Disabled'	825
Administrative Templates (User)	827
Control Panel	827
Personalization (formerly Desktop Themes)	827
BL968-1011 - Ensure 'Enable screen saver' is set to 'Enabled'	827
BL968-3326 - Ensure 'Password protect the screen saver' is set to 'Enabled'	829
BL968-4456 - Ensure 'Screen saver timeout' is set to 'Enabled: 900 seconds or fewer, but not 0'	831
Start Menu and Taskbar	833
Notifications	

	833
BL968-1936 - Ensure 'Turn off toast notifications on the lock screen' is set to 'Enabled'	
System	833
Internet Communication Management	835
Internet Communication settings	835
BL968-3506 - Ensure 'Turn off Help Experience Improvement Program' is set to 'Enabled'	835
Windows Components	837
Attachment Manager	837
BL968-2421 - Ensure 'Do not preserve zone information in file attachments' is set to 'Disabled'	837
BL968-4885 - Ensure 'Notify antivirus programs when opening attachments' is set to 'Enabled'	839
Cloud Content	841
BL968-2206 - Ensure 'Configure Windows spotlight on lock screen' is set to 'Disabled'	841
BL968-5581 - Ensure 'Do not suggest third-party content in Windows spotlight' is set to 'Enabled'	843
BL968-3666 - Ensure 'Turn off all Windows spotlight features' is set to 'Enabled'	845
Network Sharing	847
BL968-4706 - Ensure 'Prevent users from sharing files within their profile.' is set to 'Enabled'	847
Windows Installer	849
BL968-4886 - Ensure 'User Configuration: Always install with elevated privileges' is set to 'Disabled'	849
Windows Media Player	851
Playback	851
BL968-1076 - Ensure 'Prevent Codec Download' is set to 'Enabled'	851
Group Policy Preferences (GPP)	853
Audit	853
BL968-1001 - Configure 'Maximum log size (KB) of PowerShell'	853
BL968-1000 - Configure 'Maximum log size (KB) of TerminalServices-LocalSessionManager'	855
Network Services	856
BL968-0991 - Configure 'Access-based Enumeration'	856

BL968-0261 - Configure 'Default Share Permissions'	858
BL968-5981 - Configure 'IPv6 Site-to-Site Static Tunnels'	859
BL968-0531 - Configure 'Sharing Wizard'	861
BL968-0117 - Configure 'SMBv3 protocol encryption'	862
BL968-0118 - Do Not Allow Unencrypted SMB Sessions	864
Operating System	866
BL968-0641 - Configure 'Additional LSA Protection'	866
Transport Layer Security	868
BL968-0596 - Disable 'SSL 2.0' Protocol	869
BL968-0891 - Disable 'SSL 3.0' Protocol	872
BL968-0312 - Disable 'TLS 1.0' Protocol	875
BL968-0313 - Disable 'TLS 1.1' Protocol	878
BL968-0314 - Enable 'TLS 1.2' Protocol	881
BL968-0315 - Disable 'NULL' Cipher Suites	884
BL968-3906 - Disable 'DES' Cipher Suites	886
BL968-0821 - Disable 'RC2' Cipher Suites	888
BL968-0131 - Disable 'RC4' Cipher Suites	890
BL968-0317 - Disable 'Triple DES' Cipher Suites	893
BL968-0318 - Enable 'AES 128/128' Cipher Suites	895
BL968-0319 - Enable 'AES 256/256' Cipher Suites	897
BL968-0320 - Disable 'MD5' Hashing Algorithm	899
BL968-0323 - Disable 'SHA-1' Hashing Algorithm	901
BL968-0484 - Ensure sufficient 'Modulus Size in the DHE Key Exchange'	903
BL968-0325 - Configure TLS Cipher Suite Ordering	906
Rules not based on Group Policy Objects or Preferences (GPOs, GPPs)	909
3rd Party Tools	909
BL968-0322 - Enable the Corporate Scan Service Agent	909
BL968-0066 - Enable an Endpoint Detection and Response Agent	911
BL968-0422 - Install a Virus Scanner	913
Accounts and Permissions	914
BL968-0771 - Kerberos Delegation	914
BL968-0004 - Reset Password of kbrtgt Account Regularly (DC only)	916
BL968-0177 - Permissions on Shared Folders	918
BL968-0271 - Special Protection of High-Value Accounts	920
BL968-1066 - Use Domain User Accounts	922
BL968-0416 - Users allowed for Remote Desktop	924
Active Directory	925
BL968-0049 - Domain Controller Hardening	925
Audit	926
BL968-0516 - Configure 'Auditing Privileged Group Members Logons'	926
BL968-0486 - Configure 'Audit User Mailbox Attribute' (DC only)	928
Operating System	930
BL968-0180 - Check Windows Service Paths	930
BL968-0002 - Configure 'DACLS for Windows Services'	932

Definitions	935
Glossary	938
References	939

Introduction

Objectives

The objective of this document is to define the rules which provide a secure configuration, increase the overall security level, and reduce the attack surface and vulnerability exposure of platforms, systems and applications.

The Security Measure Plan for Windows Server 2016 is an *Information Security Baseline* that is part of the *Siemens Information Security Policy Framework* [1].

Scope and Applicability

This Security Measure Plan sets the mandatory hardening rules for Windows Server 2016 systems. In particular, it is limited to the following versions:

- *Windows Server 2016 Standard, version 1607,*
- *Windows Server 2016 Datacenter, version 1607.*

The Security Measure Plan partially uses content from

- CIS Microsoft Windows Server 2016 RTM (Release 1607) Benchmark, v1.2.0 - released 05-27-2020.

The *Security Measure Plan* is binding for all units of Siemens AG and applies to Siemens' Affiliated Companies in accordance with Siemens Circular No. 105 "Implementation of Siemens-internal regulations in Affiliated Companies" [2], whereas separate agreements apply to listed Equity Investments.

Notes:

Considering that Microsoft offers with every update of Windows Server 2016 additional important security and feature enhancements, the Security Measure Plan focuses on the above version and strongly recommends using this version for deployment within Siemens.

Managed servers:

This document is written for Windows 2016 servers that are managed in an Active Directory Domain (e.g., Siemens OneAD). Some settings make only sense to be set on Domain Controllers, e.g., [BL968-1611](#) (Ensure 'Audit Directory Service Changes' is set to 'Success' (DC only)). Those rules are marked with **(DC only)** at the end of the **Rule Title**.

Other settings make only sense to be set on Domain Member servers, e.g., [BL968-5341](#) (Ensure 'Password Settings: Password Age (Days)' is set to 'Enabled: 45 or fewer' (MS only)). Those rules are marked with **(MS only)** at the end of the **Rule Title**.

Unmanaged Servers:

Windows 2016 servers without Active Directory membership (also known as Standalone or Unmanaged Servers) shall not be used. More information can be found in the corresponding rule: [BL968-0110](#) (Configure 'Active Directory Domain Membership').

Listings in this Security Measure Plan

Listings using the following format

```
<sample code>
```

```
Listing: BL968-9999_[C|I]99_99.ps1
```

are extracted into separate files (having the *Listing* title as file name). The filename uses the following syntax

```
RuleNumber_Implementation|CheckSection_AscendingNumber.FileExtension
```

All scripts are stored into a single ZIP archive file and can be used as a starting point for your own implementation. You can download the ZIP archive file at

https://intranet.for.siemens.com/wll/0049/Policies/Scripts_Windows_Server_2016.zip

Roles and Responsibilities

Throughout this document, the following roles are used to assign responsibilities for the implementation of the rules:

- [Asset Manager](#).

Information Security Policy Framework

All Information Security rules and regulations at Siemens are documented and further detailed in the Information Security Policy Framework. It lays down the roles and responsibilities, and the set of rules and practices that regulate how Siemens and its affiliated companies protect the company information and business processes.

Details regarding the Policy Framework can be found on the [Cybersecurity Governance Website](#).

Readability

The rules in this document are structured as follows:

- **Header** Each rule starts with a header containing the following information:
 - **Rule ID:** The left-hand side of the header displays the unique identifier of the rule to be used for referencing the rule from other documents. The identifier *BLxxx-yyyy* is divided in two parts, of which the first part *BLxxx* represents the document identifier, and the second part *yyyy* constitutes a unique rule identifier within the document.
 - **Target Audience:** Directly under the Rule ID, one or more roles (as defined in the Siemens Information Security Framework) are displayed. These roles are responsible for implementing the rule.
 - **EVAL flag and date:** If a rule is under evaluation, an EVAL flag and the end date of the evaluation period is displayed to the right of the Rule ID. The evaluation period shall be used to:
 - Communicate the new version of the Security Measure Plan to the relevant teams,
 - Identify the rules applicable to your area of responsibility,
 - Evaluate and plan all necessary changes to the contractual agreements with involved Service providers (e.g., SLAs, contract changes),
 - Plan and define a strategy to implement the rules (e.g., identify possible issues, allocate proper resources),

- Update all related existing documents, processes, and procedures,
- Deploy all necessary changes to all affected systems within your area of responsibility.

The rule will become binding after the end of the evaluation period. An expired EVAL flag will only be removed from the rule once an update to the document is available.

- **ACP Level:** The **ACP** level is indicated on the right-hand side of the header; the rule is applicable to those systems whose **ACP** rating falls into levels as displayed in the rule header. The semantics is as follows: if at least one of the **ACP** levels *Confidentiality* (C), *Integrity* (I), or *Availability* (A) of a system match with the **ACP** level displayed in the rule's header, then the rule must be implemented for the system in question. In case of conflicting rules, the rule with the higher **ACP** rating shall be implemented.
- **Rule:** This Section describes the essence of the rule and is to be considered as normative *binding part of the rule*.
- **Additional normative sections (apart from 'Rule' Section of the header) :**
 - **Exemption (if applicable):** This Section indicates under which circumstances a rule may not apply. If the conditions of the exemption are met, no Information Security exception for this rule deviation is required. Each exemption has a relative id, e.g. E01, so that it can be referenced in conjunction with the Rule ID as, e.g., BL123-1234:E01.
- **Informative Sections:**
 - **Description:** The description provides information which helps the readers to understand the rule.
 - **Rationale:** This Section provides information about the rationale behind the rule. It should, for example, help Asset Managers to evaluate requests for rule exceptions.
 - **Implementation Example:** This Section provides descriptions and examples on how to implement the rule. Please note that this is only an example on how to implement, the demand stated in the Rule Section may also be implemented by other means. Each implementation has a relative id, e.g. I01, so that it can be referenced in conjunction with the Rule ID as, e.g., BL123-1234:I01.
 - **Check Example (optional):** This Section provides descriptions and examples on how to check the rule implementation. Please note that this is only an example on how to check the implementation. Each check has a relative id, e.g., C01, so that it can be referenced in conjunction with the Rule ID as, e.g., BL123-1234:C01.
 - **Cross references (optional):** This Section provides cross references to other rules (inside or outside the Siemens Information Security Framework). Cross references may, for example, inform about the rules the rule in question is based upon.
- **Additional Metadata**
 - **Version History:** This Section provides version history information of the rule: In a PDF export, only the latest entry is shown, contrary to the [SFeRA](#) website which holds the complete version history.

Hardware Security

BL968-0031

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Require TPM 2.0

Rule The implementation of a TPM 2.0 module in the system hardware is required.

The TPM 2.0 module must meet following requirements:

- All TPM configurations must comply with local laws and regulations.
- Firmware-based components that implement TPM capabilities must implement version 2.0 of the TPM specification.
- An EK certificate must either be pre-provisioned to the TPM by the hardware vendor or be capable of being retrieved by the device during the first boot experience.
- It must ship with SHA-256 PCR banks and implement PCRs 0 through 23 for SHA-256. Note that it is acceptable to ship TPMs with a single switchable PCR bank that can be utilized for SHA-256 measurements.
- It must support TPM2_HMAC command.

Please note, that these requirements are directly quoted from the Microsoft web site [Minimum hardware requirements](#).

E01 - Existing servers with TPM 1.2 module

Systems which already have a TPM 1.2 module installed can be used until its end of life. However, these systems cannot use security features which require a TPM 2.0 module.

E02 - Existing servers without TPM module

Owner of systems which do not have a TPM 1.2 module installed should consider purchasing an update board which is possibly available for specific servers. The TPM chip increases the security level significantly.

Description

Trusted Platform Module (TPM) comes in versions 1.2 and 2.0. Both are supported with Windows 10 and Windows Server 2016 out of the box.

While Windows 10 and Windows Server 2016 work with TPM 1.2 chips, there are several strong reasons to use TPM 2.0 chips:

- Support for additional encryption algorithms beyond RSA and the SHA-1 hashing algorithm
- Enhanced authorization for improved TPM management
- Additional cryptographic services to enhance the security

- TPM 2.0 lockout policy is configured by Windows, ensuring a consistent dictionary attack protection guarantee
- Modern Standby/Connected Standby certification
- Azure AD join requires TPM with keyed-hash message authentication code (HMAC) and Endorsement Key (EK) certificate for key attestation support
- It is expected that new features in future versions of Windows 10 and Windows Server 2016 require TPM 2.0 as well.

Rationale

Specific security features in current and future versions of Windows 10 and Windows Server 2016 require TPM 2.0:

- Device Encryption
- Windows Defender System Guard
- Autopilot
- SecureBIO (Biometrics)
- DRTM (Dynamic Root of Trust Measurement, which is part of Intel Trusted Execution Technology)

I01 - Implementation Example

Purchase only computer hardware with TPM 2.0 chips which meet the requirements listed in the *Rule* section.

More information can be found here: [Microsoft: Windows Server 2016 System Requirements](#)

It is advisable to get a written confirmation from the vendor that the hardware model fulfills the requirements.

C01 - Identify the TPM version of your system

You can run the PowerShell command below with administrative privileges to identify the TPM version available on the system:

```
$TPMSpecVersion=(Get-WmiObject -Class Win32_TPM -Namespace root/cimv2/security/MicrosoftTPM).SpecVersion
switch($TPMSpecVersion)
{
    {$_ -like "2.0*"} {"This computer uses a TPM 2.0 module."}
    {$_ -like "1.2*"} {"This computer uses a TPM 1.2 module."}
    {$_ -like "Not supported*"} {"This computer does not use any TPM module."}
    {$_ -like ""} {"This computer does not use any TPM module."}
}
```

Listing: BL968-0031_C01_01.ps1

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Moved the TPM requirements from Implementation to Rule section. Extended the Check to handle systems where the data is unavailable.

BL968-0249

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Update BIOS/UEFI Firmware

Rule Install the latest BIOS/UEFI version.

Note: Implement this rule **before** configuring the BIOS/UEFI firmware and installing the Operating System as otherwise you may end up installing your system a second time.

E01 - Exemption

This rule is not mandatory for systems with no BIOS/UEFI configuration or no update capabilities such as cloud instances in AWS / Azure or with only virtualized, emulated BIOS/UEFI such as virtual machines.

Description

BIOS and UEFI are a type of firmware used during the boot process of a computer. Unified Extensible Firmware Interface (UEFI) is a new firmware that replaces the older BIOS on modern computers, introducing several security improvements and enhancements.

Rationale

Computer vendors release new versions of their BIOS or UEFI firmware regularly to fix vulnerabilities, bugs, or introduce new features, amongst other reasons. UEFI is required for many of the new security features introduced with *Windows 10* and *Windows Server 2016* (e.g., Credential Guard, Device Guard).

I01 - Implementation Example

Determine the version of the BIOS/UEFI of your computer. Press the key that opens the BIOS/UEFI Setup page (e.g., F2, F10) while your computer is booting up and navigate through the menus until you find the version of your BIOS/ UEFI.

Once you have determined the version of your BIOS, go to the vendor site, and look for the *support* site or the *drivers and downloads* site for your particular computer model to find out if a newer version exists.

Install the latest release of the BIOS/UEFI according to the vendor instructions.

Note: The exact implementation procedure depends on the specific BIOS/UEFI firmware. For details on BIOS/UEFI settings please refer to the manual of the computer system or mainboard.

Note: It is of utmost importance to meet all requirements defined by the vendor and follow the exact procedure the vendor states.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.6.1-03

Based on Siemens Information Security Policy Framework Rule 12.6.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Adapted the Windows 10 MP/Windows Server 2016 rule; not part of CIS Server 2019 Baseline. Added exemption for systems without BIOS configuration capabilities.

BL968-0452

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Disable Compatibility Support Module

Rule Disable the Compatibility Support Module (CSM).

Note: Implement this rule **before** configuring the UEFI firmware and installing the Operating System as otherwise you may end up installing your system a second time.

E01 - Existing Windows Server 2016 installations in BIOS mode

This rule is not mandatory for already existing Windows Server 2016 installed in BIOS mode, where an immediate re-installation of system is not possible due to operational topics (e.g., availability).

However, this decision must be documented (preferably incl. the time frame where the reinstallation is planned).

E02 - Exemption

This rule is not mandatory for systems with no BIOS/UEFI configuration capabilities such as cloud instances in AWS / Azure, offering this configuration possibility.

Description

Most UEFI firmware implementations offer the Compatibility Support Module (CSM) component for backward compatibility with legacy BIOS systems, for example when you want to install an operating system that does not support the new UEFI specification. CSM allows you to run the operating system in BIOS mode, instead of in UEFI mode.

Rationale

Windows 10 and *Windows Server 2016* need to run in UEFI mode to be able to use many of the new security features, such as Credential Guard. In addition, UEFI mode introduced several security improvements compared with the legacy BIOS mode.

I01 - Implementation Example

The implementation procedure depends on the specific BIOS/UEFI firmware of the particular computer system. For details on BIOS/UEFI settings please refer to the manual of the computer system or the motherboard.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Adapted the Windows 10 MP/Windows Server 2016 rule; not part of CIS Server 2016 Baseline. Added two exemptions for existing BIOS installed systems and cloud instances.

BL968-0362

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Enable UEFI Secure Boot

Rule Enable UEFI Secure Boot.

Note: Implement this rule **before** configuring the UEFI firmware and installing the Operating System as otherwise you may end up installing your system a second time.

E01 - Existing Windows Server 2016 installations in BIOS mode

If you already installed Windows Server 2016 in BIOS mode on your system, and cannot reinstall the system immediately due to operational topics (e.g., availability), then you can postpone the enabling of the UEFI mode.

However, this decision must be documented (preferably incl. the time frame where enabling UEFI Secure Boot option is planned).

E02 - Exemption

This rule is not mandatory for systems with no BIOS/UEFI configuration capabilities such as cloud instances in AWS / Azure, offering this configuration possibility.

Description

UEFI Secure Boot was introduced in version 2.3.1 of the UEFI specification and provides a method to prevent systems from starting operating systems or loading drivers not digitally signed by a trusted party. UEFI Secure Boot prevents the system from booting if unauthorized changes have been made.

Rationale

An attacker might change the boot loader process of the system to add malicious components at the operating system kernel, for example, to intercept encryption keys. In addition, UEFI Secure Boot is required for many of the new security features introduced with *Windows 10* and *Windows Server 2016* (e.g., Credential Guard, Device Guard).

I01 - Implementation Example

The exact implementation procedure depends on the specific BIOS/UEFI firmware. For details on BIOS/UEFI settings please refer to the manual of the computer system or mainboard.

C01 - Determining UEFI Secure Boot

You can run the PowerShell script below with administrative privileges to verify whether UEFI Secure Boot is enabled:


```
$status = (Confirm-SecureBootUEFI)
if ($status) {
    "UEFI Secure Boot is enabled."
}
else {
    "UEFI Secure Boot is not enabled or the computer is configured in BIOS mode."
}
```

Listing: BL968-0362_C01_01.ps1

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Adapted the Windows 10 MP/Windows Server 2016 rule; not part of CIS Server 2016 Baseline. Added exemption for cloud instances.

BL968-0988

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Enable Virtualization Technology

Rule Enable Virtualization Technology.

Note: Implement this rule **before** installing the Operating System as otherwise you may end up installing your system a second time.

E01 - Exemption

This rule is not mandatory for systems with no BIOS/UEFI configuration capabilities offering this configuration possibility, such as cloud instances in AWS / Azure or with only virtualized, emulated BIOS/UEFI such as virtual machines.

Description

Virtualization Technology is a feature integrated directly into the CPU which allows the use of hardware-assisted virtualization. Unlike software-based virtualization, hardware-assisted virtualization uses hardware components to provide virtualization, which improves the performance and security. However, the CPU must support this feature.

Microsoft *Windows Server 2016* uses virtualization to increase the security of certain critical features, such as Credential Guard, or Device Guard. For example, Credential Guard makes use of an isolated virtual section to store the secrets so that only specific processes can work with them, even when the operating system is compromised.

Rationale

If Virtualization Technology is not enabled, these security features cannot be used.

I01 - Implementation Example

The implementation procedure depends on the specific UEFI firmware of the particular computer system. For details on UEFI settings please refer to the manual of the computer system or mainboard.

C01 - Determining the status of Virtualization

You can run the PowerShell command below to verify whether your computer has Virtualization Technology activated.

```
$status_Virt_supported = $(gwmi -Class Win32_processor).VMMonitorModeExtensions
$status_Virt_enabled   = $(gwmi -Class Win32_processor).VirtualizationFirmwareEnabled
$status_HyperV_present = (gcim -Class Win32_ComputerSystem).HypervisorPresent
if (($status_Virt_supported -and $status_Virt_enabled) -or ($status_HyperV_present)) {
    "This computer supports virtualization and the feature is enabled in the UEFI."
}
else {
    "This computer does either not support virtualization or the feature is not enabled in the UEFI."
}
```

Listing: BL968-0988_C01_01.ps1

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Adapted the Windows 10 MP rule; not part of CIS Server 2016 Baseline. Added exemption for systems with BIOS/UEFI not offering virtualizations.

BL968-4812

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Enable IOMMU Technology

Rule Enable IOMMU technology (i.e., VT-d on Intel chips or AMD-Vi on AMD chips).

Note: Implement this rule **before** installing the Operating System as otherwise you may end up installing your system a second time.

E01 - Systems without IOMMU support

This rule is not mandatory, if the system does not support IOMMU. It is recommended to update the computer with the next hardware refresh to meet the requirements.

Description

An Input-Output Memory Management Unit (IOMMU) is a hardware that directly connects a DMA device to the main memory. In particular, it maps the virtual addresses used by the device to the actual physical addresses.

Rationale

Without IOMMU, DMA devices can access the main memory without any supervision or control. Thus, an attacker might connect a special DMA device to the computer and have access, obtain, or modify the content of the memory in order to modify the operating system or obtain sensitive information.

I01 - Implementation Example

The implementation procedure depends on the specific UEFI firmware of the particular computer system. For details on UEFI settings please refer to the manual of the computer system or mainboard.

For example, on Lenovo computers, use the steps below to enable *VT-d*:

1. Press the *F1* key when your computer boots up to enter the UEFI setup page,
2. Go to the *Security* tab, and open the *Virtualization* site,
3. Enable the option *VT-d*.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Adapted the Windows 10 MP rule; not part of CIS Server 2016 Baseline.

BL968-0986

Asset Manager

C	I	A
123	123	123

Set a BIOS/UEFI Boot Password

Rule Set a BIOS/UEFI password to boot the system.

Note: The BIOS/UEFI boot password is exempt from the password change requirements of the *Specific Information Security Policy: Access Control* [Rule ID: 09.4.3-04](#).

E01 - Systems with Hard disk encryption and boot password

This rule is not mandatory, if the computer is protected by full hard disk encryption and requires a password before you can boot the computer. More information can be found here:

- [BL968-0291 Configure 'Enforce drive encryption type on operation system drives'](#) ,
- [BL968-0841 Configure 'Require additional authentication at startup'](#) .

E02 - Systems which need to restart automatically

This rule is not mandatory, if the system needs to be able to restart automatically. However, additional physical security rules must be implemented:

- No physical access to the system without physical access restrictions, such as locked cabinet in a secured server room or data center.

Description

The BIOS/UEFI Setup page contains several settings that can be configured. Some of them are security relevant, such as boot sequence, setup and boot access password, wake-on LAN, system time, or secure boot.

Rationale

The password to boot the system prevents users from booting the computer or booting from removable devices. Without a boot password an attacker could use techniques to bypass the Windows password and access local data.

I01 - Implementation Example

The implementation depends on the specific BIOS/UEFI firmware of the particular computer system. For details on BIOS/UEFI settings please refer to the manual of the computer system or mainboard.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 09.1.1-07

Based on Siemens Information Security Policy Framework Rule 09.4.3-04

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Adapted the Windows 10 MP/Windows Server 2016 rule; not part of CIS Server 2019 Baseline.

BL968-0620

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Set a Password to Access BIOS/UEFI Setup

Rule Set a password to access the BIOS/UEFI setup.

Note: The BIOS/UEFI password to access the setup is exempt from the password change requirements of the *Specific Information Security Policy: Access Control* [Rule ID: 09.4.3-04](#).

E01 - Exemption

This rule is not mandatory for systems with no BIOS/UEFI configuration capabilities such as cloud instances in AWS / Azure or with only virtualized, emulated BIOS/UEFI such as virtual machines.

Description

The BIOS or UEFI firmware of your computer can be configured by entering the setup page before the operating system starts. It provides some low-level configuration settings, including security relevant settings (e.g., virtualization technology, boot order, system time).

Rationale

A malicious user with physical access to the system might disable some security relevant settings on the setup page to be able to run different attacks, for example, he or she might disable UEFI Secure Boot to run a malicious unsigned program at boot time (e.g., a keylogger).

I01 - Implementation Example

The implementation depends on the specific BIOS/UEFI firmware of the particular computer system. For details on BIOS/UEFI settings please refer to the manual of the computer system or mainboard.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 09.1.1-07

Based on Siemens Information Security Policy Framework Rule 09.4.3-04

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Adapted the Windows 10 MP/Windows Server 2016 rule; not part of CIS Server 2019 Baseline. Added exemption for systems without BIOS configuration capabilities.

BL968-0003

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Configure 'Intel AMT Login Bypass'

Rule Change the default Intel AMT password.

Note: The Intel AMT password is exempt from the password change requirements of the *Specific Information Security Policy: Access Control* [Rule ID: 09.4.3-04](#).

E01 - Exemption

This rule is not mandatory for systems with no BIOS/UEFI configuration capabilities such as cloud instances in AWS / Azure, offering this configuration possibility.

Description

Intel AMT Login Bypass

A security issue in Intel Active Management Technology (AMT) allows local access to the AMT interface with the default password. The issue affects computer hardware equipped with the Intel AMT feature. Unauthorized access to the Intel AMT feature allows various configuration changes which could potentially allow an attacker to remotely control the affected system.

Technical Details

Intel AMT is a management technology that is built into hardware with Intel CPUs. The feature is designed to manage large corporate computer fleets, allowing remote access monitoring and maintenance functions.

The Intel AMT interface can be loaded by pressing **CTRL-P** on the keyboard during the hardware boot process. Access to the Intel AMT feature is possible if the default Intel AMT password has not been previously changed. The default Intel AMT password is "admin".

The issue can be exploited even if a UEFI or BitLocker password has been set.

While the issue can be exploited to enable remote access in a matter of seconds, an attacker still needs physical access to the victim's device to initiate the attack.

More information can be found here: [Siemens CERT - Intel AMT Login Bypass](#).

Affected Devices/Services

Any hardware device which includes the Intel AMT feature and has the default AMT password is affected by the issue.

Not all hardware devices with Intel CPUs include the AMT feature. For instance, CPU models older than 4-5 years do not include the Intel AMT feature. Siemens CERT initiated an investigation to identify affected models.

Rationale

Unauthorized access to the local Intel AMT feature allows an attacker to enable remote management via an administrator GUI, through which a number of functionalities are available, including power on/off, wiping the disks, changing boot configuration and monitoring network packets and the user screen.

I01 - Implementation Example

The only possible mitigation actions at the moment is to change the default Intel AMT password. The new AMT password must be secure with a strong password. See the [Intel AMT Configuration Utility - User Guide](#) for details.

Additionally, it is recommended to also disable the AMT feature. This can be done via UEFI (BIOS), although depending on the OEM, it may be non-trivial or not possible at all.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 09.1.1-07

Based on Siemens Information Security Policy Framework Rule 09.4.3-04

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed during review: Added exemption for cloud instances. Adapted the Windows 10 MP/Windows Server 2016 rule; not part of CIS Server 2016 Baseline.

BL968-0442

Asset Manager

C	I	A
123	123	123

Configure 'Secure Built-in Remote Management Interface'

Rule

Ensure that existing remote management interfaces of a server are either disabled or not connected to any network.

E01 - Server which require a Built-in Remote Management Interface

If you require a remote management interface to your server, secure it by following these generic rules:

- Remote management interfaces must only be connected to a separated, isolated management network (at least a separate VLAN). Especially, the interface must never be directly reachable from the Siemens Intranet.
- Passwords for accounts on the remote management interface must follow the Siemens password policy for Administrators. Especially, replace well-known or default passwords.
- If the remote management interface offers the possibilities of security auditing and sending security events to a SIEM, then logging must be additionally configured.
Minimal monitoring encompasses checking if reboots and successful connections to the system match authorized actions taken by administrators, and examining failed login attempts (e.g., unusual sources or number of failed attempts).
- Always apply the manufacturer's up-to-date security patches for the firmware of the remote management interface.
- Make sure that only secured protocols are allowed for access. Protocols that use plain text transmission of passwords like telnet, snmp, http forms etc. must be disabled.

Description

Most server systems are equipped with a built-in remote management interface. This interface can typically be used to access (e.g., view screen) and manage (e.g., restart, boot from external media) the system without the need for the main operating system to be running. While this can be very useful for some troubleshooting cases (e.g., a non-bootable OS), these interfaces can also allow an attacker to easily take over the whole system. Thus, such interfaces have to be sufficiently secured.

The different server system vendors use many different names for these interfaces, including Integrated Remote Management Controller (iRMC) (Fujitsu), Integrated Dell Remote Access Controller (iDRAC), HP Integrated Lights Out (iLO), IBM Integrated Management Module, etc. More generic names are Server Management Board or Intelligent Platform Management Interface (IPMI).

These interfaces are implemented as embedded systems with operating system, web server, user administration and alarm management etc. and also supplied with power when the server system itself is in standby mode. Communication is carried out via a LAN connection, which can be shared with the server system or used exclusively for system management.

Rationale

Built-in remote management interfaces typically come with default passwords for the main administrative user account. There is a high risk that an attacker who has access to the Siemens Intranet can easily gain full control over a server if default security configuration has not been adjusted.

I01 - Implementation Example

The implementation depends on the specific remote management interface of the particular system and your environment. For details please refer to the appropriate documentation.

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 13.1.3-06](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Changed during review: Rephrased rule to emphasize existing remote management interfaces. Adapted the Windows Server 2016 rule; not part of CIS Server 2019 Baseline.

System Setup

BL968-0172

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Install Windows using UEFI mode

Rule

Install Windows in UEFI mode (not in BIOS mode).

E01 - Existing Windows Server 2016 installations in BIOS mode

If you already installed Windows Server 2016 in BIOS mode on your system, and cannot reinstall the system immediately due to operational topics (e.g., availability), then you can postpone the reinstallation in UEFI mode.

However, this decision must be documented (preferably incl. the time frame where the reinstallation is planned).

E02 - Exemption

This rule is not mandatory for systems with no UEFI installation capabilities such as cloud instances in AWS / Azure, where this feature is at the time of writing not available as a stable feature.

This exemption is not valid any longer and will be removed latest, when this feature is available in a stable version.

Description

Microsoft Windows can be installed either in BIOS mode or in UEFI mode. The legacy BIOS mode uses the old Master Boot Record (MBR) partitioning scheme, whereas the UEFI mode uses the new GUID Partition Table (GPT) partition scheme which replaces the older MBR. Both schemes are used to store the partitioning information of a disk. GPT introduces several improvements over MBR, such as a better performance for large disks, or data recovery in case of data corruption. UEFI-based systems can only boot from GPT disks.

Rationale

UEFI is required for many of the new security features introduced with *Windows 10* and *Windows Server 2016* (e.g., Credential Guard, Device Guard).

I01 - Implementation Example

If your disk was formatted using MBR, you will receive the following error message during the installation process:

Windows cannot be installed to this disk. The selected disk has an MBR partition table. On EFI systems, Windows can only be installed to GPT disks.

To fix the error, you need to convert the disk into the GPT format:

1. Open an administrative Command Prompt window (press *Shift + F10* if you are already installing Windows),
2. Type *Diskpart* and press *Enter*,
3. Type *List Disk* to show the list of disks on your computer,
4. Select the disk where you want to install Windows with the command *Select Disk <number>*,
5. Type *Clean* to remove any partition or volume,
6. Type *Convert GPT* to convert the MBR disk into a GPT disk,
7. Close the Command Prompt window and continue with the installation.

Note: The media containing the Windows installation files (e.g., USB stick) needs to be formatted in GPT format as well.

You can find more information about GPT on: <https://msdn.microsoft.com/en-us/windows/hardware/gg463525.aspx>.

C01 - Determining UEFI or BIOS mode

Once you have installed Windows, you can verify that Windows is running in UEFI mode by using the *System Information* panel:

1. Open the *System Information* panel (*msinfo32.exe*),
2. In the right pane, look for the parameter *BIOS Mode*, and check its value:
 - *Legacy*: Computer is working in BIOS Mode.
 - *UEFI*: Computer is working in UEFI Mode.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed during review: Added exemption for cloud instances where UEFI is currently beta feature.
Adapted the Windows 10 MP/Windows Server 2019 rule; not part of CIS Server 2016 Baseline.

BL968-0017

Asset Manager

C	I	A
123	123	123

Limit Additional Server Roles

Rule

Ensure that only one server role is installed on a Windows Server 2016.

E01 - Default Roles

The server roles 'File Server' and 'Storage Services' are installed by default on Windows Server 2016 and are allowed to be installed, if required.

E02 - Microsoft recommendation

If an official Microsoft recommendation exists to install several roles on the same server, e.g., 'DNS Server' and 'Active Directory Domain Services', then those roles are allowed to be installed together on one Windows 2016 Server.

Description

An installation of Windows Server 2016 shall follow the general concepts of **Least-Privilege-Principle** and **segregation of duties**. Both concepts ensure that the Operating system processes operate at a privilege level not higher than necessary to accomplish the desired service.

As an example: The roles 'Active Directory Domain Services' and 'Print and Document Services' shall never be installed on a single Windows Server 2016. The *Print administrator* would need privileged local rights to install printer drivers. But these rights might also be used to get privileged access to the Active Directory database.

Furthermore, server roles like 'DNS Server' and 'DHCP Server' on a single Windows Server 2016 can even influence each other in a negative way (from security point of view).

Rationale

Installing more than one server role on a single Windows 2016 Server is contrary to the concept of **Least-Privilege-Principle** as well as to the concept of **Segregation of Duties**. Additionally, it can result in weak security and open possibilities to attackers.

I01 - Implementation Example

Ensure either in "Windows Server Manager -> Manage -> Add Roles and Features -> Add Roles and Feature Wizard -> Roles" or using PowerShell ('Get-WindowsFeature') that not more than one Windows server role is installed.

Note: The roles 'File Server' and 'Storage Service' are installed by default and are exempted from this rule (see exemptions).

Crossreferences

Based on Siemens Information Security Policy Framework Rule 09.4.1-01

Based on Siemens Information Security Policy Framework Rule 06.1.2-02

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Adapted the Windows Server 2012/Windows Server 2019 rule; not part of CIS Server 2016 Baseline.

BL968-0032

Asset Manager

C	I	A
123	123	123

Configure 'Windows Server Features'

Rule

- The following features shall not be installed on any Windows 2016 Server:
 - Internet Printing Client,
 - LPR Port Monitor,
 - Simple TCP/IP Services,
 - SMB 1.0/CIFS File Sharing Support,
 - SNMP Service,
 - WINS Server,
 - Wireless LAN Service.

In general, limit the installed features of a server to only those, which are absolutely **required for the intended service to be provided**.

Description

Unnecessary features increase the attack surface of a system. Limiting features of a system to only those necessary reduces this potential. The standard installation option (previously called Server Core) further reduces the risk when selected at installation.

Rationale

Services which may have impact to the whole infrastructure of Siemens (e.g., WINS, DHCP) shall only be provided by the responsible service providers.

Outdated services which may increase the attack surface of the server (e.g., SNMP, SMBv1) shall not be installed on any server.

Additionally, limiting features of a system to only those required for the provided service reduces attack surface of a system.

I01 - Implementation Example

Ensure either in "Windows Server Manager -> Manage -> Add Roles and Features -> Add Roles and Feature Wizard -> Roles ->Next" or using PowerShell ("Get-WindowsFeature") that only necessary and allowed features are installed.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Adapted the Windows Server 2012/Windows Server 2019 rule; not part of CIS Server 2016 Baseline.

BL968-0110

Asset Manager

C	I	A
123	123	123

Configure 'Active Directory Domain Membership'

Rule

Ensure that a server is a member of Siemens *OneAD*.

E01 - Isolated Network

The rule is not mandatory, if the system is connected to a separated, isolated network and no direct connection from the Siemens Intranet and from other Siemens systems is possible.

E02 - Security Conditions

If a non *OneAD* domain is qualified to provide the same security standards as *OneAD* itself, it is acceptable to join this domain instead. The assessment of the non *OneAD* domain shall be signed by the service owner of *OneAD* and shall be regularly re-approved.

Description

Domain membership ensures the availability of various security features, e.g.:

- An enterprise configuration rule set that needs to be followed but which can be quickly and flexibly adapted (e.g., using domain GPOs),
- An automatic deployment of machine certificates,
- A regular auditing process which detects any misconfiguration,
- A monitoring process that detects and assess potentially suspicious behavior,
- An incident process to assess and limit the effect of a potential attack.

The membership in one of the Siemens *OneAD* domains provides both, the experienced security professional personal as well as the technical conditions to accomplish a secure operation.

Rationale

Windows Server 2016 shall be operated in the most secure way. A membership in a Siemens *OneAD* domain offers the required security level as well as centrally provided security features. With a joint company domain, you can react very fast on zero-day exploits and other upcoming security threats.

A server without any domain membership (stand-alone) or with a membership in a domain with lower security standards than Siemens *OneAD* offers an entry-point for attackers to the Siemens infrastructure.

I01 - Implementation Example

Execute the following PowerShell command with administrative privileges to join a domain:

```
Add-Computer -DomainName <domain_name> -Credential  
<username_with_domain_rights> -PassThru -Verbose
```


C01 - Verifying if a system is joined to a domain

Execute the following PowerShell script to verify if a computer is joined to a domain:

```
$status = (Get-WmiObject -Class Win32_ComputerSystem).PartOfDomain
if ($status) {
    "This computer is joined to the domain $((Get-WmiObject -Class Win32_ComputerSystem).Domain)."
}
else {
    "This computer is not joined to a domain."
}
```

Listing: BL968-0110_C01_01.ps1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Adapted the Windows Server 2012/Windows Server 2019 rule; not part of CIS Server 2016 Baseline.

BL968-0747

Asset Manager

C	I	A
123	123	123

No Direct Remote Access from the Internet

Rule A direct remote access from the Internet to an Intranet server shall not be possible (e.g., RDP, VNC, TeamViewer).

Description

In this context, direct means employing technologies like RD Gateway/RD Web Access but not a VPN with strong authentication. To protect the server as well as the Intranet as a whole, direct RDP access must not be possible.

As well as Microsoft's RDP Protocol, other vendors and protocols are available to establish a Remote Desktop Connection. None of these are acceptable for use directly from the Internet.

Rationale

Direct Remote access to an Intranet server from the Internet without additional security measures makes it easy for an attacker to perform various attacks (e.g., login using stolen credentials, locking out credentials, performing attacks on the server/RDP port itself).

I01 - Implementation Example

Install a Windows 2016 Server only in networks which do not allow direct Remote Access from the Internet.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0769

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Subscribe to the Cybersecurity Governance Announcement Service

Rule

Subscribe to the *Cybersecurity Governance Announcement Service*.

Description

The *Cybersecurity Governance Announcement Service* is being used to notify subscribers about

- Changes in the Information Security policy framework which require mandatory actions (e.g., update of Information Security regulations),
- Specific Software vulnerabilities which require mandatory actions contrary to the standard process (e.g., a vulnerability is being exploited within Siemens and requires immediate remediation),
- Any other topics related to Cybersecurity Governance.

Rationale

A system responsible who does not subscribe to this service will not be informed about important security relevant notifications which require mandatory actions. This may end up in an insecure system being misused by attackers.

IO1 - Implementation Example

Siemens *Cybersecurity Governance* offers an Intranet page which lists all valid *Cybersecurity Governance Announcements* at <https://intranet.siemens.com/seg-announcement/>.

On that webpage you also find the possibility to subscribe to the announcement service with a valid email address and Siemens GID.

C01 - Checking your subscription to the Cybersecurity Governance Announcement Service

Visit the Intranet page at <https://intranet.siemens.com/seg-announcement/> and select the topic *Manage Subscription*. The upcoming webpage will let you know if you are subscribed to this service or not.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Adapted the Windows 10 MP rule; not part of CIS Server 2016 Baseline.

Account Policies

This section contains recommendations for account policies.

Password Policy

This section contains recommendations for password policy.

BL968-2896

Asset Manager

C	I	A
123	123	123

Ensure 'Enforce password history' is set to '24 or more password(s)'

Rule

Ensure 'Enforce password history' is set to '24 or more password(s)'.

Description

This policy setting determines the number of renewed, unique passwords that have to be associated with a user account before you can reuse an old password. The value for this policy setting must be between 0 and 24 passwords. To maintain the effectiveness of this policy setting, use the setting described in [BL968-5266 Ensure 'Minimum password age' is set to '1 or more day\(s\)'](#) to prevent users from repeatedly changing their password.

Rationale

The longer a user uses the same password, the greater the chance that an attacker can determine the password through brute force attacks. Also, any accounts that may have been compromised will remain exploitable for as long as the password is left unchanged. If password changes are required but password reuse is not prevented, or if users continually reuse a small number of passwords, the effectiveness of a good password policy is greatly reduced.

If you specify a low number for this policy setting, users will be able to use the same small number of passwords repeatedly. If you do not also configure the Minimum password age setting, users might repeatedly change their passwords until they can reuse their original password.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to 24 or more password(s) :

Computer Configuration\Policies\Windows Settings\Security Settings\Account Policies>Password Policy\Enforce password history

Impact:

The major impact of this configuration is that users must create a new password every time they are required to change their old one. If users are required to change their passwords to new unique values, there is an increased risk of users who write their passwords somewhere so that they do not forget them. Another risk is that users may create passwords that change incrementally (for example, password01, password02, and so on) to facilitate memorization but make them easier to guess. Also, an excessively low value for the Minimum password age setting will likely increase administrative overhead, because users who forget their passwords might ask the help desk to reset them frequently.

Impact:

Users must create a new password every time they are required to change their old one. At least 24 times.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 09.3.1-08](#)

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 1.1.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2741

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Maximum password age' is configured

Rule Ensure 'Maximum password age' is configured:

- For enabled **Standard Accounts**: value is set to '180 or fewer days, but not 0',
- For enabled **Privileged Accounts**: value is set to '45 or fewer days, but not 0',
- For enabled Standard **Shared User Accounts**: value is set to '180 or fewer days, but not 0',
- For enabled Privileged **Shared User Accounts**: value is set to '45 or fewer days, but not 0',
- For enabled Standard and Privileged **Service Accounts**: value is set to '365 or fewer days, but not 0'.

E01 - Accounts whose passwords are verified by a technical solution for compromised password detection (blacklist and behavioral analytics based)

The rule is not mandatory for accounts whose passwords are verified by a technical solution for compromised password detection (blacklist and behavioral analytics based).

A technical solution for compromised password detection complying to these requirements is available via Siemens OneAD and Siemens Azure AD and is implemented based on the features of [Azure AD Identity Protection](#) and [Microsoft Defender for Identity](#).

On systems, where this rule is omitted, either a Privileged Access Management or an organizational solution must be used for those accounts which are not part of Siemens OneAD (e.g., local accounts).

Description

This policy setting defines how long users can use their password before it expires.

Values for this policy setting range from 0 to 999 days. If you set the value to 0, the password will never expire.

Because attackers can crack passwords, the more frequently you change the password the less opportunity an attacker has to use a cracked password. However, the lower this value is set, the higher the potential for an increase in calls to help desk support due to users having to change their password or forgetting which password is current.

Rationale

The longer a password exists the higher the likelihood that it will be compromised by a brute force attack, by an attacker gaining general knowledge about the user, or by the user sharing the password. Configuring the Maximum password age setting to 0 so that users are never required to change their passwords is a major security risk because that allows a compromised password to be used by the malicious user for as long as the valid user has authorized access.

I01 - Implementation Example

To establish the recommended configuration via GP for enabled [Standard Accounts](#), set the following UI path to 180 or fewer days, but not 0:

Computer Configuration\Policies\Windows Settings\Security Settings\Account Policies>Password Policy\Maximum password age

For servers joined to a domain 'Fine-grained password policies (FGPP)' can be used to configure the recommended configuration for enabled [Privileged Accounts](#) as well as for enabled [Service Accounts](#).

Impact:

If the Maximum password age setting is too low, users are required to change their passwords very often. Such a configuration can reduce security in the organization because users might write their passwords in an insecure location or lose them. If the value for this policy setting is too high, the level of security within an organization is reduced because it allows potential attackers more time in which to discover user passwords or to use compromised accounts.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 09.4.3-04](#)

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 1.1.2

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added Check section, added different account types. Combined with previous rule BL968-2742. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5266

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Minimum password age' is set to '1 or more day(s)'

Rule

Ensure 'Minimum password age' is set to '1 or more day(s)'.

E01 - Privileged Access Management Solutions

This rule is not mandatory, i.e., the respective setting can be set to 0, for systems which are **exclusively** managed by Privileged Access Management solutions, such as CyberArk, using automated session establishment hiding account credentials from connecting user.

Description

This policy setting determines the number of days that you must use a password before you can change it. The range of values for this policy setting is between 1 and 999 days. (You may also set the value to 0 to allow immediate password changes). The default value for this setting is 0 days.

Rationale

Users may have favorite passwords that they like to use because they are easy to remember and they believe that their password choice is secure from compromise. Unfortunately, passwords are compromised and if an attacker is targeting a specific individual user account, with foreknowledge of data about that user, reuse of old passwords can cause a security breach. To address password reuse a combination of security settings is required. Using this policy setting with the Enforce password history setting prevents the easy reuse of old passwords. For example, if you configure the Enforce password history setting to ensure that users cannot reuse any of their last 12 passwords, they could change their password 13 times in a few minutes and reuse the password they started with, unless you also configure the Minimum password age setting to a number that is greater than 0. You must configure this policy setting to a number that is greater than 0 for the Enforce password history setting to be effective.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to 1 or more day(s) :

Computer Configuration\Policies\Windows Settings\Security Settings\Account Policies>Password Policy\Minimum password age

Impact:

If an administrator sets a password for a user but wants that user to change the password when the user first logs on, the administrator must select the User must change password at next logon check box, or the user will not be able to change the password until the next day.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 09.3.1-08](#)

[Based on Siemens Information Security Policy Framework Rule 09.4.3-05](#)

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 1.1.3

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added PAM exemption, added Check section. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2261

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Minimum password length' is configured

Rule Ensure 'Minimum password length' is configured:

- For enabled **Standard Accounts**: value is set to '12 or more character(s)',
- For enabled **Privileged Accounts**: value is set to '15 or more character(s)',
- For enabled Standard and Privileged **Shared User Accounts**: value is set to '15 or more character(s)',
- For enabled Standard and Privileged **Service Accounts**: value is set to '20 character(s)'.

Note: Due to technical limitations, Microsoft does not offer more than 20 characters for the password length.

Description

This policy setting determines the least number of characters that make up a password for a user account. There are many different theories about how to determine the best password length for an organization, but perhaps "pass phrase" is a better term than "password." In Microsoft Windows 2000 and newer, pass phrases can be quite long and can include spaces. Therefore, a phrase such as "I want to drink a \$5 milkshake" is a valid pass phrase; it is a considerably stronger password than an 8 or 10 character string of random numbers and letters, and yet is easier to remember. Users must be educated about the proper selection and maintenance of passwords, especially with regard to password length.

A 12-character password can be considered providing accurate security for enabled user accounts. This length allows users to easily remember their passwords, but is also long enough to protect passwords against a brute force attack. Additional complexity rules reduce the attacker's chances for success with a dictionary attack.

Note: In Windows Server 2016 and older versions of Windows Server, the GUI of the Local Security Policy (LSP), Local Group Policy Editor (LGPE) and Group Policy Management Editor (GPME) would not let you set this value higher than 14 characters. However, starting with Windows Server 2019, Microsoft changed the GUI to allow up to a 20 character minimum password length.

Rationale

Types of password attacks include dictionary attacks (which attempt to use common words and phrases) and brute force attacks (which try every possible combination of characters). Also, attackers sometimes try to obtain the account database so they can use tools to discover the accounts and passwords.

I01 - Implementation Example

To establish the recommended configuration via GP for enabled **Standard Accounts**, set the following UI path to 12 or more character(s) :

Computer Configuration\Policies\Windows Settings\Security Settings\Account Policies\Password Policy\Minimum password length

For servers joined to a domain 'Fine-grained password policies (FGPP)' can be used to configure the recommended configuration for enabled [Privileged Accounts](#) as well as for enabled [Service Accounts](#).

Impact:

User accounts must be secured with a password consisting of a defined length of characters depending on the user type.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 09.3.1-07](#)

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 1.1.4

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added Check section, added different account types. Combined with previous rule BL968-8186. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3756

Asset Manager

C	I	A
123	123	123

Ensure 'Password must meet complexity requirements' is set to 'Enabled'

Rule

Ensure 'Password must meet complexity requirements' is set to 'Enabled'.

Description

This policy setting checks all new passwords to ensure that they meet basic requirements for strong passwords.

When this policy is enabled, passwords must meet the following minimum requirements:

- Not contain the user's account name or parts of the user's full name that exceed two consecutive characters
- Contain characters from three of the following four categories:
 - English uppercase characters (A through Z)
 - English lowercase characters (a through z)
 - Base 10 digits (0 through 9)
 - Non-alphabetic characters (for example, !, \$, #, %)

Rationale

Passwords that contain only alphanumeric characters are extremely easy to discover with several publicly available tools.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Windows Settings\Security Settings\Account Policies>Password Policy>Password must meet complexity requirements

Impact:

None - This rule has been enabled for a long time.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 09.3.1-02

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 1.1.5

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2411

Asset Manager

C	I	A
123	123	123

Ensure 'Store passwords using reversible encryption' is set to 'Disabled'

Rule

Ensure 'Store passwords using reversible encryption' is set to 'Disabled'.

Description

This policy setting determines whether the operating system stores passwords in a way that uses reversible encryption, which provides support for application protocols that require knowledge of the user's password for authentication purposes. Passwords that are stored with reversible encryption are essentially the same as plaintext versions of the passwords.

Rationale

Enabling this policy setting allows the operating system to store passwords in a weaker format that is much more susceptible to compromise and weakens your system security.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Account Policies>Password Policy\Store passwords using reversible encryption

Impact:

This setting prohibits the usage of CHAP- and Digest Authentication. Both have not been allowed at Siemens already for a long time as they support weak password protection.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 09.4.3-06](#)

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 1.1.6

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Account Lockout Policy

This section contains recommendations for account lockout policy.

BL968-5216

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Account lockout duration' is configured

Rule

Ensure 'Account lockout duration' is set to '30' or more minute(s).

Description

This policy setting determines the length of time that must pass before a locked account is unlocked, and a user can try to log on again. The setting does this by specifying the number of minutes a locked out account will remain unavailable. If the value for this policy setting is configured to 0, locked out accounts will remain locked out until an administrator manually unlocks them.

Although it might seem like a good idea to configure the value for this policy setting to a high value, such a configuration will likely increase the number of calls that the help desk receives to unlock accounts locked by mistake. Users should be aware of the length of time a lock remains in place, so that they realize they only need to call the help desk if they have an extremely urgent need to regain access to their computer.

Rationale

A denial of service (DoS) condition can be created if an attacker abuses the Account lockout threshold and repeatedly attempts to log on with a specific account. Once you configure the Account lockout threshold setting, the account will be locked out after the specified number of failed attempts. If you configure the Account lockout duration setting to 0, then the account will remain locked out until an administrator unlocks it manually.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to 30 or more minute(s) :

Computer Configuration\Policies\Windows Settings\Security Settings\Account Policies\Account Lockout Policy\Account lockout duration

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 1.2.1

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added Check section, removed 0 as allowed value. This rule is not consistent with the CIS recommendation as it uses a different minimum duration of 30.

BL968-5041

Asset Manager

C	I	A
123	123	123

Ensure 'Account lockout threshold' is set to '10 or fewer invalid logon attempt(s), but not 0'

Rule Ensure 'Account lockout threshold' is set to '10 or fewer invalid logon attempt(s), but not 0'.

Description

This policy setting determines the number of failed logon attempts before the account is locked. Setting this policy to 0 does not conform to the benchmark as doing so disables the account lockout threshold.

Rationale

Setting an account lockout threshold reduces the likelihood that an online password brute force attack will be successful. Setting the account lockout threshold too low introduces risk of increased accidental lockouts and/or a malicious actor intentionally locking out accounts.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to 10 or fewer invalid login attempt(s), but not 0:

Computer Configuration\Policies\Windows Settings\Security Settings\Account Policies\Account Lockout Policy\Account lockout threshold

Impact:

A locked-out account will not be usable until it is reset by an administrator or until the account lockout duration expires.

If you enforce this setting an attacker could cause a denial of service condition by deliberately generating failed logons for multiple user, therefore, the Account Lockout Duration should be configured to a relatively low value.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 1.2.2

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5241

Asset Manager

C	I	A
123	123	123

Ensure 'Reset account lockout counter after' is set to '30 or more minute(s)'

Rule

Ensure 'Reset account lockout counter after' is set to '30 or more minute(s)'.

Description

This policy setting determines the length of time before the Account lockout threshold resets to zero. The default value for this policy setting is Not Defined. If the Account lockout threshold is defined, this reset time must be less than or equal to the value for the Account lockout duration setting.

If you leave this policy setting at its default value or configure the value to an interval that is too long, your environment could be vulnerable to a denial of service (DoS) attack. An attacker could maliciously perform a number of failed logon attempts on all users in the organization, which will lock out their accounts. If no policy were determined to reset the account lockout, it would be a manual task for administrators. Conversely, if a reasonable time value is configured for this policy setting, users would be locked out for a set period until all of the accounts are unlocked automatically.

Rationale

Users can accidentally lock themselves out of their accounts if they mistype their password multiple times. To reduce the chance of such accidental lockouts, the Reset account lockout counter after setting determines the number of minutes that must elapse before the counter that tracks failed logon attempts and triggers lockouts is reset to 0.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to 30 or more minute(s) :

Computer Configuration\Policies\Windows Settings\Security Settings\Account Policies\Account Lockout Policy\Reset account lockout counter after

Impact:

If you do not configure this policy setting or if the value is configured to an interval that is too long, a DoS attack could occur. An attacker could maliciously attempt to log on to each user's account numerous times and lock out their accounts as described in the preceding paragraphs. If you do not configure the Reset account lockout counter after setting, administrators would have to manually unlock all accounts. If you configure this policy setting to a reasonable value the users would be locked out for some period, after which their accounts would unlock automatically. Be sure that you notify users of the values used for this policy setting so that they will wait for the lockout timer to expire before they call the help desk about their inability to log on.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 1.2.3

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Local Policies

This section contains recommendations for local policies.

User Rights Assignment

This section contains recommendations for user rights assignments.

BL968-1606

Asset Manager

C	I	A
123	123	123

Ensure 'Access Credential Manager as a trusted caller' is set to 'No One'

Rule

Ensure 'Access Credential Manager as a trusted caller' is set to 'No One'.

Description

This security setting is used by Credential Manager during Backup and Restore. No accounts should have this user right, as it is only assigned to Winlogon. Users' saved credentials might be compromised if this user right is assigned to other entities.

Rationale

If an account is given this right the user of the account may create an application that calls into Credential Manager and is returned the credentials for another user.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to No One :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Access Credential Manager as a trusted caller

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Note: 'No One' is not an existing local or domain group. Using 'No One' shows that no account is assigned to this GP.

Impact:

None - this is the default configuration.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1181

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Access this computer from the network' is configured

Rule Ensure 'Access this computer from the network' is set on

- **Domain Controllers** to: Administrators, Authenticated Users, ENTERPRISE DOMAIN CONTROLLERS.
- **Member Servers** to: Administrators, Backup Operators, Authenticated Users.

Note: The above lists are to be treated as whitelists, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting allows other users on the network to connect to the computer and is required by various network protocols that include

- Server Message Block (SMB)-based protocols
- NetBIOS
- Common Internet File System (CIFS)
- Component Object Model Plus (COM+).

Rationale

Users who can connect from their computer to the network can access resources on target computers for which they have permission. For example, the Access this computer from the network user right is required for users to connect to shared printers and folders.

I01 - Implementation Example

To establish the recommended configuration via GP, configure the following UI path:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Access this computer from the network

- **Domain Controller:** Administrators, Authenticated Users, ENTERPRISE DOMAIN CONTROLLERS.
- **Member Server:** Administrators, Backup Operators, Authenticated Users.

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

If you remove the Access this computer from the network user right on domain controllers for all users, no one will be able to log on to the domain or use network resources. If you remove this user right on member servers, users will not be able to connect to those servers through the network. Successful negotiation of IPsec connections requires that the initiating machine has this right; therefore it is recommended that it is assigned to the Users group. If you have installed optional components such as ASP.NET or Internet Information Services (IIS), you may need to assign this user right to additional accounts that are required by those components. It is important to verify that authorized users are assigned this user right for the computers they need to access the network.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.3

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added Backup Operators as allowed value, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Textual rephrasing of whitelist note in rule.

BL968-5526

Asset Manager

C	I	A
123	123	123

Ensure 'Act as part of the operating system' is set to 'No One'

Rule

Ensure 'Act as part of the operating system' is set to 'No One'.

Description

This policy setting allows a process to assume the identity of any user and thus gain access to the resources that the user is authorized to access.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale

The **Act as part of the operating system** user right is extremely powerful. Anyone with this user right can take complete control of the computer and erase evidence of their activities.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to No One :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Act as part of the operating system

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Note: 'No One' is not an existing local or domain group. Using 'No One' shows that no account is assigned to this GP.

Impact:

There should be little or no impact, because the 'Act as part of the operating system' user right is rarely needed by any accounts other than the Local System account.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.4

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3986

Asset Manager

C	I	A
123	123	123

Ensure 'Add workstations to domain' is set to 'Administrators' (DC only)

Rule Ensure 'Add workstations to domain' is set

- on **Domain Controllers** to: 'Administrators'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting specifies which users can add computer workstations to a specific domain. For this policy setting to take effect, it must be assigned to the user as part of the Domain Controller Policy for the domain.

Rationale

The **Add workstations to domain** user right presents a moderate vulnerability. Users with this right could add a computer to the domain that is configured in a way that violates organizational security policies.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Administrators** :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Add workstations to domain

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

This countermeasure will force users to follow the process to add her or his computer to the Siemens domain. It will not affect existing computers unless they are removed from and re-added to the domain.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.5

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3021

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Adjust memory quotas for a process' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE'

Rule Ensure 'Adjust memory quotas for a process' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

E01 - Exemption

If an active application on the server requires dedicated service accounts needing this permission (e.g., Microsoft IIS or Microsoft SQL Server), then these dedicated service accounts can be added to the list of allowed values.

The additional accounts need to be documented accordingly.

Description

This policy setting allows a user to adjust the maximum amount of memory that is available to a process. The ability to adjust memory quotas is useful for system tuning, but it can be abused. In the wrong hands, it could be used to launch a denial of service (DoS) attack.

Rationale

A user with the **Adjust memory quotas for a process** user right can reduce the amount of memory that is available to any process, which could cause business-critical network applications to become slow or to fail. In the wrong hands, this privilege could be used to start a denial of service (DoS) attack.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators, LOCAL SERVICE, NETWORK SERVICE`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Adjust memory quotas for a process

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

Organizations that have not restricted users to roles with limited privileges will find it difficult to impose this countermeasure. Also, if you have installed optional components such as ASP.NET or IIS, you may need to assign the **Adjust memory quotas for a process** user right to additional accounts that are required by those components. Otherwise, this countermeasure should have no impact on most computers. If this user right is necessary for a user account, it can be assigned to a local computer account instead of a domain account.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.6

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed during review: Added exemption E01. Textual rephrasing of whitelist note in rule, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1226

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Allow log on locally' is configured

Rule Ensure 'Allow log on locally' is set

- **on Domain Controllers** to: Administrators.
- **on Member Servers** to: Administrators, Backup Operators.

Note: The above lists are to be treated as whitelists, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

E01 - Exemption

Users who need to log on through Terminal Services or IIS can additionally be granted this user right. These additional users must be documented.

E02 - Exemption

This rule can be extended with an additional, dedicated group 'AllowLogonLocallyUsers', requiring this permission. This group shall only be configured locally with those users who explicitly require this user right on that specific server.

The members of this local group must be documented.

Description

This policy setting determines which users can interactively log on to computers in your environment. Logons that are initiated by pressing the CTRL+ALT+DEL key sequence on the client computer keyboard require this user right.

Rationale

Any account with the **Allow log on locally** user right can log on at the console of the computer. If you do not restrict this user right to legitimate users who need to be able to log on to the console of the computer, unauthorized users could download and run malicious software to elevate their privileges.

I01 - Implementation Example

To establish the recommended configuration via GP, configure the following UI path:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Allow log on locally

- **Domain Controller:** The recommended state for this setting is: Administrators.

- **Member Server:** The recommended state for this setting is: Administrators, Backup Operators.

Impact:

This measure limits the abilities of users on servers by avoiding local logons.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.7

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added exemption for additional, dedicated group, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Textual rephrasing of whitelist note in rule. Rephrased exemption E02.

BL968-2181

Asset Manager

C	I	A
123	123	123

Ensure 'Allow log on through Remote Desktop Services' is configured

Rule Ensure 'Allow log on through Remote Desktop Services' is set on

- **Domain Controllers** to: Administrators.
- **Member Servers** to: Administrators, Backup Operators, Remote Desktop Users.

Note: The above lists are to be treated as whitelists, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

E01 - Role: Remote Desktop Connection Broker

If the role "Remote Desktop Services" is installed and 'Remote Desktop Connection Broker' service runs, then the group 'Authenticated Users' can be included in the list of allowed groups on Member Servers.

Description

This policy setting determines which users or groups have the right to log on as a Terminal Services client.

This user right prevents unwanted users from gaining access to computers on your network by means of the Remote Assistance feature.

Rationale

Any account with the **Allow log on through Remote Desktop Services** user right can log on to the remote console of the computer. If you do not restrict this user right to legitimate users who need to log on to the console of the computer, unauthorized users could download and run malicious software to elevate their privileges.

Note: 'Backup operators' are additionally added to this rule, because it should not be necessary to use an account with full Administrator rights for backup operations.

I01 - Implementation Example

To establish the recommended configuration via GP, configure the following UI path:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Allow log on through Remote Desktop Services

- **Domain Controller:** Administrators.
- **Member Server:** Administrators, Backup Operators, Remote Desktop Users.

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Note: Assign Write or Read permissions to specific users or dedicated groups. Never assign these two permissions to very general groups, such as Domain Users, Authenticated Users, Everyone, or siemens.netUsers

Impact:

Removal of the 'Allow log on through Terminal Services' user right from other groups or membership changes in these default groups could limit the abilities of users who perform specific administrative roles in your environment.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.8

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942) Changed during review: Textual rephrasing of whitelist note in rule.

BL968-5841

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Back up files and directories' is configured

Rule Ensure 'Back up files and directories' is set to 'Administrators' or 'Administrators, Backup Operators'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting allows users to circumvent file and directory permissions to back up the system. This user right is enabled only when an application (such as NTBACKUP) attempts to access a file or directory through the NTFS file system backup application programming interface (API). Otherwise, the assigned file and directory permissions apply.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale

Users who are able to back up data from a computer could take the backup media to a non-domain computer on which they have administrative privileges and restore the data. They could take ownership of the files and view any unencrypted data that is contained within the backup set.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators` or `Administrators, Backup Operators`.

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Back up files and directories

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

Changes in the membership of the groups that have the **Back up files and directories** user right could limit the abilities of users who are assigned to specific administrative roles in your environment. You should confirm that authorized backup administrators are still able to perform backup operations.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.10

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Textual rephrasing of whitelist note in rule, added Backup operators as allowed value, added Check section. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5246

Asset Manager

C	I	A
123	123	123

Ensure 'Change the system time' is set to 'Administrators, LOCAL SERVICE'

Rule Ensure 'Change the system time' is set to 'Administrators, LOCAL SERVICE'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting determines which users and groups can change the time and date on the internal clock of the computers in your environment. Users who are assigned this user right can affect the appearance of event logs. When a computer's time setting is changed, logged events reflect the new time, not the actual time that the events occurred.

Note: Discrepancies between the time on the local computer and on the Domain Controllers in your environment may cause problems for the Kerberos authentication protocol, which could make it impossible for users to log on to the domain or obtain authorization to access domain resources after they are logged on. Also, problems will occur when Group Policy is applied to client computers if the system time is not synchronized with the Domain Controllers.

Rationale

Users who can change the time on a computer could cause several problems. For example, time stamps on event log entries could be made inaccurate, time stamps on files and folders that are created or modified could be incorrect, and computers that belong to a domain may not be able to authenticate themselves or users who try to log on to the domain from them. Also, because the Kerberos authentication protocol requires that the requester and authenticator have their clocks synchronized within an administrator-defined skew period, an attacker who changes a computer's time may cause that computer to be unable to obtain or grant Kerberos tickets.

The risk from these types of events is mitigated on most Domain Controllers, Member Servers, and end-user computers because the Windows Time service automatically synchronizes time with Domain Controllers in the following ways:

- All client desktop computers and Member Servers use the authenticating Domain Controller as their inbound time partner.
- All Domain Controllers in a domain nominate the Primary Domain Controller (PDC) Emulator operations master as their inbound time partner.
- All PDC Emulator operations masters follow the hierarchy of domains in the selection of their inbound time partner.
- The PDC Emulator operations master at the root of the domain is authoritative for the organization. Therefore, it is recommended that you configure this computer to synchronize with a reliable external time server.

This vulnerability becomes much more serious if an attacker is able to change the system time and then stop the Windows Time service or reconfigure it to synchronize with a time server that is not accurate.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Administrators, LOCAL SERVICE :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Change the system time

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

There should be no impact for all computers that belong to Siemens domains. Unmanaged computers that do not belong to the Siemens domains have to be configured to synchronize with a reliable source, so there this setting should not have any impact as well.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.11

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3046

Asset Manager

C	I	A
123	123	123

Ensure 'Change the time zone' is set to 'Administrators, LOCAL SERVICE'

Rule Ensure 'Change the time zone' is set to 'Administrators, LOCAL SERVICE'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This setting determines which users can change the time zone of the computer. This ability holds no great danger for the computer and may be useful for mobile workers.

Rationale

Changing the time zone represents little vulnerability because the system time is not affected. This setting merely enables users to display their preferred time zone while being synchronized with Domain Controllers in different time zones.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators, LOCAL SERVICE`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Change the time zone

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Note: 'No One' is not an existing local or domain group. Using 'No One' shows that no account is assigned to this GP.

Impact:

None - this is the default configuration.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.12

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1406

Asset Manager

C	I	A
123	123	123

Ensure 'Create a pagefile' is set to 'Administrators'

Rule Ensure 'Create a pagefile' is set to 'Administrators'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting allows users to change the size of the pagefile. By making the pagefile extremely large or extremely small, an attacker could easily affect the performance of a compromised computer.

Rationale

Users who can change the page file size could make it extremely small or move the file to a highly fragmented storage volume, which could cause reduced computer performance.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Create a pagefile

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.13

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3231

Asset Manager

C	I	A
123	123	123

Ensure 'Create a token object' is set to 'No One'

Rule

Ensure 'Create a token object' is set to 'No One'.

Description

This policy setting allows a process to create an access token, which may provide elevated rights to access sensitive data.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale

A user account that is given this user right has complete control over the system and can lead to the system being compromised. It is highly recommended that you do not assign any user accounts this right.

The operating system examines a user's access token to determine the level of the user's privileges. Access tokens are built when users log on to the local computer or connect to a remote computer over a network. When you revoke a privilege, the change is immediately recorded, but the change is not reflected in the user's access token until the next time the user logs on or connects. Users with the ability to create or modify tokens can change the level of access for any currently logged on account. They could escalate their own privileges or create a denial of service (DoS) condition.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to No One :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Create a token object

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Note: 'No One' is not an existing local or domain group. Using 'No One' shows that no account is assigned to this GP.

Impact:

None - this is the default configuration.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.14

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5831

Asset Manager

C	I	A
123	123	123

Ensure 'Create global objects' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE'

Rule Ensure 'Create global objects' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting determines whether users can create global objects that are available to all sessions. Users can still create objects that are specific to their own session if they do not have this user right.

Users who can create global objects could affect processes that run under other users' sessions. This capability could lead to a variety of problems, such as application failure or data corruption.

Rationale

Users who can create global objects could affect Windows services and processes that run under other user or system accounts. This capability could lead to a variety of problems, such as application failure, data corruption and elevation of privilege.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE`:

`Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Create global objects`

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.15

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1281

Asset Manager

C	I	A
123	123	123

Ensure 'Create permanent shared objects' is set to 'No One'

Rule

Ensure 'Create permanent shared objects' is set to 'No One'.

Description

This user right is useful to kernel-mode components that extend the object namespace. However, components that run in kernel mode have this user right inherently. Therefore, it is typically not necessary to specifically assign this user right.

Rationale

Users who have the **Create permanent shared objects** user right could create new shared objects and expose sensitive data to the network.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to No One :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Create permanent shared objects

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Note: 'No One' is not an existing local or domain group. Using 'No One' shows that no account is assigned to this GP.

Impact:

None - this is the default configuration.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.16

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3541

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Create symbolic links' is set to 'Administrators'

Rule Ensure 'Create symbolic links' is set to Administrators.

On **Member Servers**: This user right can additionally be assigned to the special group Virtual Machines, if required.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting determines which users can create symbolic links. In Windows Vista, existing NTFS file system objects, such as files and folders, can be accessed by referring to a new kind of file system object called a symbolic link. A symbolic link is a pointer (much like a shortcut or .lnk file) to another file system object, which can be a file, folder, shortcut, or another symbolic link. The difference between a shortcut and a symbolic link is that a shortcut only works from within the Windows shell. To other programs and applications, shortcuts are just another file, whereas with symbolic links, the concept of a shortcut is implemented as a feature of the NTFS file system.

Symbolic links can potentially expose security vulnerabilities in applications that are not designed to use them. For this reason, the privilege for creating symbolic links should only be assigned to trusted users. By default, only Administrators can create symbolic links.

Rationale

Users who have the **Create symbolic links** user right could inadvertently or maliciously expose your system to symbolic link attacks. Symbolic link attacks can be used to change the permissions on a file, to corrupt data, to destroy data, or as a Denial of Service attack.

I01 - Implementation Example

To implement the recommended configuration state, set the following UI path to Administrators

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Create symbolic links

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

In most cases there will be no impact because this is the default configuration. However, on Windows Servers with the Hyper-V server role installed, this user right should also be granted to the special group Virtual Machines - otherwise you will not be able to create new virtual machines.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.17

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Textual rephrasing of whitelist note in rule, also allowed special group Virtual Machines, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1221

Asset Manager

C	I	A
123	123	123

Ensure 'Debug programs' is set to 'Administrators'

Rule Ensure 'Debug programs' is set to 'Administrators'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Note: As the permission 'Debug programs' is highly critical, it should be assigned to a single administrator account only as long as this user right is needed to resolve a problem.

Description

This policy setting determines which user accounts will have the right to attach a debugger to any process or to the kernel, which provides complete access to sensitive and critical operating system components. Developers who are debugging their own applications do not need to be assigned this user right; however, developers who are debugging new system components will need it.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale

The **Debug programs** user right can be exploited to capture sensitive computer information from system memory, or to access and modify kernel or application structures. Some attack tools exploit this user right to extract hashed passwords and other private security information, or to insert rootkit code. By default, the **Debug programs** user right is assigned only to administrators, which helps to mitigate the risk from this vulnerability.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Debug programs

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

If you revoke this user right, no one will be able to debug programs. However, typical circumstances rarely require this capability on production computers. If a problem arises that requires an application to be debugged on a production server, you can move the server to a different OU temporarily and assign the **Debug programs** user right to a separate Group Policy for that OU.

The service account that is used for the cluster service needs the **Debug programs** user right; if it does not have it, Windows Clustering will fail.

Tools that are used to manage processes will be unable to affect processes that are not owned by the person who runs the tools. For example, the Windows Debugging tool Kill.exe [Microsoft - Kill Tool](#) requires this user right for administrators to terminate processes that they did not start.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.19

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1251

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Deny access to this computer from the network' is configured

Rule

Ensure 'Deny access to this computer from the network' is set on

- **Domain Controllers** to: 'Anonymous logon', 'Guests', 'all service accounts'.
- **Member Servers** to: 'Guests', 'Local Guest Account', 'Built-in local Administrator', 'all service accounts'.

Note: As it might be difficult to know 'all service accounts' in OneAD, at least all known services accounts shall be listed instead.

Note: The above lists are to be treated as blacklists, which implies that the above listed values have to be present to accomplish this rule in an assessment, but further, additional values are also allowed.

E01 - Accounts required to start services

Service accounts that are used to start services that must connect to the computer over the network are valid exemptions to this rule.

Description

This policy setting prohibits users from connecting to a computer from across the network, which would allow users to access and potentially modify data remotely. In high security environments, there should be no need for remote users to access data on a computer. Instead, file sharing should be accomplished through the use of network servers. This user right supersedes the **Access this computer from the network** user right if an account is subject to both policies.

Rationale

Users who can log on to the computer over the network can enumerate lists of account names, group names, and shared resources. Users with permission to access shared folders and files can connect over the network and possibly view or modify data.

I01 - Implementation Example

To establish the recommended configuration via GP, configure the following UI path:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Deny access to this computer from the network

- **Domain Controllers:** Anonymous logon, Guests, all service accounts.
- **Member Servers:** Guests, Local Guest Account, Built-in local Administrator account, all service accounts

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Note: 'all service accounts' is not an existing local or domain group. 'all service accounts' stands for those accounts which assigned to a Windows service.

Impact:

If you configure the 'Deny access to this computer from the network' user right for other groups, you could limit the abilities of users who are assigned to specific administrative roles in your environment. You should verify that delegated tasks will not be negatively affected (see the link above in the description section).

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.20

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Moved exemption 02 to Rule Note, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Textual rephrasing of blacklist note in rule.

BL968-1156

Asset Manager

C	I	A
123	123	123

Ensure 'Deny log on as a batch job' is set to 'Guests'

Rule Ensure 'Deny log on as a batch job' is set to 'Guests'.

Note: The above list is to be treated as a blacklist, which implies that the above listed values have to be present to accomplish this rule in an assessment, but further, additional values are also allowed.

Description

This policy setting determines which accounts will not be able to log on to the computer as a batch job. A batch job is not a batch (.bat) file, but rather a batch-queue facility. Accounts that use the Task Scheduler to schedule jobs need this user right.

The 'Deny log on as a batch job' user right supersedes the user right [BL968-5032 Ensure 'Log on as a batch job' is configured](#), which could be used to allow accounts to schedule jobs that consume excessive system resources. Such an occurrence could cause a denial of service (DoS) condition. Failure to assign this user right to the recommended accounts can be a security risk.

Note: If you assign the 'Deny log on as a batch job' user right to other accounts, you could deny users who are assigned to specific administrative roles the ability to perform their required job activities. You should confirm that delegated tasks will not be affected adversely.

Rationale

Accounts that have the **Log on as a batch job** user right could be used to schedule jobs that could consume excessive computer resources and cause a denial of service (DoS) condition.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path is set to `Guests` :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Deny log on as a batch job

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

None - The configuration 'Guests' is not allowed at Siemens.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.22

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of blacklist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1831

Asset Manager

C	I	A
123	123	123

Ensure 'Deny log on as a service' is set to 'Guests'

Rule Ensure 'Deny log on as a service' is set to 'Guests'.

Note: The above list is to be treated as a blacklist, which implies that the above listed values have to be present to accomplish this rule in an assessment, but further, additional values are also allowed.

Description

This security setting determines which service accounts are prevented from registering a process as a service. This policy setting supersedes the user right [BL968-5031 Configure 'Log on as a service'](#) policy setting if an account is subject to both policies.

Note: This security setting does not apply to the `System`, `Local Service`, or `Network Service` accounts.

Rationale

Accounts that can log on as a service could be used to configure and start new unauthorized services, such as a keylogger or other malicious software. The benefit of the specified countermeasure is somewhat reduced by the fact that only users with administrative privileges can install and configure services, and an attacker who has already attained that level of access could configure the service to run with the `System` account.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path is set to `Guests` :

`Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Deny log on as a service`

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

If you assign the **Deny log on as a service** user right to specific accounts, services may not be able to start and a denial of service (DoS) condition could result.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.23

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4186

Asset Manager

C	I	A
123	123	123

Ensure 'Deny log on locally' is set to 'Guests'

Rule Ensure 'Deny log on locally' is set to 'Guests'.

Note: The above list is to be treated as a blacklist, which implies that the above listed values have to be present to accomplish this rule in an assessment, but further, additional values are also allowed.

Description

This security setting determines which users are prevented from logging on at the computer. This policy setting supersedes the **Allow log on locally** policy setting if an account is subject to both policies.

Important: If you apply this security policy to the `Everyone` group, no one will be able to log on locally.

Rationale

Any account with the ability to log on locally could be used to log on at the console of the computer. If this user right is not restricted to legitimate users who need to log on to the console of the computer, unauthorized users might download and run malicious software that elevates their privileges.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path is set to `Guests` :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Deny log on locally

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

If you assign the **Deny log on locally** user right to additional accounts, you could limit the abilities of users who are assigned to specific roles in your environment.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.24

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of blacklist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2561

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Deny log on through Remote Desktop Services' is configured

Rule Ensure 'Deny log on through Remote Desktop Services' is set to 'Guests' and 'all service accounts'.

Note: As it might be difficult to know 'all service accounts' in OneAD, at least all known services accounts shall be listed instead.

Note: The above list is to be treated as a blacklist, which implies that the above listed values have to be present to accomplish this rule in an assessment, but further, additional values are also allowed.

Description

This policy setting determines whether users can log on as Remote Desktop clients. After the baseline Member Server is joined to a domain environment, there is no need to use local accounts to access the server from the network. Domain accounts can access the server for administration and end-user processing. This user right supersedes the **Allow log on through Remote Desktop Services** user right if an account is subject to both policies.

More information can be found here: [Microsoft Docs: Deny log on through Remote Desktop Services](#).

Rationale

Any account with the right to log on through Remote Desktop Services could be used to log on to the remote console of the computer. If this user right is not restricted to legitimate users who need to log on to the console of the computer, unauthorized users might download and run malicious software that elevates their privileges.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to include `Guests`, `all service accounts`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Deny log on through Remote Desktop Services

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Note: 'all service accounts' is not an existing local or domain group. 'all service accounts' stands for those accounts which assigned to a Windows service.

Impact:

If you assign the 'Deny log on through Terminal Services' user right to other groups, you could limit the abilities of users who are assigned to specific administrative roles in your environment. Accounts that have this user right will be unable to connect to the computer through either Terminal Services or Remote Assistance. You should confirm that delegated tasks will not be negatively impacted.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.25

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Textual rephrasing of blacklist note in rule, moved exemption 01 to Rule Note, added Check section. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5881

Asset Manager

C	I	A
123	123	123

Ensure 'Enable computer and user accounts to be trusted for delegation' is configured

Rule Ensure 'Enable computer and user accounts to be trusted for delegation' is set on

- **Domain Controllers** to: 'Administrators'.
- **Member Servers** to: 'No One'.

Description

This policy setting allows users to change the Trusted for Delegation setting on a computer object in Active Directory. Abuse of this privilege could allow unauthorized users to impersonate other users on the network.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale

Misuse of the **Enable computer and user accounts to be trusted for delegation** user right could allow unauthorized users to impersonate other users on the network. An attacker could exploit this privilege to gain access to network resources and make it difficult to determine what has happened after a security incident.

I01 - Implementation Example

To establish the recommended configuration via GP, configure the following UI path:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Enable computer and user accounts to be trusted for delegation

- **Domain Controller:** Administrators.
- **Member Server:** No One.

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Note: 'No One' is not an existing local or domain group. Using 'No One' shows that no account is assigned to this GP.

Impact:

None - this is the default configuration.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.27

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.28

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Removed inappropriate note in rule, added second CIS crossreference, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1756

Asset Manager

C	I	A
123	123	123

Ensure 'Force shutdown from a remote system' is set to 'Administrators'

Rule Ensure 'Force shutdown from a remote system' is set to 'Administrators'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting allows users to shut down Windows Vista-based and newer computers from remote locations on the network. Anyone who has been assigned this user right can cause a denial of service (DoS) condition, which would make the computer unavailable to service user requests. Therefore, it is recommended that only highly trusted administrators be assigned this user right.

Rationale

Any user who can shut down a computer could cause a denial of service (DoS) condition to occur. Therefore, this user right should be tightly restricted.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators` :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Force shutdown from a remote system

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

If you remove the **Force shutdown from a remote system** user right from the Server Operator group, you could limit the abilities of users who are assigned to specific administrative roles in your environment. You should confirm that delegated activities will not be adversely affected.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.29

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2586

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Generate security audits' is set to 'LOCAL SERVICE, NETWORK SERVICE'

Rule Ensure 'Generate security audits' is set to 'LOCAL SERVICE, NETWORK SERVICE'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

E01 - Exemption

If an active application on the server requires dedicated service accounts needing this permission (e.g., Microsoft IIS or Microsoft SQL Server), then these dedicated service accounts can be added to the list of allowed values.

The additional accounts need to be documented accordingly.

Description

This policy setting determines which users or processes can generate audit records in the Security log.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale

An attacker could use this capability to create a large number of audited events, which would make it more difficult for a system administrator to locate any illicit activity. Also, if the event log is configured to overwrite events as needed, any evidence of unauthorized activities could be overwritten by a large number of unrelated events.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `LOCAL SERVICE, NETWORK SERVICE`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Generate security audits

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

On most computers, this is the default configuration and there will be no negative impact.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.30

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed during review: Added exemption E01. Textual rephrasing of whitelist note in rule, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3166

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Impersonate a client after authentication' is configured

Rule Ensure 'Impersonate a client after authentication' is set to 'Administrators', 'LOCAL SERVICE', 'NETWORK SERVICE', 'SERVICE'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

E01 - Exemption

If an active application on the server requires dedicated service accounts needing this permission (e.g., Microsoft IIS or Microsoft SQL Server), then these dedicated service accounts can be added to the list of allowed values.

The additional accounts need to be documented accordingly.

Description

The policy setting allows programs that run on behalf of a user to impersonate that user (or another specified account) so that they can act on behalf of the user. If this user right is required for this kind of impersonation, an unauthorized user will not be able to convince a client to connect - for example, by remote procedure call (RPC) or named pipes - to a service that they have created to impersonate that client, which could elevate the unauthorized user's permissions to administrative or system levels.

Services that are started by the Service Control Manager have the built-in Service group added by default to their access tokens. COM servers that are started by the COM infrastructure and configured to run under a specific account also have the Service group added to their access tokens. As a result, these processes are assigned this user right when they are started.

Also, a user can impersonate an access token if any of the following conditions exist:

- The access token that is being impersonated is for this user.
- The user, in this logon session, logged on to the network with explicit credentials to create the access token.
- The requested level is less than Impersonate, such as Anonymous or Identify.

An attacker with the **Impersonate a client after authentication** user right could create a service, trick a client to make them connect to the service, and then impersonate that client to elevate the attacker's level of access to that of the client.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale

An attacker with the **Impersonate a client after authentication** user right could create a service, trick a client to make them connect to the service, and then impersonate that client to elevate the attacker's level of access to that of the client.

I01 - Implementation Example

To establish the recommended configuration via GP, configure the following UI path to Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Impersonate a client after authentication

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

In most cases this configuration will have no impact.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.31

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed during review: Added exemption E01. Textual rephrasing of whitelist note in rule. Added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4146

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Increase scheduling priority' is set to 'Administrators, Window Manager\Window Manager Group'

Rule

Ensure 'Increase scheduling priority' is set to 'Administrators, Window Manager\Window Manager Group'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting determines whether users can increase the base priority class of a process. (It is not a privileged operation to increase relative priority within a priority class). This user right is not required by administrative tools that are supplied with the operating system but might be required by software development tools.

Rationale

A user who is assigned this user right could increase the scheduling priority of a process to Real-Time, which would leave little processing time for all other processes and could lead to a denial of service (DoS) condition.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators, Window Manager\Window Manager Group`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Increase scheduling priority

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.33

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Textual rephrasing of whitelist note in rule, also allowed Window Manager Group, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4031

Asset Manager

C	I	A
123	123	123

Ensure 'Load and unload device drivers' is set to 'Administrators'

Rule Ensure 'Load and unload device drivers' is set to 'Administrators'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting allows users to dynamically load a new device driver on a system. An attacker could potentially use this capability to install malicious code that appears to be a device driver. This user right is required for users to add local printers or printer drivers in Windows Vista.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale

Device drivers run as highly privileged code. A user who has the **Load and unload device drivers** user right could unintentionally install malicious code that masquerades as a device driver. Administrators should exercise greater care and install only drivers with verified digital signatures.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Load and unload device drivers

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

None - Only Administrators are allowed to load or unload device drivers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.34

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1441

Asset Manager

C	I	A
123	123	123

Ensure 'Lock pages in memory' is set to 'No One'

Rule

Ensure 'Lock pages in memory' is set to 'No One'.

Description

This policy setting allows a process to keep data in physical memory, which prevents the system from paging the data to virtual memory on disk. If this user right is assigned, significant degradation of system performance can occur.

Rationale

Users with the **Lock pages in memory** user right could assign physical memory to several processes, which could leave little or no RAM for other processes and result in a denial of service (DoS) condition.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to No One :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Lock pages in memory

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Note: 'No One' is not an existing local or domain group. Using 'No One' shows that no account is assigned to this GP.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.35

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5032

EVAL until 2022-02-28

Asset Manager

C	I	A
3	3	3

Ensure 'Log on as a batch job' is configured

Rule Ensure 'Log on as a batch job' is set to 'Administrators' or 'Administrators, Backup Operators'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

E01 - Exemption

If mandatorily required operational procedures (e.g., patching using third-party tools) on the server require dedicated service accounts needing this permission (e.g., BladeLogicRSCD), then these dedicated service accounts can be added to the list of allowed values.

The additional accounts need to be documented accordingly including its operational purpose.

Description

This policy setting allows accounts to log on using the task scheduler service. Because the task scheduler is often used for administrative purposes, it may be needed in enterprise environments. However, its use should be restricted in high security environments to prevent misuse of system resources or to prevent attackers from using the right to launch malicious code after gaining user level access to a computer. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

More information can be found here: [Microsoft Docs: Log on as a batch job](#).

Rationale

The **Log on as a batch job** user right presents a low-risk vulnerability. For most organizations, the default settings are sufficient.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators` or `Administrators, Backup Operators`:

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Log on as a batch job

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

None - this is the default configuration.

Computers cannot assign the user right to accounts that are used for scheduled jobs in the Task Scheduler.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.36

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed during review: Added exemption for mandatorily required additional service accounts. Textual rephrasing of whitelist note in rule, added Backup Operators as allowed value, added Check section. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5031

Asset Manager

C	I	A
123	123	123

Configure 'Log on as a service'

Rule

Ensure 'Log on as a service' is set to a minimized number of accounts.

Description

If a service should run under a newly created account, then the 'Log on as a service' right has to be assigned here. Only the built-in accounts 'Local System', 'Local Service' and 'Network Service' have the built-in right to 'Log on as a service'.

Note: By definition, the Network Service account has the 'Log on as a service' user right. This right is not granted through the Group Policy setting.

More information can be found here: [Windows IT Pro Center - Log on as a service](#).

Rationale

To start network services or continuously running services the user right 'Log on as a service' is required for the installed service account. It should be considered that attackers with privileged rights could always install a service to run with the powerful 'Local System' account, which has the 'Logon as a service' user right assigned by default.

I01 - Implementation Example

By definition, the Network Service account has the 'Log on as a service' user right. This right is not granted through the Group Policy setting. You should minimize the number of other accounts that are granted this user right

Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Log on as a service

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

On most computers, restricting the 'Log on as a service' user right to the Local System, Local Service, and Network Service built-in accounts is the default configuration, and there is no negative impact.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Adapted from Siemens Windows Server 2019 (BL942).

BL968-1701

Asset Manager

C	I	A
123	123	123

Ensure 'Manage auditing and security log' is configured

Rule Ensure 'Manage auditing and security log' is set to 'Administrators'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting determines which users can change the auditing options for files and directories and clear the Security log.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale

The ability to manage the Security event log is a powerful user right and it should be closely guarded. Anyone with this user right can clear the Security log to erase important evidence of unauthorized activity.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Administrators:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Manage auditing and security log

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

None - this is the default configuration.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.37

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2716

Asset Manager

C	I	A
123	123	123

Ensure 'Modify an object label' is set to 'No One'

Rule

Ensure 'Modify an object label' is set to 'No One'.

Description

This privilege determines which user accounts can modify the integrity label of objects, such as files, registry keys, or processes owned by other users. Processes running under a user account can modify the label of an object owned by that user to a lower level without this privilege.

Rationale

By modifying the integrity label of an object owned by another user a malicious user may cause them to execute code at a higher level of privilege than intended.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to No One :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Modify an object label

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Note: 'No One' is not an existing local or domain group. Using 'No One' shows that no account is assigned to this GP.

Impact:

None - this is the default configuration.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.39

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3861

Asset Manager

C	I	A
123	123	123

Ensure 'Modify firmware environment values' is set to 'Administrators'

Rule Ensure 'Modify firmware environment values' is set to 'Administrators'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting allows users to configure the system-wide environment variables that affect hardware configuration. This information is typically stored in the Last Known Good Configuration. Modification of these values and could lead to a hardware failure that would result in a denial of service condition.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale

Anyone who is assigned the **Modify firmware environment values** user right could configure the settings of a hardware component to cause it to fail, which could lead to data corruption or a denial of service (DoS) condition.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators` :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Modify firmware environment values

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.40

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5176

Asset Manager

C	I	A
123	123	123

Ensure 'Perform volume maintenance tasks' is set to 'Administrators'

Rule Ensure 'Perform volume maintenance tasks' is set to 'Administrators'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

E01 - Exemption

This rule can be extended to a different group, which might be required administrating an application on a server. However, this group needs to be treated as the 'Administrators' group.

Description

This policy setting allows users to manage the system's volume or disk configuration, which could allow a user to delete a volume and cause data loss as well as a denial-of-service condition.

Rationale

A user who is assigned the **Perform volume maintenance tasks** user right could delete a volume, which could result in the loss of data or a denial of service (DoS) condition.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Administrators** :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Perform volume maintenance tasks

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.41

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5136

Asset Manager

C	I	A
123	123	123

Ensure 'Profile single process' is set to 'Administrators'

Rule Ensure 'Profile single process' is set to 'Administrators'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

E01 - Exemption

This user right might be required if Windows Management Instrumentation (WMI) (e.g., System Monitor) is configured to collect data. It is allowed to assign this user right to a specified Service Account dedicated for this purpose.

Description

This policy setting determines which users can use tools to monitor the performance of non-system processes. Typically, you do not need to configure this user right to use the Microsoft Management Console (MMC) Performance snap-in. However, you do need this user right if System Monitor is configured to collect data using Windows Management Instrumentation (WMI). Restricting the **Profile single process** user right prevents intruders from gaining additional information that could be used to mount an attack on the system.

Rationale

The **Profile single process** user right presents a moderate vulnerability. An attacker with this user right could monitor a computer's performance to help identify critical processes that they might wish to attack directly. The attacker may also be able to determine what processes run on the computer so that they could identify countermeasures that they may need to avoid, such as antivirus software, an intrusion-detection system, or which other users are logged on to a computer.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators` :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Profile single process

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.42

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2221

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Profile system performance' is set to 'Administrators, NT SERVICE\WdiServiceHost'

Rule Ensure 'Profile system performance' is set to 'Administrators, NT SERVICE\WdiServiceHost'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting allows users to use tools to view the performance of different system processes, which could be abused to allow attackers to determine a system's active processes and provide insight into the potential attack surface of the computer.

More information can be found here: [Microsoft Docs: Profile system performance](#).

Rationale

The **Profile system performance** user right poses a moderate vulnerability. Attackers with this user right could monitor a computer's performance to help identify critical processes that they might wish to attack directly. Attackers may also be able to determine what processes are active on the computer so that they could identify countermeasures that they may need to avoid, such as antivirus software or an intrusion detection system.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators, NT SERVICE\WdiServiceHost`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Profile system performance

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

None - this is the default configuration.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.43

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Textual rephrasing of whitelist note in rule, added WdiServiceHost in alignment with CIS and feedback, added Check section. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3136

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Replace a process level token' is set to 'LOCAL SERVICE, NETWORK SERVICE'

Rule Ensure 'Replace a process level token' is set to 'LOCAL SERVICE', 'NETWORK SERVICE'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

E01 - Exemption

If an active application on the server requires dedicated service accounts needing this permission (e.g., Microsoft IIS or Microsoft SQL Server), then these dedicated service accounts can be added to the list of allowed values.

The additional accounts need to be documented accordingly.

Description

This policy setting allows one process or service to start another service or process with a different security access token, which can be used to modify the security access token of that sub-process and result in the escalation of privileges.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale

Users with the **Replace a process level token** privilege are able to start processes as other users whose credentials they know. They could use this method to hide their unauthorized actions on the computer. (On Windows 2000-based computers, use of the **Replace a process level token** user right also requires the user to have the **Adjust memory quotas for a process** user right that is discussed earlier in this section).

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `LOCAL SERVICE, NETWORK SERVICE`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Replace a process level token

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

On most computers, this is the default configuration and there will be no negative impact.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.44

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed during review: Added exemption E01. Textual rephrasing of whitelist note in rule, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2811

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Restore files and directories' is configured

Rule Ensure 'Restore files and directories' is set to 'Administrators' or 'Administrators, Backup Operators'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting determines which users can bypass file, directory, registry, and other persistent object permissions when restoring backed up files and directories on computers that run Windows Vista (or newer) in your environment. This user right also determines which users can set valid security principals as object owners; it is similar to the **Back up files and directories** user right.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale

An attacker with the **Restore files and directories** user right could restore sensitive data to a computer and overwrite data that is more recent, which could lead to loss of important data, data corruption, or a denial of service. Attackers could overwrite executable files that are used by legitimate administrators or system services with versions that include malicious software to grant themselves elevated privileges, compromise data, or install backdoors for continued access to the computer.

Note: Even if the following countermeasure is configured, an attacker could still restore data to a computer in a domain that is controlled by the attacker. Therefore, it is critical that organizations carefully protect the media that is used to back up data.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators` or `Administrators, Backup Operators`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Restore files and directories

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

Only Administrators are allowed to restore files and directories.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.45

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Textual rephrasing of whitelist note in rule, added Backup Operators as allowed value, added Check section. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5236

Asset Manager

C	I	A
123	123	123

Ensure 'Shut down the system' is set to 'Administrators'

Rule Ensure 'Shut down the system' is set to 'Administrators'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting determines which users who are logged on locally to the computers in your environment can shut down the operating system with the Shut Down command. Misuse of this user right can result in a denial of service condition.

Rationale

The ability to shut down Domain Controllers and Member Servers should be limited to a very small number of trusted Administrators. Although the **Shut down the system** user right requires the ability to log on to the server, you should be very careful about which accounts and groups you allow to shut down a Domain Controller or Member Server.

When a Domain Controller is shut down, it is no longer available to process logons, serve Group Policy, and answer Lightweight Directory Access Protocol (LDAP) queries. If you shut down Domain Controllers that possess Flexible Single Master Operations (FSMO) roles, you can disable key domain functionality, such as processing logons for new passwords — one of the functions of the Primary Domain Controller (PDC) Emulator role.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators` :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Shut down the system

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

The impact of removing these default groups from the **Shut down the system** user right could limit the delegated abilities of assigned roles in your environment. You should confirm that delegated activities will not be adversely affected.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.46

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4801

Asset Manager

C	I	A
123	123	123

Ensure 'Synchronize directory service data' is set to 'No One'

Rule

Ensure 'Synchronize directory service data' is set to 'No One'.

Description

This security setting determines which users and groups have the authority to synchronize all directory service data. This is also known as Active Directory synchronization.

Rationale

The **Synchronize directory service data** user right affects Domain Controllers; only Domain Controllers should be able to synchronize directory service data. Domain Controllers have this user right inherently because the synchronization process runs in the context of the `System` account on Domain Controllers. Attackers who have this user right can view all information stored within the directory. They could then use some of that information to facilitate additional attacks or expose sensitive data, such as direct telephone numbers or physical addresses.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `No One` :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Synchronize directory service data

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Note: 'No One' is not an existing local or domain group. Using 'No One' shows that no account is assigned to this GP.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.47

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4176

Asset Manager

C	I	A
123	123	123

Ensure 'Take ownership of files or other objects' is set to 'Administrators'

Rule Ensure 'Take ownership of files or other objects' is set to 'Administrators'.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting allows users to take ownership of files, folders, registry keys, processes, or threads. This user right bypasses any permissions that are in place to protect objects to give ownership to the specified user.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale

Any users with the **Take ownership of files or other objects** user right can take control of any object, regardless of the permissions on that object, and then make any changes they wish to that object. Such changes could result in exposure of data, corruption of data, or a denial of service (DoS) condition.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators` :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Take ownership of files or other objects

Note: This GP has to be activated at first by enabling the checkbox 'Define these policy settings'.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.2.48

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Security Options

This section contains recommendations for security options.

Accounts

This section contains recommendations related to default accounts.

BL968-3116

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Accounts: Administrator account status' is set to 'Disabled' (MS only)

Rule

Ensure 'Accounts: Administrator account status' is set to 'Disabled' (MS only).

Description

This policy setting enables or disables the Administrator account during normal operation. When a computer is booted into safe mode, the Administrator account is always enabled, regardless of how this setting is configured. Note that this setting will have no impact when applied to the Domain Controllers organizational unit via group policy because Domain Controllers have no local account database. It can be configured at the domain level via group policy, similar to account lockout and password policy settings.

Rationale

In some organizations, it can be a daunting management challenge to maintain a regular schedule for periodic password changes for local accounts. Therefore, you may want to disable the built-in Administrator account instead of relying on regular password changes to protect it from attack. Another reason to disable this built-in account is that it cannot be locked out no matter how many failed logons it accrues, which makes it a prime target for brute force attacks that attempt to guess passwords. Also, this account has a well-known security identifier (SID) and there are third-party tools that allow authentication by using the SID rather than the account name. This capability means that even if you rename the Administrator account, an attacker could launch a brute force attack by using the SID to log on.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Administrator account status

Administrative tasks using the built-in Administrator have to be adapted using a personalized account.

Note: It is allowed to create one separate local administrator account for the specific case that no Domain Controller can be reached but an administrative login is required. More information can be found here: [BL968-1066 Use Domain User Accounts](#).

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.1.1

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Rule is only valid for Member servers. Added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5281

Asset Manager

C	I	A
123	123	123

Ensure 'Accounts: Block Microsoft accounts' is set to 'Users can't add or log on with Microsoft accounts'

Rule

Ensure 'Accounts: Block Microsoft accounts' is set to 'Users can't add or log on with Microsoft accounts'.

Description

This policy setting prevents users from adding new Microsoft accounts on this computer.

Rationale

Organizations that want to effectively implement identity management policies and maintain firm control of what accounts are used to log onto their computers will probably want to block Microsoft accounts. Organizations may also need to block Microsoft accounts in order to meet the requirements of compliance standards that apply to their information systems.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Users can't add or log on with Microsoft accounts`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Block Microsoft accounts

Impact:

Users will not be able to log onto the computer with their Microsoft account.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:NoConnectedUser
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.1.2

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1081

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Accounts: Guest account status' is set to 'Disabled' (MS only)

Rule

Ensure 'Accounts: Guest account status' is set to 'Disabled' (MS only).

Description

This policy setting determines whether the Guest account is enabled or disabled. The Guest account allows unauthenticated network users to gain access to the system.

Note: This setting will have no impact when applied to the Domain Controllers organizational unit via group policy because Domain Controllers have no local account database. It can be configured at the domain level via group policy, similar to account lockout and password policy settings.

Rationale

The default Guest account allows unauthenticated network users to log on as Guest with no password. These unauthorized users could access any resources that are accessible to the Guest account over the network. This capability means that any network shares with permissions that allow access to the Guest account, the Guests group, or the Everyone group will be accessible over the network, which could lead to the exposure or corruption of data.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Guest account status

Impact:

None - The Guest account has been disabled for a long time at Siemens.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.1.3

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Rule is only valid for Member servers. Added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4126

Asset Manager

C	I	A
123	123	123

Ensure 'Accounts: Limit local account use of blank passwords to console logon only' is set to 'Enabled'

Rule Ensure 'Accounts: Limit local account use of blank passwords to console logon only' is set to 'Enabled'.

Description

This policy setting determines whether local accounts that are not password protected can be used to log on from locations other than the physical computer console. If you enable this policy setting, local accounts that have blank passwords will not be able to log on to the network from remote client computers. Such accounts will only be able to log on at the keyboard of the computer.

More information on minimum password length can be found here:

- [BL968-2261 Ensure 'Minimum password length' is configured](#).

Rationale

Blank passwords are a serious threat to computer security and should be forbidden through both organizational policy and suitable technical measures. In fact, the default settings for Active Directory domains require complex passwords of at least seven characters. However, if users with the ability to create new accounts bypass your domain-based password policies, they could create accounts with blank passwords. For example, a user could build a stand-alone computer, create one or more accounts with blank passwords, and then join the computer to the domain. The local accounts with blank passwords would still function. Anyone who knows the name of one of these unprotected accounts could then use it to log on.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Limit local account use of blank passwords to console logon only

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:LimitBlankPasswordUse

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.1.4

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Audit

This section contains recommendations related to auditing controls.

BL968-1716

Asset Manager

C	I	A
123	123	123

Ensure 'Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings' is set to 'Enabled'

Rule

Ensure 'Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings' is set to 'Enabled'.

Description

This policy setting allows administrators to enable the more precise auditing capabilities present in Windows Vista.

The Audit Policy settings available in Windows Server 2003 Active Directory do not yet contain settings for managing the new auditing subcategories. To properly apply the auditing policies prescribed in this baseline, the Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings setting needs to be configured to Enabled.

Important: Be very cautious about audit settings that can generate a large volume of traffic. For example, if you enable either success or failure auditing for all of the Privilege Use subcategories, the high volume of audit events generated can make it difficult to find other types of entries in the Security log. Such a configuration could also have a significant impact on system performance.

Rationale

Prior to the introduction of auditing subcategories in Windows Vista, it was difficult to track events at a per-system or per-user level. The larger event categories created too many events and the key information that needed to be audited was difficult to find. Windows allows audit policy to be managed in a more precise way using audit policy subcategories. In case of an incident precise audit logs might be extremely precious.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings

Impact:

The following legacy policies will be completely ignored:

- Audit Policy: Audit account logon events,
- Audit Policy: Audit account management,
- Audit Policy: Audit directory service access,
- Audit Policy: Audit logon events,
- Audit Policy: Audit object access,
- Audit Policy: Audit policy change,
- Audit Policy: Audit privilege use,
- Audit Policy: Audit process tracking,
- Audit Policy: Audit system events.

More information can be found here: [Microsoft Support - Security auditing settings are not applied to Windows Vista-based and Window Server 2008-based computers when you deploy a domain-based policy.](#)

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:SCENoApplyLegacyAuditPolicy
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.2.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3301

Asset Manager

C	I	A
123	123	123

Ensure 'Audit: Shut down system immediately if unable to log security audits' is set to 'Disabled'

Rule

Ensure 'Audit: Shut down system immediately if unable to log security audits' is set to 'Disabled'.

E01 - Exemption

This rule is not mandatory, if a country-specific legal demand or other requirements as Common Criteria certification exist.

Note: Ensure that the required availability level of the server is considered sufficiently.

Description

This policy setting determines whether the system shuts down if it is unable to log Security events. It is a requirement for Trusted Computer System Evaluation Criteria (TCSEC)-C2 and Common Criteria certification to prevent auditable events from occurring if the audit system is unable to log them. Microsoft has chosen to meet this requirement by halting the system and displaying a stop message if the auditing system experiences a failure. When this policy setting is enabled, the system will be shut down if a security audit cannot be logged for any reason.

If the Audit: Shut down system immediately if unable to log security audits setting is enabled, unplanned system failures can occur. The administrative burden can be significant, especially if you also configure the Retention method for the Security log to Do not overwrite events (clear log manually). This configuration causes a repudiation threat (a backup operator could deny that they backed up or restored data) to become a denial of service (DoS) vulnerability, because a server could be forced to shut down if it is overwhelmed with logon events and other security events that are written to the Security log. Also, because the shutdown is not graceful, it is possible that irreparable damage to the operating system, applications, or data could result. Although the NTFS file system guarantees its integrity when an ungraceful computer shutdown occurs, it cannot guarantee that every data file for every application will still be in a usable form when the computer restarts.

If the security log is full and an existing entry cannot be overwritten, the following Stop message appears:

****STOP: C0000244 {Audit Failed}****

To recover, an administrator must log on, archive the log (optional), clear the log, and reset this option as desired.

Attackers could use common attacking tools which offer commands to drop event logging.

Rationale

If the computer is unable to record events to the Security log, critical evidence or important troubleshooting information may not be available for review after a security incident. Also, an attacker could potentially generate a large volume of Security log events to purposely force a computer shutdown.

Shutting down a server because of being unable to record events to the Security log, may lead to an unintended service blackout. This risk is considered higher than the risk of an intentionally disabled Security log.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Audit: Shut down system immediately if unable to log security audits

Impact:

- Servers will continue to work even if the Audit system is unable to log security events,
- An attacker could potentially disable Security log events to hide its activities on the server.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:CrashOnAuditFail
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.2.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

DCOM

Security related information regarding DCOM can be found here:

[DCOM: Machine Access Restrictions in Security Descriptor Definition Language \(SDDL\) syntax](#) .

BL968-0621

Asset Manager

C	I	A
123	123	123

Configure 'DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax'

Rule

Ensure 'DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax' is set to 'Not Defined'.

Description

This policy setting specifies which users or groups are allowed to access applications remotely or locally using the DCOM protocol.

Rationale

By default, no servers are listed here. Adding additional machine accounts can open the attack surface for DCOM applications.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Not Defined:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax

Impact:

None - this the default configuration.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0181

Asset Manager

C	I	A
123	123	123

Configure 'DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax'

Rule

Ensure DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax' is set to 'Not Defined'.

Description

This policy setting specifies which users or groups are allowed to launch applications remotely or locally using the DCOM protocol.

Rationale

By default, no servers are listed here. Adding additional machine accounts can open the attack surface for DCOM applications.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Not Defined:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\'DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax

Impact:

None - this the default configuration.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Devices

This section contains recommendations related to managing devices.

BL968-3111

Asset Manager

C	I	A
123	123	123

Ensure 'Devices: Allowed to format and eject removable media' is set to 'Administrators'

Rule

Ensure 'Devices: Allowed to format and eject removable media' is set to 'Administrators'.

Description

This policy setting determines who is allowed to format and eject removable NTFS media. You can use this policy setting to prevent unauthorized users from removing data on one computer to access it on another computer on which they have local administrator privileges.

Rationale

Users may be able to move data on removable disks to a different computer where they have administrative privileges. The user could then take ownership of any file, grant themselves full control, and view or modify any file. The fact that most removable storage devices will eject media by pressing a mechanical button diminishes the advantage of this policy setting.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators` :

`Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Devices: Allowed to format and eject removable media`

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon:AllocatedDASD
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.4.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Changed during review: Removed planned exemption as Microsoft only provides configuration possibilities for pre-defined options, but no dedicated groups providing a secure alternative option. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5566

Asset Manager

C	I	A
123	123	123

Ensure 'Devices: Prevent users from installing printer drivers' is set to 'Enabled'

Rule

Ensure 'Devices: Prevent users from installing printer drivers' is set to 'Enabled'.

Description

For a computer to print to a shared printer, the driver for that shared printer must be installed on the local computer. This security setting determines who is allowed to install a printer driver as part of connecting to a shared printer.

Note: This setting does not affect the ability to add a local printer. This setting does not affect Administrators.

Rationale

It may be appropriate in some organizations to allow users to install printer drivers on their own workstations. However, you should allow only Administrators, not users, to do so on servers, because printer driver installation on a server may unintentionally cause the computer to become less stable. A malicious user could install inappropriate printer drivers in a deliberate attempt to damage the computer, or a user might accidentally install malicious software that masquerades as a printer driver. It is feasible for an attacker to disguise a Trojan horse program as a printer driver. The program may appear to users as if they must use it to print, but such a program could unleash malicious code on your computer network.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Devices: Prevent users from installing printer drivers

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Print\Providers\LanMan Print Services\Servers:AddPrinterDrivers
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.4.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Domain controller

This section contains recommendations related to Domain Controllers.

BL968-1036

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Domain controller: Allow server operators to schedule tasks' is set to 'Disabled' (DC only)

Rule

Ensure 'Domain controller: Allow server operators to schedule tasks' is set to 'Disabled' (DC only).

Description

This policy setting determines whether members of the Server Operators group are allowed to submit jobs by means of the AT schedule facility. The impact of this policy setting configuration should be small for most organizations. Users, including those in the Server Operators group, will still be able to create jobs by means of the Task Scheduler Wizard, but those jobs will run in the context of the account with which the user authenticates when they set up the job.

Note: An AT Service Account can be modified to select a different account rather than the LOCAL SYSTEM account. To change the account, open System Tools, click Scheduled Tasks, and then click Accessories folder. Then click AT Service Account on the Advanced menu.

Rationale

If you enable this policy setting, jobs that are created by server operators by means of the AT service will execute in the context of the account that runs that service. By default, that is the local SYSTEM account. If you enable this policy setting, server operators could perform tasks that SYSTEM is able to do but that they would typically not be able to do, such as add their account to the local Administrators group.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Domain controller: Allow server operators to schedule tasks

Impact:

None - this is the default behavior. Note that users (including those in the Server Operators group) are still able to create jobs by means of the Task Scheduler Wizard. However, those jobs will run in the context of the account that the user authenticates with when setting up the job.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:SubmitControl
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.5.1

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed scope to DC only, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1206

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Domain controller: LDAP server signing requirements' is set to 'Require signing' (DC only)

Rule

Ensure 'Domain controller: LDAP server signing requirements' is set to 'Require signing' (DC only).

Description

This policy setting determines whether the Lightweight Directory Access Protocol (LDAP) server requires LDAP clients to negotiate data signing.

Note: Domain member computers must have *Network security: LDAP signing requirements* (see [BL968-1296 Ensure 'Network security: LDAP client signing requirements' is set to 'Require signing'](#)) set to *Negotiate signing* or higher. If not, they will fail to authenticate once the above *Require signing* value is configured on the Domain Controllers. Fortunately, *Negotiate signing* is the default in the client configuration.

Note #2: This policy setting does not have any impact on LDAP simple bind (`ldap_simple_bind`) or LDAP simple bind through SSL (`ldap_simple_bind_s`). No Microsoft LDAP clients that are shipped with Windows XP Professional use LDAP simple bind or LDAP simple bind through SSL to talk to a Domain Controller.

Important Note: The client-partners must also be configured to support LDAP signing; see following rules:

- [BL968-4151 Ensure 'Domain member: Digitally encrypt or sign secure channel data \(always\)' is set to 'Enabled'](#).
- [BL968-2266 Ensure 'Domain member: Digitally sign secure channel data \(when possible\)' is set to 'Enabled'](#).

Rationale

Unsigned network traffic is susceptible to man-in-the-middle attacks. In such attacks, an intruder captures packets between the server and the client, modifies them, and then forwards them to the client. Where LDAP servers are concerned, an attacker could cause a client to make decisions that are based on false records from the LDAP directory. To lower the risk of such an intrusion in an organization's network, you can implement strong physical security measures to protect the network infrastructure. Also, you could implement Internet Protocol security (IPsec) authentication header mode (AH), which performs mutual authentication and packet integrity for IP traffic to make all types of man-in-the-middle attacks extremely difficult.

Additionally, allowing the use of regular, unsigned LDAP permits credentials to be received over the network in clear text, which could very easily result in the interception of account passwords by other systems on the network.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Require signing`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Domain controller: LDAP server signing requirements

Impact:

Unless TLS/SSL is being used, the LDAP data signing option must be negotiated. Clients that do not support LDAP signing will be unable to run LDAP queries against the Domain Controllers. All Windows 2000-based computers in your organization that are managed from Windows Server 2003-based or Windows XP-based computers and that use Windows NT Challenge/Response (NTLM) authentication must have Windows 2000 Service Pack 3 (SP3) installed. Alternatively, these clients must have a registry change. Also, some non-Microsoft operating systems do not support LDAP signing. If you enable this policy setting, client computers that use those operating systems may be unable to access domain resources.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\NTDS\Parameters:LDAPServerIntegrity
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.5.2

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed scope to DC only, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1126

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Domain controller: Refuse machine account password changes' is set to 'Disabled' (DC only)

Rule

Ensure 'Domain controller: Refuse machine account password changes' is set to 'Disabled' (DC only).

Description

This security setting determines whether Domain Controllers will refuse requests from member computers to change computer account passwords.

Note: Some problems can occur as a result of machine account password expiration, particularly if a machine is reverted to a previous point-in-time state, as is common with virtual machines. Depending on how far back the reversion is, the older machine account password stored on the machine may no longer be recognized by the domain controllers, and therefore the computer loses its domain trust. This can also disrupt non-persistent VDI implementations, and devices with write filters that disallow permanent changes to the OS volume. Some organizations may choose to exempt themselves from this recommendation and disable machine account password expiration for these situations.

Rationale

If you enable this policy setting on all Domain Controllers in a domain, domain members will not be able to change their computer account passwords, and those passwords will be more susceptible to attack.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Domain controller: Refuse machine account password changes

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Netlogon\Parameters:RefusePasswordChange
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.5.3

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed scope to DC only, added Check section. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Domain member

This section contains recommendations related to domain membership.

BL968-4151

Asset Manager

C	I	A
123	123	123

Ensure 'Domain member: Digitally encrypt or sign secure channel data (always)' is set to 'Enabled'

Rule Ensure 'Domain member: Digitally encrypt or sign secure channel data (always)' is set to 'Enabled'.

Description

This policy setting determines whether all secure channel traffic that is initiated by the domain member must be signed or encrypted.

Rationale

When a computer joins a domain, a computer account is created. After it joins the domain, the computer uses the password for that account to create a secure channel with the Domain Controller for its domain every time that it restarts. Requests that are sent on the secure channel are authenticated - and sensitive information such as passwords are encrypted - but the channel is not integrity-checked, and not all information is encrypted.

Digital encryption and signing of the secure channel are good ideas where it is supported. The secure channel protects domain credentials as they are sent to the Domain Controller.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled** :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Domain member: Digitally encrypt or sign secure channel data (always)

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Netlogon\Parameters:RequireSignOrSeal
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.6.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1886

Asset Manager

C	I	A
123	123	123

Ensure 'Domain member: Digitally encrypt secure channel data (when possible)' is set to 'Enabled'

Rule

Ensure 'Domain member: Digitally encrypt secure channel data (when possible)' is set to 'Enabled'.

Description

This policy setting determines whether a domain member should attempt to negotiate encryption for all secure channel traffic that it initiates.

Rationale

When a computer joins a domain, a computer account is created. After it joins the domain, the computer uses the password for that account to create a secure channel with the Domain Controller for its domain every time that it restarts. Requests that are sent on the secure channel are authenticated - and sensitive information such as passwords are encrypted - but the channel is not integrity-checked, and not all information is encrypted.

Digital encryption and signing of the secure channel are good ideas where it is supported. The secure channel protects domain credentials as they are sent to the Domain Controller.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Domain member: Digitally encrypt secure channel data (when possible)

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Netlogon\Parameters:SealSecureChannel
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.6.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2266

Asset Manager

C	I	A
123	123	123

Ensure 'Domain member: Digitally sign secure channel data (when possible)' is set to 'Enabled'

Rule

Ensure 'Domain member: Digitally sign secure channel data (when possible)' is set to 'Enabled'.

Description

This policy setting determines whether a domain member should attempt to negotiate whether all secure channel traffic that it initiates must be digitally signed. Digital signatures protect the traffic from being modified by anyone who captures the data as it traverses the network.

Rationale

When a computer joins a domain, a computer account is created. After it joins the domain, the computer uses the password for that account to create a secure channel with the Domain Controller for its domain every time that it restarts. Requests that are sent on the secure channel are authenticated - and sensitive information such as passwords are encrypted - but the channel is not integrity-checked, and not all information is encrypted.

Digital encryption and signing of the secure channel are good ideas where it is supported. The secure channel protects domain credentials as they are sent to the Domain Controller.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Domain member: Digitally sign secure channel data (when possible)

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Netlogon\Parameters:SignSecureChannel
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.6.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4266

Asset Manager

C	I	A
123	123	123

Ensure 'Domain member: Disable machine account password changes' is set to 'Disabled'

Rule

Ensure 'Domain member: Disable machine account password changes' is set to 'Disabled'.

Description

This policy setting determines whether a domain member can periodically change its computer account password. Computers that cannot automatically change their account passwords are potentially vulnerable, because an attacker might be able to determine the password for the system's domain account.

Note: Some problems can occur as a result of machine account password expiration, particularly if a machine is reverted to a previous point-in-time state, as is common with virtual machines. Depending on how far back the reversion is, the older machine account password stored on the machine may no longer be recognized by the domain controllers, and therefore the computer loses its domain trust. This can also disrupt non-persistent VDI implementations, and devices with write filters that disallow permanent changes to the OS volume. Some organizations may choose to exempt themselves from this recommendation and disable machine account password expiration for these situations.

Rationale

Computers that cannot automatically change their account passwords are potentially vulnerable, because an attacker might be able to determine the password for the system's domain account.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Domain member: Disable machine account password changes

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Netlogon\Parameters:DisablePasswordChange
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.6.4

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3476

Asset Manager

C	I	A
123	123	123

Ensure 'Domain member: Maximum machine account password age' is set to '30 or fewer days, but not 0'

Rule

Ensure 'Domain member: Maximum machine account password age' is set to '30 or fewer days, but not 0'.

Description

This policy setting determines the maximum allowable age for a computer account password. By default, domain members automatically change their domain passwords every 30 days.

Rationale

In Active Directory-based domains, each computer has an account and password just like every user. By default, the domain members automatically change their domain password every 30 days. If you increase this interval significantly, or set it to 0 so that the computers no longer change their passwords, an attacker will have more time to undertake a brute force attack to guess the passwords of computer accounts.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to 30 or fewer days, but not 0:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Domain member: Maximum machine account password age

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.6.5

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2756

Asset Manager

C	I	A
123	123	123

Ensure 'Domain member: Require strong (Windows 2000 or later) session key' is set to 'Enabled'

Rule

Ensure 'Domain member: Require strong (Windows 2000 or later) session key' is set to 'Enabled'.

Description

When this policy setting is enabled, a secure channel can only be established with Domain Controllers that are capable of encrypting secure channel data with a strong (128-bit) session key.

To enable this policy setting, all Domain Controllers in the domain must be able to encrypt secure channel data with a strong key, which means all Domain Controllers must be running Microsoft Windows 2000 or newer.

Rationale

Session keys that are used to establish secure channel communications between Domain Controllers and member computers are much stronger in Windows 2000 than they were in previous Microsoft operating systems. Whenever possible, you should take advantage of these stronger session keys to help protect secure channel communications from attacks that attempt to hijack network sessions and eavesdropping. (Eavesdropping is a form of hacking in which network data is read or altered in transit. The data can be modified to hide or change the sender, or be redirected).

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Domain member: Require strong (Windows 2000 or later) session key

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Netlogon\Parameters:RequireStrongKey
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.6.6

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Interactive logon

This section contains recommendations related to interactive logons.

BL968-0471

Asset Manager

C	I	A
123	123	123

Configure 'Interactive logon: Display user information when the session is locked'

Rule

Ensure 'Interactive logon: Display user information when the session is locked' is set to 'Do not display user information'.

E01 - Dedicated remote desktop servers

On remote desktop servers with end user logons, this setting might cause a major user acceptance problem, since the majority of the sessions are using the same user account as the local session. Therefore, this rule is not mandatory for dedicated remote desktop servers with end user logons.

Description

This policy setting determines if specific user information (display name, domain, username) of a locked session is being displayed on the Secure Desktop.

Rationale

Displayed user information of a locked session on the Secure Desktop might be helpful for an attacker to execute a brute-force attack.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Do not display user information:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Interactive logon: Display user information when the session is locked

Impact:

No names are displayed on the Secure Desktop.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3941

Asset Manager

C	I	A
123	123	123

Ensure 'Interactive logon: Do not require CTRL+ALT+DEL' is set to 'Disabled'

Rule

Ensure 'Interactive logon: Do not require CTRL+ALT+DEL' is set to 'Disabled'.

Description

This policy setting determines whether users must press CTRL+ALT+DEL before they log on.

Rationale

Microsoft developed this feature to make it easier for users with certain types of physical impairments to log on to computers that run Windows. If users are not required to press CTRL+ALT+DEL, they are susceptible to attacks that attempt to intercept their passwords. If CTRL+ALT+DEL is required before logon, user passwords are communicated by means of a trusted path.

An attacker could install a Trojan horse program that looks like the standard Windows logon dialog box and capture the user's password. The attacker would then be able to log on to the compromised account with whatever level of privilege that user has.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Interactive logon: Do not require CTRL+ALT+DEL

Impact:

Users must press CTRL+ALT+DEL before they log on to Windows unless they use a smart card for Windows logon. A smart card is a tamper-proof device that stores security information.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:DisableCAD
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.7.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2796

Asset Manager

C	I	A
123	123	123

Ensure 'Interactive logon: Do not display last user name' is set to 'Enabled'

Rule

Ensure 'Interactive logon: Do not display last user name' is set to 'Enabled'.

Description

This policy setting determines whether the account name of the last user to log on to the client computers in your organization will be displayed in each computer's respective Windows logon screen. Enable this policy setting to prevent intruders from collecting account names visually from the screens of desktop or laptop computers in your organization.

Rationale

An attacker with access to the console (for example, someone with physical access or someone who is able to connect to the server through Remote Desktop Services) could view the name of the last user who logged on to the server. The attacker could then try to guess the password, use a dictionary, or use a brute-force attack to try and log on.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Interactive logon: Do not display last user name

Note: This setting was renamed to *Interactive logon: Do not display last user name*, starting with version 1809.

Impact:

The name of the last user to successfully log on will not be displayed in the Windows logon screen.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:DontDisplayLastUserName
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.7.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5071

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Interactive logon: Machine inactivity limit' is set to '900 or fewer second(s), but not 0'

Rule

Ensure 'Interactive logon: Machine inactivity limit' is set to '900 or fewer second(s), but not 0'.

E01 - Privileged Access Management Solutions

This rule is not mandatory, i.e., the respective setting can be set to 0, for systems which are **exclusively** managed by Privileged Access Management solutions, such as CyberArk, using automated session establishment hiding account credentials from connecting user.

Description

Windows notices inactivity of a logon session, and if the amount of inactive time exceeds the inactivity limit, then the screen saver will run, locking the session.

Note: A value of 0 does not conform to the benchmark as it disables the machine inactivity limit.

Rationale

If a user forgets to lock their computer when they walk away it is possible that a passerby will hijack it.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to 900 or fewer seconds, but not 0:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Interactive logon: Machine inactivity limit

Note: This setting applies only to computer objects, regardless of who logs on. A screen saver should also be enabled on user objects. For more information see: [BL968-1011 Ensure 'Enable screen saver' is set to 'Enabled'](#) and [BL968-4456 Ensure 'Screen saver timeout' is set to 'Enabled: 900 seconds or fewer, but not 0'](#).

Impact:

The screen saver will automatically activate when the computer has been unattended for the amount of time specified. The impact should be minimal since the screen saver is enabled by default.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:InactivityTimeoutSecs

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.7.3

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added PAM exemption, added Check section. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5072

Asset Manager

C	I	A
		123

Configure 'Interactive logon: Machine account lockout threshold'

Rule

Ensure 'Interactive logon: Machine account lockout threshold' is set to '0'.

Description

This setting determines how many failed logon attempts are allowed before the server will be locked by using BitLocker. If this amount is exceeded, the TPM protectors will be invalidated and the machine will be rebooted into the Windows Recovery Environment (WRE). Here, the machine can only be unlocked with the 48-digit recovery password.

More information can be found here: [Microsoft Docs: Interactive logon: Machine account lockout threshold](#).

Note: Only BitLocker protected machines will process this policy setting.

Rationale

An attacker could lockout not only user accounts, but also server accounts with several random logon attempts. But to restore access to a device resulting from a BitLocker lock out is much more challenging than unlocking a user account.

The operational risk of using this feature seems to be higher than the increase in security.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to 0:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Interactive logon: Machine account lockout threshold

Impact:

None - this is the default value.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1571

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Interactive logon: Number of previous logons to cache (in case domain controller is not available)' is set to '0' (MS only)

Rule

Ensure 'Interactive logon: Number of previous logons to cache (in case domain controller is not available)' is set to '0' (MS only).

E01 - Exemption

For servers not member of a domain, the 'Interactive logon: Number of previous logons to cache (in case domain controller is not available)' setting can be set to a value of '2'.

Description

This policy setting determines whether a user can log on to a Windows domain using cached account information. Logon information for domain accounts can be cached locally to allow users to log on even if a Domain Controller cannot be contacted. This policy setting determines the number of unique users for whom logon information is cached locally. If this value is set to 0, the logon cache feature is disabled. An attacker who is able to access the file system of the server could locate this cached information and use a brute force attack to determine user passwords.

Rationale

The number that is assigned to this policy setting indicates the number of users whose logon information the computer will cache locally. If the number is set to 4, then the computer caches logon information for 4 users. When a 5th user logs on to the computer, the server overwrites the oldest cached logon session.

Users who access the computer console will have their logon credentials cached on that computer. An attacker who is able to access the file system of the computer could locate this cached information and use a brute force attack to attempt to determine user passwords. To mitigate this type of attack, Windows encrypts the information and obscures its physical location.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to 0 :

```
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Interactive logon: Number of previous logons to cache (in case domain controller is not available)
```

Impact:

If no domain controller can be contacted (e.g., in case of movement to a new data center) the credentials of a local account of the local administrator group must be available.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon:CachedLogonsCount
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.7.6

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added exemption, added Check section. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942), added an exemption.

BL968-2311

Asset Manager

C	I	A
123	123	123

Ensure 'Interactive logon: Require Domain Controller Authentication to unlock workstation' is set to 'Enabled' (MS only)

Rule

Ensure 'Interactive logon: Require Domain Controller Authentication to unlock workstation' is set to 'Enabled' (MS only).

E01 - Exemption

For servers not member of a domain, the 'Interactive logon: Require Domain Controller authentication to unlock workstation' setting has no impact. In such a case, this setting can be set to 'Disabled' or 'Not Defined'.

Description

Logon information is required to unlock a locked computer. For domain accounts, this security setting determines whether it is necessary to contact a Domain Controller to unlock a computer.

Rationale

By default, the computer caches in memory the credentials of any users who are authenticated locally. The computer uses these cached credentials to authenticate anyone who attempts to unlock the console. When cached credentials are used, any changes that have recently been made to the account - such as user rights assignments, account lockout, or the account being disabled - are not considered or applied after the account is authenticated. User privileges are not updated, and (more importantly) disabled accounts are still able to unlock the console of the computer.

I01 - Implementation Example

To implement the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Interactive logon: Require Domain Controller Authentication to unlock workstation

Impact:

When the console on a computer is locked, either by a user or automatically by a screen saver time-out, the console can only be unlocked if a Domain Controller is available to re-authenticate the domain account that is being used to unlock the computer. If no Domain Controller is available, the user cannot unlock the computer.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon:ForceUnlockLogon
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.7.8

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3401

Asset Manager

C	I	A
123	123	123

Ensure 'Interactive logon: Smart card removal behavior' is configured

Rule

Ensure 'Interactive logon: Smart card removal behavior' is set to 'Lock Workstation' or 'Force Logoff' or 'Disconnect if a Remote Desktop Services session'.

Description

This policy setting determines what happens when the smart card for a logged-on user is removed from the smart card reader.

Rationale

Users sometimes forget to lock their workstations when they are away from them, allowing the possibility for malicious users to access their computers. If smart cards are used for authentication, the computer should automatically lock itself when the card is removed to ensure that only the user with the smart card is accessing resources using those credentials.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Lock Workstation` or higher:

`Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Interactive logon: Smart card removal behavior`

Impact:

If you select `Lock Workstation`, the workstation is locked when the smart card is removed, allowing users to leave the area, take their smart card with them, and still maintain a protected session.

If you select `Force Logoff`, users are automatically logged off when their smart card is removed.

If you select `Disconnect if a Remote Desktop Services session`, removal of the smart card disconnects the session without logging the users off. This allows the user to insert the smart card and resume the session later, or at another smart card reader-equipped computer, without having to log on again. If the session is local, this policy will function identically to `Lock Workstation`.

Enforcing this setting on computers used by people who must log onto multiple computers in order to perform their duties could be frustrating and lower productivity. For example, if network administrators are limited to a single account but need to log into several computers simultaneously in order to effectively manage the network enforcing this setting will limit them to logging onto one computer at a time. For these reasons it is recommended that this setting only be enforced on workstations used for purposes commonly associated with typical users such as document creation and email.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed, noting that values of `Force Logoff` or `Disconnect if a Remote Desktop Services session` are also acceptable settings. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon:ScRemoveOption
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.7.9

Based on [Siemens Information Security Policy Framework Rule 11.2.9-01](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Microsoft network client

This section contains recommendations related to configuring the Microsoft network client.

BL968-2021

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Microsoft network client: Digitally sign communications (always)' is set to 'Enabled'

Rule

Ensure 'Microsoft network client: Digitally sign communications (always)' is set to 'Enabled'.

E01 - Exemption

This rule is not mandatory for systems which ensure, that all SMB connections are encrypted. i.e., rule [BL968-0117 Configure 'SMBv3 protocol encryption'](#) as well as rule [BL968-0118 Do Not Allow Unencrypted SMB Sessions](#) are implemented on those systems.

Description

This policy setting determines whether packet signing is required by the SMB client component.

SMB is the resource-sharing protocol that is supported by many Windows operating systems. It is the basis of NetBIOS and many other protocols. SMB signatures authenticate users and the servers that host the data. If either side fails the authentication process, data transmission does not take place.

[Microsoft IT Pro Center: Microsoft network client: Digitally sign communications \(always\)](#) .

Rationale

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then modify the traffic and forward it so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data.

SMB is the resource sharing protocol that is supported by many Windows operating systems. It is the basis of NetBIOS and many other protocols. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network client: Digitally sign communications (always)

Impact:

- The Microsoft network client will not communicate with a Microsoft network server unless that server agrees to perform SMB packet signing,
- Some older applications and operating systems such as legacy Samba Versions may not be able to communicate with the servers by means of the SMB protocol,
- Using SMB packet signing can impose up to a 15 percent performance degradation on file service transactions.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters:RequireSecuritySignature
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.8.1

Based on [Siemens Information Security Policy Framework Rule 13.2.3-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed during review: Added exemption E01. Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5611

Asset Manager

C	I	A
123	123	123

Ensure 'Microsoft network client: Digitally sign communications (if server agrees)' is set to 'Enabled'

Rule

Ensure 'Microsoft network client: Digitally sign communications (if server agrees)' is set to 'Enabled'.

Description

This policy setting determines whether the SMB client will attempt to negotiate SMB packet signing.

Enabling this policy setting enforces signed SMB communication (if supported by both sides).

More information can be found here: [Microsoft IT Pro Center: SMBv1 Microsoft network client: Digitally sign communications \(if server agrees\)](#).

Rationale

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then modify the traffic and forward it so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data.

SMB is the resource sharing protocol that is supported by many Windows operating systems. It is the basis of NetBIOS and many other protocols. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network client: Digitally sign communications (if server agrees)

Impact:

None - this is the default behavior. Using SMB packet signing can impose up to a 15 percent performance degradation on file service transactions.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:


```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters:EnableSecuritySignature
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.8.2

[Based on Siemens Information Security Policy Framework Rule 13.2.3-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4441

Asset Manager

C	I	A
123	123	123

Ensure 'Microsoft network client: Send unencrypted password to third-party SMB servers' is set to 'Disabled'

Rule Ensure 'Microsoft network client: Send unencrypted password to third-party SMB servers' is set to 'Disabled'.

Description

This policy setting determines whether the SMB redirector will send plaintext passwords during authentication to third-party SMB servers that do not support password encryption.

It is recommended that you disable this policy setting unless there is a strong business case to enable it. If this policy setting is enabled, unencrypted passwords will be allowed across the network.

Rationale

If you enable this policy setting, the server can transmit passwords in plaintext across the network to other computers that offer SMB services, which is a significant security risk. These other computers may not use any of the SMB security mechanisms that are included with Windows Server 2003.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network client: Send unencrypted password to third-party SMB servers

Impact:

None - this is the default behavior.

Some very old applications and operating systems such as MS-DOS, Windows for Workgroups 3.11, and Windows 95a may not be able to communicate with the servers in your organization by means of the SMB protocol.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters:EnablePlainTextPassword
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.8.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Microsoft network server

This section contains recommendations related to configuring the Microsoft network server.

BL968-4521

Asset Manager

C	I	A
123	123	123

Ensure 'Microsoft network server: Amount of idle time required before suspending session' is set to '15 or fewer minute(s)'

Rule Ensure 'Microsoft network server: Amount of idle time required before suspending session' is set to '15 or fewer minute(s)'.

Description

This policy setting allows you to specify the amount of continuous idle time that must pass in an SMB session before the session is suspended because of inactivity. Administrators can use this policy setting to control when a computer suspends an inactive SMB session. If client activity resumes, the session is automatically reestablished.

The maximum value is 99999, which is over 69 days; in effect, this value disables the setting.

Rationale

Each SMB session consumes server resources, and numerous null sessions will slow the server or possibly cause it to fail. An attacker could repeatedly establish SMB sessions until the server's SMB services become slow or unresponsive.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to 15 or fewer minute(s) :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network server: Amount of idle time required before suspending session

Impact:

There will be little impact because SMB sessions will be re-established automatically if the client resumes activity.

15 minutes is the default value.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters:AutoDisconnect
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.9.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Removed the limitation to not set 0, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0051

Asset Manager

C	I	A
123	123	123

Configure 'Microsoft network server: Attempt S4U2Self to obtain claim information'

Rule

Ensure 'Microsoft network server: Attempt S4U2Self to obtain claim information' is set to 'Default'.

Description

This policy setting defines if Windows machines prior to Windows 8 (Server 2008R2) can access shares on file servers protected with user claims. The file server can use the Kerberos Service-For-User-To-Self (S4U2Self) functionality to get the required claim-enabled access token for the user account.

Setting this policy to 'Default' (automatic) allows a Windows file server to automatically evaluate whether claims are needed for the user.

Rationale

This setting enables a file server to use the Kerberos Service-For-User-To-Self (S4U2Self) functionality.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Default:

Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network server: Attempt S4U2Self to obtain claim information

Impact:

None - this the default configuration.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2936

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Microsoft network server: Digitally sign communications (always)' is set to 'Enabled'

Rule

Ensure 'Microsoft network server: Digitally sign communications (always)' is set to 'Enabled'.

E01 - Exemption

This rule is not mandatory for systems which ensure, that all SMB connections are encrypted. i.e., rule [BL968-0117 Configure 'SMBv3 protocol encryption'](#) as well as rule [BL968-0118 Do Not Allow Unencrypted SMB Sessions](#) are implemented on those systems.

Description

This policy setting determines whether packet signing is required by the SMB server component. Enable this policy setting in a mixed environment to prevent downstream clients from using the workstation as a network server.

More information can be found here: [Microsoft IT Pro Center: Microsoft network server: Digitally sign communications \(always\)](#).

Rationale

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then modify the traffic and forward it so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data.

SMB is the resource sharing protocol that is supported by many Windows operating systems. It is the basis of NetBIOS and many other protocols. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network server: Digitally sign communications (always)

Impact:

- The Microsoft network server will not communicate with a Microsoft network client unless that client agrees to perform SMB packet signing,

- Using SMB packet signing can impose up to a 15 percent performance degradation on file service transactions.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters:RequireSecuritySignature
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.9.2

[Based on Siemens Information Security Policy Framework Rule 13.2.3-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed during review: Added exemption E01. Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3631

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Microsoft network server: Digitally sign communications (if client agrees)' is set to 'Enabled'

Rule

Ensure 'Microsoft network server: Digitally sign communications (if client agrees)' is set to 'Enabled'.

E01 - Exemption

This rule is not mandatory for systems which ensure, that all SMB connections are encrypted. i.e., rule [BL968-0117 Configure 'SMBv3 protocol encryption'](#) as well as rule [BL968-0118 Do Not Allow Unencrypted SMB Sessions](#) are implemented on those systems.

Description

This policy setting determines whether the SMB server will negotiate SMB packet signing with clients that request it. If no signing request comes from the client, a connection will be allowed without a signature if the **Microsoft network server: Digitally sign communications (always)** setting is not enabled.

More information can be found here: [Microsoft IT Pro Center: SMBv1 Microsoft network server: Digitally sign communications \(if client agrees\)](#).

Rationale

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then modify the traffic and forward it so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data.

SMB is the resource sharing protocol that is supported by many Windows operating systems. It is the basis of NetBIOS and many other protocols. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network server: Digitally sign communications (if client agrees)

Impact:

The Microsoft network server will negotiate SMB packet signing as requested by the client. That is, if packet signing has been enabled on the client, packet signing will be negotiated.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters:EnableSecuritySignature
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.9.3

[Based on Siemens Information Security Policy Framework Rule 13.2.3-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed during review: Added exemption E01. Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2486

Asset Manager

C	I	A
123	123	123

Ensure 'Microsoft network server: Disconnect clients when logon hours expire' is set to 'Enabled'

Rule

Ensure 'Microsoft network server: Disconnect clients when logon hours expire' is set to 'Enabled'.

Description

This security setting determines whether to disconnect users who are connected to the local computer outside their user account's valid logon hours. This setting affects the Server Message Block (SMB) component. If you enable this policy setting you should also enable *Network security: Force logoff when logon hours expire* (Rule 2.3.11.6).

If your organization configures logon hours for users, this policy setting is necessary to ensure they are effective.

Rationale

If your organization configures logon hours for users, then it makes sense to enable this policy setting. Otherwise, users who should not have access to network resources outside of their logon hours may actually be able to continue to use those resources with sessions that were established during allowed hours.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled**:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network server: Disconnect clients when logon hours expire

Impact:

None - this is the default behavior. If logon hours are not used in your organization, this policy setting will have no impact. If logon hours are used, existing user sessions will be forcibly terminated when their logon hours expire.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters:enableforcedlogoff
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.9.4

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4531

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Microsoft network server: Server SPN target name validation level' is set to 'Required from client' (MS only)

Rule

Ensure 'Microsoft network server: Server SPN target name validation level' is set to 'Required from client' (MS only).

Description

This policy setting controls the level of validation a computer with shared folders or printers (the server) performs on the service principal name (SPN) that is provided by the client computer when it establishes a session using the server message block (SMB) protocol.

The server message block (SMB) protocol provides the basis for file and print sharing and other networking operations, such as remote Windows administration. The SMB protocol supports validating the SMB server service principal name (SPN) within the authentication blob provided by a SMB client to prevent a class of attacks against SMB servers referred to as SMB relay attacks. This setting will affect both SMB1 and SMB2.

This setting will affect both SMB1 and SMB2.

More information can be found here: [Windows IT Pro Center - Microsoft network server: Server SPN target name validation level](#).

Note: Since the release of the MS [KB3161561](#) security patch, this setting can cause significant issues (such as replication problems, group policy editing issues and blue screen crashes) on Domain Controllers when used *simultaneously* with UNC path hardening (i.e., rule [BL968-1186 Ensure 'Hardened UNC Paths' is set to 'Enabled, with "Require Mutual Authentication" and "Require Integrity" set for all NETLOGON and SYSVOL shares' \(DC only\)](#)).

Therefore, this setting should not be set on domain controllers because of possible operational issues.

Rationale

This policy setting can help to prevent so called 'SMB relay attacks' (SMBv1 and SMBv2 are affected). The identity of a computer can be spoofed using this class of attacks to gain unauthorized access to network resources.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Required from client:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Microsoft network server: Server SPN target name validation level

Impact:

All Windows operating systems support both a client-side SMB component and a server-side SMB component. This setting affects the server SMB behavior, and its implementation should be carefully evaluated and tested to prevent disruptions to file and print serving capabilities.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters:SMBServerNameHardeningLevel
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.9.5

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Fixed wrong value name, removed exemption 01, added Check section. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Network access

This section contains recommendations related to network access.

BL968-1931

Asset Manager

C	I	A
123	123	123

Ensure 'Network access: Allow anonymous SID/Name translation' is set to 'Disabled'

Rule Ensure 'Network access: Allow anonymous SID/Name translation' is set to 'Disabled'.

Description

This policy setting determines whether an anonymous user can request security identifier (SID) attributes for another user, or use a SID to obtain its corresponding username.

Rationale

If this policy setting is enabled, a user with local access could use the well-known Administrator's SID to learn the real name of the built-in Administrator account, even if it has been renamed. That person could then use the account name to initiate a password guessing attack.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Allow anonymous SID/Name translation

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.10.1

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5726

Asset Manager

C	I	A
123	123	123

Ensure 'Network access: Do not allow anonymous enumeration of SAM accounts' is set to 'Enabled' (MS only)

Rule

Ensure 'Network access: Do not allow anonymous enumeration of SAM accounts' is set to 'Enabled' (MS only).

Description

This policy setting controls the ability of anonymous users to enumerate the accounts in the Security Accounts Manager (SAM). If you enable this policy setting, users with anonymous connections will not be able to enumerate domain account usernames on the systems in your environment. This policy setting also allows additional restrictions on anonymous connections.

Note: This policy has no effect on Domain Controllers.

Rationale

An unauthorized user could anonymously list account names and use the information to attempt to guess passwords or perform social engineering attacks. (Social engineering attacks try to deceive users in some way to obtain passwords or some form of security information).

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Do not allow anonymous enumeration of SAM accounts

Impact:

None - this is the default behavior. It will be impossible to establish trusts with Windows NT 4.0-based domains. Also, client computers that run older versions of the Windows operating system such as Windows NT 3.51 and Windows 95 will experience problems when they try to use resources on the server.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:RestrictAnonymousSAM
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.10.2

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5631

Asset Manager

C	I	A
123	123	123

Ensure 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' is set to 'Enabled' (MS only)

Rule

Ensure 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' is set to 'Enabled' (MS only).

Description

This policy setting controls the ability of anonymous users to enumerate SAM accounts as well as shares. If you enable this policy setting, anonymous users will not be able to enumerate domain account usernames and network share names on the systems in your environment.

Even with this policy setting enabled, anonymous users will have access to resources with permissions that explicitly include the built-in group, `ANONYMOUS LOGON`.

Note: This policy has no effect on Domain Controllers.

Rationale

An unauthorized user could anonymously list account names and shared resources and use the information to attempt to guess passwords or perform social engineering attacks. (Social engineering attacks try to deceive users in some way to obtain passwords or some form of security information).

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Do not allow anonymous enumeration of SAM accounts and shares

Impact:

Very old Operating Systems as Windows NT4.0 or old Samba versions will experience problems.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:RestrictAnonymous
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.10.3

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5016

Asset Manager

C	I	A
123	123	123

Ensure 'Network access: Do not allow storage of passwords and credentials for network authentication' is set to 'Enabled'

Rule

Ensure 'Network access: Do not allow storage of passwords and credentials for network authentication' is set to 'Enabled'.

E01 - Exemption

This rule is not mandatory in case of

- all locally stored accounts follow strictly both the concept of 'Least-Privilege-Principle' and the concept of 'Segregation of Duties',
- BitLocker drive encryption is enabled on the server's operating system drive (see [BL968-0291 Configure 'Enforce drive encryption type on operating system drives'](#)).

Description

This policy setting determines whether Credential Manager (formerly called Stored User Names and Passwords) saves passwords or credentials for later use when it gains domain authentication.

Note: Changes to this setting will not take effect until Windows is restarted.

Note: Credentials are locally stored in the built-in 'Credential Manager' that can be opened with 'control /name Microsoft.CredentialManager'. In that application, locally stored accounts can be checked and removed for each user profile.

Rationale

Passwords that are cached can be accessed by the user when logged on to the computer. Although this information may sound obvious, a problem can arise if the user unknowingly executes hostile code that reads the passwords and forwards them to another, unauthorized user.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Do not allow storage of passwords and credentials for network authentication

Impact:

Credential Manager will not store passwords and credentials on the computer. Users will be forced to enter passwords whenever they log on to network resources that aren't accessible to their domain account.

This policy setting should have no impact on users who access network resources that are configured to allow access with their Active Directory-based domain account.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:DisableDomainCreds
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.10.4

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5501

Asset Manager

C	I	A
123	123	123

Ensure 'Network access: Let Everyone permissions apply to anonymous users' is set to 'Disabled'

Rule

Ensure 'Network access: Let Everyone permissions apply to anonymous users' is set to 'Disabled'.

Description

This policy setting determines what additional permissions are assigned for anonymous connections to the computer.

Rationale

An unauthorized user could anonymously list account names and shared resources and use the information to attempt to guess passwords, perform social engineering attacks, or launch denial of service (DoS) attacks.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Let Everyone permissions apply to anonymous users

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:EveryoneIncludesAnonymous
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.10.5

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3091

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Configure 'Network access: Named Pipes that can be accessed anonymously'

Rule

Ensure 'Network access: Named Pipes that can be accessed anonymously' -> 'Define this policy setting in this template' is activated and the list

- on **Domain Controllers** contains the values: 'LSARPC', 'NETLOGON', 'SAMR'.
- on **Member Servers** contains the value: <blank> (i.e. None).

Description

This policy setting determines which communication sessions, or pipes, will have attributes and permissions that allow anonymous access.

More information can be found here: [Windows IT Pro Center: Network access: Named Pipes that can be accessed anonymously](#).

Rationale

Limiting named pipes that can be accessed anonymously will reduce the attack surface of the system.

I01 - Implementation Example

To establish the recommended configuration via GP, configure the following UI path:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Named Pipes that can be accessed anonymously

- on **Domain Controller**: to LSARPC, NETLOGON, SAMR.
- on **Member Server**: to <blank> (i.e., None).

Set this policy to <blank>; that is, enable the policy setting, but do not enter named pipes in the text box.

Impact:

This configuration disables NULL session access over named pipes, and applications that rely on this feature or on unauthenticated access to named pipes no longer function. This may break trust between Windows Server 2003 domains in a mixed mode environment.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters:NullSessionPipes
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.10.6

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.10.7

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Merged DC and MS setting, removed exemption 01. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5421

Asset Manager

C	I	A
123	123	123

Configure 'Network access: Remotely accessible registry paths'

Rule Ensure 'Network access: Remotely accessible registry paths' contains no other entries than

- System\CurrentControlSet\Control\ProductOptions
- System\CurrentControlSet\Control\Server Applications
- Software\Microsoft\Windows NT\CurrentVersion

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting determines which registry paths will be accessible over the network, regardless of the users or groups listed in the access control list (ACL) of the winreg registry key.

Note: This setting does not exist in Windows XP. There was a setting with that name in Windows XP, but it is called "Network access: Remotely accessible registry paths and sub- paths" in Windows Server 2003, Windows Vista, and Windows Server 2008 (non-R2).

Note #2: When you configure this setting, you specify a list of one or more objects. The delimiter used when entering the list is a line feed or carriage return, that is, type the first object on the list, press the Enter button, type the next object, press Enter again, etc. The setting value is stored as a comma-delimited list in group policy security templates. It is also rendered as a comma-delimited list in Group Policy Editor's display pane and the Resultant Set of Policy console. It is recorded in the registry as a line-feed delimited list in a REG_MULTI_SZ value.

Rationale

The registry is a database that contains computer configuration information, and much of the information is sensitive. An attacker could use this information to facilitate unauthorized activities. To reduce the risk of such an attack, suitable ACLs are assigned throughout the registry to help protect it from access by unauthorized users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to:

- System\CurrentControlSet\Control\ProductOptions
- System\CurrentControlSet\Control\Server Applications
- Software\Microsoft\Windows NT\CurrentVersion

Computer Configuration\Policies\Windows Settings\Security \Settings\Local Policies\Security Options\Network access: Remotely accessible registry paths

Impact:

None - this is the default behavior. However, if you remove the default registry paths from the list of accessible ones, remote management tools such as the Microsoft Baseline Security Analyzer and Microsoft Systems Management Server could fail, as they require remote access to the registry to properly monitor and manage computers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedExactPaths:Machine
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.10.8

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3316

Asset Manager

C	I	A
123	123	123

Configure 'Network access: Remotely accessible registry paths and sub-paths'

Rule Ensure 'Network access: Remotely accessible registry paths and sub-paths' contains on

- **Member Servers** no other entries than:
 - System\CurrentControlSet\Control\Print\Printers
 - System\CurrentControlSet\Services\Eventlog
 - Software\Microsoft\OLAP Server
 - Software\Microsoft\Windows NT\CurrentVersion\Print
 - Software\Microsoft\Windows NT\CurrentVersion\Windows
 - System\CurrentControlSet\Control\ContentIndex
 - System\CurrentControlSet\Control\Terminal Server
 - System\CurrentControlSet\Control\Terminal Server\UserConfig
 - System\CurrentControlSet\Control\Terminal Server\DefaultUserConfiguration
 - Software\Microsoft\Windows NT\CurrentVersion\Perflib
 - System\CurrentControlSet\Services\SysmonLog
- **Servers that hold the 'Active Directory Certificate Services Role' with 'Certification Authority Role Service'** no other entries than the above list and additionally
 - System\CurrentControlSet\Services\CertSvc

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting determines which registry paths and sub-paths will be accessible over the network, regardless of the users or groups listed in the access control list (ACL) of the winreg registry key.

Note: In Windows XP this setting is called "Network access: Remotely accessible registry paths," the setting with that same name in Windows Vista, Windows Server 2008 (non-R2), and Windows Server 2003 does not exist in Windows XP.

Note #2: When you configure this setting, you specify a list of one or more objects. The delimiter used when entering the list is a line feed or carriage return, that is, type the first object on the list, press the Enter button, type the next object, press Enter again, etc. The setting value is stored as a comma-delimited list in group policy security templates. It is also rendered as a comma-delimited list in Group Policy Editor's display pane and the Resultant Set of Policy console. It is recorded in the registry as a line-feed delimited list in a REG_MULTI_SZ value.

Rationale

The registry contains sensitive computer configuration information that could be used by an attacker to facilitate unauthorized activities. The fact that the default ACLs assigned throughout the registry are fairly restrictive and help to protect the registry from access by unauthorized users reduces the risk of such an attack.

I01 - Implementation Example

To implement the recommended configuration state, set the following Group Policy setting to:

```
System\CurrentControlSet\Control\Print\Printers
System\CurrentControlSet\Services\Eventlog
Software\Microsoft\OLAP Server
Software\Microsoft\Windows NT\CurrentVersion\Print
Software\Microsoft\Windows NT\CurrentVersion\Windows
System\CurrentControlSet\Control\ContentIndex
System\CurrentControlSet\Control\Terminal Server
System\CurrentControlSet\Control\Terminal Server\UserConfig
System\CurrentControlSet\Control\Terminal Server\DefaultUserConfiguration
Software\Microsoft\Windows NT\CurrentVersion\Perflib
System\CurrentControlSet\Services\SysmonLog
```

Additionally, for servers that hold the 'Active Directory Certificate Services Role' with 'Certification Authority Role Service':

```
System\CurrentControlSet\Services\SysmonLog
```

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Remotely accessible registry paths and sub-paths

Note: When you configure this setting, you specify a list of one or more objects. The delimiter used when entering the list is a line feed or carriage return. The setting value is stored as a comma-delimited list in group policy security templates.

Impact:

If you remove the default registry paths from the list of accessible ones, remote management tools such as the Microsoft Baseline Security Analyzer and Microsoft Systems Management Server could fail, as they require remote access to the registry to properly monitor and manage computers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedPaths:Machine
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.10.9

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4041

Asset Manager

C	I	A
123	123	123

Ensure 'Network access: Restrict anonymous access to Named Pipes and Shares' is set to 'Enabled'

Rule

Ensure 'Network access: Restrict anonymous access to Named Pipes and Shares' is set to 'Enabled'.

Description

When enabled, this policy setting restricts anonymous access to only those shares and pipes that are named in the `Network access: Named pipes that can be accessed anonymously` and `Network access: Shares that can be accessed anonymously` settings. This policy setting controls null session access to shares on your computers by adding `RestrictNullSessAccess` with the value 1 in the

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters
```

registry key. This registry value toggles null session shares on or off to control whether the server service restricts unauthenticated clients' access to named resources.

Rationale

Null sessions are a weakness that can be exploited through shares (including the default shares) on computers in your environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Restrict anonymous access to Named Pipes and Shares

Impact:

None - this is the default configuration.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters:RestrictNullSessAccess
```


Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.10.10

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2351

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Network access: Restrict clients allowed to make remote calls to SAM' is set to 'Administrators: Remote Access: Allow' (MS only)

Rule

Ensure 'Network access: Restrict clients allowed to make remote calls to SAM' is set to 'Administrators: Remote Access: Allow' (MS only).

E01 - Non-administrator account

If a non-administrator account is qualified to provide the same security standards as the administrator account itself, it is acceptable to add this account additionally. The assessment of the additional non-administrator account shall be signed by the service owner of OneAD and shall be regularly re-approved.

E02 - Privileged Access Management Solutions

This rule's setting can be extended with system local accounts, which are **exclusively** managed and used by Privileged Access Management solutions, such as CyberArk, using automated session establishment hiding account credentials from connecting user.

Description

This policy setting allows you to restrict remote RPC connections to SAM.

Note: A Windows 10 R1607, Server 2016 or newer OS is required to access and set this value in Group Policy.

Rationale

To ensure that an unauthorized user cannot anonymously list local account names or groups and use the information to attempt to guess passwords or perform social engineering attacks. (Social engineering attacks try to deceive users in some way to obtain passwords or some form of security information).

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Administrators: Remote Access: Allow`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Restrict clients allowed to make remote calls to SAM

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:restrictremotesam
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.10.11

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Added exemption E02 for PAM accounts.

BL968-5681

Asset Manager

C	I	A
123	123	123

Ensure 'Network access: Shares that can be accessed anonymously' is set to 'None'

Rule

Ensure 'Network access: Shares that can be accessed anonymously' is set to 'None'.

Description

This policy setting determines which network shares can be accessed by anonymous users. The default configuration for this policy setting has little effect because all users have to be authenticated before they can access shared resources on the server.

Rationale

It is very dangerous to allow any values in this setting. Any shares that are listed can be accessed by any network user, which could lead to the exposure or corruption of sensitive data.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `<blank>` (i.e., None):

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Shares that can be accessed anonymously

Set this policy to `<blank>`; that is, enable the policy setting, but do not put anything in the text box.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters:NullSessionShares
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.10.12

Based on [Siemens Information Security Policy Framework Rule 09.1.1-07](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4796

Asset Manager

C	I	A
123	123	123

Ensure 'Network access: Sharing and security model for local accounts' is set to 'Classic - local users authenticate as themselves'

Rule

Ensure 'Network access: Sharing and security model for local accounts' is set to 'Classic - local users authenticate as themselves'.

Description

This policy setting determines how network logons that use local accounts are authenticated. The Classic option allows precise control over access to resources, including the ability to assign different types of access to different users for the same resource. The Guest only option allows you to treat all users equally. In this context, all users authenticate as Guest only to receive the same access level to a given resource.

Note: This setting does not affect interactive logons that are performed remotely by using such services as Telnet or Remote Desktop Services (formerly called Terminal Services).

Rationale

With the Guest only model, any user who can authenticate to your computer over the network does so with guest privileges, which probably means that they will not have write access to shared resources on that computer. Although this restriction does increase security, it makes it more difficult for authorized users to access shared resources on those computers because ACLs on those resources must include access control entries (ACEs) for the Guest account. With the Classic model, local accounts should be password protected. Otherwise, if Guest access is enabled, anyone can use those user accounts to access shared system resources.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Classic - local users authenticate as themselves`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Sharing and security model for local accounts

Impact:

None - this is the default configuration for domain-joined computers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:ForceGuest
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.10.13

[Based on Siemens Information Security Policy Framework Rule 09.1.1-07](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Network security

This section contains recommendations related to network security.

BL968-1106

Asset Manager

C	I	A
123	123	123

Ensure 'Network security: Allow Local System to use computer identity for NTLM' is set to 'Enabled'

Rule Ensure 'Network security: Allow Local System to use computer identity for NTLM' is set to 'Enabled'.

Description

This policy setting determines whether Local System services that use Negotiate when reverting to NTLM authentication can use the computer identity. This policy is supported on at least Windows 7 or Windows Server 2008 R2.

Rationale

When connecting to computers running versions of Windows earlier than Windows Vista or Windows Server 2008 (non-R2), services running as Local System and using SPNEGO (Negotiate) that revert to NTLM use the computer identity. In Windows 7, if you are connecting to a computer running Windows Server 2008 or Windows Vista, then a system service uses either the computer identity or a NULL session. When connecting with a NULL session, a system-generated session key is created, which provides no protection but allows applications to sign and encrypt data without errors. When connecting with the computer identity, both signing and encryption is supported in order to provide data protection.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

```
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Allow Local System to use computer identity for NTLM
```

Impact:

Services running as Local System that use Negotiate when reverting to NTLM authentication will use the computer identity. This might cause some authentication requests between Windows operating systems to fail and log an error.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:UseMachineId
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.11.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5996

Asset Manager

C	I	A
123	123	123

Ensure 'Network security: Allow LocalSystem NULL session fallback' is set to 'Disabled'

Rule

Ensure 'Network security: Allow LocalSystem NULL session fallback' is set to 'Disabled'.

Description

This policy setting determines whether NTLM is allowed to fall back to a NULL session when used with LocalSystem.

Rationale

NULL sessions are less secure because by definition they are unauthenticated.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Allow LocalSystem NULL session fallback

Impact:

Any applications that require NULL sessions for LocalSystem will not work as designed. But because of the rule [BL968-3091 Configure 'Network access: Named Pipes that can be accessed anonymously'](#) 'Null Sessions' are not allowed at Siemens.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa\MSV1_0:AllowNullSessionFallback
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.11.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4311

Asset Manager

C	I	A
123	123	123

Ensure 'Network Security: Allow PKU2U authentication requests to this computer to use online identities.' is set to 'Disabled'

Rule

Ensure 'Network Security: Allow PKU2U authentication requests to this computer to use online identities.' is set to 'Disabled'.

Description

This setting determines if online identities are able to authenticate to this computer.

The Public Key Cryptography Based User-to-User (PKU2U) protocol introduced in Windows 7 and Windows Server 2008 R2 is implemented as a security support provider (SSP). The SSP enables peer-to-peer authentication, particularly through the Windows 7 media and file sharing feature called HomeGroup, which permits sharing between computers that are not members of a domain.

With PKU2U, a new extension was introduced to the Negotiate authentication package, `Spnego.dll`. In previous versions of Windows, Negotiate decided whether to use Kerberos or NTLM for authentication. The extension SSP for Negotiate, `Negoexts.dll`, which is treated as an authentication protocol by Windows, supports Microsoft SSPs including PKU2U.

When computers are configured to accept authentication requests by using online IDs, `Negoexts.dll` calls the PKU2U SSP on the computer that is used to log on. The PKU2U SSP obtains a local certificate and exchanges the policy between the peer computers. When validated on the peer computer, the certificate within the metadata is sent to the logon peer for validation and associates the user's certificate to a security token and the logon process completes.

Rationale

The PKU2U protocol is a peer-to-peer authentication protocol - authentication should be managed centrally in most managed networks.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network Security: Allow PKU2U authentication requests to this computer to use online identities.

Impact:

None - this is the default configuration for domain-joined computers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa\pku2u:AllowOnlineID
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.11.3

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5821

Asset Manager

C	I	A
123	123	123

Ensure 'Network security: Configure encryption types allowed for Kerberos' is configured

Rule Ensure 'Network security: Configure encryption types allowed for Kerberos' contains only

- AES128_HMAC_SHA1,
- AES256_HMAC_SHA1,
- Future encryption types.

Note: The above list is to be treated as a whitelist, which implies that the above listed values do not need all be present to accomplish this rule in an assessment, but no additional values are allowed.

Description

This policy setting allows you to set the encryption types that Kerberos is allowed to use.

Rationale

The strength of each encryption algorithm varies from one to the next, choosing stronger algorithms will reduce the risk of compromise however doing so may cause issues when the computer attempts to authenticate with systems that do not support them.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to

- AES128_HMAC_SHA1
- AES256_HMAC_SHA1
- Future encryption types

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Configure encryption types allowed for Kerberos

Impact:

If an encryption type is not selected, then it will not be allowed.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\Kerberos\Parameters:SupportedEncryptionTypes
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.11.4

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Textual rephrasing of whitelist note in rule, added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5406

Asset Manager

C	I	A
123	123	123

Ensure 'Network security: Do not store LAN Manager hash value on next password change' is set to 'Enabled'

Rule Ensure 'Network security: Do not store LAN Manager hash value on next password change' is set to 'Enabled'.

Description

This policy setting determines whether the LAN Manager (LM) hash value for the new password is stored when the password is changed. The LM hash is relatively weak and prone to attack compared to the cryptographically stronger Microsoft Windows NT hash. Since LM hashes are stored on the local computer in the security database, passwords can then be easily compromised if the database is attacked.

Note: Older operating systems and some third-party applications may fail when this policy setting is enabled. Also, note that the password will need to be changed on all accounts after you enable this setting to gain the proper benefit.

The recommended state for this setting is: `Enabled`.

Rationale

The SAM file can be targeted by attackers who seek access to username and password hashes. Such attacks use special tools to crack passwords, which can then be used to impersonate users and gain access to resources on your network. These types of attacks will not be prevented if you enable this policy setting, but it will be much more difficult for these types of attacks to succeed.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Do not store LAN Manager hash value on next password change

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:NoLMHash
```


Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.11.5

Based on [Siemens Information Security Policy Framework Rule 09.4.3-06](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2161

Asset Manager

C	I	A
123	123	123

Ensure 'Network security: LAN Manager authentication level' is set to 'Send NTLMv2 response only. Refuse LM & NTLM'

Rule

Ensure 'Network security: LAN Manager authentication level' is set to 'Send NTLMv2 response only. Refuse LM & NTLM'.

Description

LAN Manager (LM) was a family of early Microsoft client/server software (predating Windows NT) that allowed users to link personal computers together on a single network. LM network capabilities included transparent file and print sharing, user security features, and network administration tools. In Active Directory domains, the Kerberos protocol is the default authentication protocol. However, if the Kerberos protocol is not negotiated for some reason, Active Directory will use LM, NTLM, or NTLMv2. LAN Manager authentication includes the LM, NTLM, and NTLM version 2 (NTLMv2) variants, and is the protocol that is used to authenticate all Windows clients when they perform the following operations:

- Join a domain
- Authenticate between Active Directory forests
- Authenticate to down-level domains
- Authenticate to computers that do not run Windows 2000, Windows Server 2003, or Windows XP
- Authenticate to computers that are not in the domain

The Network security: LAN Manager authentication level setting determines which challenge/response authentication protocol is used for network logons. This choice affects the level of authentication protocol used by clients, the level of session security negotiated, and the level of authentication accepted by servers.

Rationale

Windows 2000 and Windows XP clients were configured by default to send LM and NTLM authentication responses (Windows 95-based and Windows 98-based clients only send LM). The default settings in OSes predating Windows Vista / Windows Server 2008 (non-R2) allowed all clients to authenticate with servers and use their resources. However, this meant that LM responses - the weakest form of authentication response - were sent over the network, and it was potentially possible for attackers to sniff that traffic to more easily reproduce the user's password.

The Windows 95, Windows 98, and Windows NT operating systems cannot use the Kerberos version 5 protocol for authentication. For this reason, in a Windows Server 2003 domain, these computers authenticate by default with both the LM and NTLM protocols for network authentication. You can enforce a more secure authentication protocol for Windows 95, Windows 98, and Windows NT by using NTLMv2. For the logon process, NTLMv2 uses a secure channel to protect the authentication process. Even if you use NTLMv2 for older clients and servers, Windows-based clients, and servers that are members of the domain will use the Kerberos authentication protocol to authenticate with Windows Server 2003 or newer Domain Controllers. For these reasons, it is strongly preferred to restrict the use of LM & NTLM (non-v2) as much as possible.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to: Send NTLMv2 response only. Refuse LM & NTLM:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: LAN Manager authentication level

Impact:

Clients use NTLMv2 authentication only and use NTLMv2 session security if the server supports it; Domain Controllers refuse LM and NTLM (accept only NTLMv2 authentication). Clients that do not support NTLMv2 authentication will not be able to authenticate in the domain and access domain resources by using LM and NTLM.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:LmCompatibilityLevel
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.11.7

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1296

Asset Manager

C	I	A
123	123	123

Ensure 'Network security: LDAP client signing requirements' is set to 'Require signing'

Rule

Ensure 'Network security: LDAP client signing requirements' is set to 'Require signing'.

Description

This policy setting determines the level of data signing that is requested on behalf of clients that issue LDAP BIND requests.

Note: This policy setting does not have any impact on LDAP simple bind (`ldap_simple_bind`) or LDAP simple bind through SSL (`ldap_simple_bind_s`). No Microsoft LDAP clients that are included with Windows XP Professional use `ldap_simple_bind` or `ldap_simple_bind_s` to communicate with a Domain Controller.

Rationale

Unsigned network traffic is susceptible to man-in-the-middle attacks in which an intruder captures the packets between the client and server, modifies them, and then forwards them to the server. For an LDAP server, this susceptibility means that an attacker could cause a server to make decisions that are based on false or altered data from the LDAP queries. To lower this risk in your network, you can implement strong physical security measures to protect the network infrastructure. Also, you can make all types of man-in-the-middle attacks extremely difficult if you require digital signatures on all network packets by means of IPsec authentication headers.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Require signing`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: LDAP client signing requirements

Impact:

None - this setting has already been established at Siemens. Clients that do not support LDAP-Signing will not be able to establish a LDAP connection.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LDAP:LDAPClientIntegrity
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.11.8

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4901

Asset Manager

C	I	A
123	123	123

Ensure 'Network security: Minimum session security for NTLM SSP based (including secure RPC) clients' is set to 'Require NTLMv2 session security, Require 128-bit encryption'

Rule

Ensure 'Network security: Minimum session security for NTLM SSP based (including secure RPC) clients' is set to

- Require NTLMv2 session security,
- Require 128-bit encryption.

Description

This policy setting determines which behaviors are allowed by clients for applications using the NTLM Security Support Provider (SSP). The SSP Interface (SSPI) is used by applications that need authentication services. The setting does not modify how the authentication sequence works but instead require certain behaviors in applications that use the SSPI.

Note: These values are dependent on the *Network security: LAN Manager Authentication Level* (see rule [BL968-2161 Ensure 'Network security: LAN Manager authentication level' is set to 'Send NTLMv2 response only. Refuse LM&NTLM'](#)) security setting value.

Rationale

You can enable both options for this policy setting to help protect network traffic that uses the NTLM Security Support Provider (NTLM SSP) from being exposed or tampered with by an attacker who has gained access to the same network. In other words, these options help protect against man-in-the-middle attacks.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to:

- Require NTLMv2 session security
- Require 128-bit encryption

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Minimum session security for NTLM SSP based (including secure RPC) clients

Impact:

None - This setting has been already set long time ago at Siemens.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa\MSV1_0:NTLMMinClientSec
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.11.9

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4791

Asset Manager

C	I	A
123	123	123

Ensure 'Network security: Minimum session security for NTLM SSP based (including secure RPC) servers' is set to 'Require NTLMv2 session security, Require 128-bit encryption'

Rule

Ensure 'Network security: Minimum session security for NTLM SSP based (including secure RPC) servers' is set to

- Require NTLMv2 session security,
- Require 128-bit encryption.

Description

This policy setting determines which behaviors are allowed by servers for applications using the NTLM Security Support Provider (SSP). The SSP Interface (SSPI) is used by applications that need authentication services. The setting does not modify how the authentication sequence works but instead require certain behaviors in applications that use the SSPI.

Note: These values are dependent on the *Network security: LAN Manager Authentication Level* (see rule [BL968-2161 Ensure 'Network security: LAN Manager authentication level' is set to 'Send NTLMv2 response only. Refuse LM&NTLM'](#)) security setting value.

Rationale

You can enable all of the options for this policy setting to help protect network traffic that uses the NTLM Security Support Provider (NTLM SSP) from being exposed or tampered with by an attacker who has gained access to the same network. That is, these options help protect against man-in-the-middle attacks.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to

- Require NTLMv2 session security
- Require 128-bit encryption

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Minimum session security for NTLM SSP based (including secure RPC) servers

Impact:

None - This setting has been required long time ago on Siemens servers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa\MSV1_0:NTLMinServerSec
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.11.10

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0281

Asset Manager

C	I	A
123	123	123

Configure 'Network security: Restrict NTLM: Add remote server exceptions for NTLM authentication'

Rule

Ensure 'Restrict NTLM: Add remote server exceptions for NTLM authentication' -> 'Define this policy setting in this template' is activated and the list contains a '<blank>' value.

Description

This policy determines an exception list of computers that are allowed to use NTLM pass-through authentication, even if [BL968-0981 Configure 'Network security: Restrict NTLM: NTLM authentication in this domain'](#) is set to 'Deny all'.

More information can be found here: [Windows IT Pro Center: Network security: Restrict NTLM: Add remote server exceptions for NTLM authentication](#) -> Best practices.

Note: If servers have to be added to this list, an exception request has to be raised and approved by your [Chief Cybersecurity Officer, CCSO](#).

Rationale

Windows computers that are allowed to use the NTLM protocol for authentication are prone to several types of attacks exploiting well-known security weaknesses in NTLM.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to <blank> (i.e. None):

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Restrict NTLM: Add remote server exceptions for NTLM authentication

Set this policy to a <blank>; that is, enable the policy setting, but do not put anything in the text box.

Impact:

None - this is the default configuration.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0636

Asset Manager

C	I	A
123	123	123

Configure 'Network security: Restrict NTLM: Add server exceptions in this domain'

Rule

Ensure 'Network security: Restrict NTLM: Add server exceptions in this domain' -> 'Define this policy setting in this template' is activated and the list contains a '<blank>' value.

Description

This policy determines an exception list of computers that are allowed to use NTLM pass-through authentication, even if [BL968-0981 Configure 'Network security: Restrict NTLM: NTLM authentication in this domain'](#) is set to 'Deny all'.

More information can be found here: [Windows IT Pro Center: Network security: Restrict NTLM: Add server exceptions in this domain](#).

Note: In case of servers have to be added to this list, an exception request has to be raised and approved by your [Chief Cybersecurity Officer, CCSO](#).

Rationale

Windows computers that are allowed to use the NTLM protocol for authentication are prone to several types of attacks exploiting well-known security weaknesses in NTLM.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to <blank> (i.e. None):

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Restrict NTLM: Add server exceptions in this domain

Set this policy to a <blank>; that is, enable the policy setting, but do not put anything in the text box.

Impact:

None - this is the default configuration.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0646

Asset Manager

C	I	A
123	123	123

Configure 'Network security: Restrict NTLM: Audit Incoming NTLM Traffic'

Rule Ensure 'Network security: Restrict NTLM: Audit Incoming NTLM Traffic' is set to `Enable auditing for all accounts`.

Description

This policy defines the way incoming NTLM traffic is audited. The following three settings are available:

- "Disable" or "Not Defined": No log events for incoming NTLM traffic will be logged,
- "Enable auditing for domain accounts": Log events for **NTLM pass-through** authentication requests will be logged,
- "Enable auditing for all accounts": Log events for **all NTLM** authentication requests will be logged.

Basically, this setting works similar as the "Network Security: Restrict NTLM: Incoming NTLM traffic" policy setting but it does not block the traffic but rather audit it.

Note: Audit events are written in the 'Operational' log located under the 'Applications and Services Log\Microsoft\Windows\NTLM' log.

Rationale

This policy setting enables the creation of helpful events to find machines which use the NTLM protocol - however, it does not mitigate the weaknesses of the NTLM/NTLMv2 protocol.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enable auditing for all accounts`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Restrict NTLM: Audit Incoming NTLM Traffic

Impact:

Additional, potentially helpful NTLM log events will be created.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0056

Asset Manager

C	I	A
123	123	123

Configure 'Network security: Restrict NTLM: Audit NTLM authentication in this domain' (DC only)

Rule

Ensure 'Network security: Restrict NTLM: Audit NTLM authentication in this domain' is set

- on Domain Controllers to: 'Enable all'.

Description

This policy defines the way incoming NTLM traffic is audited. The following five settings are available:

- "Disable" or "Undefined": No log events for NTLM authentication in this domain will be logged,
- "Enable for domain accounts to domain servers": Events for NTLM authentication logon attempts for domain accounts will be logged,
- "Enable for domain accounts": Events for NTLM authentication logon attempts that use domain accounts will be logged,
- "Enable for domain servers" Events for NTLM authentication requests to all servers in the domain will be logged.
- "Enable all": Events for NTLM pass-through authentication requests from its servers and for its accounts will be logged.

Basically, this setting works similar as the "Network Security: Restrict NTLM: NTLM authentication in this domain" policy setting but it does not block the traffic but rather audit it.

Note: Audit events are written in the 'Operational' log located under the 'Applications and Services Log\Microsoft\Windows\NTLM' log.

Rationale

This policy setting enables the creation of helpful events to find machines which use the NTLM protocol - however, it does not mitigate the weaknesses of the NTLM/NTLMv2 protocol.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enable all`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Restrict NTLM: Audit NTLM authentication in this domain

Impact:

Additional, potentially helpful NTLM log events will be created.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0686

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Configure 'Network security: Restrict NTLM: Incoming NTLM traffic'

Rule

Ensure 'Network security: Restrict NTLM: Incoming NTLM traffic' is set to Deny all accounts.

E01 - Privileged Access Management Solutions

This rule's setting can be set to Deny all domain accounts, for systems which are managed by Privileged Access Management solutions, such as CyberArk, which use local pool accounts for establishing automated sessions hiding account credentials from connecting users.

Description

This policy determines if incoming NTLM traffic is allowed or not.

Rationale

The various weaknesses in the NTLM protocol can be exploited by an attacker to compromise Siemens servers. Denying NTLM eliminates this attack vector.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Deny all accounts

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Restrict NTLM: Incoming NTLM traffic

Impact:

The server will deny NTLM authentication requests from incoming traffic and display an NTLM blocked error. NTLM shall not be used at Siemens for quite some time.

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added exemption for PAM solutions using local pool accounts.

BL968-0981

Asset Manager

C	I	A
123	123	123

Configure 'Network security: Restrict NTLM: NTLM authentication in this domain'

Rule

Ensure 'Network security: Restrict NTLM: NTLM authentication in this domain' is set to Deny all.

Description

This policy determines whether NTLM authentication within a domain from this domain controller is denied or allowed.

The following five settings are available:

- "Disabled" or "Not defined": All NTLM pass-through authentication requests within the domain are allowed,
- "Deny for domain accounts to domain servers": All NTLM authentication logon attempts to all servers in the domain that are using domain accounts are denied and cause an NTLM blocked error,
- "Deny for domain account": All NTLM authentication logon attempts from domain accounts are denied and cause an NTLM blocked error,
- "Deny for domain servers": NTLM authentication requests to all servers in the domain are denied and cause an NTLM blocked error,
- "Deny all": All NTLM pass-through authentication requests from its servers and for its accounts are denied and cause an NTLM blocked error.

Note: Block events are recorded on this computer in the 'Operational' log located under the 'Applications and Services Log/Microsoft/Windows/NTLM' log (see [BL968-0056 Configure 'Network security: Restrict NTLM: Audit NTLM authentication in this domain' \(DC only\)](#)).

Rationale

The various weaknesses in the NTLM protocol can be exploited by an attacker to compromise Siemens servers. Denying NTLM eliminates this attack vector.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Deny all

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Restrict NTLM: NTLM authentication in this domain

Impact:

The domain controller will deny all NTLM pass-through authentication requests from its servers and for its accounts and return an NTLM blocked error unless the server name is on the exception list of the rule [BL968-0636 Configure 'Network security: Restrict NTLM: Add server exceptions in this domain'](#) .

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0456

Asset Manager

C	I	A
123	123	123

Configure 'Network security: Restrict NTLM: Outgoing NTLM traffic to remote servers'

Rule Ensure 'Network security: Restrict NTLM: Outgoing NTLM traffic to remote servers' is set to `Allow all`.

Note: `Audit all` or `Deny all` are permitted as well as they offer even better security than `Allow all`. In future versions of the Measure Plan for Windows Server 2016 it is planned to set this setting to `Deny All`.

Description

This policy determines whether outgoing NTLM traffic from this Windows server to any Windows remote server is denied or allowed. The following three settings are available:

- "Allow all": or "Not defined": NTLM authentication to a remote server by using is allowed,
- "Audit all": Each NTLM authentication request from the client to a remote server is logged. This helps to identify those servers receiving NTLM authentication requests from the client computer,
- "Deny all": Each NTLM authentication request from the client to a remote server is denied.

Note: Audit and block events are recorded on this computer in the 'Operational' log located under the 'Applications and Services Log/Microsoft/Windows/NTLM' log (see [BL968-0056 Configure 'Network security: Restrict NTLM: Audit NTLM authentication in this domain' \(DC only\)](#)).

Rationale

The various weaknesses in the NTLM protocol can be exploited by an attacker to compromise servers. Denying NTLM eliminates this attack vector.

Note: At the time of writing this document, Outgoing NTLM traffic might be required for specific functionalities in Windows (e.g., SID translation). Therefore, this setting should not be set to `Deny all` without thorough evaluation.

More information can be found here: [Microsoft - Troubleshooting SID translation failures from the obvious to the not so obvious](#).

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Allow all` or `Audit all`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Restrict NTLM: Outgoing NTLM traffic to remote servers

Note: This setting should not be set to `Deny all` before having been set to `Audit all` for some time. This allows to ensure that no NTLM authentication requests are made by clients or servers.

Impact:

The client computer cannot authenticate identities to a remote server by using NTLM authentication. NTLM shall not be used at Siemens for quite some time.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Recovery console

This section contains rules for Recovery console policy.

BL968-0421

Asset Manager

C	I	A
123	123	123

Configure 'Recovery console: Allow automatic administrative logon'

Rule

Ensure 'Recovery console: Allow automatic administrative logon' is set to Disabled.

Description

This security setting determines if the password for the Administrator account must be given before access to the system is granted. If this option is enabled, the Recovery Console does not require you to provide a password, and it automatically logs on to the system.

Rationale

The recovery console must be protected from attacker by the Administrator Password, because the recovery console offers administrative commands which may bypass security controls.

I01 - Implementation Example

Set the following UI path to Disabled :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Recovery console: Allow automatic administrative logon

Impact:

None - this is the default configuration.

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0571

Asset Manager

C	I	A
123	123	123

Configure 'Recovery console: Allow floppy copy and access to all drives and all folders'

Rule Ensure 'Recovery console: Allow floppy copy and access to all drives and all folders' is set to Disabled.

E01 - Exemption

If, in case of an operational problem, administration-personnel needs unrestricted access to the recovery console, then a timely limited (a few hours) setting of Enabled is acceptable. During this time, the server must be carefully protected from being physically accessed by third parties.

Description

Enabling this security option makes the Recovery Console SET command available, which allows you to set the following Recovery Console environment variables:

- AllowWildCards: Enable wildcard support for some commands (such as the DEL command),
- AllowAllPaths: Allow access to all files and folders on the computer,
- AllowRemovableMedia: Allow files to be copied to removable media, such as a floppy disk,
- NoCopyPrompt: Do not prompt when overwriting an existing file.

Rationale

An attacker who can cause the system to restart into the Recovery Console could steal sensitive data and leave no audit or access trail.

I01 - Implementation Example

Set the following UI path to Disabled :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Recovery console: Allow floppy copy and access to all drives and all folders

Impact:

None - this is the default configuration.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Shutdown

This section contains recommendations related to the Windows shutdown functionality.

BL968-4576

Asset Manager

C	I	A
123	123	123

Ensure 'Shutdown: Allow system to be shut down without having to log on' is set to 'Disabled'

Rule Ensure 'Shutdown: Allow system to be shut down without having to log on' is set to 'Disabled'.

Description

This policy setting determines whether a computer can be shut down when a user is not logged on. If this policy setting is enabled, the shutdown command is available on the Windows logon screen. It is recommended to disable this policy setting to restrict the ability to shut down the computer to users with credentials on the system.

Note: In Server 2008 R2 and older versions, this setting had no impact on Remote Desktop (RDP) / Terminal Services sessions - it only affected the local console. However, Microsoft changed the behavior in Windows Server 2012 (non-R2) and above, where if set to Enabled, RDP sessions are also allowed to shut down or restart the server.

Note:

Microsofts default values are:

- Default on workstations: Enabled,
- Default on servers: Disabled.

Rationale

Users who can access the console locally could shut down the computer. Attackers could also walk to the local console and restart the server, which would cause a temporary denial of service (DoS) condition. Attackers could also shut down the server and leave all of its applications and services unavailable. As noted in the Description above, the Denial of Service (DoS) risk of enabling this setting dramatically increases in Windows Server 2012 (non-R2) and above, as even remote users could then shut down or restart the server from the logon screen of an RDP session.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Shutdown: Allow system to be shut down without having to log on

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:ShutdownWithoutLogon
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.13.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

System cryptography

This section contains rules for System Cryptography policy.

BL968-0931

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Configure 'System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing'

Rule

Ensure 'System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing' is set to 'Disabled'.

Description

The Federal Information Processing Standard (FIPS) 140 is written by the National Institute of Standards and Technology (NIST) regarding requirements and standards for cryptographic hard- and software. FIPS 140 compliancy will be ensured on a Windows machine if this rule is enabled.

Though FIPS 140 does not offer the latest and most secure cryptographic algorithms like AES256 or SHA256, but insecure protocols like 3DES or SHA-1 are still available.

Rationale

A FIPS-compliant TLS/SSL security provider provides only the cipher suite TLS_RSA_WITH_3DES_EDE_CBC_SHA. The containing 3DES and SHA-1 protocols inside this cipher are nowadays prohibited and should not be used any longer.

IO1 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing

Impact: None - this is the default configuration.

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Removed exemption 01. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0381

Asset Manager

C	I	A
123	123	123

Configure 'System cryptography: Force strong key protection for user keys stored on the computer'

Rule

Ensure 'System cryptography: Force strong key protection for user keys stored on the computer' is set to 'User must enter a password each time they use a key'.

Description

This policy setting defines whether users have to provide a password (distinct to their domain password!) for the system to get access to their private key.

These options are available:

- User input is not required when new keys are stored and used,
- User is prompted when the key is first used,
- User must enter a password each time they use a key.

Rationale

As private keys are often used to protect confidential data, the access to them should be secured as good as possible. The setting "User must enter a password each time they use a key" makes it harder for an attacker to read encrypted or write bogusly signed data, even if the attacker got full access to a server and the administrator's logon password.

I01 - Implementation Example

Set the following UI path to User must enter a password each time they use a key:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\System Cryptography: Force strong key protection for user keys stored on the computer

Impact:

Users must type their password every time they access a key that is stored on their computer. For example, if users use an S/MIME certificate to digitally sign their email, they are forced to type the password for that certificate every time they send a signed email message.

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 10.1.2-12](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

System objects

This section contains recommendations related to system objects.

BL968-2676

Asset Manager

C	I	A
123	123	123

Ensure 'System objects: Require case insensitivity for non-Windows subsystems' is set to 'Enabled'

Rule Ensure 'System objects: Require case insensitivity for non-Windows subsystems' is set to 'Enabled'.

Description

This policy setting determines whether case insensitivity is enforced for all subsystems. The Microsoft Win32 subsystem is case insensitive. However, the kernel supports case sensitivity for other subsystems, such as the Portable Operating System Interface for UNIX (POSIX). Because Windows is case insensitive (but the POSIX subsystem will support case sensitivity), failure to enforce this policy setting makes it possible for a user of the POSIX subsystem to create a file with the same name as another file by using mixed case to label it. Such a situation can block access to these files by another user who uses typical Win32 tools, because only one of the files will be available.

At Siemens, no other subsystems are allowed (see [BL968-0081 Configure 'System Settings: Optional subsystems'](#)).

Rationale

Because Windows is case-insensitive, but the POSIX subsystem will support case sensitivity, failure to enable this policy setting would make it possible for a user of that subsystem to create a file with the same name as another file but with a different mix of upper and lower-case letters. Such a situation could potentially confuse users when they try to access such files from normal Win32 tools because only one of the files will be available.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\System objects: Require case insensitivity for non-Windows subsystems

Impact:

None - this is the default configuration.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Session Manager\Kernel:ObCaseInsensitive
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.15.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1486

Asset Manager

C	I	A
123	123	123

Ensure 'System objects: Strengthen default permissions of internal system objects (e.g. Symbolic Links)' is set to 'Enabled'

Rule

Ensure 'System objects: Strengthen default permissions of internal system objects (e.g. Symbolic Links)' is set to 'Enabled'.

Description

This policy setting determines the strength of the default discretionary access control list (DACL) for objects. Active Directory maintains a global list of shared system resources, such as DOS device names, mutexes, and semaphores. In this way, objects can be located and shared among processes. Each type of object is created with a default DACL that specifies who can access the objects and what permissions are granted.

More information can be found here: [Windows IT Pro Center: System objects: Strengthen default permissions of internal system objects \(e.g., Symbolic Links\)](#) -> Vulnerability.

Rationale

This policy setting is enabled by default to protect against a known vulnerability that can be used with hard links or symbolic links. Hard links are actual directory entries in the file system. With hard links, the same data in a file system can be referred to by different file names. Symbolic links are text files that provide a pointer to the file that is interpreted and followed by the operating system as a path to another file or directory. Because symbolic links are a separate file, they can exist independently of the target location. If a symbolic link is deleted, its target location remains unaffected. When this setting is disabled, it is possible for a malicious user to destroy a data file by creating a link that looks like a temporary file that the system automatically creates, such as a sequentially named log file, but it points to the data file that the malicious user wants to eradicate. When the system writes the files with that name, the data is overwritten. Enabling System objects: Strengthen default permissions of internal system objects (e.g. Symbolic Links) prevents an attacker from exploiting programs that create files with predictable names by not allowing them to write to objects that they did not create.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled**:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\System objects: Strengthen default permissions of internal system objects (e.g. Symbolic Links)

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Session Manager:ProtectionMode
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.15.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

System settings

This section contains rules for System Settings policy.

BL968-0081

Asset Manager

C	I	A
123	123	123

Configure 'System Settings: Optional subsystems'

Rule Ensure 'System settings: Optional subsystems' -> 'Define this policy setting in this template' is activated and the list contains a '<blank>' value.

Note: In case the POSIX subsystem should be added, you need to check that rule [BL968-2676 Ensure 'System objects: Require case insensitivity for non-Windows subsystems' is set to 'Enabled'](#) is implemented as well. Keep in mind, that an exception request has to be raised and approved by your [Chief Cybersecurity Officer, CCSO](#) if the POSIX subsystem should be added.

Description

This security setting determines which subsystems can optionally be started up to support your applications. With this security setting, you can specify as many subsystems to support your applications as your environment demands.

Note: The POSIX subsystem is only required if specific applications use that subsystem.

Rationale

The POSIX subsystem has a serious weakness regarding termination and protection of processes, so that even users with lower privileges can get access to other more privileged users processes.

I01 - Implementation Example

Set the following UI path to <blank> (i.e. None):

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\System settings: Optional subsystems

Set this policy to <blank> (which enables the policy setting), but do not put anything in the text box.

Impact:

Applications that rely on the POSIX subsystem or other subsystems do not operate.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

User Account Control

This section contains recommendations related to User Account Control.

BL968-4942

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'User Account Control: Admin Approval Mode for the Built-in Administrator account' is set to 'Enabled'

Rule

Ensure 'User Account Control: Admin Approval Mode for the Built-in Administrator account' is set to 'Enabled'.

Description

This policy setting controls the behavior of Admin Approval Mode for the built-in Administrator account.

Rationale

One of the risks that the User Account Control feature introduced with Windows Vista is trying to mitigate is that of malicious software running under elevated credentials without the user or administrator being aware of its activity. An attack vector for these programs was to discover the password of the account named "Administrator" because that user account was created for all installations of Windows. To address this risk, in Windows Vista and newer, the built-in Administrator account is now disabled by default. In a default installation of a new computer, accounts with administrative control over the computer are initially set up in one of two ways:

- If the computer is not joined to a domain, the first user account you create has the equivalent permissions as a local administrator.
- If the computer is joined to a domain, no local administrator accounts are created. The Enterprise or Domain Administrator must log on to the computer and create one if a local administrator account is warranted.

Once Windows is installed, the built-in Administrator account may be manually enabled, but we strongly recommend that this account remains disabled.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\User Account Control: Admin Approval Mode for the Built-in Administrator account

Impact:

The built-in Administrator account uses Admin Approval Mode. Users that log on using the local Administrator account will be prompted for consent whenever a program requests an elevation in privilege, just like any other user would.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:FilterAdministratorToken
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.17.1

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-4943

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' is set to 'Prompt for consent on the secure desktop'

Rule

Ensure 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' is set to 'Prompt for consent on the secure desktop'.

Description

This policy setting controls the behavior of the elevation prompt for administrators.

Rationale

One of the risks that the UAC feature introduced with Windows Vista is trying to mitigate is that of malicious software running under elevated credentials without the user or administrator being aware of its activity. This setting raises awareness to the administrator of elevated privilege operations and permits the administrator to prevent a malicious program from elevating its privilege when the program attempts to do so.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Prompt for consent on the secure desktop`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode

Impact:

When an operation (including execution of a Windows binary) requires elevation of privilege, the user is prompted on the secure desktop to select either Permit or Deny. If the user selects Permit, the operation continues with the user's highest available privilege.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:ConsentPromptBehaviorAdmin
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.17.2

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-4944

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'User Account Control: Behavior of the elevation prompt for standard users' is set to 'Automatically deny elevation requests'

Rule

Ensure 'User Account Control: Behavior of the elevation prompt for standard users' is set to 'Automatically deny elevation requests'.

Description

This policy setting controls the behavior of the elevation prompt for standard users.

Rationale

One of the risks that the User Account Control feature introduced with Windows Vista is trying to mitigate is that of malicious programs running under elevated credentials without the user or administrator being aware of their activity. This setting raises awareness to the user that a program requires the use of elevated privilege operations and requires that the user be able to supply administrative credentials in order for the program to run.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Automatically deny elevation requests`:

```
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\User Account Control: Behavior of the elevation prompt for standard users
```

Impact:

When an operation requires elevation of privilege, a configurable access denied error message is displayed. An enterprise that is running desktops as standard user may choose this setting to reduce help desk calls.

Note: With this setting configured as recommended, the default error message displayed when a user attempts to perform an operation or run a program requiring privilege elevation (without Administrator rights) is " *This program will not run. This program is blocked by group policy. For more information, contact your system administrator.* " Some users who are not used to seeing this message may believe that the operation or program they attempted to run is specifically blocked by group policy, as that is what the message seems to imply. This message may therefore result in user questions as to why that specific operation/program is blocked, when in fact, the problem is that they need to perform the operation or run the program with an Administrative account (or "Run as Administrator" if it is already an Administrator account), and they are not doing that.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:ConsentPromptBehaviorUser
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.17.3

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-4945

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'User Account Control: Detect application installations and prompt for elevation' is set to 'Enabled'

Rule

Ensure 'User Account Control: Detect application installations and prompt for elevation' is set to 'Enabled'.

Description

This policy setting controls the behavior of application installation detection for the computer.

Rationale

Some malicious software will attempt to install itself after being given permission to run. For example, malicious software with a trusted application shell. The user may have given permission for the program to run because the program is trusted, but if they are then prompted for installation of an unknown component this provides another way of trapping the software before it can do damage.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\User Account Control: Detect application installations and prompt for elevation

Impact:

When an application installation package is detected that requires elevation of privilege, the user is prompted to enter an administrative username and password. If the user enters valid credentials, the operation continues with the applicable privilege.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:EnableInstallerDetection
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.17.4

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-4946

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' is set to 'Enabled'

Rule

Ensure 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' is set to 'Enabled'.

Description

This policy setting controls whether applications that request to run with a User Interface Accessibility (UIAccess) integrity level must reside in a secure location in the file system. Secure locations are limited to the following:

- ...\\Program Files\\, including subfolders
- ...\\Windows\\System32\\
- ...\\Program Files (x86)\\, including subfolders (for 64-bit versions of Windows)

Note: Windows enforces a public key infrastructure (PKI) signature check on any interactive application that requests to run with a UIAccess integrity level regardless of the state of this security setting.

Rationale

UIAccess Integrity allows an application to bypass User Interface Privilege Isolation (UIPI) restrictions when an application is elevated in privilege from a standard user to an administrator. This is required to support accessibility features such as screen readers that are transmitting user interfaces to alternative forms. A process that is started with UIAccess rights has the following abilities:

- To set the foreground window.
- To drive any application window using SendInput function.
- To use read input for all integrity levels using low-level hooks, raw input, GetKeyState, GetAsyncKeyState, and GetKeyboardInput.
- To set journal hooks.
- To use AttachThreadInput to attach a thread to a higher integrity input queue.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\\Policies\\Windows Settings\\Security Settings\\Local Policies\\Security Options\\User Account Control: Only elevate UIAccess applications that are installed in secure locations

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:EnableSecureUIAPaths
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.17.5

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-4947

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'User Account Control: Run all administrators in Admin Approval Mode' is set to 'Enabled'

Rule

Ensure 'User Account Control: Run all administrators in Admin Approval Mode' is set to 'Enabled'.

Description

This policy setting controls the behavior of all User Account Control (UAC) policy settings for the computer. If you change this policy setting, you must restart your computer.

Note: If this policy setting is disabled, the Security Center notifies you that the overall security of the operating system has been reduced.

Rationale

This is the setting that turns on or off UAC. If this setting is disabled, UAC will not be used and any security benefits and risk mitigations that are dependent on UAC will not be present on the system.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\User Account Control: Run all administrators in Admin Approval Mode

Impact:

None - this is the default behavior. Users and administrators will need to learn to work with UAC prompts and adjust their work habits to use least privilege operations.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:EnableLUA
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.17.6

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-4948

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'User Account Control: Switch to the secure desktop when prompting for elevation' is set to 'Enabled'

Rule

Ensure 'User Account Control: Switch to the secure desktop when prompting for elevation' is set to 'Enabled'.

Description

This policy setting controls whether the elevation request prompt is displayed on the interactive user's desktop or the secure desktop.

Rationale

Standard elevation prompt dialog boxes can be spoofed, which may cause users to disclose their passwords to malicious software. The secure desktop presents a very distinct appearance when prompting for elevation, where the user desktop dims, and the elevation prompt UI is more prominent. This increases the likelihood that users who become accustomed to the secure desktop will recognize a spoofed elevation prompt dialog box and not fall for the trick.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

```
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\User Account Control: Switch to the secure desktop when prompting for elevation
```

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:PromptOnSecureDesktop
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.17.7

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-4949

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'User Account Control: Virtualize file and registry write failures to per-user locations' is set to 'Enabled'

Rule

Ensure 'User Account Control: Virtualize file and registry write failures to per-user locations' is set to 'Enabled'.

Description

This policy setting controls whether application write failures are redirected to defined registry and file system locations. This policy setting mitigates applications that run as administrator and write run-time application data to:

- %ProgramFiles%
- %windir%
- %windir%\System32
- HKEY_LOCAL_MACHINE\SOFTWARE

Rationale

This setting reduces vulnerabilities by ensuring that legacy applications only write data to permitted locations.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\User Account Control: Virtualize file and registry write failures to per-user locations

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:EnableVirtualization
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 2.3.17.8

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

Windows Firewall with Advanced Security

This section contains recommendations for configuring the Windows Firewall.

Domain Profile

This section contains recommendations for the Domain Profile of the Windows Firewall.

BL968-3226

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Domain: Firewall state' is set to 'On (recommended)'

Rule

Ensure 'Windows Firewall: Domain: Firewall state' is set to 'On (recommended)'.

E01 - Exemption

This rule is not mandatory, if the system is operated in an environment, where an external firewall appliance offers at minimum the same protection level and satisfies the following requirements:

- The system is in a network zone, not directly reachable from the Internet.
- By default, new incoming connections are blocked, except for manually approved dedicated ports, where the system provides a service.

Description

Select On (recommended) to have Windows Firewall with Advanced Security use the settings for this profile to filter network traffic. If you select Off, Windows Firewall with Advanced Security will not use any of the firewall rules or connection security rules for this profile.

Rationale

If the firewall is turned off all traffic will be able to access the system and an attacker may be more easily able to remotely exploit a weakness in a network service.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to On (recommended) :

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Firewall state

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile:EnableFirewall
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.1.1

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1741

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Domain: Inbound connections' is set to 'Block (default)'

Rule

Ensure 'Windows Firewall: Domain: Inbound connections' is set to 'Block (default)'.

E01 - Exemption

This rule is not mandatory, if the system is operated in an environment, where an external firewall appliance offers at minimum the same protection level and satisfies the following requirements:

- The system is in a network zone, not directly reachable from the Internet.
- By default, new incoming connections are blocked, except for manually approved dedicated ports, where the system provides a service.

Description

This setting determines the behavior for inbound connections that do not match an inbound firewall rule.

Note: If "Windows Firewall: Domain: Firewall state" is set to `Off`, then this rule has no effect.

Rationale

If the firewall allows all traffic to access the system, then an attacker may be more easily able to remotely exploit a weakness in a network service.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Block (default)` :

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Inbound connections

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile:DefaultInboundAction
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.1.2

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added exemption 01, added Check section. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3446

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Domain: Logging: Name' is configured

Rule

Ensure 'Windows Firewall: Domain: Logging: Name' is set to
`%SystemRoot%\System32\logfiles\firewall\domainfw.log`.

Description

Use this option to specify the path and name of the file in which Windows Firewall will write its log information.

Rationale

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to
`%SystemRoot%\System32\logfiles\firewall\domainfw.log`:

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Logging Customize\Name

Impact:

The log file will be stored in the specified file.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile\Logging\LogFilePath
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.1.5

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5486

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Domain: Logging: Size limit (KB)' is configured

Rule

Ensure 'Windows Firewall: Domain: Logging: Size limit (KB)' is set to '32,767 KB'.

Description

Use this option to specify the size limit of the file in which Windows Firewall will write its log information.

Rationale

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to 32,767 KB

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Logging Customize\Size limit (KB)

Impact:

The log file size will be limited to the specified size, old events will be overwritten by newer ones when the limit is reached.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile\Logging\LogFileSize
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.1.6

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5971

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Domain: Logging: Log dropped packets' is set to 'Yes'

Rule

Ensure 'Windows Firewall: Domain: Logging: Log dropped packets' is set to 'Yes'.

Description

Use this option to log when Windows Firewall with Advanced Security discards an inbound packet for any reason. The log records why and when the packet was dropped. Look for entries with the word DROP in the action column of the log.

Rationale

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Yes :

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Logging Customize\Log dropped packets

Impact:

Information about dropped packets will be recorded in the firewall log file.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile\Logging\LogDroppedPackets
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.1.7

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5291

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Domain: Logging: Log successful connections' is set to 'Yes'

Rule

Ensure 'Windows Firewall: Domain: Logging: Log successful connections' is set to 'Yes'.

Description

Use this option to log when Windows Firewall with Advanced Security allows an inbound connection. The log records why and when the connection was formed. Look for entries with the word ALLOW in the action column of the log.

Rationale

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Yes :

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Domain Profile\Logging Customize\Log successful connections

Impact:

Information about successful connections will be recorded in the firewall log file.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile\Logging\LogSuccessfulConnections
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.1.8

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Private Profile

This section contains recommendations for the Private Profile of the Windows Firewall.

BL968-5576

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Private: Firewall state' is set to 'On (recommended)'

Rule

Ensure 'Windows Firewall: Private: Firewall state' is set to 'On (recommended)'.

E01 - Exemption

This rule is not mandatory, if the system is operated in an environment, where an external firewall appliance offers at minimum the same protection level and satisfies the following requirements:

- The system is in a network zone, not directly reachable from the Internet.
- By default, new incoming connections are blocked, except for manually approved dedicated ports, where the system provides a service.

Description

Select On (recommended) to have Windows Firewall with Advanced Security use the settings for this profile to filter network traffic. If you select Off, Windows Firewall with Advanced Security will not use any of the firewall rules or connection security rules for this profile.

Rationale

If the firewall is turned off all traffic will be able to access the system and an attacker may be more easily able to remotely exploit a weakness in a network service.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to On (recommended) :

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Private Profile\Firewall state

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PrivateProfile:EnableFirewall
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.2.1

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3486

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Windows Firewall: Private: Inbound connections' is set to 'Block (default)'

Rule

Ensure 'Windows Firewall: Private: Inbound connections' is set to 'Block (default)'.

E01 - Exemption

This rule is not mandatory, if the system is operated in an environment, where an external firewall appliance offers at minimum the same protection level and satisfies the following requirements:

- The system is in a network zone, not directly reachable from the Internet.
- By default, new incoming connections are blocked, except for manually approved dedicated ports, where the system provides a service.

Description

This setting determines the behavior for inbound connections that do not match an inbound firewall rule.

Rationale

If the firewall allows all traffic to access the system, then an attacker may be more easily able to remotely exploit a weakness in a network service.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Block (default)** :

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Private Profile\Inbound connections

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PrivateProfile:DefaultInboundAction
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.2.2

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1901

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Private: Logging: Name' is configured

Rule

Ensure 'Windows Firewall: Private: Logging: Name' is set to
`%SystemRoot%\System32\logfiles\firewall\privatefw.log`.

Description

Use this option to specify the path and name of the file in which Windows Firewall will write its log information.

Rationale

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to
`%SystemRoot%\System32\logfiles\firewall\privatefw.log`:

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Private Profile\Logging Customize\Name

Impact:

The log file will be stored in the specified file.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PrivateProfile\Logging\LogFilePath
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.2.5

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5121

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Private: Logging: Size limit (KB)' is configured

Rule

Ensure 'Windows Firewall: Private: Logging: Size limit (KB)' is set to '32,767 KB'.

Description

Use this option to specify the size limit of the file in which Windows Firewall will write its log information.

Rationale

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to 32,767 KB:

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Private Profile\Logging Customize\Size limit (KB)

Impact:

The log file size will be limited to the specified size, old events will be overwritten by newer ones when the limit is reached.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PrivateProfile\Logging\LogFileSize
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.2.6

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1646

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Private: Logging: Log dropped packets' is set to 'Yes'

Rule

Ensure 'Windows Firewall: Private: Logging: Log dropped packets' is set to 'Yes'.

Description

Use this option to log when Windows Firewall with Advanced Security discards an inbound packet for any reason. The log records why and when the packet was dropped. Look for entries with the word DROP in the action column of the log.

Rationale

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Yes :

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Private Profile\Logging Customize\Log dropped packets

Impact:

Information about dropped packets will be recorded in the firewall log file.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PrivateProfile\Logging\LogDroppedPackets
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.2.7

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5141

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Private: Logging: Log successful connections' is set to 'Yes'

Rule

Ensure 'Windows Firewall: Private: Logging: Log successful connections' is set to 'Yes'.

Description

Use this option to log when Windows Firewall with Advanced Security allows an inbound connection. The log records why and when the connection was formed. Look for entries with the word ALLOW in the action column of the log.

Rationale

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Yes :

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Private Profile\Logging Customize\Log successful connections

Impact:

Information about successful connections will be recorded in the firewall log file.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PrivateProfile\Logging\LogSuccessfulConnections
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.2.8

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Public Profile

This section contains recommendations for the Public Profile of the Windows Firewall.

BL968-5086

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Public: Firewall state' is set to 'On (recommended)'

Rule

Ensure 'Windows Firewall: Public: Firewall state' is set to 'On (recommended)'.

E01 - Exemption

This rule is not mandatory, if the system is operated in an environment, where an external firewall appliance offers at minimum the same protection level and satisfies the following requirements:

- The system is in a network zone, not directly reachable from the Internet.
- By default, new incoming connections are blocked, except for manually approved dedicated ports, where the system provides a service.

Description

Select On (recommended) to have Windows Firewall with Advanced Security use the settings for this profile to filter network traffic. If you select Off, Windows Firewall with Advanced Security will not use any of the firewall rules or connection security rules for this profile.

Rationale

If the firewall is turned off all traffic will be able to access the system and an attacker may be more easily able to remotely exploit a weakness in a network service.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to On (recommended):

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Firewall state

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PublicProfile:EnableFirewall
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.3.1

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2696

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Windows Firewall: Public: Inbound connections' is set to 'Block (default)'

Rule

Ensure 'Windows Firewall: Public: Inbound connections' is set to 'Block (default)'.

E01 - Exemption

This rule is not mandatory, if the system is operated in an environment, where an external firewall appliance offers at minimum the same protection level and satisfies the following requirements:

- The system is in a network zone, not directly reachable from the Internet.
- By default, new incoming connections are blocked, except for manually approved dedicated ports, where the system provides a service.

Description

This setting determines the behavior for inbound connections that do not match an inbound firewall rule.

Rationale

If the firewall allows all traffic to access the system, then an attacker may be more easily able to remotely exploit a weakness in a network service.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Block (default)** :

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Inbound connections

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PublicProfile:DefaultInboundAction
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.3.2

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5656

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Public: Outbound connections' is set to 'Block'

Rule

Ensure 'Windows Firewall: Public: Outbound connections' is set to 'Block'.

Description

This setting determines the behavior for outbound connections that do not match an outbound firewall rule.

Note: If you set Outbound connections to Block and then deploy the firewall policy by using a GPO, computers that receive the GPO settings cannot receive subsequent Group Policy updates unless you create and deploy an outbound rule that enables Group Policy to work. Predefined rules for Core Networking include outbound rules that enable Group Policy to work. Ensure that these outbound rules are active, and thoroughly test firewall profiles before deploying.

Rationale

Some people believe that it is prudent to block all outbound connections except those specifically approved by the user or administrator. Microsoft disagrees with this opinion, blocking outbound connections by default will force users to deal with a large number of dialog boxes prompting them to authorize or block applications such as their web browser or instant messaging software. Additionally, blocking outbound traffic has little value because if an attacker has compromised the system, they can reconfigure the firewall anyway.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Block:

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Outbound connections

Impact:

Local Administrators could open unnecessary ports and expose the system to remote attack.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PublicProfile:DefaultOutboundAction
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.3.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1431

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Public: Settings: Apply local firewall rules' is set to 'No'

Rule

Ensure 'Windows Firewall: Public: Settings: Apply local firewall rules' is set to 'No'.

Description

This setting controls whether local administrators are allowed to create local firewall rules that apply together with firewall rules configured by Group Policy.

Note: When the Apply local firewall rules setting is configured to No , it is recommended to also configure the Display a notification setting to No . Otherwise, users will continue to receive messages that ask if they want to unblock a restricted inbound connection, but the user's response will be ignored.

Rationale

When in the Public profile, there should be no special local firewall exceptions per computer. These settings should be managed by a centralized policy.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to No :

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Settings Customize\Apply local firewall rules

Impact:

Administrators can still create firewall rules, but the rules will not be applied.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PublicProfile:AllowLocalPolicyMerge
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.3.5

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5446

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Public: Settings: Apply local connection security rules' is set to 'No'

Rule Ensure 'Windows Firewall: Public: Settings: Apply local connection security rules' is set to 'No'.

Description

This setting controls whether local administrators are allowed to create connection security rules that apply together with connection security rules configured by Group Policy.

Rationale

Users with administrative privileges might create firewall rules that expose the system to remote attack.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to No :

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Settings Customize\Apply local connection security rules

Impact:

Administrators can still create local connection security rules, but the rules will not be applied.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PublicProfile:AllowLocalIPsecPolicyMerge
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.3.6

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5061

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Public: Logging: Name' is configured

Rule

Ensure 'Windows Firewall: Public: Logging: Name' is set to
`%SystemRoot%\System32\logfiles\firewall\publicfw.log`.

Description

Use this option to specify the path and name of the file in which Windows Firewall will write its log information.

Rationale

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to
`%SystemRoot%\System32\logfiles\firewall\publicfw.log`:

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Logging Customize\Name

Impact:

The log file will be stored in the specified file.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PublicProfile\Logging\LogFilePath
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.3.7

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4526

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Public: Logging: Size limit (KB)' is configured

Rule

Ensure 'Windows Firewall: Public: Logging: Size limit (KB)' is set to '32,767 KB'.

Description

Use this option to specify the size limit of the file in which Windows Firewall will write its log information.

Rationale

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to 32,767 KB:

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Logging Customize\Size limit (KB)

Impact:

The log file size will be limited to the specified size, old events will be overwritten by newer ones when the limit is reached.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PublicProfile\Logging\LogFileSize
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.3.8

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2706

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Public: Logging: Log dropped packets' is set to 'Yes'

Rule

Ensure 'Windows Firewall: Public: Logging: Log dropped packets' is set to 'Yes'.

Description

Use this option to log when Windows Firewall with Advanced Security discards an inbound packet for any reason. The log records why and when the packet was dropped. Look for entries with the word DROP in the action column of the log.

Rationale

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Yes :

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Logging Customize\Log dropped packets

Impact:

Information about dropped packets will be recorded in the firewall log file.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PublicProfile\Logging\LogDroppedPackets
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.3.9

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4911

Asset Manager

C	I	A
123	123	123

Ensure 'Windows Firewall: Public: Logging: Log successful connections' is set to 'Yes'

Rule

Ensure 'Windows Firewall: Public: Logging: Log successful connections' is set to 'Yes'.

Description

Use this option to log when Windows Firewall with Advanced Security allows an inbound connection. The log records why and when the connection was formed. Look for entries with the word ALLOW in the action column of the log.

Rationale

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Yes :

Computer Configuration\Policies\Windows Settings\Security Settings\Windows Firewall with Advanced Security\Windows Firewall with Advanced Security\Windows Firewall Properties\Public Profile\Logging Customize\Log successful connections

Impact:

Information about successful connections will be recorded in the firewall log file.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\PublicProfile\Logging\LogSuccessfulConnections
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 9.3.10

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Advanced Audit Policy Configuration

This section contains recommendations for configuring the Windows audit facilities.

Account Logon

This section contains recommendations for configuring the Account Logon audit policy.

BL968-5866

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Credential Validation' is set to 'Success and Failure'

Rule

Ensure 'Audit Credential Validation' is set to 'Success and Failure'.

Description

This subcategory reports the results of validation tests on credentials submitted for a user account logon request. These events occur on the computer that is authoritative for the credentials. For domain accounts, the Domain Controller is authoritative, whereas for local accounts, the local computer is authoritative. In domain environments, most of the Account Logon events occur in the Security log of the Domain Controllers that are authoritative for the domain accounts. However, these events can occur on other computers in the organization when local accounts are used to log on.

Events for this subcategory include:

- 4774: An account was mapped for logon.
- 4775: An account could not be mapped for logon.
- 4776: The Domain Controller attempted to validate the credentials for an account.
- 4777: The Domain Controller failed to validate the credentials for an account.

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success and Failure`:

```
Computer Configuration\Policies\Windows Settings\Security Settings\Advanced  
Audit Policy Configuration\Audit Policies\Account Logon\Audit Credential  
Validation
```

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.1.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0361

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Kerberos Authentication Service' is set to 'Success and Failure' (DC Only)

Rule

Ensure 'Audit Kerberos Authentication Service' is set to 'Success and Failure' (DC Only).

Description

This subcategory reports the results of events generated after a Kerberos authentication TGT request. Kerberos is a distributed authentication service that allows a client running on behalf of a user to prove its identity to a server without sending data across the network. This helps mitigate an attacker or server from impersonating a user.

- 4768: A Kerberos authentication ticket (TGT) was requested.
- 4771: Kerberos pre-authentication failed.
- 4772: A Kerberos authentication ticket request failed.

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success and Failure`:

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Account Logon\Audit Kerberos Authentication Service

Impact:

Event volume: High on Kerberos Key Distribution Center servers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.1.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-0511

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Kerberos Service Ticket Operations' is set to 'Success and Failure' (DC Only)

Rule

Ensure 'Audit Kerberos Service Ticket Operations' is set to 'Success and Failure' (DC Only).

Description

This subcategory reports the results of events generated by Kerberos authentication ticket-granting ticket (TGT) requests. Kerberos Service Ticket requests (TGS requests) occur as part of service use and access requests by specific accounts. Auditing these events will record the IP address from which the account requested TGS, when TGS was requested, and which encryption type was used.

- 4769: A Kerberos service ticket was requested.
- 4770: A Kerberos service ticket was renewed.
- 4773: A Kerberos service ticket request failed.

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success and Failure`:

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Account Logon\Audit Kerberos Service Ticket Operations

Impact:

The estimation of the event volume differs between the explanation inside the GPO and the Microsoft literature.

Event volume: Low (Referencing the description inside the Windows GPO),

Event volume: Very High on Kerberos Key Distribution Center servers. (Referencing the cited website at the end of the description section above).

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.1.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Account Management

This section contains recommendations for configuring the Account Management audit policy.

BL968-1736

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Computer Account Management' is set to 'Success' (DC only)

Rule

Ensure 'Audit Computer Account Management' is set to 'Success' (DC only).

Description

This subcategory reports each event of computer account management, such as when a computer account is created, changed, deleted, renamed, disabled, or enabled. Events for this subcategory include:

- 4741: A computer account was created.
- 4742: A computer account was changed.
- 4743: A computer account was deleted.

This subcategory doesn't have Failure events, so there is no recommendation to enable Failure auditing for this subcategory.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Computer Account Management](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Success :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Account Management\Audit Computer Account Management

Impact:

Event volume: Low on domain controllers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.2.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4741

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Distribution Group Management' is set to 'Success' (DC only)

Rule

Ensure 'Audit Distribution Group Management' is set to 'Success' (DC only).

Description

This subcategory reports each event of distribution group management, such as when a distribution group is created, changed, or deleted or when a member is added to or removed from a distribution group. If you enable this Audit policy setting, administrators can track events to detect malicious, accidental, and authorized creation of group accounts. Events for this subcategory include:

- 4744: A security-disabled local group was created.
- 4745: A security-disabled local group was changed.
- 4746: A member was added to a security-disabled local group.
- 4747: A member was removed from a security-disabled local group.
- 4748: A security-disabled local group was deleted.
- 4749: A security-disabled global group was created.
- 4750: A security-disabled global group was changed.
- 4751: A member was added to a security-disabled global group.
- 4752: A member was removed from a security-disabled global group.
- 4753: A security-disabled global group was deleted.
- 4759: A security-disabled universal group was created.
- 4760: A security-disabled universal group was changed.
- 4761: A member was added to a security-disabled universal group.
- 4762: A member was removed from a security-disabled universal group.
- 4763: A security-disabled universal group was deleted.

Auditing these events may provide incident-handler-staff with insight when investigating an incident. For example, when a given unauthorized user was added to a sensitive distribution group.

This subcategory doesn't have Failure events, so there is no recommendation to enable Failure auditing for this subcategory.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Distribution Group Management](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Success :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced
Audit Policy Configuration\Audit Policies\Account Management\Audit Distribution
Group Management

Impact:

- This subcategory generates events only on domain controllers,
- Event volume: Low.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.2.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2956

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Other Account Management Events' is set to 'Success' (DC only)

Rule

Ensure 'Audit Other Account Management Events' is set to 'Success' (DC only).

Description

This subcategory reports other account management events. Events for this subcategory include:

- 4782: The password hash an account was accessed.
- 4793: The Password Policy Checking API was called.

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Success :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced
Audit Policy Configuration\Audit Policies\Account Management\Audit Other
Account Management Events

Impact:

Event volume: Low on domain controllers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.2.4

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5391

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Security Group Management' is set to 'Success'

Rule

Ensure 'Audit Security Group Management' is set to 'Success'.

Description

This subcategory reports each event of security group management, such as when a security group is created, changed, or deleted or when a member is added to or removed from a security group. If you enable this Audit policy setting, administrators can track events to detect malicious, accidental, and authorized creation of security group accounts. Events for this subcategory include:

- 4727: A security-enabled global group was created.
- 4728: A member was added to a security-enabled global group.
- 4729: A member was removed from a security-enabled global group.
- 4730: A security-enabled global group was deleted.
- 4731: A security-enabled local group was created.
- 4732: A member was added to a security-enabled local group.
- 4733: A member was removed from a security-enabled local group.
- 4734: A security-enabled local group was deleted.
- 4735: A security-enabled local group was changed.
- 4737: A security-enabled global group was changed.
- 4754: A security-enabled universal group was created.
- 4755: A security-enabled universal group was changed.
- 4756: A member was added to a security-enabled universal group.
- 4757: A member was removed from a security-enabled universal group.
- 4758: A security-enabled universal group was deleted.
- 4764: A group's type was changed.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Security Group Management](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced
Audit Policy Configuration\Audit Policies\Account Management\Audit Security
Group Management

Impact:

Event volume: Low.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.2.5

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4016

Asset Manager

C	I	A
123	123	123

Ensure 'Audit User Account Management' is set to 'Success and Failure'

Rule

Ensure 'Audit User Account Management' is set to 'Success and Failure'.

Description

This subcategory reports each event of user account management, such as when a user account is created, changed, or deleted; a user account is renamed, disabled, or enabled; or a password is set or changed. If you enable this Audit policy setting, administrators can track events to detect malicious, accidental, and authorized creation of user accounts. Events for this subcategory include:

- 4720: A user account was created.
- 4722: A user account was enabled.
- 4723: An attempt was made to change an account's password.
- 4724: An attempt was made to reset an account's password.
- 4725: A user account was disabled.
- 4726: A user account was deleted.
- 4738: A user account was changed.
- 4740: A user account was locked out.
- 4765: SID History was added to an account.
- 4766: An attempt to add SID History to an account failed.
- 4767: A user account was unlocked.
- 4780: The ACL was set on accounts which are members of administrators groups.
- 4781: The name of an account was changed:
- 4794: An attempt was made to set the Directory Services Restore Mode.
- 5376: Credential Manager credentials were backed up.
- 5377: Credential Manager credentials were restored from a backup.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit User Account Management](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success and Failure`:

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced
Audit Policy Configuration\Audit Policies\Account Management\Audit User Account
Management

Impact:

Event volume: Low.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.2.6

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Detailed Tracking

This section contains recommendations for configuring the Detailed Tracking audit policy.

BL968-1591

Asset Manager



Ensure 'Audit PNP Activity' is set to 'Success'

Rule

Ensure 'Audit PNP Activity' is set to 'Success'.

Description

This policy setting allows you to audit when plug and play detects an external device.

Event List:

Event Number	Event Title
6416(S)	A new external device was recognized by the System
6419(S)	A request was made to disable a device
6420(S)	A device was disabled
6421(S)	A request was made to enable a device
6422(S)	A device was enabled
6423(S)	The installation of this device is forbidden by system policy
6424(S)	The installation of this device was allowed, after having previously been forbidden by policy

This subcategory doesn't have Failure events, so there is no recommendation to enable Failure auditing for this subcategory.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit PNP Activity](#).

Note: A Windows 10, Server 2016 or newer OS is required to access and set this value in Group Policy.

Rationale

Enabling this setting will allow a user to audit events when a device is plugged into a system. This can help alert IT staff if unapproved devices are plugged in.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced
Audit Policy Configuration\Audit Policies\Detailed Tracking\Audit PNP Activity

Impact:

Event volume: Varies, depending on how the computer is used. For servers it should be 'Low'.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.3.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2511

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Process Creation' is set to 'Success'

Rule

Ensure 'Audit Process Creation' is set to 'Success'.

Description

This subcategory reports the creation of a process and the name of the program or user that created it. Events for this subcategory include:

- 4688: A new process has been created.
- 4696: A primary token was assigned to process.

This subcategory doesn't have Failure events, so there is no recommendation to enable Failure auditing for this subcategory.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Process Creation](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Detailed Tracking\Audit Process Creation

Impact:

Event volume: Low to Medium, depending on system usage.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.3.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

DS Access

This section contains recommendations for configuring the Directory Services Access audit policy.

BL968-4586

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Directory Service Access' is set to 'Failure' (DC only)

Rule

Ensure 'Audit Directory Service Access' is set to 'Failure' (DC only).

Description

This subcategory reports when an AD DS object is accessed. Only objects with SACLs cause audit events to be generated, and only when they are accessed in a manner that matches their SACL. These events are similar to the directory service access events in previous versions of Windows Server. This subcategory applies only to Domain Controllers. Events for this subcategory include:

- 4662 : An operation was performed on an object.

Microsoft recommends (see the following link) auditing only Failure-events with this subcategory. To track successful changes to Active Directory objects should be better done through the 'Audit Directory Service Changes' subcategory.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Directory Service Access](#).

Rationale

Auditing these events may be useful when investigating a security incident.

It is better to track changes to Active Directory objects through the rule [BL968-1611 Ensure 'Audit Directory Service Changes' is set to 'Success' \(DC only\)](#). However, 'Audit Directory Service Changes' doesn't give you information about failed access attempts, so we recommend Failure auditing in this subcategory to track failed access attempts to Active Directory objects.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Failure` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\DS Access\Audit Directory Service Access

Impact:

Event volume: High on servers running AD DS role services.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.4.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1611

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Directory Service Changes' is set to 'Success' (DC only)

Rule

Ensure 'Audit Directory Service Changes' is set to 'Success' (DC only).

Description

This subcategory reports changes to objects in Active Directory Domain Services (AD DS). The types of changes that are reported are create, modify, move, and undelete operations that are performed on an object. DS Change auditing, where appropriate, indicates the old and new values of the changed properties of the objects that were changed. Only objects with SACLs cause audit events to be generated, and only when they are accessed in a manner that matches their SACL. Some objects and properties do not cause audit events to be generated due to settings on the object class in the schema. This subcategory applies only to Domain Controllers. Events for this subcategory include:

- 5136 : A directory service object was modified.
- 5137 : A directory service object was created.
- 5138 : A directory service object was undeleted.
- 5139 : A directory service object was moved.

Tracking actions related to high value or critical Active Directory objects, for example, changes to AdminSDHolder container or Domain Admins group objects is important.

This subcategory doesn't have Failure events, so there is no recommendation to enable Failure auditing for this subcategory.

This subcategory makes sense only on domain controllers.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Directory Service Changes](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

This policy allows to track actions related to high value or critical Active Directory objects, for example, changes to AdminSDHolder container, see: [Active Directory Security: AdminSDHolder](#), or Domain Admins group objects.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Success :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\DS Access\Audit Directory Service Changes

Impact:

Event volume: High on domain controllers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.4.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Logon/Logoff

This section contains recommendations for configuring the Logon/Logoff audit policy.

BL968-3146

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Account Lockout' is set to 'Failure'

Rule

Ensure 'Audit Account Lockout' is set to 'Failure'.

Description

This subcategory reports when a user's account is locked out as a result of too many failed logon attempts. Events for this subcategory include:

- 4625: An account failed to log on.

This subcategory doesn't have Success events, so there is no recommendation to enable Success auditing for this subcategory.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Account Lockout](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Failure` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Logon/Logoff\Audit Account Lockout

Impact:

Event volume: Low.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.5.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3366

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Group Membership' is set to 'Success'

Rule

Ensure 'Audit Group Membership' is set to 'Success'.

Description

This policy allows you to audit the group membership information in the user's logon token. Events in this subcategory are generated on the computer on which a logon session is created. For an interactive logon, the security audit event is generated on the computer that the user logged on to. For a network logon, such as accessing a shared folder on the network, the security audit event is generated on the computer hosting the resource.

This subcategory doesn't have Failure events, so there is no recommendation to enable Failure auditing for this subcategory.

Note: A Windows 10, Server 2016 or higher OS is required to access and set this value in Group Policy.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Group Membership](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Logon/Logoff\Audit Group Membership

Impact:

Event volume: Medium on a domain controller or network servers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.5.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4261

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Logon' is set to 'Success and Failure'

Rule

Ensure 'Audit Logon' is set to 'Success and Failure'.

Description

This subcategory reports when a user attempts to log on to the system. These events occur on the accessed computer. For interactive logons, the generation of these events occurs on the computer that is logged on to. If a network logon takes place to access a share, these events generate on the computer that hosts the accessed resource. If you configure this setting to No auditing, it is difficult or impossible to determine which user has accessed or attempted to access organization computers. Events for this subcategory include:

- 4624: An account was successfully logged on.
- 4625: An account failed to log on.
- 4648: A logon was attempted using explicit credentials.
- 4675: SIDs were filtered.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Logon](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success and Failure`:

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Logon/Logoff\Audit Logon

Impact:

Event volume: Medium on a domain controllers or network servers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.5.4

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5431

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Other Logon/Logoff Events' is set to 'Success and Failure'

Rule

Ensure 'Audit Other Logon/Logoff Events' is set to 'Success and Failure'.

Description

This subcategory reports other logon/logoff-related events, such as Remote Desktop Services session disconnects and reconnects, using RunAs to run processes under a different account, and locking and unlocking a workstation. Events for this subcategory include:

- 4649: A replay attack was detected.
- 4778: A session was reconnected to a Window Station.
- 4779: A session was disconnected from a Window Station.
- 4800: The workstation was locked.
- 4801: The workstation was unlocked.
- 4802: The screen saver was invoked.
- 4803: The screen saver was dismissed.
- 5378: The requested credentials delegation was disallowed by policy.
- 5632: A request was made to authenticate to a wireless network.
- 5633: A request was made to authenticate to a wired network.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Other Logon/Logoff Events](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success and Failure`:

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Logon/Logoff\Audit Other Logon/Logoff Events

Impact:

Event volume: Low - typically you will not get any of these events.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.5.5

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5251

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Special Logon' is set to 'Success'

Rule Ensure 'Audit Special Logon' is set to 'Success'.

Description

This subcategory reports when a special logon is used. A special logon is a logon that has administrator-equivalent privileges and can be used to elevate a process to a higher level. Events for this subcategory include:

- 4964 : Special groups have been assigned to a new logon.

This subcategory doesn't have Failure events, so there is no recommendation to enable Failure auditing for this subcategory.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Special Logon](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

Auditing this subcategory is a precondition for [BL968-0516 Configure 'Auditing Privileged Group Members Logons'](#).

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Logon/Logoff\Audit Special Logon

Impact:

Event volume: Medium on domain controllers or network servers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.5.6

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Object Access

This section contains recommendations for configuring the Object Access audit policy.

BL968-0346

Asset Manager

C	I	A
123	123	123

Ensure 'Audit File Share' is set to 'Success and Failure'

Rule

Ensure 'Audit File Share' is set to 'Success and Failure'.

Description

This policy setting allows you to audit attempts to access a shared folder.

Note: There are no system access control lists (SACLs) for shared folders. If this policy setting is enabled, access to all shared folders on the system is audited.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit File Share](#) .

Rationale

In an enterprise managed environment, it is important to track deletion, creation, modification, and access events for network shares. Any unusual file sharing activity may be useful in an investigation of potentially malicious activity.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success and Failure` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Object Access\Audit File Share

Impact:

Event volume:

- High on a file server or domain controller because of SYSVOL network access required by Group Policy,
- High on file servers,
- Low on member servers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.6.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-0347

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Detailed File Share' is set to 'Failure'

Rule

Ensure 'Audit Detailed File Share' is set to 'Failure'.

Description

This subcategory allows you to audit attempts to access files and folders on a shared folder. Events for this subcategory include:

- 5145: network share object was checked to see whether client can be granted desired access.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Detailed File Share](#).

Rationale

Auditing the Failures will log which unauthorized users attempted (and failed) to get access to a file or folder on a network share on this computer, which could possibly be an indication of malicious intent.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Failure :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Object Access\Audit Detailed File Share

Impact:

Event volume:

The volume of Failure events for member servers should not be very high.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.6.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-7474

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Other Object Access Events' is set to 'Success and Failure'

Rule

Ensure 'Audit Other Object Access Events' is set to 'Success and Failure'.

Description

This policy setting allows you to audit events generated by the management of task scheduler jobs or COM+ objects.

For scheduler jobs, the following are audited:

- Job created.
- Job deleted.
- Job enabled.
- Job disabled.
- Job updated.

For COM+ objects, the following are audited:

- Catalog object added.
- Catalog object updated.
- Catalog object deleted.

Eventlist:

Event Number	Event Title
4671(-)	An application attempted to access a blocked ordinal through the TBS
4691(S)	Indirect access to an object was requested
5148(F)	The Windows Filtering Platform has detected a denial of service (DoS) attack and entered a defensive mode; packets associated with this attack will be discarded
5149(F)	The denial of service (DoS) attack has subsided and normal processing is being resumed
4698(S)	A scheduled task was created
4699(S)	A scheduled task was deleted
4700(S)	A scheduled task was enabled
4701(S)	A scheduled task was disabled
4702(S)	A scheduled task was updated
5888(S)	An object in the COM+ Catalog was modified
5889(S)	An object was deleted from the COM+ Catalog
5890(S)	An object was added to the COM+ Catalog

More information about this subcategory can be found here:

[Windows IT Pro Center: Audit Other Object Access Events](#) .

Rationale

The unexpected creation of scheduled tasks and COM+ objects could potentially be an indication of malicious activity. Since these types of actions are generally low volume, it may be useful to capture them in the audit logs for use during an investigation.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success` and `Failure` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Object Access\Audit Other Object Access Events

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.6.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0441

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Removable Storage' is set to 'Success and Failure'

Rule

Ensure 'Audit Removable Storage' is set to 'Success and Failure'.

Description

This policy setting allows you to audit user attempts to access file system objects on a removable storage device. A security audit event is generated only for all objects for all types of access requested. If you configure this policy setting, an audit event is generated each time an account accesses a file system object on a removable storage. Success audits record successful attempts and Failure audits record unsuccessful attempts. If you do not configure this policy setting, no audit event is generated when an account accesses a file system object on a removable storage.

Eventlist:

Event Number	Event Title
4656(S, F)	A handle to an object was requested
4658(S)	The handle to an object was closed
4663(S)	An attempt was made to access an object

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Removable Storage](#).

Rationale

Auditing removable storage may be useful when investigating an incident. For example, if an individual is suspected of copying sensitive information onto a USB drive.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success and Failure`:

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Object Access\Audit Removable Storage

Impact:

Event volume: depending on how many removable storage devices are connected to a server.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.6.4

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Policy Change

This section contains recommendations for configuring the Policy Change audit policy.

BL968-2916

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Audit Policy Change' is set to 'Success'

Rule

Ensure 'Audit Audit Policy Change' is set to 'Success'.

Description

This subcategory reports changes in audit policy including SACL changes. Events for this subcategory include:

- 4715: The audit policy (SACL) on an object was changed.
- 4719: System audit policy was changed.
- 4902: The Per-user audit policy table was created.
- 4904: An attempt was made to register a security event source.
- 4905: An attempt was made to unregister a security event source.
- 4906: The CrashOnAuditFail value has changed.
- 4907: Auditing settings on object were changed.
- 4908: Special Groups Logon table modified.
- 4912: Per User Audit Policy was changed.

This subcategory doesn't have Failure events, so there is no recommendation to enable Failure auditing for this subcategory.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Audit Policy Change](#).

Rationale

Auditing these events may be useful when investigating a security incident. Almost all events in this subcategory have security relevance and have to be monitored.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Policy Change\Audit Audit Policy Change

Impact:

Event volume: Low.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.7.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3381

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Authentication Policy Change' is set to 'Success'

Rule

Ensure 'Audit Authentication Policy Change' is set to 'Success'.

Description

This subcategory reports changes in authentication policy. Events for this subcategory include:

- 4706: A new trust was created to a domain.
- 4707: A trust to a domain was removed.
- 4713: Kerberos policy was changed.
- 4716: Trusted domain information was modified.
- 4717: System security access was granted to an account.
- 4718: System security access was removed from an account.
- 4739: Domain Policy was changed.
- 4864: A namespace collision was detected.
- 4865: A trusted forest information entry was added.
- 4866: A trusted forest information entry was removed.
- 4867: A trusted forest information entry was modified.

This subcategory doesn't have Failure events, so there is no recommendation to enable Failure auditing for this subcategory.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Authentication Policy Change](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

- On domain controllers, it is important to enable Success audit for this subcategory to be able to get information related to operations with domain and forest trusts, changes in Kerberos policy and some other events included in this subcategory.
- On member servers it is important to enable Success audit for this subcategory to be able to get information related to changes in user logon rights policies and password policy changes.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced
Audit Policy Configuration\Audit Policies\Policy Change\Audit Authentication
Policy Change

Impact:

Event volume: Low.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.7.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-0776

Asset Manager

C	I	A
123	123	123

Ensure 'Audit MPSSVC Rule-Level Policy Change' is set to 'Success and Failure'

Rule

Ensure 'Audit MPSSVC Rule-Level Policy Change' is set to 'Success and Failure'.

Description

This subcategory determines whether the operating system generates audit events when changes are made to policy rules for the Microsoft Protection Service (MPSSVC.exe). Events for this subcategory include:

- 4944: The following policy was active when the Windows Firewall started.
- 4945: A rule was listed when the Windows Firewall started.
- 4946: A change has been made to Windows Firewall exception list. A rule was added.
- 4947: A change has been made to Windows Firewall exception list. A rule was modified.
- 4948: A change has been made to Windows Firewall exception list. A rule was deleted.
- 4949: Windows Firewall settings were restored to the default values.
- 4950: A Windows Firewall setting has changed.
- 4951: A rule has been ignored because its major version number was not recognized by Windows Firewall.
- 4952: Parts of a rule have been ignored because its minor version number was not recognized by Windows Firewall. The other parts of the rule will be enforced.
- 4953: A rule has been ignored by Windows Firewall because it could not parse the rule.
- 4954: Windows Firewall Group Policy settings have changed. The new settings have been applied.
- 4956: Windows Firewall has changed the active profile.
- 4957: Windows Firewall did not apply the following rule.
- 4958: Windows Firewall did not apply the following rule because the rule referred to items not configured on this computer.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit MPSSVC Rule-Level Policy Change](#).

Rationale

Changes to firewall rules are important for understanding the security state of the computer and how well it is protected against network attacks.

Success events shows you changes in Windows Firewall rules and settings, active configuration and rules after Windows Firewall Service startup and default configuration restore actions. Failure events may help to identify configuration problems with Windows Firewall rules or settings.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success` and `Failure` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Policy Change\Audit MPSSVC Rule-Level Policy Change

Impact:

Event volume: Medium.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.7.4

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0956

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Other Policy Change Events' is set to 'Failure'

Rule

Ensure 'Audit Other Policy Change Events' is set to 'Failure'.

Description

This subcategory contains events about EFS Data Recovery Agent policy changes, changes in Windows Filtering Platform filter, status on Security policy settings updates for local Group Policy settings, Central Access Policy changes, and detailed troubleshooting events for Cryptographic Next Generation (CNG) operations.

- 5063: A cryptographic provider operation was attempted.
- 5064: A cryptographic context operation was attempted.
- 5065: A cryptographic context modification was attempted.
- 5066: A cryptographic function operation was attempted.
- 5067: A cryptographic function modification was attempted.
- 5068: A cryptographic function provider operation was attempted.
- 5069: A cryptographic function property operation was attempted.
- 5070: A cryptographic function property modification was attempted.
- 6145: One or more errors occurred while processing security policy in the group policy objects.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Other Policy Change Events](#),

Rationale

This setting can help detect errors in applied Security settings which came from Group Policy, and failure events related to Cryptographic Next Generation (CNG) functions.

Audit Other Policy Change Events contains events about EFS Data Recovery Agent policy changes, changes in Windows Filtering Platform filter, status on Security policy settings updates for local Group Policy settings, Central Access Policy changes, and detailed troubleshooting events for Cryptographic Next Generation (CNG) operations.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Failure :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Policy Change\Audit Other Policy Change Events

Impact:

Event volume: Low.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.7.5

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Privilege Use

This section contains recommendations for configuring the Privilege Use audit policy.

BL968-3361

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Sensitive Privilege Use' is set to 'Success and Failure'

Rule

Ensure 'Audit Sensitive Privilege Use' is set to 'Success and Failure'.

Description

This subcategory reports when a user account or service uses a sensitive privilege. A sensitive privilege includes the following user rights:

- Act as part of the operating system
- Back up files and directories
- Create a token object
- Debug programs
- Enable computer and user accounts to be trusted for delegation
- Generate security audits
- Impersonate a client after authentication
- Load and unload device drivers
- Manage auditing and security log
- Modify firmware environment values
- Replace a process-level token
- Restore files and directories
- Take ownership of files or other objects

Auditing this subcategory will create a high volume of events. Events for this subcategory include:

- 4672: Special privileges assigned to new logon.
- 4673: A privileged service was called.
- 4674: An operation was attempted on a privileged object.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Sensitive Privilege Use](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

Microsoft recommends tracking Success and Failure for this subcategory of events, especially if the sensitive privileges were used by a user account.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success` and `Failure` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced
Audit Policy Configuration\Audit Policies\Privilege Use\Audit Sensitive
Privilege Use

Impact:

Event volume: High.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.8.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

System

This section contains recommendations for configuring the System audit policy.

BL968-3481

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Other System Events' is set to 'Success and Failure'

Rule

Ensure 'Audit Other System Events' is set to 'Success and Failure'.

Description

This subcategory reports on other system events. Events for this subcategory include:

- 5024 : The Windows Firewall Service has started successfully.
- 5025 : The Windows Firewall Service has been stopped.
- 5027 : The Windows Firewall Service was unable to retrieve the security policy from the local storage. The service will continue enforcing the current policy.
- 5028 : The Windows Firewall Service was unable to parse the new security policy. The service will continue with currently enforced policy.
- 5029: The Windows Firewall Service failed to initialize the driver. The service will continue to enforce the current policy.
- 5030: The Windows Firewall Service failed to start.
- 5032: Windows Firewall was unable to notify the user that it blocked an application from accepting incoming connections on the network.
- 5033 : The Windows Firewall Driver has started successfully.
- 5034 : The Windows Firewall Driver has been stopped.
- 5035 : The Windows Firewall Driver failed to start.
- 5037 : The Windows Firewall Driver detected critical runtime error. Terminating.
- 5058: Key file operation.
- 5059: Key migration operation.

Microsoft recommends enabling `Success` and `Failure` auditing because you will be able to get Windows Firewall Service and Windows Firewall Driver status events.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Other System Events](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

Capturing these audit events may be useful for identifying when the Windows Firewall is not performing as expected.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success` and `Failure` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\System\Audit Other System Events

Impact:

Event volume: Low.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.9.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2211

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Security State Change' is set to 'Success'

Rule

Ensure 'Audit Security State Change' is set to 'Success'.

Description

This subcategory reports changes in security state of the system, such as when the security subsystem starts and stops. Events for this subcategory include:

- 4608: Windows is starting up.
- 4609: Windows is shutting down.
- 4616: The system time was changed.
- 4621: Administrator recovered system from CrashOnAuditFail. Users who are not administrators will now be allowed to log on. Some auditable activity might not have been recorded.

This subcategory doesn't have Failure events, so there is no recommendation to enable Failure auditing for this subcategory.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Security State Change](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

Audit Security State Change contains Windows startup, recovery, and shutdown events, and information about changes in system time.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success` :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\System\Audit Security State Change

Impact:

Event volume: Low.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.9.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2381

Asset Manager

C	I	A
123	123	123

Ensure 'Audit Security System Extension' is set to 'Success'

Rule

Ensure 'Audit Security System Extension' is set to 'Success'.

Description

This subcategory reports the loading of extension code such as authentication packages by the security subsystem. Events for this subcategory include:

- 4610: An authentication package has been loaded by the Local Security Authority.
- 4611: A trusted logon process has been registered with the Local Security Authority.
- 4614: A notification package has been loaded by the Security Account Manager.
- 4622: A security package has been loaded by the Local Security Authority.
- 4697: A service was installed in the system.

This subcategory doesn't have Failure events, so there is no recommendation to enable Failure auditing for this subcategory.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit Security System Extension](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

Audit Security System Extension contains information about the loading of an authentication package, notification package, or security package, plus information about trusted logon process registration events.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Success :

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\System\Audit Security System Extension

Impact:

Event volume: Low.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.9.4

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4281

Asset Manager

C	I	A
123	123	123

Ensure 'Audit System Integrity' is set to 'Success and Failure'

Rule

Ensure 'Audit System Integrity' is set to 'Success and Failure'.

Description

This subcategory reports on violations of integrity of the security subsystem. Events for this subcategory include:

- 4612 : Internal resources allocated for the queuing of audit messages have been exhausted, leading to the loss of some audits.
- 4615 : Invalid use of LPC port.
- 4618 : A monitored security event pattern has occurred.
- 4816 : RPC detected an integrity violation while decrypting an incoming message.
- 5038 : Code integrity determined that the image hash of a file is not valid. The file could be corrupt due to unauthorized modification or the invalid hash could indicate a potential disk device error.
- 5056: A cryptographic self test was performed.
- 5057: A cryptographic primitive operation failed.
- 5060: Verification operation failed.
- 5061: Cryptographic operation.
- 5062: A kernel-mode cryptographic self test was performed.

Violations of security subsystem integrity are critical and could indicate a potential security attack.

More information about this subcategory can be found here: [Windows IT Pro Center: Audit System Integrity](#).

Rationale

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected.

'Audit System Integrity' determines whether the operating system audits events that violate the integrity of the security subsystem.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Success and Failure`:

Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\System\Audit System Integrity

Impact:

Event volume: Low.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 17.9.5

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Administrative Templates (Computer)

This section contains computer-based recommendations from Group Policy Administrative Templates (ADMX).

Control Panel

This section contains recommendations for Control Panel settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Personalization

This section contains recommendations for Control Panel personalization settings.

This Group Policy section is provided by the Group Policy template `ControlPanelDisplay.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

BL968-1506

Asset Manager



Ensure 'Prevent enabling lock screen camera' is set to 'Enabled'

Rule

Ensure 'Prevent enabling lock screen camera' is set to 'Enabled'.

Description

Disables the lock screen camera toggle switch in PC Settings and prevents a camera from being invoked on the lock screen.

Rationale

Disabling the lock screen camera extends the protection afforded by the lock screen to camera features.

Requiring logon will ensure the device cannot be used by an unauthorized user to take screen shots of the room in which the server resides.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Control Panel\Personalization\Prevent enabling lock screen camera

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `ControlPanelDisplay.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Impact:

If you enable this setting, users will no longer be able to enable or disable lock screen camera access in PC Settings, and the camera cannot be invoked on the lock screen.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Personalization:NoLockScreenCamera
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.1.1.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5111

Asset Manager

C	I	A
123	123	123

Ensure 'Prevent enabling lock screen slide show' is set to 'Enabled'

Rule

Ensure 'Prevent enabling lock screen slide show' is set to 'Enabled'.

Description

Disables the lock screen slide show settings in PC Settings and prevents a slide show from playing on the lock screen.

Rationale

Disabling the lock screen slide show extends the protection afforded by the lock screen to slide show contents. Turning off this feature will limit access to the information to a logged on user.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Administrative Templates\Control
Panel\Personalization\Prevent enabling lock screen slide show

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template ControlPanelDisplay.admx/adml that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Impact:

If you enable this setting, users will no longer be able to modify slide show settings in PC Settings, and no slide show will ever start.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Personalization:NoLockScreenSlideshow
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.1.1.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Regional and Language Options

This section contains recommendation settings for Regional and Language Options.

This Group Policy section is provided by the Group Policy template `Globalization.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-4681

Asset Manager



Ensure 'Allow Input Personalization' is set to 'Disabled'

Rule

Ensure 'Allow Input Personalization' is set to 'Disabled'.

Description

This policy enables the automatic learning component of input personalization that includes speech, inking, and typing. Automatic learning enables the collection of speech and handwriting patterns, typing history, contacts, and recent calendar information. It is required for the use of Cortana. Some of this collected information may be stored on the user's OneDrive, in the case of inking and typing; some of the information will be uploaded to Microsoft to personalize speech.

Rationale

If this setting is Enabled sensitive information could be stored in the cloud or sent to Microsoft.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Control Panel\Regional and Language Options\Allow Input Personalization

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `Globalization.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

Note #2: This setting was renamed to *Allow users to enable online speech recognition services* starting with the Windows 10 R1809 & Server 2019 Administrative Templates.

Impact:

Automatic learning of speech, inking, and typing stops and users cannot change its value via PC Settings.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\InputPersonalization:AllowInputPersonalization
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.1.2.2

[Based on Siemens Information Security Policy Framework Rule 07.1.2-01](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-06](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-07](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-08](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-11](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-16](#)

[Based on Siemens Information Security Policy Framework Rule 13.2.4-01](#)

[Based on Siemens Information Security Policy Framework Rule 13.2.4-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

LAPS

This section contains recommendations for configuring Microsoft Local Administrator Password Solution (LAPS).

This Group Policy section is provided by the Group Policy template `AdmPwd.admx/adml` that is included with LAPS.

BL968-0612

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure LAPS AdmPwd GPO Extension / CSE is installed (MS only)

Rule

Ensure LAPS AdmPwd GPO Extension / CSE is installed (MS only).

E01 - Exemption

This rule is not mandatory, if another solution (software solution or approved organizational process) is used to follow the Siemens rules for local Administrator passwords.

Description

In May 2015, Microsoft released the Local Administrator Password Solution (LAPS) tool, which is free and supported software that allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and Member Servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed.

The LAPS tool requires a small Active Directory Schema update in order to implement, as well as installation of a Group Policy Client Side Extension (CSE) on targeted computers. Please see the LAPS documentation for details.

LAPS supports Windows Vista or newer workstation OSes, and Server 2003 or newer server OSes. LAPS does not support standalone computers - they must be joined to a domain.

Rationale

Due to the difficulty in managing local Administrator passwords, many organizations choose to use the same password on all workstations and/or Member Servers when deploying them. This creates a serious attack surface security risk because if an attacker manages to compromise one system and learn the password to its local Administrator account, then they can leverage that account to instantly gain access to all other computers that also use that password for their local Administrator account.

I01 - Implementation Example

In order to utilize LAPS, a minor Active Directory Schema update is required, and a Group Policy Client Side Extension (CSE) must be installed on each managed computer. When LAPS is installed, the file AdmPwd.dll must be present in the following location and registered in Windows (the LAPS AdmPwd GPO Extension / CSE installation does this for you):

C:\Program Files\LAPS\CSE\AdmPwd.dll

Impact:

No impact. When installed and registered properly, AdmPwd.dll takes no action unless given appropriate GPO commands during Group Policy refresh. It is not a memory-resident agent or service.

In a disaster recovery scenario, where Active Directory is not available, the local Administrator password will not be retrievable and a local password reset using a tool (such as Microsoft's Disaster and Recovery Toolset (DaRT) Recovery Image) may be necessary.

If the GPO Extension is not installed, the LAPS rules listed below will not work:

- [BL968-4626](#) Ensure 'Do not allow password expiration time longer than required by policy' is set to 'Enabled' (MS only),
- [BL968-2851](#) Ensure 'Enable Local Admin Password Management' is set to 'Enabled' (MS only) ,
- [BL968-3176](#) Ensure 'Password Settings: Password Complexity' is set to 'Enabled: Large letters + small letters + numbers + special characters' (MS only),
- [BL968-5551](#) Ensure 'Password Settings: Password Length' is set to 'Enabled: 15 or more' (MS only),
- [BL968-5341](#) Ensure 'Password Settings: Password Age (Days)' is set to 'Enabled: 45 or fewer' (MS only).

C01 - Example Check

The LAPS AdmPwd GPO Extension / CSE can be verified to be installed by the presence of the following registry value:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\GPExtensions\{D76B9641-3288-4f75-942D-087DE603E3EA}:DllName
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.2.1

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4626

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Do not allow password expiration time longer than required by policy' is set to 'Enabled' (MS only)

Rule

Ensure 'Do not allow password expiration time longer than required by policy' is set to 'Enabled' (MS only).

E01 - Exemption

This rule is not mandatory, if another solution (software solution or approved organizational process) is used to follow the Siemens rules for local Administrator passwords.

Description

In May 2015, Microsoft released the Local Administrator Password Solution (LAPS) tool, which is free and supported software that allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and Member Servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed.

The LAPS tool requires a small Active Directory Schema update in order to implement, as well as installation of a Group Policy Client Side Extension (CSE) on targeted computers. Please see the LAPS documentation for details.

LAPS supports Windows Vista or newer workstation OSes, and Server 2003 or newer server OSes. LAPS does not support standalone computers - they must be joined to a domain.

Rationale

Due to the difficulty in managing local Administrator passwords, many organizations choose to use the same password on all workstations and/or Member Servers when deploying them. This creates a serious attack surface security risk because if an attacker manages to compromise one system and learn the password to its local Administrator account, then they can leverage that account to instantly gain access to all other computers that also use that password for their local Administrator account.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\LAPS\Do not allow password expiration time longer than required by policy

Note: This Group Policy path does not exist by default. An additional Group Policy template (AdmPwd.admx/adml) is required - it is included with [Microsoft Local Administrator Password Solution \(LAPS\)](#). Further details are described in Microsoft's "LAPS_OperationsGuide.docx".

Note: The rule [BL968-0612 Ensure LAPS AdmPwd GPO Extension / CSE is installed \(MS only\)](#) has to be implemented before this setting becomes effective.

Impact:

Planned password expiration longer than password age dictated by "Password Settings" policy is NOT allowed.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft Services\AdmPwd:PwdExpirationProtectionEnabled
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.2.2

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2851

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Enable Local Admin Password Management' is set to 'Enabled' (MS only)

Rule

Ensure 'Enable Local Admin Password Management' is set to 'Enabled' (MS only).

E01 - Exemption

This rule is not mandatory, if another solution (software solution or approved organizational process) is used to follow the Siemens rules for local Administrator passwords.

Description

In May 2015, Microsoft released the Local Administrator Password Solution (LAPS) tool, which is free and supported software that allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and Member Servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed.

The LAPS tool requires a small Active Directory Schema update in order to implement, as well as installation of a Group Policy Client Side Extension (CSE) on targeted computers. Please see the LAPS documentation for details.

LAPS supports Windows Vista or newer workstation OSes, and Server 2003 or newer server OSes. LAPS does not support standalone computers - they must be joined to a domain.

Rationale

Due to the difficulty in managing local Administrator passwords, many organizations choose to use the same password on all workstations and/or Member Servers when deploying them. This creates a serious attack surface security risk because if an attacker manages to compromise one system and learn the password to its local Administrator account, then they can leverage that account to instantly gain access to all other computers that also use that password for their local Administrator account.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\LAPS\Enable Local Admin Password Management

Note: This Group Policy path does not exist by default. An additional Group Policy template (AdmPwd.admx/adml) is required - it is included with [Microsoft Local Administrator Password Solution \(LAPS\)](#). Further details are described in Microsoft's "LAPS_OperationsGuide.docx".

Note: The rule [BL968-0612 Ensure LAPS AdmPwd GPO Extension / CSE is installed \(MS only\)](#) has to be implemented before this setting becomes effective.

Impact:

In a disaster recovery scenario, where Active Directory is not available, the local Administrator password will not be retrievable and a local password reset using a tool (such as Microsoft's Disaster and Recovery Toolset (DaRT) Recovery Image) may be necessary.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Services\AdmPwd:AdmPwdEnabled
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.2.3

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3176

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Password Settings: Password Complexity' is set to 'Enabled: Large letters + small letters + numbers + special characters' (MS only)

Rule

Ensure 'Password Settings: Password Complexity' is set to 'Enabled: Large letters + small letters + numbers + special characters' (MS only).

E01 - Exemption

This rule is not mandatory, if another solution (software solution or approved organizational process) is used to follow the Siemens rules for local Administrator passwords.

Description

In May 2015, Microsoft released the Local Administrator Password Solution (LAPS) tool, which is free and supported software that allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and Member Servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed.

The LAPS tool requires a small Active Directory Schema update in order to implement, as well as installation of a Group Policy Client Side Extension (CSE) on targeted computers. Please see the LAPS documentation for details.

LAPS supports Windows Vista or newer workstation OSes, and Server 2003 or newer server OSes. LAPS does not support standalone computers - they must be joined to a domain.

Rationale

Due to the difficulty in managing local Administrator passwords, many organizations choose to use the same password on all workstations and/or Member Servers when deploying them. This creates a serious attack surface security risk because if an attacker manages to compromise one system and learn the password to its local Administrator account, then they can leverage that account to instantly gain access to all other computers that also use that password for their local Administrator account.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`, and configure the `Password Complexity` option to `Large letters + small letters + numbers + special characters`:

`Computer Configuration\Policies\Administrative Templates\LAPS>Password Settings`

Note: This Group Policy path does not exist by default. An additional Group Policy template (`AdmPwd.admx/adml`) is required - it is included with Microsoft Local Administrator Password Solution (LAPS).

Note: The rule [BL968-0612 Ensure LAPS AdmPwd GPO Extension / CSE is installed \(MS only\)](#) has to be implemented before this setting becomes effective.

Impact:

LAPS-generated passwords will be required to contain large letters + small letters + numbers + special characters.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft Services\AdmPwd:PasswordComplexity
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.2.4

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5551

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Password Settings: Password Length' is set to 'Enabled: 15 or more' (MS only)

Rule

Ensure 'Password Settings: Password Length' is set to 'Enabled: 15 or more' (MS only).

E01 - Exemption

This rule is not mandatory, if another solution (software solution or approved organizational process) is used to follow the Siemens rules for local Administrator passwords.

Description

In May 2015, Microsoft released the Local Administrator Password Solution (LAPS) tool, which is free and supported software that allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and Member Servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed.

The LAPS tool requires a small Active Directory Schema update in order to implement, as well as installation of a Group Policy Client Side Extension (CSE) on targeted computers. Please see the LAPS documentation for details.

LAPS supports Windows Vista or newer workstation OSes, and Server 2003 or newer server OSes. LAPS does not support standalone computers - they must be joined to a domain.

Rationale

Due to the difficulty in managing local Administrator passwords, many organizations choose to use the same password on all workstations and/or Member Servers when deploying them. This creates a serious attack surface security risk because if an attacker manages to compromise one system and learn the password to its local Administrator account, then they can leverage that account to instantly gain access to all other computers that also use that password for their local Administrator account.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`, and configure the `Password Length` option to `15 or more`:

Computer Configuration\Policies\Administrative Templates\LAPS>Password Settings

Note: This Group Policy path does not exist by default. An additional Group Policy template (`AdmPwd.admx/adml`) is required - it is included with Microsoft Local Administrator Password Solution (LAPS).

Note: The rule [BL968-0612 Ensure LAPS AdmPwd GPO Extension / CSE is installed \(MS only\)](#) has to be implemented before this setting becomes effective.

Impact:

LAPS-generated passwords will be required to have a length of 15 characters (or more, if selected).

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft Services\AdmPwd:PasswordLength
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.2.5

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Rephrased exemption 01, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5341

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Password Settings: Password Age (Days)' is set to 'Enabled: 45 or fewer' (MS only)

Rule

Ensure 'Password Settings: Password Age (Days)' is set to 'Enabled: 45 or fewer' (MS only).

E01 - Exemption

This rule is not mandatory, if another solution (software solution or approved organizational process) is used to follow the Siemens rules for local Administrator passwords.

Description

In May 2015, Microsoft released the Local Administrator Password Solution (LAPS) tool, which is free and supported software that allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and Member Servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed.

The LAPS tool requires a small Active Directory Schema update in order to implement, as well as installation of a Group Policy Client Side Extension (CSE) on targeted computers. Please see the LAPS documentation for details.

LAPS supports Windows Vista or newer workstation OSes, and Server 2003 or newer server OSes. LAPS does not support standalone computers - they must be joined to a domain.

Rationale

Due to the difficulty in managing local Administrator passwords, many organizations choose to use the same password on all workstations and/or Member Servers when deploying them. This creates a serious attack surface security risk because if an attacker manages to compromise one system and learn the password to its local Administrator account, then they can leverage that account to instantly gain access to all other computers that also use that password for their local Administrator account.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`, and configure the `Password Age (Days)` option to `45 or fewer`:

Computer Configuration\Policies\Administrative Templates\LAPS>Password Settings

Note: This Group Policy path does not exist by default. An additional Group Policy template (`AdmPwd.admx/adml`) is required - it is included with Microsoft Local Administrator Password Solution (LAPS).

Note: The rule [BL968-0612 Ensure LAPS AdmPwd GPO Extension / CSE is installed \(MS only\)](#) has to be implemented before this setting becomes effective.

Impact:

LAPS-generated passwords will be required to have a maximum age of 45 days (or fewer, if selected).

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft Services\AdmPwd>PasswordAgeDays
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.2.6

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Rephrased exemption 01, added Check section. Aligned value with password policy. This rule is relaxed from the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

MS Security Guide

This section contains settings for configuring additional settings from the MS Security Guide.

This Group Policy section is provided by the Group Policy template `SecGuide.admx/adml`. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

BL968-1191

Asset Manager

C	I	A
123	123	123

Ensure 'Apply UAC restrictions to local accounts on network logons' is set to 'Enabled' (MS only)

Rule Ensure 'Apply UAC restrictions to local accounts on network logons' is set to 'Enabled' (MS only).

Description

This setting controls whether local accounts can be used for remote administration via network logon (e.g., NET USE, connecting to C\$, etc.). Local accounts are at high risk for credential theft when the same account and password is configured on multiple systems. Enabling this policy significantly reduces that risk.

Enabled: Applies UAC token-filtering to local accounts on network logons. Membership in powerful group such as Administrators is disabled and powerful privileges are removed from the resulting access token. This configures the `LocalAccountTokenFilterPolicy` registry value to 0. This is the default behavior for Windows.

Disabled: Allows local accounts to have full administrative rights when authenticating via network logon, by configuring the `LocalAccountTokenFilterPolicy` registry value to 1.

For more information about local accounts and credential theft, review the "[Mitigating Pass-the-Hash \(PtH\) Attacks and Other Credential Theft Techniques](#)" documents.

For more information about `LocalAccountTokenFilterPolicy`, see Microsoft Knowledge Base article 951016: [Description of User Account Control and remote restrictions in Windows Vista](#).

Rationale

Local accounts are at high risk for credential theft when the same account and password is configured on multiple systems. Ensuring this policy is Enabled significantly reduces that risk.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\MS Security Guide\Apply UAC restrictions to local accounts on network logons

Note: This Group Policy path does not exist by default. An additional Group Policy template (SecGuide.admx/adml) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:LocalAccountTokenFilterPolicy
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.3.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4843

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Configure SMB v1 client driver' is set to 'Enabled: Disable driver (recommended)'

Rule

Ensure 'Configure SMB v1 client driver' is set to 'Enabled: Disable driver (recommended)'.

Description

This setting configures the start type for the Server Message Block version 1 (SMBv1) client driver service (`MRxSmb10`), which is recommended to be disabled.

Note: Do not, *under any circumstances*, configure this overall setting as `Disabled`, as doing so will delete the underlying registry entry altogether, which will cause serious problems.

Rationale

Since September 2016, Microsoft has strongly encouraged that SMBv1 be disabled and no longer used on modern networks, as it is a 30-year-old design that is much more vulnerable to attacks than much newer designs such as SMBv2 and SMBv3.

More information on this can be found at the following links:

[Stop using SMB1 | Storage at Microsoft](#)

[Disable SMB v1 in Managed Environments with Group Policy – "Stay Safe" Cyber Security Blog](#)

[Disabling SMBv1 through Group Policy – Microsoft Security Guidance blog](#)

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled: Disable driver (recommended)` :

Computer Configuration\Policies\Administrative Templates\MS Security Guide\Configure SMB v1 client driver

Note: This Group Policy path does not exist by default. An additional Group Policy template (`SecGuide.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

Some legacy OSes (e.g., Windows XP, Server 2003 or older), applications and appliances may no longer be able to communicate with the system once SMBv1 is disabled. We recommend careful testing be performed to determine the impact prior to configuring this as a widespread control, and where possible, remediate any incompatibilities found with the vendor of the incompatible system. Microsoft is also maintaining a thorough (although not comprehensive) list of known SMBv1 incompatibilities at this link: [SMB1 Product Clearinghouse | Storage at Microsoft](#).

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\mrxsmb10:Start
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.3.2

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-4844

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Configure SMB v1 server' is set to 'Disabled'

Rule

Ensure 'Configure SMB v1 server' is set to 'Disabled'.

Description

This setting configures the server-side processing of the Server Message Block version 1 (SMBv1) protocol.

Rationale

Since September 2016, Microsoft has strongly encouraged that SMBv1 be disabled and no longer used on modern networks, as it is a 30-year-old design that is much more vulnerable to attacks than newer designs such as SMBv2 and SMBv3.

More information on this can be found at the following links:

[Stop using SMB1 | Storage at Microsoft](#)

[Disable SMB v1 in Managed Environments with Group Policy – “Stay Safe” Cyber Security Blog](#)

[Disabling SMBv1 through Group Policy – Microsoft Security Guidance blog](#)

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\MS Security
Guide\Configure SMB v1 server

Note: This Group Policy path does not exist by default. An additional Group Policy template (`SecGuide.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

Some legacy OSes (e.g., Windows XP, Server 2003 or older), applications and appliances may no longer be able to communicate with the system once SMBv1 is disabled. We recommend careful testing be performed to determine the impact prior to configuring this as a widespread control, and where possible, remediate any incompatibilities found with the vendor of the incompatible system. Microsoft is also maintaining a thorough (although not comprehensive) list of known SMBv1 incompatibilities at this link: [SMB1 Product Clearinghouse | Storage at Microsoft](#)

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters:SMB1
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.3.3

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-0063

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Enable Structured Exception Handling Overwrite Protection (SEHOP)' is set to 'Enabled'

Rule

Ensure 'Enable Structured Exception Handling Overwrite Protection (SEHOP)' is set to 'Enabled'.

Description

Windows includes support for Structured Exception Handling Overwrite Protection (SEHOP). We recommend enabling this feature to improve the security profile of the computer.

Rationale

This feature is designed to block exploits that use the Structured Exception Handler (SEH) overwrite technique. This protection mechanism is provided at run-time. Therefore, it helps protect applications regardless of whether they have been compiled with the latest improvements, such as the /SAFESEH option.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\MS Security
Guide\Enable Structured Exception Handling Overwrite Protection (SEHOP)

Note: This Group Policy path does not exist by default. An additional Group Policy template (`SecGuide.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

More information is available at [MSKB 956607: How to enable Structured Exception Handling Overwrite Protection \(SEHOP\) in Windows operating systems](#).

Impact:

This is the default value.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Session  
Manager\kernel:DisableExceptionChainValidation
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.3.4

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4845

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Extended Protection for LDAP Authentication (Domain Controllers only)' is set to 'Enabled: Enabled, always (recommended)' (DC Only)

Rule Ensure 'Extended Protection for LDAP Authentication (Domain Controllers only)' is set to 'Enabled: Enabled, always (recommended)' (DC Only).

Description

This setting controls LDAP authentication over SSL/TLS to help make it more secure.

Note: All LDAP clients must have the [CVE-2017-8563](#) security update to be compatible with Domain Controllers that have this setting enabled.

More information on this setting is available at: [Use the LdapEnforceChannelBinding registry entry to make LDAP authentication over SSL-TLS more secure.](#)

Rationale

Configuring the LdapEnforceChannelBinding registry value can help to increase protection against "man-in-the-middle" attacks.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled: Enabled, always (recommended)** :

Computer Configuration\Policies\Administrative Templates\MS Security Guide\Extended Protection for LDAP Authentication (Domain Controllers only)

Note: This Group Policy path does not exist by default. An additional Group Policy template (SecGuide.admx/adml) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

All LDAP clients must provide channel binding information. The server rejects authentication requests from clients that do not do so. Clients must have the [CVE-2017-8563](#) security update to support this feature, and may have compatibility issues with Domain Controllers without the security update. This may also mean that LDAP authentication requests over SSL/TLS that previously worked may stop working until the security update is installed.

When first deploying this setting, you may **initially** want to only set it to the alternate setting of Enabled: Enabled, when supported (instead of Enabled: Enabled, always (recommended)) on all Domain Controllers. This alternate, **interim** setting enables support for LDAP client channel binding but does not *require* it. Then set one DC that is not currently being targeted by LDAP clients to Enabled: Enabled, always (recommended) , and test each of the critical LDAP clients against that DC (and remediating as necessary), before deploying Enabled: Enabled, always (recommended) to the rest of the DCs.

Older OSes such as Windows XP, Windows Server 2003, Windows Vista and Windows Server 2008 (non-R2), will first require patches for [Microsoft Security Advisory 973811](#) , as well as all associated fixes, in order to be compatible with domain controllers that have this setting deployed.

More information on this setting is available at: [Use the LdapEnforceChannelBinding registry entry to make LDAP authentication over SSL-TLS more secure.](#)

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\NTDS\Parameters:LdapEnforceChannelBinding
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.3.5

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-5741

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'NetBT NodeType configuration' is set to 'Enabled: P-node (recommended)'

Rule

Ensure 'NetBT NodeType configuration' is set to 'Enabled: P-node (recommended)'.

Description

This setting determines which method NetBIOS over TCP/IP (NetBT) uses to register and resolve names. The available methods are:

- The B-node (broadcast) method only uses broadcasts.
- The P-node (point-to-point) method only uses name queries to a name server (WINS).
- The M-node (mixed) method broadcasts first, then queries a name server (WINS) if broadcast failed.
- The H-node (hybrid) method queries a name server (WINS) first, then broadcasts if the query failed.

Note: Resolution through LMHOSTS or DNS follows these methods. If the `NodeType` registry value is present, it overrides any `DhcpNodeType` registry value. If neither `NodeType` nor `DhcpNodeType` is present, the computer uses B-node (broadcast) if there are no WINS servers configured for the network, or H-node (hybrid) if there is at least one WINS server configured.

Rationale

In order to help mitigate the risk of NetBIOS Name Service (NBT-NS) poisoning attacks, setting the node type to P-node (point-to-point) will prevent the system from sending out NetBIOS broadcasts.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled: P-node (recommended)` :

Computer Configuration\Policies\Administrative Templates\MS Security Guide\NetBT NodeType configuration

Note: This change does not take effect until the computer has been restarted.

Note #2: This Group Policy path does not exist by default. An additional Group Policy template (`SecGuide.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Please note that this setting is **only** available in the *Security baseline (FINAL) for Windows 10 v1903 and Windows Server v1903* (or newer) release of `SecGuide.admx/adml` , so if you previously downloaded this template, you may need to update it from a newer Microsoft baseline to get this new *NetBT NodeType configuration* setting.

Impact:

NetBIOS name resolution queries will require a defined and available WINS server for external NetBIOS name resolution. If a WINS server is not defined or not reachable, and the desired hostname is not defined in the local cache, local LMHOSTS or HOSTS files, NetBIOS name resolution will fail.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\NetBT\Parameters:NodeType
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.3.6

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Removed Implementation 02, added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4076

Asset Manager

C	I	A
123	123	123

Ensure 'WDigest Authentication' is set to 'Disabled'

Rule

Ensure 'WDigest Authentication' is set to 'Disabled'.

Description

When WDigest authentication is enabled, Lsass.exe retains a copy of the user's plaintext password in memory, where it can be at risk of theft. If this setting is not configured, WDigest authentication is disabled in Windows 8.1 and in Windows Server 2012 R2; it is enabled by default in earlier versions of Windows and Windows Server.

For more information about local accounts and credential theft, review the " [Mitigating Pass-the-Hash \(PtH\) Attacks and Other Credential Theft Techniques](#) " documents.

For more information about `UseLogonCredential` , see Microsoft Knowledge Base article 2871997: [Microsoft Security Advisory Update to improve credentials protection and management May 13, 2014](#) .

Rationale

Preventing the plaintext storage of credentials in memory may reduce opportunity for credential theft.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled` :

Computer Configuration\Policies\Administrative Templates\MS Security
Guide\WDigest Authentication (disabling may require KB2871997)

Note: This Group Policy path does not exist by default. An additional Group Policy template (`SecGuide.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

None - this is also the default configuration for Server 2012 R2 and newer.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest:UseLogonCredential
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.3.7

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

MSS (Legacy)

This section contains recommendations for the Microsoft Solutions for Security (MSS) settings.

This Group Policy section is provided by the Group Policy template `MSS-legacy.admx/adml`. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

BL968-4171

Asset Manager

C	I	A
123	123	123

Ensure 'MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)' is set to 'Disabled'

Rule Ensure 'MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)' is set to 'Disabled'.

Description

This setting is separate from the Welcome screen feature in Windows XP and Windows Vista; if that feature is disabled, this setting is not disabled. If you configure a computer for automatic logon, anyone who can physically gain access to the computer can also gain access to everything that is on the computer, including any network or networks to which the computer is connected. Also, if you enable automatic logon, the password is stored in the registry in plaintext, and the specific registry key that stores this value is remotely readable by the Authenticated Users group.

For additional information, see Microsoft Knowledge Base article 324737: [How to turn on automatic logon in Windows](#).

Rationale

If you configure a computer for automatic logon, anyone who can physically gain access to the computer can also gain access to everything that is on the computer, including any network or networks that the computer is connected to. Also, if you enable automatic logon, the password is stored in the registry in plaintext. The specific registry key that stores this setting is remotely readable by the Authenticated Users group. As a result, this entry is appropriate only if the computer is physically secured and if you ensure that untrusted users cannot remotely see the registry.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\MSS (Legacy)\MSS:
(AutoAdminLogon) Enable Automatic Logon (not recommended)

Note: This Group Policy path does not exist by default. An additional Group Policy template (`MSS-legacy.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon:AutoAdminLogon
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.4.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5706

Asset Manager

C	I	A
123	123	123

Ensure 'MSS: (DisableIPSourceRouting IPv6) IP source routing protection level (protects against packet spoofing)' is set to 'Enabled: Highest protection, source routing is completely disabled'

Rule Ensure 'MSS: (DisableIPSourceRouting IPv6) IP source routing protection level (protects against packet spoofing)' is set to 'Enabled: Highest protection, source routing is completely disabled'.

Description

IP source routing is a mechanism that allows the sender to determine the IP route that a datagram should follow through the network.

Rationale

An attacker could use source routed packets to obscure their identity and location. Source routing allows a computer that sends a packet to specify the route that the packet takes.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled: Highest protection, source routing is completely disabled**:

Computer Configuration\Policies\Administrative Templates\MSS (Legacy)\MSS: (DisableIPSourceRouting IPv6) IP source routing protection level (protects against packet spoofing)

Note: This Group Policy path does not exist by default. An additional Group Policy template (`MSS-legacy.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

All incoming source routed packets will be dropped.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip6\Parameters:DisableIPSourceRouting
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.4.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2131

Asset Manager

C	I	A
123	123	123

Ensure 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' is set to 'Enabled: Highest protection, source routing is completely disabled'

Rule

Ensure 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' is set to 'Enabled: Highest protection, source routing is completely disabled'.

Description

IP source routing is a mechanism that allows the sender to determine the IP route that a datagram should take through the network. It is recommended to configure this setting to Not Defined for enterprise environments and to Highest Protection for high security environments to completely disable source routing.

Rationale

An attacker could use source routed packets to obscure their identity and location. Source routing allows a computer that sends a packet to specify the route that the packet takes.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled: Highest protection, source routing is completely disabled:

Computer Configuration\Policies\Administrative Templates\MSS (Legacy)\MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)

Note: This Group Policy path does not exist by default. An additional Group Policy template (`MSS-legacy.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

All incoming source routed packets will be dropped.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters:DisableIPSourceRouting
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.4.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3251

Asset Manager

C	I	A
123	123	123

Ensure 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' is set to 'Disabled'

Rule Ensure 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' is set to 'Disabled'.

Description

Internet Control Message Protocol (ICMP) redirects cause the IPv4 stack to plumb host routes. These routes override the Open Shortest Path First (OSPF) generated routes.

Rationale

This behavior is expected. The problem is that the 10 minute time-out period for the ICMP redirect-plumbed routes, temporarily creates a network situation in which traffic will no longer be routed properly for the affected host. Ignoring such ICMP redirects will limit the system's exposure to attacks that will impact its ability to participate on the network.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Administrative Templates\MSS (Legacy)\MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes

Note: This Group Policy path does not exist by default. An additional Group Policy template (MSS-legacy.admx/adml) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

When Routing and Remote Access Service (RRAS) is configured as an autonomous system boundary router (ASBR), it does not correctly import connected interface subnet routes. Instead, this router injects host routes into the OSPF routes. However, the OSPF router cannot be used as an ASBR router, and when connected interface subnet routes are imported into OSPF the result is confusing routing tables with strange routing paths.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters:EnableICMPRedirect
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.4.4

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1456

Asset Manager

EVAL until 2022-02-28

C	I	A
3	3	

Ensure 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds' is set to 'Enabled: 300,000 or 5 minutes (recommended)'

Rule

Ensure 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds' is set to 'Enabled: 300,000 or 5 minutes (recommended)'.

Description

This value controls how often TCP attempts to verify that an idle connection is still intact by sending a keep-alive packet. If the remote computer is still reachable, it acknowledges the keep-alive packet.

Rationale

An attacker who is able to connect to network applications could establish numerous connections to cause a denial of service (DoS) condition.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled: 300,000 or 5 minutes (recommended)` :

Computer Configuration\Policies\Administrative Templates\MSS (Legacy)\MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds

Note: This Group Policy path does not exist by default. An additional Group Policy template (`MSS-legacy.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

Keep-alive packets are not sent by default by Windows. However, some applications may configure the TCP stack flag that requests keep-alive packets. For such configurations, you can lower this value from the default setting of two hours to five minutes to disconnect inactive sessions more quickly.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters:KeepAliveTime
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.4.5

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Removed exemption 01, added Check section. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4847

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers' is set to 'Enabled'

Rule

Ensure 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers' is set to 'Enabled'.

Description

NetBIOS over TCP/IP is a network protocol that among other things provides a way to easily resolve NetBIOS names that are registered on Windows-based systems to the IP addresses that are configured on those systems. This setting determines whether the computer releases its NetBIOS name when it receives a name-release request.

Rationale

The NetBT protocol is designed not to use authentication, and is therefore vulnerable to spoofing. Spoofing makes a transmission appear to come from a user other than the user who performed the action. A malicious user could exploit the unauthenticated nature of the protocol to send a name-conflict datagram to a target computer, which would cause the computer to relinquish its name and not respond to queries.

An attacker could send a request over the network and query a computer to release its NetBIOS name. As with any change that could affect applications, it is recommended that you test this change in a non-production environment before you change the production environment.

The result of such an attack could be to cause intermittent connectivity issues on the target computer, or even to prevent the use of Network Neighborhood, domain logons, the NET SEND command, or additional NetBIOS name resolution.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Administrative Templates\MSS (Legacy)\MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers

Note: This Group Policy path does not exist by default. An additional Group Policy template (`MSS-legacy.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\NetBT\Parameters:NoNameReleaseOnDemand
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.4.6

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-1346

Asset Manager

C	I	A
3	3	

Ensure 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)' is set to 'Disabled'

Rule Ensure 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)' is set to 'Disabled'.

Description

This setting is used to enable or disable the Internet Router Discovery Protocol (IRDP), which allows the system to detect and configure default gateway addresses automatically as described in RFC 1256 on a per-interface basis.

Rationale

An attacker who has gained control of a computer on the same network segment could configure a computer on the network to impersonate a router. Other computers with IRDP enabled would then attempt to route their traffic through the already compromised computer.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled` :

Computer Configuration\Policies\Administrative Templates\MSS (Legacy)\MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)

Note: This Group Policy path does not exist by default. An additional Group Policy template (`MSS-legacy.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

Windows will not automatically detect and configure default gateway addresses on the computer.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters:PerformRouterDiscovery
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.4.7

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2496

Asset Manager

C	I	A
123	123	123

Ensure 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)' is set to 'Enabled'

Rule

Ensure 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)' is set to 'Enabled'.

Description

The DLL search order can be configured to search for DLLs that are requested by running processes in one of two ways:

- Search folders specified in the system path first, and then search the current working folder.
- Search current working folder first, and then search the folders specified in the system path.

When enabled, the registry value is set to 1. With a setting of 1, the system first searches the folders that are specified in the system path and then searches the current working folder. When disabled the registry value is set to 0 and the system first searches the current working folder and then searches the folders that are specified in the system path.

Applications will be forced to search for DLLs in the system path first. For applications that require unique versions of these DLLs that are included with the application, this entry could cause performance or stability problems.

Note: More information on how Safe DLL search mode works is available at this link: [Dynamic-Link Library Search Order - Windows applications | Microsoft Docs](#).

Rationale

If a user unknowingly executes hostile code that was packaged with additional files that include modified versions of system DLLs, the hostile code could load its own versions of those DLLs and potentially increase the type and degree of damage the code can render.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\MSS (Legacy)\MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)

Note: This Group Policy path does not exist by default. An additional Group Policy template (`MSS-legacy.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Session Manager:SafeDllSearchMode
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.4.8

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4846

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended)' is set to 'Enabled: 5 or fewer seconds'

Rule

Ensure 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended)' is set to 'Enabled: 5 or fewer seconds'.

Description

Windows includes a grace period between when the screen saver is launched and when the console is actually locked automatically when screen saver locking is enabled.

Rationale

The default grace period that is allowed for user movement before the screen saver lock takes effect is five seconds. If you leave the default grace period configuration, your computer is vulnerable to a potential attack from someone who could approach the console and attempt to log on to the computer before the lock takes effect. An entry to the registry can be made to adjust the length of the grace period.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled: 5 or fewer seconds`:

```
Computer Configuration\Policies\Administrative Templates\MSS (Legacy)\MSS:  
(ScreenSaverGracePeriod) The time in seconds before the screen saver grace  
period expires (0 recommended)
```

Note: This Group Policy path does not exist by default. An additional Group Policy template (`MSS-legacy.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

Users will have to enter their passwords to resume their console sessions as soon as the grace period ends after screen saver activation.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon:ScreenSaverGracePeriod
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.4.9

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-2498

Asset Manager

C	I	A
123	123	123

Ensure 'MSS: (TcpMaxDataRetransmissions IPv6) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3'

Rule

Ensure 'MSS: (TcpMaxDataRetransmissions IPv6) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3'.

Description

This setting controls the number of times that TCP retransmits an individual data segment (non-connect segment) before the connection is aborted. The retransmission time-out is doubled with each successive retransmission on a connection. It is reset when responses resume. The base time-out value is dynamically determined by the measured round-trip time on the connection.

Rationale

A malicious user could exhaust a target computer's resources if it never sent any acknowledgment messages for data that was transmitted by the target computer.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled: 3`:

Computer Configuration\Policies\Administrative Templates\MSS (Legacy)\MSS: (TcpMaxDataRetransmissions IPv6) How many times unacknowledged data is retransmitted

Note: This Group Policy path does not exist by default. An additional Group Policy template (`MSS-legacy.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

TCP starts a retransmission timer when each outbound segment is passed to the IP. If no acknowledgment is received for the data in a given segment before the timer expires, then the segment is retransmitted up to three times.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\TCPIP6\Parameters:TcpMaxDataRetransmissions
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.4.10

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2497

Asset Manager

C	I	A
123	123	123

Ensure 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3'

Rule

Ensure 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3'.

Description

This setting controls the number of times that TCP retransmits an individual data segment (non-connect segment) before the connection is aborted. The retransmission time-out is doubled with each successive retransmission on a connection. It is reset when responses resume. The base time-out value is dynamically determined by the measured round-trip time on the connection.

Rationale

A malicious user could exhaust a target computer's resources if it never sent any acknowledgment messages for data that was transmitted by the target computer.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled: 3**:

Computer Configuration\Policies\Administrative Templates\MSS (Legacy)\MSS:
(TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted

Note: This Group Policy path does not exist by default. An additional Group Policy template (`MSS-legacy.admx/adml`) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

TCP starts a retransmission timer when each outbound segment is passed to the IP. If no acknowledgment is received for the data in a given segment before the timer expires, then the segment is retransmitted up to three times.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters:TcpMaxDataRetransmissions
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.4.11

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4848

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' is set to 'Enabled: 90% or less'

Rule

Ensure 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' is set to 'Enabled: 90% or less'.

Description

This setting can generate a security audit in the Security event log when the log reaches a user-defined threshold.

Note: If log settings are configured to Overwrite events as needed or Overwrite events older than x days, this event will not be generated.

Rationale

If the Security log reaches 90 percent of its capacity and the computer has not been configured to overwrite events as needed, more recent events will not be written to the log. If the log reaches its capacity and the computer has been configured to shut down when it can no longer record events to the Security log, the computer will shut down and will no longer be available to provide network services.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled: 90% or less :

Computer Configuration\Policies\Administrative Templates\MSS (Legacy)\MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning

Note: This Group Policy path does not exist by default. An additional Group Policy template (MSS-legacy.admx/adml) is required. This template is part of the *Microsoft Security Compliance Toolkit*, which is available from Microsoft at [this link](#).

Impact:

An audit event will be generated when the Security log reaches the 90% percent full threshold (or whatever lower value may be set) unless the log is configured to overwrite events as needed.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Eventlog\Security:WarningLevel
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.4.12

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Network

This section contains recommendations for network settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

DNS Client

This section contains recommendations related to DNS Client.

This Group Policy section is provided by the Group Policy template `DnsClient.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-1586

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off multicast name resolution' is set to 'Enabled'

Rule

Ensure 'Turn off multicast name resolution' is set to 'Enabled'.

Description

LLMNR is a secondary name resolution protocol. With LLMNR, queries are sent using multicast over a local network link on a single subnet from a client computer to another client computer on the same subnet that also has LLMNR enabled. LLMNR does not require a DNS server or DNS client configuration, and provides name resolution in scenarios in which conventional DNS name resolution is not possible.

Rationale

An attacker can listen on a network for these LLMNR (UDP/5355) or NBT-NS (UDP/137) broadcasts and respond to them, tricking the host into thinking that it knows the location of the requested system.

Note: To completely mitigate local name resolution poisoning, in addition to this setting, the properties of each installed NIC should also be set to `Disable NetBIOS over TCP/IP` (on the WINS tab in the NIC properties). Unfortunately, there is no global setting to achieve this that automatically applies to all NICs - it is a per-NIC setting that varies with different NIC hardware installations.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

`Computer Configuration\Policies\Administrative Templates\Network\DNS Client\Turn off multicast name resolution`

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `DnsClient.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

In the event DNS is unavailable a system will be unable to request it from other systems on the same subnet.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\DNSClient:EnableMulticast
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.4.1

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Fonts

This section contains recommendations related to Fonts.

This Group Policy section is provided by the Group Policy template `GroupPolicy.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

BL968-5046

Asset Manager



Ensure 'Enable Font Providers' is set to 'Disabled'

Rule

Ensure 'Enable Font Providers' is set to 'Disabled'.

Description

This policy setting determines whether Windows is allowed to download fonts and font catalog data from an online font provider.

Rationale

In an enterprise managed environment, the IT department should be managing the changes to the system configuration, to ensure all changes are tested and approved.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Network\Fonts\Enable Font Providers

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `GroupPolicy.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows will not connect to an online font provider and will only enumerate locally-installed fonts.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:EnableFontProviders
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.5.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Lanman Workstation

This section contains recommendations related to Lanman Workstation.

This Group Policy section is provided by the Group Policy template `LanmanWorkstation.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

BL968-4466

Asset Manager



Ensure 'Enable insecure guest logons' is set to 'Disabled'

Rule

Ensure 'Enable insecure guest logons' is set to 'Disabled'.

Description

This policy setting determines if the SMB client will allow insecure guest logons to an SMB server.

Rationale

Insecure guest logons are used by file servers to allow unauthenticated access to shared folders.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Network\Lanman Workstation\Enable insecure guest logons

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `LanmanWorkstation.admx/adml` that is included with the Microsoft Windows 10 Release 1511 Administrative Templates (or newer).

Impact:

The SMB client will reject insecure guest logons. This was not originally the default behavior in older versions of Windows, but Microsoft changed the default behavior starting with Windows Server 2016 R1709: [Guest access in SMB2 disabled by default in Windows 10 and Windows Server 2016](#).

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LanmanWorkstation:AllowInsecureGuestAuth
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.8.1

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Link-Layer Topology Discovery

This section contains recommendations for Link-Layer Topology Discovery settings.

This Group Policy section is provided by the Group Policy template `LinkLayerTopologyDiscovery.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-1071

Asset Manager

C	I	A
123	123	123

Ensure 'Turn on Mapper I/O (LLTDIO) driver' is set to 'Disabled'

Rule Ensure 'Turn on Mapper I/O (LLTDIO) driver' is set to 'Disabled'.

Description

This policy setting changes the operational behavior of the Mapper I/O network protocol driver.

LLTDIO allows a computer to discover the topology of a network it is connected to. It also allows a computer to initiate Quality-of-Service requests such as bandwidth estimation and network health analysis.

Rationale

To help protect from potentially discovering and connecting to unauthorized devices, this setting should be disabled to prevent responding to network traffic for network topology discovery.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Network\Link-Layer Topology Discovery\Turn on Mapper I/O (LLTDIO) driver

Note: This Group Policy path is provided by the Group Policy template `LinkLayerTopologyDiscovery.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry locations:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:AllowLLTDIOOnDomain  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:AllowLLTDIOOnPublicNet  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:EnableLLTDIO  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:ProhibitLLTDIOOnPrivateNet
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.9.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2246

Asset Manager

C	I	A
123	123	123

Ensure 'Turn on Responder (RSPNDR) driver' is set to 'Disabled'

Rule

Ensure 'Turn on Responder (RSPNDR) driver' is set to 'Disabled'.

Description

This policy setting changes the operational behavior of the Responder network protocol driver.

The Responder allows a computer to participate in Link Layer Topology Discovery requests so that it can be discovered and located on the network. It also allows a computer to participate in Quality-of-Service activities such as bandwidth estimation and network health analysis.

Rationale

To help protect from potentially discovering and connecting to unauthorized devices, this setting should be disabled to prevent responding to network traffic for network topology discovery.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Administrative Templates\Network\Link-Layer
Topology Discovery\Turn on Responder (RSPNDR) driver

Note: This Group Policy path is provided by the Group Policy template
LinkLayerTopologyDiscovery.admx/adml that is included with all versions of the Microsoft
Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry locations:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:AllowRspndrOnDomain  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:AllowRspndrOnPublicNet  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:EnableRspndr  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:ProhibitRspndrOnPrivateNet
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.9.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Microsoft Peer-to-Peer Networking Services

This section contains recommendations for Microsoft Peer-to-Peer Networking Services settings.

This Group Policy section is provided by the Group Policy template `P2P-pnrp.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-5956

Asset Manager



Ensure 'Turn off Microsoft Peer-to-Peer Networking Services' is set to 'Enabled'

Rule

Ensure 'Turn off Microsoft Peer-to-Peer Networking Services' is set to 'Enabled'.

Description

The Peer Name Resolution Protocol (PNRP) allows for distributed resolution of a name to an IPv6 address and port number. The protocol operates in the context of *clouds*. A cloud is a set of peer computers that can communicate with each other by using the same IPv6 scope.

Peer-to-Peer protocols allow for applications in the areas of RTC, collaboration, content distribution and distributed processing.

Rationale

This setting enhances the security of the environment and reduces the overall risk exposure related to peer-to-peer networking.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Network\Microsoft Peer-to-Peer Networking Services\Turn off Microsoft Peer-to-Peer Networking Services

Note: This Group Policy path is provided by the Group Policy template `P2P-pnrp.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Microsoft Peer-to-Peer Networking Services are turned off in their entirety, and all applications dependent on them will stop working.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Peernet:Disabled
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.10.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Network Connections

This section contains recommendations for Network Connections settings.

This Group Policy section is provided by the Group Policy template `NetworkConnections.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-5966

Asset Manager



Ensure 'Prohibit installation and configuration of Network Bridge on your DNS domain network' is set to 'Enabled'

Rule Ensure 'Prohibit installation and configuration of Network Bridge on your DNS domain network' is set to 'Enabled'.

Description

You can use this procedure to controls user's ability to install and configure a Network Bridge.

Rationale

The Network Bridge setting, if enabled, allows users to create a Layer 2 Media Access Control (MAC) bridge, enabling them to connect two or more physical network segments together. A Network Bridge thus allows a computer that has connections to two different networks to share data between those networks.

In an enterprise managed environment, where there is a need to control network traffic to only authorized paths, allowing users to create a Network Bridge increases the risk and attack surface from the bridged network.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Administrative Templates\Network\Network Connections\Prohibit installation and configuration of Network Bridge on your DNS domain network

Note: This Group Policy path is provided by the Group Policy template `NetworkConnections.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Users cannot create or configure a Network Bridge.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Network Connections:NC_AllowNetBridge_NLA
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.11.2

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1561

Asset Manager

C	I	A
123	123	123

Ensure 'Prohibit use of Internet Connection Sharing on your DNS domain network' is set to 'Enabled'

Rule Ensure 'Prohibit use of Internet Connection Sharing on your DNS domain network' is set to 'Enabled'.

Description

Although this "legacy" setting traditionally applied to the use of Internet Connection Sharing (ICS) in Windows 2000, Windows XP & Server 2003, this setting now freshly applies to the Mobile Hotspot feature in Windows 10 & Server 2016.

Rationale

Non-administrators should not be able to turn on the Mobile Hotspot feature and open their Internet connectivity up to nearby mobile devices.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Network\Network Connections\Prohibit use of Internet Connection Sharing on your DNS domain network

Note: This Group Policy path is provided by the Group Policy template `NetworkConnections.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Mobile Hotspot cannot be enabled or configured by Administrators and non-Administrators alike.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Network Connections:NC_ShowSharedAccessUI
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.11.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5491

Asset Manager

C	I	A
123	123	123

Ensure 'Require domain users to elevate when setting a network's location' is set to 'Enabled'

Rule

Ensure 'Require domain users to elevate when setting a network's location' is set to 'Enabled'.

Description

This policy setting determines whether to require domain users to elevate when setting a network's location.

Rationale

Allowing regular users to set a network location increases the risk and attack surface.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Administrative Templates\Network\Network Connections\Require domain users to elevate when setting a network's location

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `NetworkConnections.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

Impact:

Domain users must elevate when setting a network's location.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Network Connections:NC_StdDomainUserSetLocation
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.11.4

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Network Provider

This section contains recommendations for Network Provider settings.

This Group Policy section is provided by the Group Policy template `NetworkProvider.admx/adml` that is included with the [MS15-011](#) / [MSKB 3000483](#) security update and the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

BL968-1186

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Hardened UNC Paths' is set to 'Enabled, with "Require Mutual Authentication" and "Require Integrity" set for all NETLOGON and SYSVOL (DC only) shares'

Rule Ensure 'Hardened UNC Paths' is set to 'Enabled, with "Require Mutual Authentication" and "Require Integrity" set for all NETLOGON and SYSVOL (DC only) shares'.

Description

This policy setting configures secure access to UNC paths.

The following three settings are available:

- `RequireMutualAuthentication=<0|1>` - When this property is set to 1, the selected UNC provider requires that the UNC provider can authenticate the identity of the remote server (in addition to the server's verification of the client's identity) in order to block spoofing attacks.
- `RequireIntegrity=<0|1>` - When this property is set to 1, MUP and the selected UNC provider must use integrity checks in order detect when third parties manipulate requests or responses while in transit between the client and server in order to block tampering attacks.
- `RequirePrivacy=<0|1>` - When this property is set to 1, MUP and the selected UNC provider must use a form of encryption in such a way that when third parties see communication between the client and the server, they cannot see any sensitive information that is contained within the communication.

More information can be found here: [Microsoft Support - Vulnerability in Group Policy could allow remote code execution: February 10, 2015](#).

Rationale

This policy setting prevents the exploitation of the remote code execution vulnerability described in the description chapter. If it is not set accurately, an attacker could gain full control of a system and install programs or manipulate any data.

All NETLOGON and SYSVOL shares have to be configured to require both mutual authentication and integrity in order to help secure Group Policy against spoofing and tampering attacks that can be leveraged to achieve remote code execution.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled with the following paths configured, at a minimum:

```
\\*\NETLOGON RequireMutualAuthentication=1, RequireIntegrity=1  
\\*\SYSVOL RequireMutualAuthentication=1, RequireIntegrity=1
```

Computer Configuration\Policies\Administrative Templates\Network\Network
Provider\Hardened UNC Paths

Note: This Group Policy path does not exist by default. An additional Group Policy template (NetworkProvider.admx/adml) is required - it is included with the [MS15-011](#) / [MSKB 3000483](#) security update or with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

Impact:

Windows only allows access to the specified UNC paths after fulfilling additional security requirements.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry locations:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\NetworkProvider\HardenedPaths:\\*\NETLOGON  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\NetworkProvider\HardenedPaths:\\*\SYSVOL
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.14.1

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed during review: Corrected title and rule with (DC only) for SYSVOL. Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

TCPIP Settings

This section contains TCP/IP configuration settings.

This Group Policy section is provided by the Group Policy template `tcPIP.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

Parameters

This section contains TCP/IP parameter configuration settings.

This Group Policy section is provided by the Group Policy template `tcPIP.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

BL968-4849

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Disable IPv6 (Ensure TCPIP6 Parameter 'DisabledComponents' is set to '0xff (255)')

Rule

Disable IPv6 (Ensure TCPIP6 Parameter 'DisabledComponents' is set to '0xff (255)').

E01 - Exemption

This rule is not mandatory, if IPv6 is used in system's network environment.

E02 - Exemption

This rule is not mandatory, if IPv6 is functionally required for system's application or service purpose, such as Microsoft Exchange.

Description

Internet Protocol version 6 (IPv6) is a set of protocols that computers use to exchange information over the Internet and over home and business networks. IPv6 allows for many more IP addresses to be assigned than IPv4 did. Older networking, hosts and operating systems may not support IPv6 natively.

Rationale

Since the vast majority of private enterprise managed networks have no need to utilize IPv6 (because they have access to private IPv4 addressing), disabling IPv6 components removes a possible attack surface that is also harder to monitor the traffic on. As a result, we recommend configuring IPv6 to a Disabled state when it is not needed.

I01 - Implementation Example

To establish the recommended configuration, set the following Registry value to 0xff (255) (DWORD) :

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\TCPIP6\Parameters:DisabledComponents
```

Note: This change does not take effect until the computer has been restarted.

Note #2: Although Microsoft does not provide an ADMX template to configure this registry value, a custom .ADM template (Disable-IPv6-Components-KB929852.adm) is provided in the CIS Benchmark Remediation Kit to facilitate its configuration. Be aware though that simply turning off the group policy setting in the .ADM template will not "undo" the change once applied. Instead, the opposite setting must be applied to change the registry value to the opposite state.

Impact:

Connectivity to other systems using IPv6 will no longer operate, and software that depends on IPv6 will cease to function. Examples of Microsoft applications that may use IPv6 include: Remote Assistance, HomeGroup, DirectAccess, Windows Mail.

This registry change is documented in Microsoft Knowledge Base article 929852: [How to disable IPv6 or its components in Windows](#) .

Note: This registry change does not take effect until the next reboot.

C01 - Example Check

Navigate to the Registry path articulated in the Implementation section and confirm it is set as prescribed.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.19.2.1

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation. Changed during review: Added exemption E02.

Windows Connect Now

This section contains recommendations for Windows Connect Now settings.

This Group Policy section is provided by the Group Policy template `WindowsConnectNow.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-2791

Asset Manager



Ensure 'Configuration of wireless settings using Windows Connect Now' is set to 'Disabled'

Rule Ensure 'Configuration of wireless settings using Windows Connect Now' is set to 'Disabled'.

Description

This policy setting allows the configuration of wireless settings using Windows Connect Now (WCN). The WCN Registrar enables the discovery and configuration of devices over Ethernet (UPnP) over in-band 802.11 Wi-Fi through the Windows Portable Device API (WPD) and via USB Flash drives. Additional options are available to allow discovery and configuration over a specific medium.

Rationale

This setting enhances the security of the environment and reduces the overall risk exposure related to user configuration of wireless settings.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Network\Windows Connect Now\Configuration of wireless settings using Windows Connect Now

Note: This Group Policy path is provided by the Group Policy template `WindowsConnectNow.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

WCN operations are disabled over all media.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry locations:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WCN\Registrars:EnableRegistrars  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WCN\Registrars:DisableUPnPRegistrar  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WCN\Registrars:DisableInBand802DOT11Registrar  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WCN\Registrars:DisableFlashConfigRegistrar  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WCN\Registrars:DisableWPDRegistrar
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.20.1

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5051

Asset Manager

C	I	A
123	123	123

Ensure 'Prohibit access of the Windows Connect Now wizards' is set to 'Enabled'

Rule

Ensure 'Prohibit access of the Windows Connect Now wizards' is set to 'Enabled'.

Description

This policy setting prohibits access to Windows Connect Now (WCN) wizards.

Rationale

Allowing standard users to access the Windows Connect Now wizard increases the risk and attack surface.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Administrative Templates\Network\Windows
Connect Now\Prohibit access of the Windows Connect Now wizards

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `WindowsConnectNow.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

The WCN wizards are turned off and users have no access to any of the wizard tasks. All the configuration related tasks including "Set up a wireless router or access point" and "Add a wireless device" are disabled.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WCN\UI:DisableWcnUi
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.20.2

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Windows Connection Manager

This section contains recommendations for Windows Connection Manager settings.

This Group Policy section is provided by the Group Policy template `WCM.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

BL968-1386

Asset Manager



Ensure 'Minimize the number of simultaneous connections to the Internet or a Windows Domain' is set to 'Enabled'

Rule Ensure 'Minimize the number of simultaneous connections to the Internet or a Windows Domain' is set to 'Enabled'.

Description

This policy setting prevents computers from establishing multiple simultaneous connections to either the Internet or to a Windows domain.

Rationale

Blocking simultaneous connections can help prevent a user unknowingly allowing network traffic to flow between the Internet and the corporate network.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Network\Windows Connection Manager\Minimize the number of simultaneous connections to the Internet or a Windows Domain

Note: This Group Policy path was updated with a new *Minimize Policy Options* sub-setting starting with the Windows 10 Release 1903 Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WcmSvc\GroupPolicy:fMinimizeConnections
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.21.1

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2816

Asset Manager

C	I	A
123	123	123

Ensure 'Prohibit connection to non-domain networks when connected to domain authenticated network' is set to 'Enabled' (MS only)

Rule

Ensure 'Prohibit connection to non-domain networks when connected to domain authenticated network' is set to 'Enabled' (MS only).

Description

This policy setting prevents computers from connecting to both a domain based network and a non-domain based network at the same time.

Rationale

The potential concern is that a user would unknowingly allow network traffic to flow between the insecure public network and the enterprise managed network.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Network\Windows Connection Manager\Prohibit connection to non-domain networks when connected to domain authenticated network

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template WCM.admx/adml that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

The computer responds to automatic and manual network connection attempts based on the following circumstances:

Automatic connection attempts - When the computer is already connected to a domain based network, all automatic connection attempts to non-domain networks are blocked. - When the computer is already connected to a non-domain based network, automatic connection attempts to domain based networks are blocked.

Manual connection attempts - When the computer is already connected to either a non-domain based network or a domain based network over media other than Ethernet, and a user attempts to create a manual connection to an additional network in violation of this policy setting, the existing network connection is disconnected and the manual connection is allowed. - When the computer is already connected to either a non-domain based network or a domain based network over Ethernet, and a user attempts to create a manual connection to an additional network in violation of this policy setting, the existing Ethernet connection is maintained and the manual connection attempt is blocked.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WcmSvc\GroupPolicy:fBlockNonDomain
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.5.21.2

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Start Menu and Taskbar

This section contains recommendations for Start Menu and Taskbar.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Notifications

This section contains recommendations for Start Menu and Taskbar Notifications.

This Group Policy section is provided by the Group Policy template `WPN.admx/adml` that is included with the Microsoft 10 Release 1803 Administrative Templates (or newer).

BL968-4850

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Turn off notifications network usage' is set to 'Enabled'

Rule

Ensure 'Turn off notifications network usage' is set to 'Enabled'.

Description

This policy setting blocks applications from using the network to send notifications to update tiles, tile badges, toast, or raw notifications. This policy setting turns off the connection between Windows and the Windows Push Notification Service (WNS). This policy setting also stops applications from being able to poll application services to update tiles.

Rationale

Windows Push Notification Services (WNS) is a mechanism to receive 3rd-party notifications and updates from the cloud/Internet. In a high security environment, external systems, especially those hosted outside the organization, should be prevented from having an impact on the secure workstations.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

User Configuration\Policies\Administrative Templates\Start Menu and Taskbar\Notifications\Turn off notifications network usage

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `WPN.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

Applications and system features will not be able receive notifications from the network from WNS or via notification polling APIs.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\CurrentVersion\PushNotifications:NoCloudApplicati  
onNotification
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.7.1.1

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Changed during review: Fixed wrong GPO UI path. This rule is consistent with the CIS recommendation.

System

This section contains recommendations for System settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Audit Process Creation

This section contains settings related to auditing of process creation events.

This Group Policy section is provided by the Group Policy template `AuditSettings.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

BL968-5126

Asset Manager

C	I	A
123	123	123

Ensure 'Include command line in process creation events' is set to 'Enabled'

Rule

Ensure 'Include command line in process creation events' is set to 'Enabled'.

Description

This policy setting determines what information is logged in security audit events when a new process has been created.

Rationale

When this policy setting is enabled, any user who has read access to the security events can read the command-line arguments for any successfully created process. Command-line arguments may contain sensitive or private information such as passwords or user data.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\System\Audit Process Creation\Include command line in process creation events

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `AuditSettings.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Impact:

The process's command line information will be included in Audit Process Creation events. Avoid typing any password in the command line as those will be logged as well.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\Audit:ProcessCreationIncludeCmdLine_Enabled
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.3.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942). The advantage of exact auditing is assessed higher by Siemens CYS Protection Services than the possible risk of password loss in the specific case of entering a clear text password in the command line.

Credentials Delegation

This section contains settings related to Credential Delegation.

This Group Policy section is provided by the Group Policy template `CredSsp.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-0100

EVAL until 2022-02-28

Asset Manager



Ensure 'Encryption Oracle Remediation' is set to 'Enabled: Force Updated Clients'

Rule Ensure 'Encryption Oracle Remediation' is set to 'Enabled: Force Updated Clients'.

Description

Some versions of the CredSSP protocol that is used by some applications (such as Remote Desktop Connection) are vulnerable to an encryption oracle attack against the client. This policy controls compatibility with vulnerable clients and servers and allows you to set the level of protection desired for the encryption oracle vulnerability.

Enabling this policy setting allows to define the acceptance-level of applications using unpatched CredSSP versions. The following three settings are available:

- **Force Updated Clients (0):** Client applications that use CredSSP will not be able to fall back to insecure versions, and services that use CredSSP will not accept unpatched clients. This setting should not be deployed until all remote hosts support the newest version.
- **Mitigated (1):** Client applications that use CredSSP will not be able to fall back to insecure versions, but services that use CredSSP will accept unpatched clients.
- **Vulnerable (2):** Client applications that use CredSSP will expose the remote servers to attacks by supporting fallback to insecure versions, and services that use CredSSP will accept unpatched clients.

More information can be found here: [Windows support - CredSSP updates for CVE-2018-0886](#).

Rationale

This setting is important to mitigate the CredSSP encryption oracle vulnerability, for which information was published by Microsoft on 03/13/2018 in [CVE-2018-0886 | CredSSP Remote Code Execution Vulnerability](#). All versions of Windows Server from Server 2008 (non-R2) onwards are affected by this vulnerability, and will be compatible with this recommendation provided that they have been patched up through May 2018 (or later).

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled: Force Updated Clients**:

Computer Configuration\Policies\Administrative Templates\System\Credentials
Delegation\Encryption Oracle Remediation

Impact:

Client applications which use CredSSP will not be able to fall back to the insecure versions and services using CredSSP will not accept unpatched clients. This setting should not be deployed until all remote hosts support the newest version, which is achieved by ensuring that all Microsoft security updates at least through May 2018 are installed.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\CredSSP\Parameters:AllowEncryptionOracle
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.4.1

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Removed relaxed ACP12 setting and merged both rules with appropriate value. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0581

Asset Manager

C	I	A
123	123	123

Configure 'Allow delegating default credentials'

Rule

Ensure 'Allow delegating default credentials' is set to 'Disabled'.

Description

This policy setting applies to CredSSP running software (e.g., Remote Desktop Connection).

A server list can be defined to which the user's default credentials can be delegated (default credentials: used for the first login to Windows).

Rationale

Delegation of credentials is always risky and may even result in loss of these credentials. It should only be granted to accounts with as few privileges as possible. The delegation should only be used with secure protocols (e.g., Kerberos delegation).

Therefore, delegation should not be granted to default credentials (see description chapter).

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled

Computer Configuration\Policies\Administrative Templates\System\Credentials
Delegation\Allow delegating default credentials

Impact:

Delegation of default credentials to any machine is not possible.

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0566

Asset Manager

C	I	A
123	123	123

Configure 'Allow delegating default credentials with NTLM-only server authentication'

Rule Ensure 'Allow delegating default credentials with NTLM-only server authentication' is set to 'Disabled'.

Description

This policy setting applies to CredsSSP running software (e.g., Remote Desktop Connection).

A server list can be defined to which the user's default credentials can be delegated (default credentials: used for the first login to Windows).

This server list applies when server authentication was achieved via NTLM. More information about NTLM authentication can be found here: [BL968-2161 Ensure 'Network security: LAN Manager authentication level' is set to 'Send NTLMv2 response only. Refuse LM & NTLM'](#).

Rationale

Delegation of credentials is always risky and may even result in loss of these credentials. It should only be granted to accounts with as few privileges as possible. The delegation should only be used with secure protocols (e.g., Kerberos, but not NTLM).

Therefore, delegation should not be granted to default credentials (see description chapter).

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled

Computer Configuration\Policies\Administrative Templates\System\Credentials
Delegation\Allow delegating default credentials with NTLM-only server
authentication

Impact:

Delegation of default credentials with NTLM-only server authentication to any machine is not possible.

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0567

Asset Manager

C	I	A
123	123	123

Configure 'Restrict delegation of credentials to remote servers'

Rule

Ensure 'Restrict delegation of credentials to remote servers' is set to 'Enabled' -> 'Use the following restricted mode: Require Restricted Admin'.

Description

If an attacker has gained full control over a machine, he or she can harvest credentials used by a regular administrator to log in remotely onto this server using RDP. With these credentials, the attacker may be able to take control of further machines.

The setting 'Require Restricted Admin' forces applications to use the 'Restricted Admin Mode' to connect to other hosts without delegating credentials.

How to use the Restricted Admin mode on client-side:

Remote Desktop Connection mstsc.exe should only be used with the option /RestrictedAdmin for making the RDP connection.

The /RestrictedAdmin switch can be combined with other switches. For example, the following command would connect to Server01 on TCP port 3390 using the RestrictedAdmin switch:

```
Mstsc.exe /V:Server01:3390 /RestrictedAdmin
```

More information can be found here: [Microsoft Technet - Remote Desktop Services: Enable Restricted Admin mode](#).

Rationale

This policy setting prevents that during the initializing process of a Remote Desktop connection user credentials are sent to remote computers and then harvested and reused by an attacker who has been able to compromise the server.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled -> Use the following restricted mode: Require Restricted Admin

Computer Configuration\Policies\Administrative Templates\System\Credentials Delegation\Restrict delegation of credentials to remote servers

Impact:

Restricted Administration mode or Remote Credential Guard is enforced, and participating apps will not delegate credentials to remote devices.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Device Guard

This section contains Device Guard settings.

This Group Policy section is provided by the Group Policy template `DeviceGuard.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

BL968-0445

EVAL until 2022-02-28

Asset Manager



Ensure 'Turn On Virtualization Based Security' is set to 'Enabled'

Rule

Ensure 'Turn On Virtualization Based Security' is set to 'Enabled'.

E01 - Exemption

If your system currently does not fulfil all requirements of Virtualization Based Security (VBS) (e.g., the Operating system is not installed in UEFI mode) and you cannot reinstall the system immediately due to operational topics (e.g., availability), then you can postpone the enabling of VBS.

However, this decision must be documented (preferably incl. the time frame where the hardware update is planned).

Description

This policy setting specifies whether Virtualization Based Security is enabled. Virtualization Based Security uses the Windows Hypervisor to provide support for security services.

Note: Virtualization Based Security requires a 64-bit version of Windows with Secure Boot enabled, which in turn requires that Windows was installed with a UEFI BIOS configuration, not a Legacy BIOS configuration. In addition, if running Windows on a virtual machine, the hardware-assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM.

More information on system requirements for this feature can be found at this link:

[Windows Defender Credential Guard Requirements \(Windows 10\) | Microsoft Docs](#) .

Rationale

Kerberos, NTLM, and Credential manager isolate secrets by using virtualization-based security. Previous versions of Windows stored secrets in the Local Security Authority (LSA). Prior to Windows 10, the LSA stored secrets used by the operating system in its process memory. With Windows Defender Credential Guard enabled, the LSA process in the operating system talks to a new component called the isolated LSA process that stores and protects those secrets. Data stored by the isolated LSA process is protected using virtualization-based security and is not accessible to the rest of the operating system.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled**:

Computer Configuration\Policies\Administrative Templates\System\Device Guard\Turn On Virtualization Based Security

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template DeviceGuard.admx/adml that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

Note: UEFI Secure Boot must be enabled on the server before enabling. More information can be found here: [BL968-0362 Enable UEFI Secure Boot](#).

Note #2: If running Windows on a virtual machine, the hardware-assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM.

Note #3: All drivers on the system must be compatible with this feature or the system may crash. The compatibility of the computer to this feature has to be carefully checked before enabling.

Note #4: Enabling Windows Defender Credential Guard on Domain Controllers is not supported. The domain controller hosts authentication services which integrate with processes isolated when Windows Defender Credential Guard is enabled, causing crashes.

Impact:

- Security-critical processes will be executed in an isolated LSA process.
- Other Hypervisors like VMWare Server or Workstation cannot be used any more.
- VBS incompatible hardware may crash.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\DeviceGuard:EnableVirtualizationBasedSecurity
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.5.1

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0846

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Turn On Virtualization Based Security: Select Platform Security Level' is set to 'Secure Boot'

Rule Ensure 'Turn On Virtualization Based Security: Select Platform Security Level' is set to 'Secure Boot'.

Note: If you select the setting 'Secure Boot and DMA protection' Virtualization Based Security becomes effective only on those servers which support **both** features.

E01 - Exemption

This rule is not mandatory, if rule [BL968-0445 Ensure 'Turn On Virtualization Based Security' is set to 'Enabled'](#) is not enabled.

Description

This policy setting specifies whether Virtualization Based Security is enabled. Virtualization Based Security uses the Windows Hypervisor to provide support for security services. DMA Protection can help to mitigate the risk of a DMA side channel attack.

An attacker might have exploited a high-speed device (e.g., network card, storage device). If that device is connected to the DMA-port of a server, then malicious data might be directly copied into the memory without any supervision of the operational system.

Note: Virtualization Based Security requires a 64-bit version of Windows with Secure Boot enabled, which in turn requires that Windows was installed with a UEFI BIOS configuration, not a Legacy BIOS configuration. In addition, if running Windows on a virtual machine, the hardware-assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM.

More information on system requirements for this feature can be found at this link:

[Windows Defender Credential Guard Requirements \(Windows 10\) | Microsoft Docs](#) .

Rationale

Secure Boot can help reduce the risk of bootloader attacks and in conjunction with DMA protections to help protect data from being scraped from memory.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Secure Boot :

Computer Configuration\Policies\Administrative Templates\System\Device Guard\Turn On Virtualization Based Security: Select Platform Security Level

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template DeviceGuard.admx/adml that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

Note #2: [BL968-0445 Ensure 'Turn On Virtualization Based Security' is set to 'Enabled'](#) has to be enabled.

Impact:

Warning: All drivers on the system must be compatible with this feature or the system may crash. Ensure that this policy setting is only deployed to computers which are known to be compatible.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\DeviceGuard:RequirePlatformSecurityFeatures
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.5.2

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1444

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Turn On Virtualization Based Security: Virtualization Based Protection of Code Integrity' is set to 'Enabled with UEFI lock'

Rule

Ensure 'Turn On Virtualization Based Security: Virtualization Based Protection of Code Integrity' is set to 'Enabled with UEFI lock'.

E01 - Exemption

This rule is not mandatory, if rule [BL968-0445 Ensure 'Turn On Virtualization Based Security' is set to 'Enabled'](#) is not enabled.

Description

This setting enables virtualization based protection of Kernel Mode Code Integrity. When this is enabled, kernel mode memory protections are enforced and the Code Integrity validation path is protected by the Virtualization Based Security feature.

Note: Virtualization Based Security requires a 64-bit version of Windows with Secure Boot enabled, which in turn requires that Windows was installed with a UEFI BIOS configuration, not a Legacy BIOS configuration. In addition, if running Windows on a virtual machine, the hardware-assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM.

More information on system requirements for this feature can be found at this link:

[Windows Defender Credential Guard Requirements \(Windows 10\) | Microsoft Docs](#) .

Rationale

The Kernel Mode code of a computer is hardened to attacks by malware and malicious code (e.g., Mimikatz). Sensitive data as passwords and keys run in Kernel Mode.

The Enabled with UEFI lock option ensures that Virtualization Based Protection of Code Integrity cannot be disabled remotely.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled with UEFI lock :

Computer Configuration\Policies\Administrative Templates\System\Device Guard\Turn On Virtualization Based Security: Virtualization Based Protection of Code Integrity

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template DeviceGuard.admx/adml that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

Note #2: [BL968-0445 Ensure 'Turn On Virtualization Based Security' is set to 'Enabled'](#) has to be enabled.

Impact:

Warning: All drivers on the system must be compatible with this feature or the system may crash. Ensure that this policy setting is only deployed to computers which are known to be compatible.

Warning #2: Once this setting is turned on and active, **Virtualization Based Security cannot be disabled solely via GPO** or any other remote method. After removing the setting from GPO, the features must also be manually disabled *locally at the machine* using the steps provided at this link:

[Manage Windows Defender Credential Guard \(Windows 10\) | Microsoft Docs](#) .

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\DeviceGuard:HypervisorEnforcedCodeIntegrity
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.5.3

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0529

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Turn On Virtualization Based Security: Credential Guard Configuration' is set to 'Enabled with UEFI lock' (MS Only)

Rule Ensure 'Turn On Virtualization Based Security: Credential Guard Configuration' is set to 'Enabled with UEFI lock' (MS Only).

Note: Enabling Windows Defender Credential Guard on Domain Controllers is not supported. The domain controller hosts authentication services which integrate with processes isolated when Windows Defender Credential Guard is enabled, causing crashes.

E01 - Exemption

This rule is not mandatory, if rule [BL968-0445 Ensure 'Turn On Virtualization Based Security' is set to 'Enabled'](#) is not enabled.

Description

This setting lets users turn on Credential Guard with virtualization-based security to help protect credentials. The "Enabled with UEFI lock" option ensures that Credential Guard cannot be disabled remotely. In order to disable the feature, you must set the Group Policy to "Disabled" as well as remove the security functionality from each computer, with a physically present user, in order to clear configuration persisted in UEFI.

The recommended state for this setting is: *Enabled with UEFI lock , but only on Member Servers (not Domain Controllers).*

Note: Virtualization Based Security requires a 64-bit version of Windows with Secure Boot enabled, which in turn requires that Windows was installed with a UEFI BIOS configuration, not a Legacy BIOS configuration. In addition, if running Windows on a virtual machine, the hardware-assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM.

More information on system requirements for this feature can be found at this link:

[Windows Defender Credential Guard Requirements \(Windows 10\) | Microsoft Docs](#) .

Note: [BL968-0445 Ensure 'Turn On Virtualization Based Security' is set to 'Enabled'](#) has to be enabled.

Rationale

The *Enabled with UEFI lock* option ensures that Credential Guard cannot be disabled remotely.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled with UEFI lock` (on Member Servers only):

Computer Configuration\Policies\Administrative Templates\System\Device Guard\Turn On Virtualization Based Security: Credential Guard Configuration

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template DeviceGuard.admx/adml that is included with the Microsoft Windows 10 Release 1511 Administrative Templates (or newer).

Impact:

Warning: All drivers on the system must be compatible with this feature or the system may crash. Ensure that this policy setting is only deployed to computers which are known to be compatible.

Warning #2: Enabling Windows Defender Credential Guard on Domain Controllers is not supported. The domain controller hosts authentication services which integrate with processes isolated when Windows Defender Credential Guard is enabled, causing crashes.

Warning #3: Once this setting is turned on and active, **Credential Guard cannot be disabled solely via GPO** or any other remote method. After removing the setting from GPO, the features must also be manually disabled *locally at the machine* using the steps provided at this link:

[Manage Windows Defender Credential Guard \(Windows 10\) | Microsoft Docs](#) .

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\DeviceGuard:LsaCfgFlags
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.5.5

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.5.6

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Early Launch Antimalware

This section contains recommendations for configuring boot-start driver initialization settings.

This Group Policy section is provided by the Group Policy template `EarlyLaunchAM.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

BL968-3141

Eval until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Boot-Start Driver Initialization Policy' is set to 'Enabled: Good only'

Rule

Ensure 'Boot-Start Driver Initialization Policy' is set to 'Enabled: Good only'.

Description

This policy setting allows you to specify which boot-start drivers are initialized based on a classification determined by an Early Launch Antimalware boot-start driver. The Early Launch Antimalware boot-start driver can return the following classifications for each boot-start driver:

- **Good** : The driver has been signed and has not been tampered with.
- **Bad** : The driver has been identified as malware. It is recommended that you do not allow known bad drivers to be initialized.
- **Bad, but required for boot** : The driver has been identified as malware, but the computer cannot successfully boot without loading this driver.
- **Unknown** : This driver has not been attested to by your malware detection application and has not been classified by the Early Launch Antimalware boot-start driver.

If you enable this policy setting you will be able to choose which boot-start drivers to initialize the next time the computer is started.

If your malware detection application does not include an Early Launch Antimalware boot-start driver or if your Early Launch Antimalware boot-start driver has been disabled, this setting has no effect and all boot-start drivers are initialized.

Rationale

This policy setting helps reduce the impact of malware that has already infected your system.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled: Good only`

Computer Configuration\Policies\Administrative Templates\System\Early Launch Antimalware\Boot-Start Driver Initialization Policy

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template EarlyLaunchAM.admx/adml that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

None - this is the default behavior. Known bad boot-start drivers are not allowed.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Policies\EarlyLaunch:DriverLoadPolicy
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.14.1

Based on Siemens Information Security Policy Framework Rule 16.1.6-01

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Based on Siemens Information Security Policy Framework Rule 12.2.1-01

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Removed relaxed ACP12 rule, merged both rules and set appropriate value. This rule is consistent, but strengthened, to the CIS recommendation.

Group Policy

This section contains recommendations for configuring group policy-related settings.

This Group Policy section is provided by the Group Policy template `GroupPolicy.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-2656

Asset Manager



Ensure 'Configure registry policy processing: Do not apply during periodic background processing' is set to 'Enabled: FALSE'

Rule Ensure 'Configure registry policy processing: Do not apply during periodic background processing' is set to 'Enabled: FALSE'.

Description

The "Do not apply during periodic background processing" option prevents the system from updating affected policies in the background while the computer is in use. When background updates are disabled, policy changes will not take effect until the next user logon or system restart.

Rationale

Setting this option to false (unchecked) will ensure that domain policy changes take effect more quickly, as compared to waiting until the next user logon or system restart.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`, then set the `Do not apply during periodic background processing` option to `FALSE` (unchecked):

Computer Configuration\Policies\Administrative Templates\System\Group Policy\Configure registry policy processing

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `GroupPolicy.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

Group Policies will be reapplied every time they are refreshed, which could have a slight impact on performance.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Group Policy\{35378EAC-683F-11D2-A89A-00C04FBBCFA2}\NoBackgroundPolicy
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.21.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5461

Asset Manager

C	I	A
123	123	123

Ensure 'Configure registry policy processing: Process even if the Group Policy objects have not changed' is set to 'Enabled: TRUE'

Rule

Ensure 'Configure registry policy processing: Process even if the Group Policy objects have not changed' is set to 'Enabled: TRUE'.

Description

The "Process even if the Group Policy objects have not changed" option updates and reapplies policies even if the policies have not changed.

Rationale

Setting this option to true (checked) will ensure unauthorized changes that might have been configured locally are forced to match the domain-based Group Policy settings again.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`, then set the `Process even if the Group Policy objects have not changed` option to `TRUE` (checked):

Computer Configuration\Policies\Administrative Templates\System\Group Policy\Configure registry policy processing

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `GroupPolicy.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

Group Policies will be reapplied even if they have not been changed, which could have a slight impact on performance.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Group Policy\{35378EAC-683F-11D2-A89A-00C04FBBCFA2}\NoGPListChanges
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.21.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5851

Asset Manager

C	I	A
123	123	123

Ensure 'Continue experiences on this device' is set to 'Disabled'

Rule

Ensure 'Continue experiences on this device' is set to 'Disabled'.

Description

This policy setting determines whether the Windows device is allowed to participate in cross-device experiences (continue experiences).

Rationale

A cross-device experience is when a system can access app and send messages to other devices. In an enterprise managed environment only trusted systems should be communicating within the network. Access to any other system should be prohibited. Only ports, protocols, and services with validated business needs should be running on a system.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Administrative Templates\System\Group Policy\Continue experiences on this device

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template GroupPolicy.admx/adml that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

The Windows device will not be discoverable by other devices, and cannot participate in cross-device experiences.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:EnableCdp
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.21.4

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3256

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off background refresh of Group Policy' is set to 'Disabled'

Rule

Ensure 'Turn off background refresh of Group Policy' is set to 'Disabled'.

Description

This policy setting prevents Group Policy from being updated while the computer is in use. This policy setting applies to Group Policy for computers, users, and Domain Controllers.

Rationale

This setting ensures that group policy changes take effect more quickly, as compared to waiting until the next user logon or system restart.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled:

Computer Configuration\Policies\Administrative Templates\System\Group Policy\Turn off background refresh of Group Policy

Note: This Group Policy path is provided by the Group Policy template `GroupPolicy.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is in effect when the following registry location does not exist:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:DisableBkGndGroupPolicy
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.21.5

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Internet Communication Management

This section contains recommendations related to Internet Communication Management.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Internet Communication settings

This section contains recommendations related to Internet Communication settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-2216

Asset Manager

C	I	A
123	123	123

Configure 'Turn off access to the Store'

Rule

Ensure 'Turn off access to the Store' is set to 'Enabled'.

Description

This policy setting specifies whether to use the Store service for finding an application to open a file with an unhandled file type or protocol association. When a user opens a file type or protocol that is not associated with any applications on the computer, the user is given the choice to select a local application or use the Store service to find an application.

Rationale

The Store service is a retail outlet built into Windows, primarily for consumer use. In an enterprise environment the IT department should be managing the installation of all applications to reduce the risk of the installation of vulnerable software.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

`Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off access to the Store`

Impact:

The "Look for an app in the Store" item in the "Open With" dialog box will be removed.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0896

Asset Manager

C	I	A
123	123	123

Configure 'Turn off Automatic Root Certificates Update'

Rule

Ensure 'Turn off Automatic Root Certificates Update' is set to 'Enabled'.

Description

This policy setting determines whether root certificates are updated automatically using the Microsoft Windows Update website.

Rationale

Siemens wants to ensure that only trustworthy root certificates will be deployed to Siemens Server. Therefore, the root certificates will be released via a Siemens CYS process and updated via an OneAD process.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled

Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off Automatic Root Certificates Update

Impact:

The computer will not contact the Windows Update website to update its root certificates.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4236

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off downloading of print drivers over HTTP' is set to 'Enabled'

Rule

Ensure 'Turn off downloading of print drivers over HTTP' is set to 'Enabled'.

Description

This policy setting controls whether the computer can download print driver packages over HTTP. To set up HTTP printing, printer drivers that are not available in the standard operating system installation might need to be downloaded over HTTP.

Rationale

Users might download drivers that include malicious code.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off downloading of print drivers over HTTP

Note: This Group Policy path is provided by the Group Policy template `ICM.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Print drivers cannot be downloaded over HTTP.

Note: This policy setting does not prevent the client computer from printing to printers on the Intranet or the Internet over HTTP. It only prohibits downloading drivers that are not already installed locally.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Printers:DisableWebPnPDownload
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.22.1.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2326

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off handwriting personalization data sharing' is set to 'Enabled'

Rule

Ensure 'Turn off handwriting personalization data sharing' is set to 'Enabled'.

Description

This setting turns off data sharing from the handwriting recognition personalization tool.

The handwriting recognition personalization tool enables Tablet PC users to adapt handwriting recognition to their own writing style by providing writing samples. The tool can optionally share user writing samples with Microsoft to improve handwriting recognition in future versions of Windows. The tool generates reports and transmits them to Microsoft over a secure connection.

The recommended state for this setting is: `Enabled`.

Rationale

A person's handwriting is Personally Identifiable Information (PII), especially when it comes to your signature. As such, it is unacceptable in many environments to automatically upload PII to a website without explicit approval by the user.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off handwriting personalization data sharing

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `ShapeCollector.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

Impact:

Tablet PC users cannot choose to share writing samples from the handwriting recognition personalization tool with Microsoft.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\TabletPC:PreventHandwritingDataSharing
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.22.1.2

Based on Siemens Information Security Policy Framework Rule 07.1.2-01

Based on Siemens Information Security Policy Framework Rule 08.2.3-06

Based on Siemens Information Security Policy Framework Rule 08.2.3-07

Based on Siemens Information Security Policy Framework Rule 08.2.3-08

Based on Siemens Information Security Policy Framework Rule 08.2.3-11

Based on Siemens Information Security Policy Framework Rule 08.2.3-16

Based on Siemens Information Security Policy Framework Rule 13.2.4-01

Based on Siemens Information Security Policy Framework Rule 13.2.4-02

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1276

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off handwriting recognition error reporting' is set to 'Enabled'

Rule

Ensure 'Turn off handwriting recognition error reporting' is set to 'Enabled'.

Description

Turns off the handwriting recognition error reporting tool.

The handwriting recognition error reporting tool enables users to report errors encountered in Tablet PC Input Panel. The tool generates error reports and transmits them to Microsoft over a secure connection. Microsoft uses these error reports to improve handwriting recognition in future versions of Windows.

Rationale

A person's handwriting is Personally Identifiable Information (PII), especially when it comes to your signature. As such, it is unacceptable in many environments to automatically upload PII to a website without explicit approval by the user.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off handwriting recognition error reporting

Note: This Group Policy path is provided by the Group Policy template `InkWatson.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Users cannot start the handwriting recognition error reporting tool or send error reports to Microsoft.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\HandwritingErrorReports:PreventHandwritingErrorReports
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.22.1.3

Based on Siemens Information Security Policy Framework Rule 07.1.2-01

Based on Siemens Information Security Policy Framework Rule 08.2.3-06

Based on Siemens Information Security Policy Framework Rule 08.2.3-07

Based on Siemens Information Security Policy Framework Rule 08.2.3-08

Based on Siemens Information Security Policy Framework Rule 08.2.3-11

Based on Siemens Information Security Policy Framework Rule 08.2.3-16

Based on Siemens Information Security Policy Framework Rule 13.2.4-01

Based on Siemens Information Security Policy Framework Rule 13.2.4-02

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1046

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off Internet Connection Wizard if URL connection is referring to Microsoft.com' is set to 'Enabled'

Rule

Ensure 'Turn off Internet Connection Wizard if URL connection is referring to Microsoft.com' is set to 'Enabled'.

Description

This policy setting specifies whether the Internet Connection Wizard can connect to Microsoft to download a list of Internet Service Providers (ISPs).

Rationale

In an enterprise managed environment, we want to lower the risk of a user unknowingly exposing sensitive data.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off Internet Connection Wizard if URL connection is referring to Microsoft.com

Note: This Group Policy path is provided by the Group Policy template `ICM.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

The "Choose a list of Internet Service Providers" path in the Internet Connection Wizard causes the wizard to exit. This prevents users from retrieving the list of ISPs, which resides on Microsoft servers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Internet Connection Wizard:ExitOnMSICW
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.22.1.4

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2271

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off Internet download for Web publishing and online ordering wizards' is set to 'Enabled'

Rule Ensure 'Turn off Internet download for Web publishing and online ordering wizards' is set to 'Enabled'.

Description

This policy setting controls whether Windows will download a list of providers for the Web publishing and online ordering wizards.

Rationale

Although the risk is minimal, enabling this setting will reduce the possibility of a user unknowingly downloading malicious content through this feature.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off Internet download for Web publishing and online ordering wizards

Note: This Group Policy path is provided by the Group Policy template `ICM.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Windows is prevented from downloading providers; only the service providers cached in the local registry are displayed.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer:NoWebServices
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.22.1.5

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2901

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off printing over HTTP' is set to 'Enabled'

Rule

Ensure 'Turn off printing over HTTP' is set to 'Enabled'.

Description

This policy setting allows you to disable the client computer's ability to print over HTTP, which allows the computer to print to printers on the Intranet as well as the Internet.

Note: This control affects printing over **both** HTTP and HTTPS.

Rationale

Information that is transmitted over HTTP through this capability is not protected and can be intercepted by malicious users. For this reason, it is not often used in enterprise managed environments.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off printing over HTTP

Note: This Group Policy path is provided by the Group Policy template ICM.admx/adml that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

The client computer will not be able to print to Internet printers over HTTP or HTTPS.

Note: This policy setting affects the client side of Internet printing only. Regardless of how it is configured, a computer could act as an Internet Printing server and make its shared printers available through HTTP.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Printers:DisableHTTPPrinting
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.22.1.6

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5476

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off Registration if URL connection is referring to Microsoft.com' is set to 'Enabled'

Rule

Ensure 'Turn off Registration if URL connection is referring to Microsoft.com' is set to 'Enabled'.

Description

This policy setting specifies whether the Windows Registration Wizard connects to Microsoft.com for online registration.

Rationale

Users in an enterprise managed environment should not be registering their own copies of Windows, providing their own PII in the process.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off Registration if URL connection is referring to Microsoft.com

Note: This Group Policy path is provided by the Group Policy template `ICM.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Users are blocked from connecting to Microsoft.com for online registration and they cannot register their copy of Windows online.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Registration Wizard Control:NoRegistration
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.22.1.7

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3576

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off Search Companion content file updates' is set to 'Enabled'

Rule

Ensure 'Turn off Search Companion content file updates' is set to 'Enabled'.

Description

This policy setting specifies whether Search Companion should automatically download content updates during local and Internet searches.

Rationale

There is a small risk that users will unknowingly reveal sensitive information because of the topics they are searching for. This risk is very low because even if this setting is enabled users still must submit search queries to the desired search engine in order to perform searches.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off Search Companion content file updates

Note: This Group Policy path is provided by the Group Policy template `ICM.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Search Companion does not download content updates during searches.

Note: Internet searches will still send the search text and information about the search to Microsoft and the chosen search provider. If you select Classic Search, the Search Companion feature will be unavailable. You can select Classic Search by clicking Start, Search, Change Preferences, and then Change Internet Search Behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\SearchCompanion:DisableContentFileUpdates
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.22.1.8

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5226

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off the "Order Prints" picture task' is set to 'Enabled'

Rule

Ensure 'Turn off the "Order Prints" picture task' is set to 'Enabled'.

Description

This policy setting specifies whether the "Order Prints Online" task is available from Picture Tasks in Windows folders.

The Order Prints Online Wizard is used to download a list of providers and allow users to order prints online.

Rationale

In an enterprise managed environment, we want to lower the risk of a user unknowingly exposing sensitive data.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off the "Order Prints" picture task

Note: This Group Policy path is provided by the Group Policy template ICM.admx/adml that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

The task "Order Prints Online" is removed from Picture Tasks in File Explorer folders.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer:NoOnlinePrintsWizard
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.22.1.9

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4166

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off the "Publish to Web" task for files and folders' is set to 'Enabled'

Rule

Ensure 'Turn off the "Publish to Web" task for files and folders' is set to 'Enabled'.

Description

This policy setting specifies whether the tasks "Publish this file to the Web", "Publish this folder to the Web", and "Publish the selected items to the Web" are available from File and Folder Tasks in Windows folders.

Rationale

Users may publish confidential or sensitive information to a public service outside of the control of the organization.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off the "Publish to Web" task for files and folders

Note: This Group Policy path is provided by the Group Policy template `ICM.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

The "Publish to Web" task is removed from File and Folder tasks in Windows folders.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer:NoPublishingWizard
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.22.1.10

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1321

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off the Windows Messenger Customer Experience Improvement Program' is set to 'Enabled'

Rule Ensure 'Turn off the Windows Messenger Customer Experience Improvement Program' is set to 'Enabled'.

Description

This policy setting specifies whether Windows Messenger can collect anonymous information about how the Windows Messenger software and service is used. Microsoft uses information collected through the Customer Experience Improvement Program to detect software flaws so that they can be corrected more quickly, enabling this setting will reduce the amount of data Microsoft is able to gather for this purpose.

Rationale

Large enterprise managed environments may not want to have information collected by Microsoft from managed client computers. Windows Messenger is not allowed to collect anonymous information about how the Windows Messenger software and service is used.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled**:

Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off the Windows Messenger Customer Experience Improvement Program

Note: This Group Policy path is provided by the Group Policy template `ICM.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Windows Messenger will not collect usage information, and the user settings to enable the collection of usage information will not be shown.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Messenger\Client:CEIP
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.22.1.11

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1841

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off Windows Customer Experience Improvement Program' is set to 'Enabled'

Rule

Ensure 'Turn off Windows Customer Experience Improvement Program' is set to 'Enabled'.

Description

This policy setting specifies whether Windows Messenger can collect anonymous information about how the Windows Messenger software and service is used.

Microsoft uses information collected through the Windows Customer Experience Improvement Program to detect software flaws so that they can be corrected more quickly, enabling this setting will reduce the amount of data Microsoft is able to gather for this purpose.

Rationale

Large enterprise managed environments may not want to have information collected by Microsoft from managed client computers. Uncontrolled data exchange with servers outside the Siemens enterprise network is not allowed. This policy setting disables the Windows Customer Experience Improvement Program so no uncontrolled information is sent to Microsoft.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off Windows Customer Experience Improvement Program

Note: This Group Policy path is provided by the Group Policy template ICM.admx/adml that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

All users are opted out of the Windows Customer Experience Improvement Program.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\SQMClient\Windows:CEIPEnable
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.22.1.12

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2571

Asset Manager

C	I	A
3	3	

Ensure 'Turn off Windows Error Reporting' is set to 'Enabled'

Rule

Ensure 'Turn off Windows Error Reporting' is set to 'Enabled'.

Description

This policy setting controls whether or not errors are reported to Microsoft.

Error Reporting is used to report information about a system or application that has failed or has stopped responding and is used to improve the quality of the product.

Rationale

If a Windows Error occurs in a secure, enterprise managed environment, the error should be reported directly to IT staff for troubleshooting and remediation. There is no benefit to the corporation to report these errors directly to Microsoft, and there is some risk of unknowingly exposing sensitive data as part of the error.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication settings\Turn off Windows Error Reporting

Note: This Group Policy path is provided by the Group Policy template ICM.admx/adml that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Users are not given the option to report errors to Microsoft.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Windows Error Reporting:Disabled  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\PCHealth\ErrorReporting:DoReport
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.22.1.13

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

KDC

BL968-0156

Asset Manager

C	I	A
123	123	123

Configure 'KDC support for claims, compound authentication and Kerberos armoring' (DC only)

Rule Ensure 'KDC support for claims, compound authentication, and Kerberos armoring' is set to 'Enabled' -> 'Supported' (DC only).

Description

This policy setting determines whether domain controllers are able to provide claims and compound authentication for Dynamic Access Control and Kerberos armoring to their domain clients (see [BL968-0211 Configure 'Kerberos client support for claims, compound authentication and Kerberos armoring'](#)).

Once this policy setting is enabled on Domain Controllers, capable clients can use this feature.

Rationale

Claims, compound authentication, and Kerberos armoring are security features, which extend secure protection mechanisms in a domain.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled -> Supported:

Computer Configuration\Policies\Administrative Templates\System\KDC\KDC support for claims, compound authentication and Kerberos armoring

Impact:

Client computers that support claims and compound authentication for Dynamic Access Control will use this feature for Kerberos authentication messages.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Kerberos

This section contains recommendations for Kerberos settings.

This Group Policy section is provided by the Group Policy template `Kerberos.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-0211

Asset Manager



Configure 'Kerberos client support for claims, compound authentication and Kerberos armoring'

Rule Ensure 'Kerberos client support for claims compound authentication and Kerberos armoring' is set to 'Enabled'.

Description

This policy setting determines whether a domain computer is able to use claims and compound authentication for Dynamic Access Control and Kerberos armoring provided by the domain controllers (see [BL968-0156 Configure 'KDC support for claims, compound authentication and Kerberos armoring' \(DC only\)](#)).

Once this policy setting is enabled on Domain Controllers, capable clients can use this feature.

Rationale

Claims, compound authentication, and Kerberos armoring are additional security features to control and secure the access to resources.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative
Templates\System\Kerberos\Kerberos client support for claims, compound
authentication and Kerberos armoring

Impact:

Clients will be able to use features of Dynamic Access Control.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4696

Asset Manager

C	I	A
123	123	123

Ensure 'Support device authentication using certificate' is set to 'Enabled: Automatic'

Rule Ensure 'Support device authentication using certificate' is set to 'Enabled: Automatic'.

Description

This policy setting allows you to set support for Kerberos to attempt authentication using the certificate for the device to the domain.

Support for device authentication using certificate will require connectivity to a DC in the device account domain which supports certificate authentication for computer accounts.

Rationale

Having stronger device authentication with the use of certificates is strongly encouraged over standard username and password authentication. Having this set to Automatic will allow certificate based authentication to be used whenever possible.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled: Automatic`:

`Computer Configuration\Policies\Administrative
Templates\System\Kerberos\Support device authentication using certificate`

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `Kerberos.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

Impact:

None - this is the default behavior. Devices will attempt to authenticate using its certificate. If the DC does not support computer account authentication using certificates then authentication with password will be attempted.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry locations:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\kerberos\parameters:DevicePKInitBehavior
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\kerberos\parameters:DevicePKInitEnabled
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.25.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Locale Services

This section contains recommendations for Locale Services settings.

This Group Policy section is provided by the Group Policy template `Globalization.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-5151

Asset Manager



Ensure 'Disallow copying of user input methods to the system account for sign-in' is set to 'Enabled'

Rule Ensure 'Disallow copying of user input methods to the system account for sign-in' is set to 'Enabled'.

Description

This policy prevents automatic copying of user input methods to the system account for use on the sign-in screen. The user is restricted to the set of input methods that are enabled in the system account.

Rationale

The more different user input methods are allowed the more attack surface will be given to an attacker. This policy setting ensures that the users are restricted to the set of input methods.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Administrative Templates\System\Locale Services\Disallow copying of user input methods to the system account for sign-in

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `Globalization.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

Users will have input methods enabled for the system account on the sign-in page.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Control  
Panel\International\BlockUserInputMethodsForSignIn
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.27.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Logon

This section contains recommendations related to the logon process and lock screen.

This Group Policy section is provided by the Group Policy template `Logon.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-4136

Asset Manager



Ensure 'Block user from showing account details on sign-in' is set to 'Enabled'

Rule

Ensure 'Block user from showing account details on sign-in' is set to 'Enabled'.

Description

This policy prevents the user from showing account details (email address or username) on the sign-in screen.

Rationale

An attacker with access to the console (for example, someone with physical access or someone who is able to connect to the server through Remote Desktop Services) could view the name of the last user who logged on to the server. The attacker could then try to guess the password, use a dictionary, or use a brute-force attack to try and log on.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Administrative Templates\System\Logon\Block user from showing account details on sign-in

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `Logon.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

The user cannot choose to show account details on the sign-in screen.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:BlockUserFromShowingAccountDetailsOnSignin
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.28.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5006

Asset Manager

C	I	A
123	123	123

Ensure 'Do not display network selection UI' is set to 'Enabled'

Rule

Ensure 'Do not display network selection UI' is set to 'Enabled'.

Description

This policy setting allows you to control whether anyone can interact with available networks UI on the logon screen.

Rationale

An unauthorized user could disconnect the PC from the network or can connect the PC to other available networks without signing into Windows.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Administrative Templates\System\Logon\Do not display network selection UI

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template Logon.admx/adml that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Impact:

The PC's network connectivity state cannot be changed without signing into Windows.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:DontDisplayNetworkSelectionUI
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.28.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5211

Asset Manager

C	I	A
123	123	123

Ensure 'Do not enumerate connected users on domain-joined computers' is set to 'Enabled'

Rule

Ensure 'Do not enumerate connected users on domain-joined computers' is set to 'Enabled'.

Description

This policy setting prevents connected users from being enumerated on domain-joined computers.

Rationale

A malicious user could use this feature to gather account names of other users, that information could then be used in conjunction with other types of attacks such as guessing passwords or social engineering. The value of this countermeasure is small because a user with domain credentials could gather the same account information using other methods.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\System\Logon\Do not enumerate connected users on domain-joined computers

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template Logon.admx/adml that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

The Logon UI will not enumerate any connected users on domain-joined computers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:DontEnumerateConnectedUsers
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.28.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1666

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Enumerate local users on domain-joined computers' is set to 'Disabled' (MS only)

Rule

Ensure 'Enumerate local users on domain-joined computers' is set to 'Disabled' (MS only).

Description

This policy setting allows local users to be enumerated on domain-joined computers.

Rationale

A malicious user could use this feature to gather account names of other users, that information could then be used in conjunction with other types of attacks such as guessing passwords or social engineering. The value of this countermeasure is small because a user with domain credentials could gather the same account information using other methods.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\System\Logon\Enumerate local users on domain-joined computers

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template Logon.admx/adml that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:EnumerateLocalUsers
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.28.4

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Restricted scope to MS only, added Check section. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3776

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off app notifications on the lock screen' is set to 'Enabled'

Rule

Ensure 'Turn off app notifications on the lock screen' is set to 'Enabled'.

Description

This policy setting allows you to prevent app notifications from appearing on the lock screen.

Rationale

App notifications might display sensitive business or personal data.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled**:

Computer Configuration\Policies\Administrative Templates\System\Logon\Turn off app notifications on the lock screen

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template Logon.admx/adml that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

No app notifications are displayed on the lock screen.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System;DisableLockScreenAppNotifications
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.28.5

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4854

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off picture password sign-in' is set to 'Enabled'

Rule

Ensure 'Turn off picture password sign-in' is set to 'Enabled'.

Description

This policy setting allows you to control whether a domain user can sign in using a picture password.

Note: If the picture password feature is permitted, the user's domain password is cached in the system vault when using it.

Rationale

Picture passwords bypass the requirement for a typed complex password. In a shared work environment, a simple shoulder surf where someone observed the on-screen gestures would allow that person to gain access to the system without the need to know the complex password. Vertical monitor screens with an image are much more visible at a distance than horizontal key strokes, increasing the likelihood of a successful observation of the mouse gestures.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\System\Logon\Turn off picture password sign-in

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `CredentialProviders.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

Users will not be able to set up or sign in with a picture password.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:BlockDomainPicturePassword
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.28.6

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2841

Asset Manager

C	I	A
123	123	123

Ensure 'Turn on convenience PIN sign-in' is set to 'Disabled'

Rule

Ensure 'Turn on convenience PIN sign-in' is set to 'Disabled'.

Description

This policy setting allows you to control whether a domain user can sign in using a convenience PIN. In Windows 10, convenience PIN was replaced with Passport, which has stronger security properties. To configure Passport for domain users, use the policies under Computer Configuration\Administrative Templates\Windows Components\Microsoft Passport for Work.

Note: The user's domain password will be cached in the system vault when using this feature.

Rationale

A PIN is created from a much smaller selection of characters than a password, so in most cases a PIN will be much less robust than a password.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\System\Logon\Turn on convenience PIN sign-in

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `CredentialProviders.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Note #2: In older Microsoft Windows Administrative Templates, this setting was initially named *Turn on PIN sign-in*, but it was renamed starting with the Windows 10 Release 1511 Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:AllowDomainPINLogon
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.28.7

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Power Management

This section contains recommendations for Power Management settings.

This Group Policy section is provided by the Group Policy template `Power.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Sleep Settings

This section contains recommendations related to Power Management Sleep mode.

This Group Policy section is provided by the Group Policy template `Power.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-1461

Asset Manager

C	I	A
123	123	123

Ensure 'Allow network connectivity during connected-standby (on battery)' is set to 'Disabled'

Rule Ensure 'Allow network connectivity during connected-standby (on battery)' is set to 'Disabled'.

Description

This policy setting allows you to control the network connectivity state in standby on modern standby-capable systems.

Rationale

Disabling this setting ensures that the computer will not be accessible to attackers over a WLAN network while left unattended, on battery and in a sleep state.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\System\Power Management\Sleep Settings\Allow network connectivity during connected-standby (on battery)

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `Power.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Network connectivity in standby (while on battery) is not guaranteed. This connectivity restriction currently only applies to WLAN networks only, but is subject to change (according to Microsoft).

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Power\PowerSettings\f15576e8-98b7-4186-b944-eafa664402d9:DCSettingIndex
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.34.6.1

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1462

Asset Manager

C	I	A
123	123	123

Ensure 'Allow network connectivity during connected-standby (plugged in)' is set to 'Disabled'

Rule Ensure 'Allow network connectivity during connected-standby (plugged in)' is set to 'Disabled'.

Description

This policy setting allows you to control the network connectivity state in standby on modern standby-capable systems.

Rationale

Disabling this setting ensures that the computer will not be accessible to attackers over a WLAN network while left unattended, plugged in and in a sleep state.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\System\Power Management\Sleep Settings\Allow network connectivity during connected-standby (plugged in)

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `Power.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Network connectivity in standby (while plugged in) is not guaranteed. This connectivity restriction currently only applies to WLAN networks only, but is subject to change (according to Microsoft).

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Power\PowerSettings\f15576e8-98b7-4186-b944-eafa664402d9:ACSettingIndex
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.34.6.2

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3416

Asset Manager

C	I	A
123	123	123

Ensure 'Require a password when a computer wakes (on battery)' is set to 'Enabled'

Rule

Ensure 'Require a password when a computer wakes (on battery)' is set to 'Enabled'.

Description

Specifies whether or not the user is prompted for a password when the system resumes from sleep.

Rationale

Enabling this setting ensures that anyone who wakes an unattended computer from sleep state will have to provide logon credentials before they can access the system.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Administrative Templates\System\Power Management\Sleep Settings\Require a password when a computer wakes (on battery)

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `Power.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Power\PowerSettings\0e796bdb-100d-47d6-a2d5-f7d2daa51f51:DCSettingIndex
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.34.6.3

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3417

Asset Manager

C	I	A
123	123	123

Ensure 'Require a password when a computer wakes (plugged in)' is set to 'Enabled'

Rule

Ensure 'Require a password when a computer wakes (plugged in)' is set to 'Enabled'.

Description

Specifies whether or not the user is prompted for a password when the system resumes from sleep.

Rationale

Enabling this setting ensures that anyone who wakes an unattended computer from sleep state will have to provide logon credentials before they can access the system.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Administrative Templates\System\Power Management\Sleep Settings\Require a password when a computer wakes (plugged in)

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `Power.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Power\PowerSettings\0e796bdb-100d-47d6-a2d5-f7d2daa51f51:ACSettingIndex
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.34.6.4

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Remote Assistance

This section contains recommendations related to Remote Assistance.

This Group Policy section is provided by the Group Policy template `RemoteAssistance.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-5771

Asset Manager



Ensure 'Configure Offer Remote Assistance' is set to 'Disabled'

Rule

Ensure 'Configure Offer Remote Assistance' is set to 'Disabled'.

Description

This policy setting allows you to turn on or turn off Offer (Unsolicited) Remote Assistance on this computer.

Help desk and support personnel will not be able to proactively offer assistance, although they can still respond to user assistance requests.

Rationale

A user might be tricked and accept an unsolicited Remote Assistance offer from a malicious user.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\System\Remote Assistance\Configure Offer Remote Assistance

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `RemoteAssistance.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:fAllowUnsolicited
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.36.1

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1621

Asset Manager

C	I	A
123	123	123

Ensure 'Configure Solicited Remote Assistance' is set to 'Disabled'

Rule

Ensure 'Configure Solicited Remote Assistance' is set to 'Disabled'.

Description

This policy setting allows you to turn on or turn off Solicited (Ask for) Remote Assistance on this computer.

Rationale

There is risk that a rogue administrator will gain access to another user's desktop session, however, they cannot connect to a user's computer unannounced or control it without permission from the user. When an expert tries to connect, the user can still choose to deny the connection or give the expert view-only privileges. The user must explicitly click the Yes button to allow the expert to remotely control the workstation.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\System\Remote Assistance\Configure Solicited Remote Assistance

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template RemoteAssistance.admx/adml that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

Users on this computer cannot use e-mail or file transfer to ask someone for help. Also, users cannot use instant messaging programs to allow connections to this computer.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:fAllowToGetHelp
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.36.2

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Remote Procedure Call

This section contains recommendations related to Remote Procedure Call.

This Group Policy section is provided by the Group Policy template `RPC.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-3291

Asset Manager



Ensure 'Enable RPC Endpoint Mapper Client Authentication' is set to 'Enabled' (MS only)

Rule Ensure 'Enable RPC Endpoint Mapper Client Authentication' is set to 'Enabled' (MS only).

Description

This policy setting controls whether RPC clients authenticate with the Endpoint Mapper Service when the call they are making contains authentication information. The Endpoint Mapper Service on computers running Windows NT4 (all service packs) cannot process authentication information supplied in this manner. This policy setting can cause a specific issue with *1-way*forest trusts if it is applied to the *trusting* domain DCs (see Microsoft [KB3073942](#)), so we do not recommend applying it to Domain Controllers.

Note: This policy will not be in effect until the system is rebooted.

Rationale

Anonymous access to RPC services could result in accidental disclosure of information to unauthenticated users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\System\Remote Procedure Call\Enable RPC Endpoint Mapper Client Authentication

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `RPC.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

RPC clients will authenticate to the Endpoint Mapper Service for calls that contain authentication information. Clients making such calls will not be able to communicate with the Windows NT4 Server Endpoint Mapper Service.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Rpc:EnableAuthEpResolution
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.37.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1516

Asset Manager

C	I	A
123	123	123

Ensure 'Restrict Unauthenticated RPC clients' is set to 'Enabled: Authenticated' (MS only)

Rule

Ensure 'Restrict Unauthenticated RPC clients' is set to 'Enabled: Authenticated' (MS only).

Description

This policy setting controls how the RPC server runtime handles unauthenticated RPC clients connecting to RPC servers.

This policy setting impacts all RPC applications. In a domain environment this policy setting should be used with caution as it can impact a wide range of functionality including group policy processing itself. Reverting a change to this policy setting can require manual intervention on each affected machine.

This policy setting should never be applied to a Domain Controller .

A client will be considered an authenticated client if it uses a named pipe to communicate with the server or if it uses RPC Security. RPC Interfaces that have specifically requested to be accessible by unauthenticated clients may be exempt from this restriction, depending on the selected value for this policy setting.

-- " **None** " allows all RPC clients to connect to RPC Servers running on the machine on which the policy setting is applied.

-- " **Authenticated** " allows only authenticated RPC Clients (per the definition above) to connect to RPC Servers running on the machine on which the policy setting is applied. Exemptions are granted to interfaces that have requested them.

-- " **Authenticated without exceptions** " allows only authenticated RPC Clients (per the definition above) to connect to RPC Servers running on the machine on which the policy setting is applied. No exceptions are allowed. **This value has the potential to cause serious problems and is not recommended.**

Note: This policy setting will not be applied until the system is rebooted.

Rationale

Unauthenticated RPC communication can create a security vulnerability.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled: Authenticated**:

Computer Configuration\Policies\Administrative Templates\System\Remote Procedure Call\Restrict Unauthenticated RPC clients

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `RPC.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

Only authenticated RPC Clients will be allowed to connect to RPC servers running on the machine on which the policy setting is applied. Exemptions are granted to interfaces that have requested them.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Rpc:RestrictRemoteClients
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.37.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Troubleshooting and Diagnostics

This section contains recommendations related to Troubleshooting and Diagnostics.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Microsoft Support Diagnostic Tool

This section contains recommendations related to the Microsoft Support Diagnostic Tool.

This Group Policy section is provided by the Group Policy template `MSDT.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-3371

Asset Manager



Ensure 'Microsoft Support Diagnostic Tool: Turn on MSDT interactive communication with support provider' is set to 'Disabled'

Rule

Ensure 'Microsoft Support Diagnostic Tool: Turn on MSDT interactive communication with support provider' is set to 'Disabled'.

Description

This policy setting configures Microsoft Support Diagnostic Tool (MSDT) interactive communication with the support provider. MSDT gathers diagnostic data for analysis by support professionals.

Rationale

Due to privacy concerns, data should never be sent to any 3rd party since this data could contain sensitive information.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\System\Troubleshooting and Diagnostics\Microsoft Support Diagnostic Tool\Microsoft Support Diagnostic Tool: Turn on MSDT interactive communication with support provider

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `MSDT.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

MSDT cannot run in support mode, and no data can be collected or sent to the support provider.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\ScriptedDiagnosticsProvider\Policy:DisableQueryRemoteServer
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.47.5.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Windows Performance PerfTrack

This section contains recommendations related to Windows Performance PerfTrack.

This Group Policy section is provided by the Group Policy template `PerformancePerftrack.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

BL968-2836

Asset Manager

C	I	A
123	123	123

Ensure 'Enable/Disable PerfTrack' is set to 'Disabled'

Rule

Ensure 'Enable/Disable PerfTrack' is set to 'Disabled'.

Description

This policy setting specifies whether to enable or disable tracking of responsiveness events.

Rationale

When enabled the aggregated data of a given event will be transmitted to Microsoft. The option exists to restrict this feature for a specific user, set the consent level, and designate specific programs for which error reports could be sent. However, centrally restricting the ability to execute PerfTrack to limit the potential for unauthorized or undesired usage, data leakage, or unintentional communications is highly recommended.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\System\Troubleshooting and Diagnostics\Windows Performance PerfTrack\Enable/Disable PerfTrack

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `PerformancePerftrack.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

Impact:

Responsiveness events are not processed.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WDI\{9c5a40da-b965-4fc3-8781-88dd50a6299d}:ScenarioExecutionEnabled
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.47.11.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

User Profiles

This section contains recommendations related to User Profiles.

This Group Policy section is provided by the Group Policy template `UserProfiles.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-4857

EVAL until 2022-02-28

Asset Manager



Ensure 'Turn off the advertising ID' is set to 'Enabled'

Rule

Ensure 'Turn off the advertising ID' is set to 'Enabled'.

Description

This policy setting turns off the advertising ID, preventing apps from using the ID for experiences across apps.

Rationale

Tracking user activity for advertising purposes, even anonymously, may be a privacy concern. In an enterprise managed environment, applications should not need or require tracking for targeted advertising.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Administrative Templates\System\User Profiles\Turn off the advertising ID

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `UserProfiles.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Impact:

The advertising ID is turned off. Apps cannot use the ID for experiences across apps.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\AdvertisingInfo\DisabledByGroupPolicy
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.49.1

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

Windows Time Service

This section contains recommendations related to the Windows Time Service.

This Group Policy section is provided by the Group Policy template `W32Time.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Time Providers

This section contains recommendations related to Time Providers.

This Group Policy section is provided by the Group Policy template `W32Time.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-4858

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Enable Windows NTP Client' is set to 'Enabled'

Rule

Ensure 'Enable Windows NTP Client' is set to 'Enabled'.

Description

This policy setting specifies whether the Windows NTP Client is enabled. Enabling the Windows NTP Client allows your computer to synchronize its computer clock with other NTP servers. You might want to disable this service if you decide to use a third-party time provider.

Rationale

A reliable and accurate account of time is important for a number of services and security requirements, including but not limited to distributed applications, authentication services, multi-user databases and logging services. The use of an NTP client (with secure operation) establishes functional accuracy and is a focal point when reviewing security relevant events.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\System\Windows Time Service\Time Providers\Enable Windows NTP Client

Note: This Group Policy path is provided by the Group Policy template `W32Time.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

You can set the local computer clock to synchronize time with NTP servers.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\W32Time\TimeProviders\NtpClient:Enabled
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.52.1.1

Based on [Siemens Information Security Policy Framework Rule 12.4.4-01](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-4859

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Enable Windows NTP Server' is set to 'Disabled' (MS only)

Rule

Ensure 'Enable Windows NTP Server' is set to 'Disabled' (MS only).

Description

This policy setting allows you to specify whether the Windows NTP Server is enabled.

Note: In most enterprise managed environments, you should *not* disable the Windows NTP Server on Domain Controllers, as it is very important for the operation of NT5DS (domain hierarchy-based) time synchronization.

Rationale

The configuration of proper time synchronization is critically important in an enterprise managed environment both due to the sensitivity of Kerberos authentication timestamps and also to ensure accurate security logging.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Administrative Templates\System\Windows Time Service\Time Providers\Enable Windows NTP Server

Note: This Group Policy path is provided by the Group Policy template `W32Time.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\W32Time\TimeProviders\NtpServer:Enabled
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.8.52.1.2

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

Windows Components

This section contains recommendations for Windows Component settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

App Package Deployment

This section contains recommendations for App Package Deployment settings.

This Group Policy section is provided by the Group Policy template `AppxPackageManager.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

BL968-4906

Asset Manager

C	I	A
123	123	123

Ensure 'Allow a Windows app to share application data between users' is set to 'Disabled'

Rule

Ensure 'Allow a Windows app to share application data between users' is set to 'Disabled'.

Description

Manages a Windows app's ability to share data between users who have installed the app. Data is shared through the `SharedLocal` folder. This folder is available through the `Windows.Storage` API.

Rationale

Users of a system could accidentally share sensitive data with other users on the same system.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

`Computer Configuration\Policies\Administrative Templates\Windows Components\App Package Deployment\Allow a Windows app to share application data between users`

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `AppxPackageManager.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\CurrentVersion\AppModel\StateManager:AllowSharedLocalAppData
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.4.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

App Privacy

This section contains rules related to App Privacy.

The Group Policy settings contained within this section are provided by the Group Policy template AppPrivacy.admx/adml that is included with the Microsoft Windows 10 Release 1607 Administrative Templates.

BL968-5901

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Let Windows apps access account information' is set to 'Enable: Force Deny'

Rule

Ensure 'Let Windows apps access account information' is set to 'Enabled: Force Deny'.

Description

Microsoft *Windows 10* and *Windows Server 2016* allows apps and desktop applications to access specific personal information about the user logged on the system, such as the name. This information is used to deliver the user a more personal experience when using *Windows 10* and *Windows Server 2016*.

Rationale

The usage of this information by the apps and desktop applications is not under the control and protection of Siemens. An appropriate usage cannot be guaranteed which may lead to leakage of Personally Identifiable Information (PII). Additionally, this information is not needed in a business environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled-> Force Deny:

Computer Configuration\Policies\Administrative Templates\Windows Components\App Privacy\Let Windows apps access account information

Note: The Group Policy path does not exist by default. An updated Group Policy template (AppPrivacy.admx/adml) is required to configure that - it is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows apps will be restricted from accessing potentially sensitive information or resources, and employees in your organization will not be able to change it.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.

BL968-5902

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Let Windows apps access call history' is set to 'Enable: Force Deny'

Rule

Ensure 'Let Windows apps access call history' is set to 'Enabled: Force Deny'.

Description

The policy setting 'Let Windows apps access call history' specifies whether Windows apps can access the history of calls made on this computer.

Rationale

The usage of this information by the apps and desktop applications is not under the control and protection of Siemens. An appropriate usage cannot be guaranteed which may lead to leakage of Personally Identifiable Information (PII). Additionally, this information is not needed in a business environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled-> Force Deny:

Computer Configuration\Policies\Administrative Templates\Windows Components\App Privacy\Let Windows apps access call history

Note: The Group Policy path does not exist by default. An updated Group Policy template (AppPrivacy.admx/adml) is required to configure that - it is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows apps will be restricted from accessing potentially sensitive information or resources, and employees in your organization will not be able to change it.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.

BL968-5903

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Let Windows apps access contacts' is set to 'Enable: Force Deny'

Rule

Ensure 'Let Windows apps access contacts' is set to 'Enabled: Force Deny'.

Description

The policy setting 'Let Windows apps access contacts' specifies whether Windows apps can access any contact stored on this computer.

Rationale

The usage of this information by the apps and desktop applications is not under the control and protection of Siemens. An appropriate usage cannot be guaranteed which may lead to leakage of Personally Identifiable Information (PII). Additionally, this information is not needed in a business environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled -> Force Deny:

Computer Configuration\Policies\Administrative Templates\Windows Components\App Privacy\Let Windows apps access contacts

Note: The Group Policy path does not exist by default. An updated Group Policy template (AppPrivacy.admx/adml) is required to configure that - it is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows apps will be restricted from accessing potentially sensitive information or resources, and employees in your organization will not be able to change it.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.

BL968-5904

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Let Windows apps access email' is set to 'Enable: Force Deny'

Rule

Ensure 'Let Windows apps access email' is set to 'Enabled: Force Deny'.

Description

The policy setting 'Let Windows apps access email' specifies whether Windows apps can access any email stored on this computer.

Rationale

The usage of this information by the apps and desktop applications is not under the control and protection of Siemens. An appropriate usage cannot be guaranteed which may lead to leakage of Personally Identifiable Information (PII). Additionally, this information is not needed in a business environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled -> Force Deny:

Computer Configuration\Policies\Administrative Templates\Windows Components\App Privacy\Let Windows apps access email

Note: The Group Policy path does not exist by default. An updated Group Policy template (AppPrivacy.admx/adml) is required to configure that - it is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows apps will be restricted from accessing potentially sensitive information or resources, and employees in your organization will not be able to change it.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.

BL968-5905

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Let Windows apps access location' is set to 'Enable: Force Deny'

Rule

Ensure 'Let Windows apps access location' is set to 'Enabled: Force Deny'.

Description

The policy setting 'Let Windows apps access location' specifies whether Windows apps can access the current location of this computer.

Rationale

The usage of this information by the apps and desktop applications is not under the control and protection of Siemens. An appropriate usage cannot be guaranteed which may lead to leakage of Personally Identifiable Information (PII). Additionally, this information is not needed in a business environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled -> Force Deny:

Computer Configuration\Policies\Administrative Templates\Windows Components\App Privacy\Let Windows apps access location

Note: The Group Policy path does not exist by default. An updated Group Policy template (AppPrivacy.admx/adml) is required to configure that - it is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows apps will be restricted from accessing potentially sensitive information or resources, and employees in your organization will not be able to change it.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.

BL968-5906

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Let Windows apps access messaging' is set to 'Enable: Force Deny'

Rule

Ensure 'Let Windows apps access messaging' is set to 'Enabled: Force Deny'.

Description

The policy setting 'Let Windows apps access messaging' specifies whether Windows apps can access any information processed with Messaging apps on this computer.

Rationale

The usage of this information by the apps and desktop applications is not under the control and protection of Siemens. An appropriate usage cannot be guaranteed which may lead to leakage of Personally Identifiable Information (PII). Additionally, this information is not needed in a business environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled -> Force Deny:

Computer Configuration\Policies\Administrative Templates\Windows Components\App Privacy\Let Windows apps access messaging

Note: The Group Policy path does not exist by default. An updated Group Policy template (AppPrivacy.admx/adml) is required to configure that - it is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows apps will be restricted from accessing potentially sensitive information or resources, and employees in your organization will not be able to change it.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.

BL968-5907

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Let Windows apps access motion' is set to 'Enable: Force Deny'

Rule

Ensure 'Let Windows apps access motion' is set to 'Enabled: Force Deny'.

Description

The policy setting 'Let Windows apps access motion' specifies whether Windows apps can access any motion data stored on this computer.

Rationale

The usage of this information by the apps and desktop applications is not under the control and protection of Siemens. An appropriate usage cannot be guaranteed which may lead to leakage of Personally Identifiable Information (PII). Additionally, this information is not needed in a business environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled -> Force Deny:

Computer Configuration\Policies\Administrative Templates\Windows Components\App Privacy\Let Windows apps access motion

Note: The Group Policy path does not exist by default. An updated Group Policy template (AppPrivacy.admx/adml) is required to configure that - it is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows apps will be restricted from accessing potentially sensitive information or resources, and employees in your organization will not be able to change it.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.

BL968-5908

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Let Windows apps access the calendar' is set to 'Enable: Force Deny'

Rule

Ensure 'Let Windows apps access the calendar' is set to 'Enabled: Force Deny'.

Description

The policy setting 'Let Windows apps access the calendar' specifies whether Windows apps can access any information stored in Calendar apps on this computer.

Rationale

The usage of this information by the apps and desktop applications is not under the control and protection of Siemens. An appropriate usage cannot be guaranteed which may lead to leakage of Personally Identifiable Information (PII). Additionally, this information is not needed in a business environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled-> Force Deny:

Computer Configuration\Policies\Administrative Templates\Windows Components\App Privacy\Let Windows apps access the calendar

Note: The Group Policy path does not exist by default. An updated Group Policy template (AppPrivacy.admx/adml) is required to configure that - it is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows apps will be restricted from accessing potentially sensitive information or resources, and employees in your organization will not be able to change it.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.

BL968-5909

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Let Windows apps access the camera' is set to 'Enable: Force Deny'

Rule

Ensure 'Let Windows apps access the camera' is set to 'Enabled: Force Deny'.

Description

The policy setting 'Let Windows apps access the camera' specifies whether Windows apps can access the camera of this computer.

Rationale

The usage of this information by the apps and desktop applications is not under the control and protection of Siemens. An appropriate usage cannot be guaranteed which may lead to leakage of Personally Identifiable Information (PII). Additionally, this information is not needed in a business environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled -> Force Deny:

Computer Configuration\Policies\Administrative Templates\Windows Components\App Privacy\Let Windows apps access the camera

Note: The Group Policy path does not exist by default. An updated Group Policy template (AppPrivacy.admx/adml) is required to configure that - it is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows apps will be restricted from accessing potentially sensitive information or resources, and employees in your organization will not be able to change it.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.

BL968-5910

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Let Windows apps access the microphone' is set to 'Enable: Force Deny'

Rule

Ensure 'Let Windows apps access the microphone' is set to 'Enabled: Force Deny'.

Description

The policy setting 'Let Windows apps access the microphone' specifies whether Windows apps can access microphone of this computer.

Rationale

The usage of this information by the apps and desktop applications is not under the control and protection of Siemens. An appropriate usage cannot be guaranteed which may lead to leakage of Personally Identifiable Information (PII). Additionally, this information is not needed in a business environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled-> Force Deny:

Computer Configuration\Policies\Administrative Templates\Windows Components\App Privacy\Let Windows apps access the microphone

Note: The Group Policy path does not exist by default. An updated Group Policy template (AppPrivacy.admx/adml) is required to configure that - it is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows apps will be restricted from accessing potentially sensitive information or resources, and employees in your organization will not be able to change it.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.

BL968-5923

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Let Windows apps access trusted devices' is set to 'Enable: Force Deny'

Rule

Ensure 'Let Windows apps access trusted devices' is set to 'Enabled: Force Deny'.

Description

The policy setting 'Let Windows apps access trusted devices' specifies whether Windows apps can access any trusted device on this computer.

Rationale

The usage of this information by the apps and desktop applications is not under the control and protection of Siemens. An appropriate usage cannot be guaranteed which may lead to leakage of Personally Identifiable Information (PII). Additionally, this information is not needed in a business environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled-> Force Deny:

Computer Configuration\Policies\Administrative Templates\Windows Components\App Privacy\Let Windows apps access trusted devices

Note: The Group Policy path does not exist by default. An updated Group Policy template (AppPrivacy.admx/adml) is required to configure that - it is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows apps will be restricted from accessing potentially sensitive information or resources, and employees in your organization will not be able to change it.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.

BL968-5912

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Let Windows apps control radios' is set to 'Enable: Force Deny'

Rule

Ensure 'Let Windows apps control radios' is set to 'Enabled: Force Deny'.

Description

The policy setting 'Let Windows apps control radios' specifies whether Windows apps can access control radios used on this computer.

Rationale

The usage of this information by the apps and desktop applications is not under the control and protection of Siemens. An appropriate usage cannot be guaranteed which may lead to leakage of Personally Identifiable Information (PII). Additionally, this information is not needed in a business environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled -> Force Deny:

Computer Configuration\Policies\Administrative Templates\Windows Components\App Privacy\Let Windows apps control radios

Note: The Group Policy path does not exist by default. An updated Group Policy template (AppPrivacy.admx/adml) is required to configure that - it is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows apps will be restricted from accessing potentially sensitive information or resources, and employees in your organization will not be able to change it.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.

BL968-5914

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Let Windows apps make phone calls' is set to 'Enable: Force Deny'

Rule

Ensure 'Let Windows apps make phone calls' is set to 'Enabled: Force Deny'.

Description

The policy setting 'Let Windows apps make phone calls' specifies whether Windows apps can initiate phone calls with Phone apps stored on this computer.

Rationale

The usage of this information by the apps and desktop applications is not under the control and protection of Siemens. An appropriate usage cannot be guaranteed which may lead to leakage of Personally Identifiable Information (PII). Additionally, this information is not needed in a business environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled-> Force Deny:

Computer Configuration\Policies\Administrative Templates\Windows Components\App Privacy\Let Windows apps make phone calls

Note: The Group Policy path does not exist by default. An updated Group Policy template (AppPrivacy.admx/adml) is required to configure that - it is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows apps will be restricted from accessing potentially sensitive information or resources, and employees in your organization will not be able to change it.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.

BL968-5915

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Let Windows apps access notifications' is set to 'Enable: Force Deny'

Rule

Ensure 'Let Windows apps access notifications' is set to 'Enabled: Force Deny'.

Description

The policy setting 'Let Windows apps access notifications' specifies whether Windows apps can access notifications issued by Windows apps used on this computer.

Rationale

The usage of this information by the apps and desktop applications is not under the control and protection of Siemens. An appropriate usage cannot be guaranteed which may lead to leakage of Personally Identifiable Information (PII). Additionally, this information is not needed in a business environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled -> Force Deny:

Computer Configuration\Policies\Administrative Templates\Windows Components\App Privacy\Let Windows apps access notifications

Note: The Group Policy path does not exist by default. An updated Group Policy template (AppPrivacy.admx/adml) is required to configure that - it is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows apps will be restricted from accessing potentially sensitive information or resources, and employees in your organization will not be able to change it.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942), but divided into separate rules.

App runtime

This section contains recommendations for App runtime settings.

This Group Policy section is provided by the Group Policy template `AppXRuntime.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

BL968-2316

Asset Manager



Ensure 'Allow Microsoft accounts to be optional' is set to 'Enabled'

Rule

Ensure 'Allow Microsoft accounts to be optional' is set to 'Enabled'.

Description

This policy setting lets you control whether Microsoft accounts are optional for Windows Store apps that require an account to sign in. This policy only affects Windows Store apps that support it.

Rationale

Enabling this setting allows an organization to use their enterprise user accounts instead of using their Microsoft accounts when accessing Windows store apps. This provides the organization with greater control over relevant credentials. Microsoft accounts cannot be centrally managed and as such enterprise credential security policies cannot be applied to them, which could put any information accessed by using Microsoft accounts at risk.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

`Computer Configuration\Policies\Administrative Templates\Windows Components\App runtime\Allow Microsoft accounts to be optional`

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `AppXRuntime.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Impact:

Windows Store apps that typically require a Microsoft account to sign in will allow users to sign in with an enterprise account instead.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:MSAOptional
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.6.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

AutoPlay Policies

This section contains recommendations for AutoPlay policies.

This Group Policy section is provided by the Group Policy template `AutoPlay.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-4926

Asset Manager



Ensure 'Disallow Autoplay for non-volume devices' is set to 'Enabled'

Rule

Ensure 'Disallow Autoplay for non-volume devices' is set to 'Enabled'.

Description

This policy setting disallows AutoPlay for MTP devices like cameras or phones.

Rationale

An attacker could use this feature to launch a program to damage a client computer or data on the computer.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Administrative Templates\Windows
Components\AutoPlay Policies\Disallow Autoplay for non-volume devices

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `AutoPlay.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

AutoPlay will not be allowed for MTP devices like cameras or phones.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Explorer:NoAutoplayfornonVolume
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.8.1

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1966

Asset Manager

C	I	A
123	123	123

Ensure 'Set the default behavior for AutoRun' is set to 'Enabled: Do not execute any autorun commands'

Rule Ensure 'Set the default behavior for AutoRun' is set to 'Enabled: Do not execute any autorun commands'.

Description

This policy setting sets the default behavior for Autorun commands. Autorun commands are generally stored in `autorun.inf` files. They often launch the installation program or other routines.

Rationale

Prior to Windows Vista, when media containing an autorun command is inserted, the system will automatically execute the program without user intervention. This creates a major security concern as code may be executed without user's knowledge. The default behavior starting with Windows Vista is to prompt the user whether autorun command is to be run. The autorun command is represented as a handler in the Autoplay dialog. Automatically executing code without any user interaction can simplify for an attacker the introduction of malicious code to a computer.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled: Do not execute any autorun commands`:

Computer Configuration\Policies\Administrative Templates\Windows Components\AutoPlay Policies\Set the default behavior for AutoRun

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `AutoPlay.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

AutoRun commands will be completely disabled.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer:NoAutorun
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.8.2

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4501

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off Autoplay' is set to 'Enabled: All drives'

Rule

Ensure 'Turn off Autoplay' is set to 'Enabled: All drives'.

Description

Autoplay starts to read from a drive as soon as you insert media in the drive, which causes the setup file for programs or audio media to start immediately. An attacker could use this feature to launch a program to damage the computer or data on the computer. Autoplay is disabled by default on some removable drive types, such as floppy disk and network drives, but not on CD-ROM drives.

Note: You cannot use this policy setting to enable Autoplay on computer drives in which it is disabled by default, such as floppy disk and network drives.

Rationale

An attacker could use this feature to launch a program to damage a client computer or data on the computer.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled: All drives**:

Computer Configuration\Policies\Administrative Templates\Windows Components\AutoPlay Policies\Turn off Autoplay

Note: This Group Policy path is provided by the Group Policy template `AutoPlay.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Autoplay will be disabled - users will have to manually launch setup or installation programs that are provided on removable media.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer:NoDriveTypeAutoRun
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.8.3

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Biometrics

This section contains recommendations related to Biometrics.

This Group Policy section is provided by the Group Policy template `Biometrics.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

Facial Features

This section contains recommendations related to Facial Feature Biometrics.

This Group Policy section is provided by the Group Policy template `Biometrics.admx/adml` that is included with the Microsoft Windows 10 Release 1511 Administrative Templates (or newer).

BL968-3876

Asset Manager



Ensure 'Use enhanced anti-spoofing when available' is set to 'Enabled'

Rule

Ensure 'Use enhanced anti-spoofing when available' is set to 'Enabled'.

Description

This policy setting determines whether enhanced anti-spoofing is configured for devices which support it.

Rationale

Enterprise managed environments are now supporting a wider range of mobile devices, increasing the security on these devices will help protect against unauthorized access on your network.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Biometrics\Facial Features\Use enhanced anti-spoofing when available

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `Biometrics.admx/adml` that is included with the Microsoft Windows 10 Release 1511 Administrative Templates (or newer).

Note #2: This settings was renamed to *Configure enhanced anti-spoofing* starting with the Windows 10 Release 1703 Administrative Templates.

Impact:

Windows will require all users on the device to use anti-spoofing for facial features, on devices which support it.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Biometrics\FacialFeatures:EnhancedAntiSpoofing
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.10.1.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BitLocker Drive Encryption

This section contains rules for BitLocker Drive Encryption settings.

BL968-7367

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Prevent memory overwrite on restart' is set to 'Disabled'

Rule

Ensure 'Prevent memory overwrite on restart' is set to 'Disabled'.

Description

Microsoft Windows includes the built-in full disk and volume encryption feature BitLocker Drive Encryption (BDE), which leverages the benefits of a Trusted Platform Module (TPM) chip. This chip is a dedicated chip to perform cryptographic operations, such as generate and store keys. Apart from encrypting fixed drives, BitLocker can be used as well to encrypt removable drives. This feature is known as *BitLocker To Go*.

Rationale

If the encryption of the hard drive has not been properly performed, for example, a weak cipher has been used or a weak password has been used, it might be trivial for an attacker to bypass the encryption protection of the drive (e.g., exploiting a vulnerability in the cipher).

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled:

Computer Configuration\Policies\Administrative Templates\Windows
Components\BitLocker Drive Encryption\Prevent memory overwrite on restart.

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016 and Siemens Windows Server 2019 (BL942). Rule has been copied from Siemens Windows 10 (BL696).

BL968-0226

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Configure the policy 'Provide the unique identifiers for your organization'

Rule

Enable the setting 'Provide the unique identifiers for your organization' and set the option 'BitLocker identification field' to the value 'Siemens AG'.

Description

The *BitLocker identification field* can be used to manage certificate-based data recovery agents. Therefore it has to be set to the unique value 'Siemens AG' and shall not be changed afterwards.

Rationale

If the encryption of the hard drive has not been properly performed, for example, a weak cipher has been used or a weak password has been used, it might be trivial for an attacker to bypass the encryption protection of the drive (e.g., exploiting a vulnerability in the cipher).

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

```
Computer Configuration\Policies\Administrative Templates\Windows  
Components\BitLocker Drive Encryption\Provide the unique identifiers for your  
organization
```

and set the option `BitLocker identification field` to the value `Siemens AG`.

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016 and Siemens Windows Server 2019 (BL942). Rule has been copied from Siemens Windows 10 (BL696).

BL968-0326

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Configure 'Choose drive encryption method and cipher strength (Windows 10 [Version 1511] and later)'

Rule Ensure 'Choose drive encryption method and cipher strength (Windows 10 [Version 1511] and later)' is set to 'Enabled' and set the options as follows:

- Set 'Select the encryption method for operating system drives' to 'XTS-AES 256-bit',
- Set 'Select the encryption method for fixed data drives' to 'XTS-AES 256-bit',
- Set 'Select the encryption method for removable data drives' to 'XTS-AES 256-bit' or 'AES-CBC 256 bit'.

Description

This policy setting determines the algorithm and cipher strength used by BitLocker Drive Encryption.

Note: The encryption type must have been selected before the drive is encrypted. This rule has no effect on already BitLocker-encrypted drives.

Note: Weaker ciphers than 'XTS-AES 256-bit' or 'AES-CBC 256-bit' are not allowed at Siemens.

Rationale

This rule guarantees that BitLocker always uses secure ciphers to encrypt user and system data. Weaker ciphers could result in access for unauthorized people to potential confidential data on lost or stolen computers or removable devices.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled

Computer Configuration\Policies\Administrative Templates\Windows Components\BitLocker Drive Encryption\Choose drive encryption method and cipher strength (Windows 10 [Version 1511] and later)

Put the following settings in place:

Setting	Value
Select the encryption method for operating system drives	XTS-AES 256-bit
Select the encryption method for fixed data drives	XTS-AES 256-bit
Select the encryption method for removable data drives	XTS-AES 256-bit or AES-CBC 256-bit

Impact:

If BitLocker is turned on, then 'XTS-AES 256-bit' or 'AES-CBC 256-bit' are the only available ciphers. There is no effect if the drive is already encrypted, or if encryption is in progress.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Removed the option 'AES-CBC 256 bit' for fixed and operating system drives. Not part of CIS Windows Server 2016. Aligned with Windows Server 2019 (BL942).

Fixed Data Drives

This section contains rules for Fixed Data Drive settings.

BL968-1636

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Choose how BitLocker-protected fixed drives can be recovered' is set to 'Disabled'

Rule

Ensure 'Choose how BitLocker-protected fixed drives can be recovered' is set to 'Disabled'.

Description

Microsoft includes specific BitLocker settings depending on the purpose of the disk drive. In particular in this rule, we focus on the following two types:

- Operating System drive: This is the drive where the operating system is installed.
- Fixed data drives: These drives contain only data but are not (easily) removable compared to a USB stick.

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker.

Rationale

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled:

Computer Configuration\Policies\Administrative Templates\Windows Components\BitLocker Drive Encryption\Fixed Data Drives\Choose how BitLocker-protected fixed drives can be recovered.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).

BL968-0336

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Configure 'Enforce drive encryption type on fixed data drives'

Rule Ensure 'Enforce drive encryption type on fixed data drives' is set to 'Enabled' -> Select the Encryption Type: 'Full Encryption'.

E01 - Already encrypted storage

This rule is not mandatory, if all local drives are encrypted with an AES256 equivalent cipher (or stronger) by other means (e.g., storage solution with encryption capabilities).

Description

This policy setting determines the encryption type used by BitLocker Drive Encryption.

Note: The encryption type must be selected before the drive is encrypted. This rule has no effect on already BitLocker encrypted drives.

Rationale

Only 'Full Encryption' guarantees that relevant data is not stored in an unencrypted area of the drive.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` -> Select the Encryption Type: `Full Encryption`.

Computer Configuration\Policies\Administrative Templates\BitLocker Drive Encryption\Fixed Data Drives\Enforce drive encryption type on fixed data drives

Impact:

The drive is encrypted with a strong algorithm. Without the BitLocker decryption (or recovery) key reading data is not possible.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Combined both exemptions into one. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Operating System Drives

BL968-0491

Asset Manager

C	I	A
123	123	123

Configure 'Allow network unlock at startup'

Rule

Ensure 'Allow network unlock at startup' is set to 'Enabled'.

Description

This policy setting determines whether a BitLocker protected TPM-enabled computer can be unlocked remotely after a reboot.

More information can be found here: [Microsoft IT Pro Center - BitLocker: How to enable Network Unlock](#).

Rationale

Operating system volumes that are protected by TPM+PIN protectors require a PIN after reboot. This might be a challenge for datacenter personnel when many systems have to be rebooted all at once. By enabling this policy setting, administrators can use a BitLocker Network Unlock certificate to remotely enter the PIN to unlock BitLocker after a reboot.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Administrative Templates\BitLocker Drive Encryption\Operating System Drives\Allow network unlock at startup

Impact:

Clients configured with a BitLocker Network Unlock certificate will be able to be rebooted remotely using a BitLocker Network Unlock certificate.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1871

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Choose how BitLocker-protected operating system drives can be recovered' is set to 'Disabled'

Rule

Ensure 'Choose how BitLocker-protected operating system drives can be recovered' is set to 'Disabled'.

Description

Microsoft includes specific BitLocker settings depending on the purpose of the disk drive. In particular in this rule, we focus on the following two types:

- Operating System drive: This is the drive where the operating system is installed.
- Fixed data drives: These drives contain only data but are not (easily) removable compared to a USB stick.

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker.

Rationale

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data. Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\BitLocker Drive Encryption\Operating System Drives\Choose how BitLocker-protected operating system drives can be recovered.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).

BL968-0331

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Configure 'Configure minimum PIN length for startup'

Rule

Ensure 'Configure minimum PIN length for startup' is set to 'Enabled' -> Minimum characters: '8' or more.

Description

This policy determines the minimum length for a Trusted Platform Module (TPM) startup PIN.

Rationale

To get access to data on an encrypted drive the knowledge of the startup PIN is required. As this PIN must also protect lost or stolen drives encrypted with BitLocker from offline attacks, the PIN length must be set at least to 8 characters.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled -> Minimum characters: '8' or more

Computer Configuration\Policies\Administrative Templates\BitLocker Drive Encryption\Operating System Drives\Configure minimum PIN length for startup

Impact:

To access the BitLocker Key stored on TPM, a 8-digit PIN is required for startup.

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed required PIN length to 8 chars. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0291

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Configure 'Enforce drive encryption type on operating system drives'

Rule Ensure 'Enforce drive encryption type on operating system drives' is set to 'Enabled' -> Select the encryption type: 'Full Encryption'.

E01 - Already encrypted storage

This rule is not mandatory, if all local drives are encrypted with an AES256 equivalent cipher (or stronger) by other means (e.g., storage solution with encryption capabilities).

Description

This policy setting determines the encryption type used by BitLocker Drive Encryption.

Note: The encryption type must be selected before the drive is encrypted. This rule has no effect on already BitLocker encrypted drives.

Rationale

Only 'Full Encryption' applied immediately after installing the Operating System, guarantees that no relevant data is stored in an unencrypted area of the drive.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled -> Select the encryption type: Full encryption

Computer Configuration\Policies\Administrative Templates\BitLocker Drive Encryption\Operating System Drives\Enforce drive encryption type on operating data drives

Impact:

BitLocker encryption on System Drives will be enforced.

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Combined both exemptions into one. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0841

Asset Manager

C	I	A
123	123	123

Configure 'Require additional authentication at startup'

Rule

- Ensure 'Require additional authentication at startup' is set to 'Enabled'.
- Ensure 'Allow BitLocker without a compatible TPM' is unchecked.
- Ensure 'Settings for computers with a TPM:' is set to
 - Configure TPM startup: Do not allow TPM
 - Configure TPM startup PIN: Require startup PIN with TPM
 - Configure TPM startup key: Allow startup key with TPM
 - Configure TPM startup key and PIN: Allow startup key and PIN with TPM.

Description

Microsoft Windows Server 2016 allows you to set up pre-boot authentication protection, which forces users to authenticate before initializing the operating system. The BitLocker encryption key is retrieved from the TPM chip only after this authentication succeeds.

Rationale

Additional authentication options make it harder for an attacker with physical access to a server to get access to company proprietary data on an encrypted drive.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` and configure the other settings as follows:

Setting	Value
Allow BitLocker without a compatible TPM	false (unchecked)
Configure TPM startup	Do not allow TPM
Configure TPM startup PIN	Require startup PIN with TPM
Configure TPM startup key	Allow startup key with TPM
Configure TPM startup key and PIN	Allow startup key and PIN with TPM

Computer Configuration\Policies\Administrative Templates\Windows Components\BitLocker Drive Encryption\Operating System Drives\Require additional authentication at startup

Impact:

To unlock BitLocker (e.g., after reboot) the PIN for the TPM is required to get access to the BitLocker key stored on the TPM chip.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Removable Data Drives

This section contains rules for Removable Data Drives policy.

BL968-9206

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Choose how BitLocker-protected removable drives can be recovered' is set to 'Disabled'

Rule

Ensure 'Choose how BitLocker-protected removable drives can be recovered' is set to 'Disabled'.

Description

Microsoft Windows includes the built-in full disk and volume encryption feature BitLocker Drive Encryption (BDE) which, apart from encrypting fixed drives, can be used to encrypt removable drives (also known as *BitLocker To Go*).

You can protect a *BitLocker To Go* encrypted device either with a smart card, a password, or with a combination of both.

Rationale

If an unencrypted USB memory stick or poorly configured (e.g., short password, weak cipher, only used disk space encrypted) gets lost or stolen, any person who finds the USB stick can plug in it to his or her computer and see the content on the stick if it is unencrypted or try to access it by guessing the password or exploiting a weakness of the cipher.

While a USB stick protected with a smart card can only be used if you have the smart card and the associated PIN, a malicious user might try to discover the password of an only password protected USB stick by using a brute-force attack.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled:

Computer Configuration\Policies\Administrative Templates\Windows Components\BitLocker Drive Encryption\Removable Data Drives\Choose how BitLocker-protected removable drives can be recovered.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).

BL968-1101

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Configure the policy 'Configure use of passwords for removable data drives'

Rule

Enable the setting 'Configure use of passwords for removable data drives' and set the options as follows:

- Select the value `Require password complexity` in the drop-down list,
- Set the option 'Minimum password length for removable data drive' to 15.

Note: The encryption password for removable data drives is exempt from the password change requirements of the *Specific Information Security Policy: Access Control* [Rule ID: 09.4.3-04](#).

Description

Microsoft Windows includes the built-in full disk and volume encryption feature BitLocker Drive Encryption (BDE) which, apart from encrypting fixed drives, can be used to encrypt removable drives (also known as *BitLocker To Go*).

You can protect a *BitLocker To Go* encrypted device either with a smart card, a password, or with a combination of both.

Rationale

If an unencrypted USB memory stick or poorly configured (e.g., short password, weak cipher, only used disk space encrypted) gets lost or stolen, any person who finds the USB stick can plug in it to his or her computer and see the content on the stick if it is unencrypted or try to access it by guessing the password or exploiting a weakness of the cipher.

While a USB stick protected with a smart card can only be used if you have the smart card and the associated PIN, a malicious user might try to discover the password of an only password protected USB stick by using a brute-force attack.

I01 - Implementation Example

To set the protection level to the desired state set the following Group Policy setting to `Enabled`

Computer Configuration\Policies\Administrative Templates\Windows Components\BitLocker Drive Encryption\Removable Data Drives\Configure use of passwords for removable data drives

and set the options as follows:

- Select the value `Require password complexity` in the drop-down list,
- Set the option *Minimum password length for removable data drive* to 15.

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).

BL968-1671

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Configure the policy 'Control use of BitLocker on removable drives'

Rule

Enable the setting 'Control use of BitLocker on removable drives' and set the options 'Allow users to apply BitLocker protection on removable data drives', and 'Allow users to suspend and decrypt BitLocker protection on removable data drives'.

Description

Microsoft Windows includes the built-in full disk and volume encryption feature BitLocker Drive Encryption (BDE) which, apart from encrypting fixed drives, can be used to encrypt removable drives (also known as *BitLocker To Go*).

You can protect a *BitLocker To Go* encrypted device either with a smart card, a password, or with a combination of both.

Rationale

If an unencrypted USB memory stick or poorly configured (e.g., short password, weak cipher, only used disk space encrypted) gets lost or stolen, any person who finds the USB stick can plug in it to his or her computer and see the content on the stick if it is unencrypted or try to access it by guessing the password or exploiting a weakness of the cipher.

While a USB stick protected with a smart card can only be used if you have the smart card and the associated PIN, a malicious user might try to discover the password of an only password protected USB stick by using a brute-force attack.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled:

Computer Configuration\Policies\Administrative Templates\Windows Components\BitLocker Drive Encryption\Removable Data Drives\Control use of BitLocker on removable drives

and set the checkbox options Allow users to apply BitLocker protection on removable data drives, and Allow users to suspend and decrypt BitLocker protection on removable data drives to a ticked state.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).

BL968-0626

Asset Manager

C	I	A
123	123	123

Configure 'Enforce drive encryption type on removable data drives'

Rule Ensure 'Enforce drive encryption type on removable data drives' is set to 'Enabled' -> Select the encryption type: 'Full Encryption'.

Description

This policy setting determines the encryption type used by BitLocker Drive Encryption.

Note: The encryption type must be selected before the drive is encrypted. This rule has no effect on already BitLocker encrypted drives.

Rationale

Only 'Full Encryption' guarantees that no relevant data is stored in an unencrypted area of the drive.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled -> Select the encryption type: Full Encryption:

Computer Configuration\Policies\Administrative Templates\BitLocker Drive Encryption\Removable Data Drives\Enforce drive encryption type on removable data drives

Impact:

Without BitLocker decryption (which requires a PIN/password or a recovery key) the data on the drive cannot be read.

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Camera

This section contains recommendations related to Camera.

This Group Policy section is provided by the Group Policy template `Camera.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

BL968-5171

Asset Manager



Ensure 'Allow Use of Camera' is set to 'Disabled'

Rule

Ensure 'Allow Use of Camera' is set to 'Disabled'.

Description

This policy setting controls whether the use of Camera devices on the machine are permitted.

Rationale

Cameras in a high security environment can pose serious privacy and data exfiltration risks - they should be disabled to help mitigate that risk.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Camera\Allow Use of Camera

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `Camera.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Users will not be able to utilize the camera on a system.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Camera:AllowCamera
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.12.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Cloud Content

This section contains recommendations related to Cloud Content.

This Group Policy section is provided by the Group Policy template `CloudContent.admx/adml` that is included with the Microsoft Windows 10 Release 1511 Administrative Templates (or newer).

BL968-4451

Asset Manager



Ensure 'Turn off Microsoft consumer experiences' is set to 'Enabled'

Rule

Ensure 'Turn off Microsoft consumer experiences' is set to 'Enabled'.

Description

This policy setting turns off experiences that help consumers make the most of their devices and Microsoft account.

Note: [Per Microsoft TechNet](#) , this policy setting only applies to Windows 10 Enterprise and Windows 10 Education editions.

Rationale

Having apps silently install in an enterprise managed environment is not good security practice - especially if the apps send data back to a 3rd party.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Administrative Templates\Windows
Components\Cloud Content\Turn off Microsoft consumer experiences

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `CloudContent.admx/adml` that is included with the Microsoft Windows 10 Release 1511 Administrative Templates (or newer).

Impact:

Users will no longer see personalized recommendations from Microsoft and notifications about their Microsoft account.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\CloudContent:DisableWindowsConsumerFeatures
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.13.1

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Connect

This section contains recommendations related to Connect.

This Group Policy section is provided by the Group Policy template `WirelessDisplay.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

BL968-2036

Asset Manager

EVAL until 2022-02-28



Ensure 'Require pin for pairing' is set to 'Enabled'

Rule

Ensure 'Require pin for pairing' is set to 'Enabled'.

Description

This policy setting controls whether or not a PIN is required for pairing to a wireless display device.

Rationale

If this setting is not configured or disabled then a PIN would not be required when pairing wireless display devices to the system, increasing the risk of unauthorized use.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Connect\Require pin for pairing

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `WirelessDisplay.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

The pairing ceremony for connecting to new wireless display devices will always require a PIN.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Connect:RequirePinForPairing
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.14.1

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed during review: Fixed value in compliance with 1607, added Check section. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Credential User Interface

This section contains recommendations related to the Credential User Interface.

This Group Policy section is provided by the Group Policy template `CredUI.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-3081

Asset Manager



Ensure 'Do not display the password reveal button' is set to 'Enabled'

Rule

Ensure 'Do not display the password reveal button' is set to 'Enabled'.

Description

This policy setting allows you to configure the display of the password reveal button in password entry user experiences.

Rationale

This is a useful feature when entering a long and complex password, especially when using a touchscreen. The potential risk is that someone else may see your password while surreptitiously observing your screen.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Credential User Interface\Do not display the password reveal button

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `CredUI.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

The password reveal button will not be displayed after a user types a password in the password entry text box.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\CredUI:DisablePasswordReveal
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.15.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1991

Asset Manager

C	I	A
123	123	123

Ensure 'Enumerate administrator accounts on elevation' is set to 'Disabled'

Rule

Ensure 'Enumerate administrator accounts on elevation' is set to 'Disabled'.

Description

This policy setting controls whether administrator accounts are displayed when a user attempts to elevate a running application.

Rationale

Users could see the list of administrator accounts, making it slightly easier for a malicious user who has logged onto a console session to try to crack the passwords of those accounts.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled` :

Computer Configuration\Policies\Administrative Templates\Windows Components\Credential User Interface\Enumerate administrator accounts on elevation

Note: This Group Policy path is provided by the Group Policy template `CredUI.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\CredUI:EnumerateAdministrators
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.15.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Data Collection and Preview Builds

This section contains settings for Data Collection and Preview Builds.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

BL968-4046

Asset Manager



Ensure 'Allow Telemetry' is set to 'Enabled 0 - Security [Enterprise Only]'

Rule

Ensure 'Allow Telemetry' is set to 'Enabled: 0 - Security [Enterprise Only]'.

Description

This policy setting determines the amount of diagnostic and usage data reported to Microsoft:

- A value of 0 - Security [Enterprise Only] will send minimal data to Microsoft. This data includes Malicious Software Removal Tool (MSRT) & Windows Defender data, if enabled, and telemetry client settings. Setting a value of 0 applies to enterprise, EDU, IoT and server devices only. Setting a value of 0 for other devices is equivalent to choosing a value of 1.
- A value of 1 - Basic sends only a basic amount of diagnostic and usage data. Note that setting values of 0 or 1 will degrade certain experiences on the device.
- A value of 2 - Enhanced sends enhanced diagnostic and usage data.
- A value of 3 - Full sends the same data as a value of 2, plus additional diagnostics data, including the files and content that may have caused the problem.

Windows 10 telemetry settings apply to the Windows operating system and some first party apps. This setting does not apply to third party apps running on Windows 10.

Note: If the *Allow Telemetry* setting is configured to 0 - Security [Enterprise Only], then the options in Windows Update to defer upgrades and updates will have no effect.

Note #2: In the Microsoft Windows 10 RTM (Release 1507) Administrative Templates, the zero value was initially named 0 - Off [Enterprise Only], but it was renamed to 0 - Security [Enterprise Only] starting with the Windows 10 Release 1511 Administrative Templates.

Rationale

Sending any data to a 3rd party vendor is a security concern and should only be done on an as needed basis.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled: 0** – Security [Enterprise Only]:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Data Collection and Preview Builds\Allow Telemetry

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template DataCollection.admx/adml that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

Impact:

Note that setting values of 0 or 1 will degrade certain experiences on the device.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\DataCollection:AllowTelemetry
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.16.1

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4646

Asset Manager

C	I	A
123	123	123

Ensure 'Do not show feedback notifications' is set to 'Enabled'

Rule

Ensure 'Do not show feedback notifications' is set to 'Enabled'.

Description

This policy setting allows an organization to prevent its devices from showing feedback questions from Microsoft.

Rationale

Users should not be sending any feedback to 3rd party vendors in an enterprise managed environment.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Data Collection and Preview Builds\Do not show feedback
notifications

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `FeedbackNotifications.admx/adml` that is included with the Microsoft Windows 10 Release 1511 Administrative Templates (or newer).

Impact:

Users will no longer see feedback notifications through the Windows Feedback app.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\DataCollection:DoNotShowFeedbackNotifications
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.16.3

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5871

Asset Manager

C	I	A
123	123	123

Ensure 'Toggle user control over Insider builds' is set to 'Disabled'

Rule

Ensure 'Toggle user control over Insider builds' is set to 'Disabled'.

Description

This policy setting determines whether users can access the Insider build controls in the Advanced Options for Windows Update. These controls are located under "Get Insider builds," and enable users to make their devices available for downloading and installing Windows preview software.

Note: This policy setting applies only to devices running Windows Server 2016, up until Release 1703. For Release 1709 or newer, Microsoft encourages using the `Manage preview builds` setting (Rule 18.9.102.1.1). We have kept this setting in the benchmark to ensure that any older builds of Windows Server 2016 in the environment are still enforced.

Rationale

It can be risky for experimental features to be allowed in an enterprise managed environment because this can introduce bugs and security holes into systems, making it easier for an attacker to gain access. It is generally preferred to only use production-ready builds. Additionally, Microsoft reserves itself enhanced rights to collect operational data of your client for analysis purposes. These rights might be even extended as such that Microsoft may connect to your client to retrieve data required to solve specific problems identified on your client.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Data Collection and Preview Builds\Toggle user control over Insider builds

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `AllowBuildPreview.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

Impact:

The item "Get Insider builds" will be unavailable.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PreviewBuilds:AllowBuildPreview
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.16.4

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Event Log Service

This section contains recommendations for configuring the Event Log Service.

This Group Policy section is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Application

This section contains recommendations for configuring the Application Event Log.

This Group Policy section is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-0077

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Application: Back up log automatically when full' is set to 'Enabled'

Rule

Ensure 'Application: Back up log automatically when full' is set to 'Enabled'.

E01 - Dedicated log server

If it is ensured, that **all** log entries will be transferred regularly to a dedicated log server, then this rule can be set to `Not configured` or `Disabled`.

E02 - Regular backup of log files

If it is ensured, that log files will be automatically backed up in the server backup and the configured maximum size of the log files is sufficient enough to cover the backup period, then this rule can be set to `Not configured` or `Disabled`. Additionally, it needs to be ensured that the log files can be restored from the backup in time for forensic investigations.

Description

This policy setting controls Event Log behavior when the log file reaches its maximum size.

When the log file reaches the maximum size (see: [BL968-0007 Ensure 'Application: Specify the maximum log file size \(KB\)' is set to 'Enabled: 131,072 or greater'](#)) and this rule is set to `Disabled`, then new events will overwrite old events.

Note: The policy setting `Computer Configuration\Policies\Windows Settings\Security Settings\Event Log\Retention method for application log` will be overwritten and might be set to `Not Defined`.

Rationale

Security log files are the basis for analyzing security incidents. Thus, such log files must be retained for a proper period of time. Siemens CHR Circular No. 44/2013 [3] regulates retention periods, analysis, and access prerequisites in Germany.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Event Log Service\Application\Back up log automatically when full

Impact:

If all three rules ,

- [BL968-0077](#) Ensure 'Application: Back up log automatically when full' is set to 'Enabled'
- [BL968-0088](#) Ensure 'Application: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'
- [BL968-0007](#) Ensure 'Application: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'

are set as described, then archive files in `%SYSTEMROOT%\System32\winevt\Logs` of 128 MB will be written.

Note: The name of the backup file is of the format `Archive-Security-<year>-<month>-<day>-<hour>-<minute>-<second>`.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Changed during review: Added exemption for server backup including log files. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0088

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Application: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'

Rule Ensure 'Application: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'.

E01 - Dedicated log server

If it is ensured, that **all** log entries will be transferred regularly to a dedicated log server, then this rule can be set to `Not configured` or `Disabled`.

E02 - Regular backup of log files

If it is ensured, that log files will be automatically backed up in the server backup and the configured maximum size of the log files is sufficient enough to cover the backup period, then this rule can be set to `Not configured` or `Disabled`. Additionally, it needs to be ensured that the log files can be restored from the backup in time for forensic investigations.

Description

This policy setting controls Event Log behavior when the log file reaches its maximum size.

Note: Old events may or may not be retained according to the *Backup log automatically when full* policy setting.

Rationale

If new events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users. Thus, such log files must be retained for a proper period of time and are not allowed to be overwritten automatically. Siemens CHR Circular No. 44/2013 [3] regulates retention periods, analysis, and access prerequisites in Germany.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service\Application\Control Event Log behavior when the log file reaches its maximum size

Note: This Group Policy path is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was initially named *Retain old events*, but it was renamed starting with the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

Impact:

If all three rules

- [BL968-0077](#) Ensure 'Application: Back up log automatically when full' is set to 'Enabled'
- [BL968-0088](#) Ensure 'Application: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'
- [BL968-0007](#) Ensure 'Application: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'

are set as described, then all event logs are archived in files located in
%SYSTEMROOT%\System32\winevt\Logs.

Note: The name of the backup file is of the format `Archive-Security-<year>-<month>-<day>-<hour>-<minute>-<second>`.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\Application:Retention
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.26.1.1

[Based on Siemens Information Security Policy Framework Rule 16.1.7-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-04](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Changed during review: Added exemption for server backup including log files. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0007

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Application: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'

Rule

Ensure 'Application: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'.

E01 - Dedicated log server

If it is ensured, that **all** log entries will be transferred regularly to a dedicated log server, then this rule can be set to Not configured or Disabled.

Description

This policy setting specifies the maximum size of the log file in kilobytes. The maximum log file size can be configured between 1 megabyte (1,024 kilobytes) and 4 terabytes (4,194,240 kilobytes) in kilobyte increments.

Rationale

All computers at Siemens should have sensible log size policy settings enabled so that unauthorized activity can be detected and tracked, and system problems can be detected and diagnosed.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled: 131,072 or greater**:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Event Log Service\Application\Specify the maximum log file size (KB)

Note: This Group Policy path is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was initially named *Maximum Log Size (KB)*, but it was renamed starting with the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method for each is set so that the computer will overwrite the oldest entries with the most recent ones. To mitigate the risk of loss of recent data, you can configure the retention method so that older events are overwritten as needed.

The consequence of this configuration is that older events will be removed from the logs. Attackers can take advantage of such a configuration, because they can generate a large number of extraneous events to overwrite any evidence of their attack. These risks can be somewhat reduced if you automate the archival and backup of event log data.

Ideally, all specifically monitored events should be sent to a server that uses Microsoft System Center Operations Manager (SCOM) or some other automated monitoring tool. Such a configuration is particularly important because an attacker who successfully compromises a server could clear the Security log. If all events are sent to a monitoring server, then you will be able to gather forensic information about the attacker's activities.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\Application:MaxSize
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.26.1.2

[Based on Siemens Information Security Policy Framework Rule 16.1.7-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-04](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Aligned with Siemens Windows Server 2019 (BL942).

Security

This section contains recommendations for configuring the Security Event Log.

This Group Policy section is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-2599

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Security: Back up log automatically when full' is set to 'Enabled'

Rule

Ensure 'Security: Back up log automatically when full' is set to 'Enabled'.

E01 - Dedicated log server

If it is ensured that **all** log entries will be transferred regularly to a dedicated log server, then this rule can be set to `Not configured` or `Disabled`.

E02 - Regular backup of log files

If it is ensured, that log files will be automatically backed up in the server backup and the configured maximum size of the log files is sufficient enough to cover the backup period, then this rule can be set to `Not configured` or `Disabled`. Additionally, it needs to be ensured that the log files can be restored from the backup in time for forensic investigations.

Description

This policy setting controls Event Log behavior when the log file reaches its maximum size.

When the log file reaches the maximum size (see: [BL968-0044 Ensure 'Security: Specify the maximum log file size \(KB\)' is set to 'Enabled: 524,288 or greater'](#)) and this rule is set to `Disabled`, then new events will overwrite old events.

Note: The policy setting `Computer Configuration\Policies\Windows Settings\Security Settings\Event Log\Retention method for security log` will be overwritten and might be set to `Not Defined`.

Rationale

Security log files are the basis for analyzing security incidents. Thus, such log files must be retained for a proper period of time. Siemens CHR Circular No. 44/2013 [3] regulates retention periods, analysis, and access prerequisites in Germany.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Event Log Service\Security\Back up log automatically when full

Impact:

If all three rules

- [BL968-2599](#) Ensure 'Security: Back up log automatically when full' is set to 'Enabled'
- [BL968-0098](#) Ensure 'Security: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'
- [BL968-0044](#) Ensure 'Security: Specify the maximum log file size (KB)' is set to 'Enabled: 524,288 or greater'

are set as described, then archive files in `%SYSTEMROOT%\System32\winevt\Logs` of 512 MB will be written.

Note: The name of the backup file is of the format `Archive-Security-<year>-<month>-<day>-<hour>-<minute>-<second>`.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Changed during review: Added exemption for server backup including log files. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0098

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Security: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'

Rule Ensure 'Security: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'.

E01 - Dedicated log server

If it is ensured, that **all** log entries will be transferred regularly to a dedicated log server, then this rule can be set to `Not configured` or `Disabled`.

E02 - Regular backup of log files

If it is ensured, that log files will be automatically backed up in the server backup and the configured maximum size of the log files is sufficient enough to cover the backup period, then this rule can be set to `Not configured` or `Disabled`. Additionally, it needs to be ensured that the log files can be restored from the backup in time for forensic investigations.

Description

This policy setting controls Event Log behavior when the log file reaches its maximum size.

Note: Old events may or may not be retained according to the *Backup log automatically when full* policy setting.

Rationale

Security log files are the basis for analyzing security incidents. Thus, such log files must be retained for a proper period of time and are not allowed to be overwritten automatically. Siemens CHR Circular No. 44/2013 [3] regulates retention periods, analysis, and access prerequisites in Germany.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service\Security\Control Event Log behavior when the log file reaches its maximum size

Note: This Group Policy path is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was initially named *Retain old events*, but it was renamed starting with the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

Impact:

If all three rules

- [BL968-2599](#) Ensure 'Security: Back up log automatically when full' is set to 'Enabled'
- [BL968-0098](#) Ensure 'Security: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'
- [BL968-0044](#) Ensure 'Security: Specify the maximum log file size (KB)' is set to 'Enabled: 524,288 or greater'

are set as described, then all event logs are archived in files located in
%SYSTEMROOT%\System32\winevt\Logs.

Note: The name of the backup file is of the format Archive-Security-<year>-<month>-<day>-<hour>-<minute>-<second>.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\Security:Retention
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.26.2.1

[Based on Siemens Information Security Policy Framework Rule 16.1.7-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-04](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Changed during review: Added exemption for server backup including log files. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0044

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Security: Specify the maximum log file size (KB)' is set to 'Enabled: 524,288 or greater'

Rule Ensure 'Security: Specify the maximum log file size (KB)' is set to 'Enabled: 524,288 or greater'.

E01 - Dedicated log server

If it is ensured, that **all** log entries will be transferred regularly to a dedicated log server, then this rule can be set to Not configured or Disabled.

Description

This policy setting specifies the maximum size of the log file in kilobytes. The maximum log file size can be configured between 1 megabyte (1,024 kilobytes) and 4 terabytes (4,194,240 kilobytes) in kilobyte increments.

Rationale

All computers at Siemens should have sensible log size policy settings enabled so that unauthorized activity can be detected and tracked, and system problems can be detected and diagnosed.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled: 524,288 or greater:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Event Log Service\Security\Specify the maximum log file size (KB)

Note: This Group Policy path is provided by the Group Policy template EventLog.admx/adml that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was initially named *Maximum Log Size (KB)*, but it was renamed starting with the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method for each is set so that the computer will overwrite the oldest entries with the most recent ones. To mitigate the risk of loss of recent data, you can configure the retention method so that older events are overwritten as needed.

The consequence of this configuration is that older events will be removed from the logs. Attackers can take advantage of such a configuration, because they can generate a large number of extraneous events to overwrite any evidence of their attack. These risks can be somewhat reduced if you automate the archival and backup of event log data.

Ideally, all specifically monitored events should be sent to a server that uses Microsoft System Center Operations Manager (SCOM) or some other automated monitoring tool. Such a configuration is particularly important because an attacker who successfully compromises a server could clear the Security log. If all events are sent to a monitoring server, then you will be able to gather forensic information about the attacker's activities.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\Security:MaxSize
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.26.2.2

[Based on Siemens Information Security Policy Framework Rule 16.1.7-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-04](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Aligned with Siemens Windows Server 2019 (BL942).

Setup

This section contains recommendations for configuring the Setup Event Log.

This Group Policy section is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-4888

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Setup: Back up log automatically when full' is set to 'Enabled'

Rule

Ensure 'Setup: Back up log automatically when full' is set to 'Enabled'.

E01 - Dedicated log server

If it is ensured that **all** log entries will be transferred regularly to a dedicated log server, then this rule can be set to `Not configured` or `Disabled`.

E02 - Regular backup of log files

If it is ensured, that log files will be automatically backed up in the server backup and the configured maximum size of the log files is sufficient enough to cover the backup period, then this rule can be set to `Not configured` or `Disabled`. Additionally, it needs to be ensured that the log files can be restored from the backup in time for forensic investigations.

Description

This policy setting controls Event Log behavior when the log file reaches its maximum size.

When the log file reaches the maximum size (see: [BL968-7113 Ensure 'Setup: Specify the maximum log file size \(KB\)' is set to 'Enabled: 131,072 or greater'](#)) and this rule is set to `Disabled`, then new events will overwrite old events.

Rationale

Security log files are the basis for analyzing security incidents. Thus, such log files must be retained for a proper period of time. Siemens CHR Circular No. 44/2013 [3] regulates retention periods, analysis, and access prerequisites in Germany.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Event Log Service\Setup\Back up log automatically when full

Impact:

If all three rules

- [BL968-4888](#) Ensure 'Setup: Back up log automatically when full' is set to 'Enabled'
- [BL968-4860](#) Ensure 'Setup: Control Event Log behavior when the log file reaches its maximum size' is set to 'Disabled'
- [BL968-7113](#) Ensure 'Setup: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'

are set as described, then archive files in %SYSTEMROOT%\System32\winevt\Logs of 128 MB will be written.

Note: The name of the backup file is of the format Archive-Setup-<year>-<month>-<day>-<hour>-<minute>-<second>.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Changed during review: Added exemption for server backup including log files. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4860

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Setup: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'

Rule Ensure 'Setup: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'.

E01 - Dedicated log server

If it is ensured, that **all** log entries will be transferred regularly to a dedicated log server, then this rule can be set to `Not configured` or `Disabled`.

E02 - Regular backup of log files

If it is ensured, that log files will be automatically backed up in the server backup and the configured maximum size of the log files is sufficient enough to cover the backup period, then this rule can be set to `Not configured` or `Disabled`. Additionally, it needs to be ensured that the log files can be restored from the backup in time for forensic investigations.

Description

This policy setting controls Event Log behavior when the log file reaches its maximum size.

Note: Old events may or may not be retained according to the *Backup log automatically when full* policy setting.

Rationale

Security log files are the basis for analyzing security incidents. Thus, such log files must be retained for a proper period of time and are not allowed to be overwritten automatically. Siemens CHR Circular No. 44/2013 [3] regulates retention periods, analysis, and access prerequisites in Germany.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service\Setup\Control Event Log behavior when the log file reaches its maximum size

Note: This Group Policy path is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was initially named *Retain old events*, but it was renamed starting with the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

Impact:

If all three rules

- [BL968-4888](#) Ensure 'Setup: Back up log automatically when full' is set to 'Enabled'
- [BL968-4860](#) Ensure 'Setup: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'
- [BL968-7113](#) Ensure 'Setup: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'

are set as described, then all event logs are archived in files located in
%SYSTEMROOT%\System32\winevt\Logs.

Note: The name of the backup file is of the format Archive-Security-<year>-<month>-<day>-<hour>-<minute>-<second>.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\Setup:Retention
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.26.3.1

[Based on Siemens Information Security Policy Framework Rule 16.1.7-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-04](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Changed during review: Added exemption for server backup including log files. This rule is not consistent with the CIS recommendation.

BL968-7113

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Setup: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'

Rule Ensure 'Setup: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'.

E01 - Dedicated log server

If it is ensured, that **all** log entries will be transferred regularly to a dedicated log server, then this rule can be set to Not configured or Disabled.

Description

This policy setting specifies the maximum size of the log file in kilobytes. The maximum log file size can be configured between 1 megabyte (1,024 kilobytes) and 4 terabytes (4,194,240 kilobytes) in kilobyte increments.

Rationale

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled: 131,072 or greater**:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Event Log Service\Setup\Specify the maximum log file size (KB)

Note: This Group Policy path is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was initially named *Maximum Log Size (KB)*, but it was renamed starting with the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method for each is set so that the computer will overwrite the oldest entries with the most recent ones. To mitigate the risk of loss of recent data, you can configure the retention method so that older events are overwritten as needed.

The consequence of this configuration is that older events will be removed from the logs. Attackers can take advantage of such a configuration, because they can generate a large number of extraneous events to overwrite any evidence of their attack. These risks can be somewhat reduced if you automate the archival and backup of event log data.

Ideally, all specifically monitored events should be sent to a server that uses Microsoft System Center Operations Manager (SCOM) or some other automated monitoring tool. Such a configuration is particularly important because an attacker who successfully compromises a server could clear the Security log. If all events are sent to a monitoring server, then you will be able to gather forensic information about the attacker's activities.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\Setup:MaxSize
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.26.3.2

[Based on Siemens Information Security Policy Framework Rule 16.1.7-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-04](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is nearly consistent with the CIS recommendation. Increased size from 32,768 KB to 131,072 kb. Aligned with Siemens Windows Server 2019 (BL942).

System

This section contains recommendations for configuring the System Event Log.

This Group Policy section is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-0020

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'System: Back up log automatically when full' is set to 'Enabled'

Rule

Ensure 'System: Back up log automatically when full' is set to 'Enabled'.

E01 - Dedicated log server

If it is ensured that **all** log entries will be transferred regularly to a dedicated log server, then this rule can be set to `Not configured` or `Disabled`.

E02 - Regular backup of log files

If it is ensured, that log files will be automatically backed up in the server backup and the configured maximum size of the log files is sufficient enough to cover the backup period, then this rule can be set to `Not configured` or `Disabled`. Additionally, it needs to be ensured that the log files can be restored from the backup in time for forensic investigations.

Description

This policy setting controls Event Log behavior when the log file reaches its maximum size.

When the log file reaches the maximum size (see: [BL968-4701 Ensure 'System: Specify the maximum log file size \(KB\)' is set to 'Enabled: 131,072 or greater'](#)) and this rule is set to `Disabled`, then new events will overwrite old events.

Note: The policy setting `Computer Configuration\Policies\Windows Settings\Security Settings\Event Log\Retention method for system log` will be overwritten and might be set to `Not Defined`.

Rationale

Security log files are the basis for analyzing security incidents. Thus, such log files must be retained for a proper period of time. Siemens CHR Circular No. 44/2013 [3] regulates retention periods, analysis, and access prerequisites in Germany.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Event Log Service\System\Back up log automatically when full

Impact:

If all three rules

- [BL968-0020](#) Ensure 'System: Back up log automatically when full' is set to 'Enabled'
- [BL968-6125](#) Ensure 'System: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'
- [BL968-4701](#) Ensure 'System: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'

are set as described, then archive files in %SYSTEMROOT%\System32\winevt\Logs of 128 MB will be written.

Note: The name of the backup file is of the format Archive-Security-<year>-<month>-<day>-<hour>-<minute>-<second>.

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Changed during review: Added exemption for server backup including log files. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-6125

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'System: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'

Rule Ensure 'System: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'.

E01 - Dedicated log server

If it is ensured, that **all** log entries will be transferred regularly to a dedicated log server, then this rule can be set to `Not configured` or `Disabled`.

E02 - Regular backup of log files

If it is ensured, that log files will be automatically backed up in the server backup and the configured maximum size of the log files is sufficient enough to cover the backup period, then this rule can be set to `Not configured` or `Disabled`. Additionally, it needs to be ensured that the log files can be restored from the backup in time for forensic investigations.

Description

This policy setting controls Event Log behavior when the log file reaches its maximum size.

Note: Old events may or may not be retained according to the *Backup log automatically when full* policy setting.

Rationale

Security log files are the basis for analyzing security incidents. Thus, such log files must be retained for a proper period of time and are not allowed to be overwritten automatically. Siemens CHR Circular No. 44/2013 [3] regulates retention periods, analysis, and access prerequisites in Germany.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Event Log Service\System\Control Event Log behavior when the log file reaches its maximum size

Note: This Group Policy path is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was initially named *Retain old events*, but it was renamed starting with the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

Impact:

If all three rules

- [BL968-0020](#) Ensure 'System: Back up log automatically when full' is set to 'Enabled'
- [BL968-6125](#) Ensure 'System: Control Event Log behavior when the log file reaches its maximum size' is set to 'Enabled'
- [BL968-4701](#) Ensure 'System: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'

are set as described, then archive files in %SYSTEMROOT%\System32\winevt\Logs of 128 MB will be written.

Note: The name of the backup file is of the format Archive-Security-<year>-<month>-<day>-<hour>-<minute>-<second>.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\System:Retention
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.26.4.1

[Based on Siemens Information Security Policy Framework Rule 16.1.7-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-04](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Changed during review: Added exemption for server backup including log files. Added exemption 01. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4701

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'System: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'

Rule

Ensure 'System: Specify the maximum log file size (KB)' is set to 'Enabled: 131,072 or greater'.

E01 - Dedicated log server

If it is ensured that **all** log entries will be transferred regularly to a dedicated log server, then this rule can be set to Not configured or Disabled.

Description

This policy setting specifies the maximum size of the log file in kilobytes. The maximum log file size can be configured between 1 megabyte (1,024 kilobytes) and 4 terabytes (4,194,240 kilobytes) in kilobyte increments.

Rationale

All computers at Siemens should have sensible log size policy settings enabled so that unauthorized activity can be detected and tracked, and system problems can be detected and diagnosed.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled: 131,072 or greater:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Event Log Service\System\Specify the maximum log file size (KB)

Note: This Group Policy path is provided by the Group Policy template EventLog.admx/adml that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was initially named *Maximum Log Size (KB)*, but it was renamed starting with the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method for each is set so that the computer will overwrite the oldest entries with the most recent ones. To mitigate the risk of loss of recent data, you can configure the retention method so that older events are overwritten as needed.

The consequence of this configuration is that older events will be removed from the logs. Attackers can take advantage of such a configuration, because they can generate a large number of extraneous events to overwrite any evidence of their attack. These risks can be somewhat reduced if you automate the archival and backup of event log data.

Ideally, all specifically monitored events should be sent to a server that uses Microsoft System Center Operations Manager (SCOM) or some other automated monitoring tool. Such a configuration is particularly important because an attacker who successfully compromises a server could clear the Security log. If all events are sent to a monitoring server, then you will be able to gather forensic information about the attacker's activities.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\System:MaxSize
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.26.4.2

[Based on Siemens Information Security Policy Framework Rule 16.1.7-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.4.1-04](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Aligned with Siemens Windows Server 2019 (BL942).

File Explorer (formerly Windows Explorer)

This section contains recommendations to control the availability of options such as menu items and tabs in dialog boxes.

This Group Policy section is provided by the Group Policy template `WindowsExplorer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was initially named *Windows Explorer* but was renamed by Microsoft to *File Explorer* starting with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

BL968-1421

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'File Explorer: Configure Windows Defender SmartScreen' is set to 'Disabled'

Rule

Ensure 'File Explorer: Configure Windows SmartScreen' is set to 'Disabled'.

Description

Windows tags downloads from the Internet with *Zone.Identifier* information. When a tagged file is executed, Windows SmartScreen drops in and checks the file by sending various information to the Microsoft Windows SmartScreen service with the intention to determine if the file is malicious or benign.

Rationale

Due to currently unresolved privacy issues and the fact that the ultimate decision is left to the user, Windows SmartScreen has to be disabled.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\File Explorer\Configure Windows SmartScreen.

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.80.1.1

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not consistent with CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).

BL968-5766

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off Data Execution Prevention for Explorer' is set to 'Disabled'

Rule

Ensure 'Turn off Data Execution Prevention for Explorer' is set to 'Disabled'.

Description

Disabling Data Execution Prevention can allow certain legacy plug-in applications to function without terminating Explorer.

Note: Some legacy plug-in applications and other software may not function with Data Execution Prevention and will require an exception to be defined for that specific plug-in/software. Running such software will require an exception request approved by your [Chief Cybersecurity Officer, CCSO](#).

Rationale

Data Execution Prevention is an important security feature supported by Explorer that helps to limit the impact of certain types of malware.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled:

Computer Configuration\Policies\Administrative Templates\Windows
Components\File Explorer\Turn off Data Execution Prevention for Explorer

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template Explorer.admx/adml that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Explorer:NoDataExecutionPrevention
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.30.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5496

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off heap termination on corruption' is set to 'Disabled'

Rule

Ensure 'Turn off heap termination on corruption' is set to 'Disabled'.

Description

Without heap termination on corruption, legacy plug-in applications may continue to function when a File Explorer session has become corrupt. Ensuring that heap termination on corruption is active will prevent this.

Rationale

Allowing an application to function after its session has become corrupt increases the risk posture to the system.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Administrative Templates\Windows
Components\File Explorer\Turn off heap termination on corruption

Note: This Group Policy path is provided by the Group Policy template `Explorer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Explorer:NoHeapTerminationOnCorruption
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.30.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2881

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off shell protocol protected mode' is set to 'Disabled'

Rule

Ensure 'Turn off shell protocol protected mode' is set to 'Disabled'.

Description

This policy setting allows you to configure the amount of functionality that the shell protocol can have. When using the full functionality of this protocol, applications can open folders and launch files. The protected mode reduces the functionality of this protocol allowing applications to only open a limited set of folders. Applications are not able to open files with this protocol when it is in the protected mode. It is recommended to leave this protocol in the protected mode to increase the security of Windows.

Rationale

Limiting the opening of files and folders to a limited set reduces the attack surface of the system.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\File Explorer\Turn off shell protocol protected mode

Note: This Group Policy path is provided by the Group Policy template `WindowsExplorer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer:PreXPSP2ShellProtocolBehavior
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.30.4

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Location and Sensors

This section contains settings for Locations and Sensors.

This Group Policy section is provided by the Group Policy template `Sensors.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

BL968-4191

Asset Manager



Ensure 'Turn off location' is set to 'Enabled'

Rule

Ensure 'Turn off location' is set to 'Enabled'.

Description

This policy setting turns off the location feature for the computer.

Rationale

This setting affects the location feature (e.g., GPS or other location tracking). From a security perspective, it is not a good idea to reveal your location to software in most cases, but there are legitimate uses, such as mapping software. However, they should not be used in high security environments.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Location and Sensors\Turn off location

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `Sensors.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

Impact:

The location feature is turned off, and all programs on the computer are prevented from using location information from the location feature.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LocationAndSensors:DisableLocation
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.39.1

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

OneDrive (formerly SkyDrive)

This section contains recommendations related to OneDrive.

The Group Policy settings contained within this section are provided by the Group Policy template `SkyDrive.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Note: This section was initially named *SkyDrive* but was renamed by Microsoft to *OneDrive* starting with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates.

BL968-4936

Asset Manager



Ensure 'Prevent the usage of OneDrive for file storage' is set to 'Enabled'

Rule

Ensure 'Prevent the usage of OneDrive for file storage' is set to 'Enabled'.

Description

This policy setting lets you prevent apps and features from working with files on OneDrive using the Next Generation Sync Client.

Rationale

Enabling this setting prevents users from accidentally (or intentionally) uploading confidential or sensitive corporate information to the OneDrive cloud service using the Next Generation Sync Client.

Note: This security concern applies to *any* cloud-based file storage application installed on a server, not just the one supplied with Windows Server.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\OneDrive\Prevent the usage of OneDrive for file storage

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `SkyDrive.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer). However, we strongly recommend you only use the version included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer). Older versions of the templates had conflicting settings in different template files for both OneDrive & SkyDrive, until it was cleaned up properly in the above version.

Note #2: In older Microsoft Windows Administrative Templates, this setting was named *Prevent the usage of SkyDrive for file storage*, but it was renamed starting with the Windows 10 RTM (Release 1507) Administrative Templates.

Impact:

Users cannot access OneDrive from the OneDrive app and file picker. Windows Store apps cannot access OneDrive using the WinRT API. OneDrive doesn't appear in the navigation pane in File Explorer. OneDrive files aren't kept in sync with the cloud. Users cannot automatically upload photos and videos from the camera roll folder.

Note: If your organization uses Office 365, be aware that this setting will prevent users from saving files to OneDrive/SkyDrive.

Note #2: If your organization has decided to implement **OneDrive for Business** and therefore needs to except itself from this recommendation, we highly suggest that you also obtain and utilize the `OneDrive.admx/adml` template that is bundled with the latest OneDrive client, as noted [at this link](#) (this template is not included with the Windows Administrative Templates). Two alternative OneDrive settings in particular from that template are worth your consideration:

- *Allow syncing OneDrive accounts for only specific organizations* - a computer-based setting that restricts OneDrive client connections to only **approved** tenant IDs.
- *Prevent users from synchronizing personal OneDrive accounts* - a user-based setting that prevents use of consumer OneDrive (i.e., non-business).

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\OneDrive:DisableFileSyncGSC
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.52.1

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Remote Desktop Services (formerly Terminal Services)

This section contains recommendations related to Remote Desktop Services.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was initially named *Terminal Services* but was renamed by Microsoft to *Remote Desktop Services* starting with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates.

Remote Desktop Connection Client

This section contains recommendations for the Remote Desktop Connection Client.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-4686

Asset Manager



Ensure 'Do not allow passwords to be saved' is set to 'Enabled'

Rule

Ensure 'Do not allow passwords to be saved' is set to 'Enabled'.

Description

This policy setting helps prevent Remote Desktop clients from saving passwords on a computer.

The recommended state for this setting is: `Enabled`.

Note: If this policy setting was previously configured as Disabled or Not configured, any previously saved passwords will be deleted the first time a Remote Desktop client disconnects from any server.

Rationale

An attacker with physical access to the computer may be able to break the protection guarding saved passwords. An attacker who compromises a user's account and connects to their computer could use saved passwords to gain access to additional hosts.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Remote Desktop Services\Remote Desktop Connection Client\Do not
allow passwords to be saved

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

The password saving checkbox will be disabled for Remote Desktop clients and users will not be able to save passwords.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:DisablePasswordSaving
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.2.2

[Based on Siemens Information Security Policy Framework Rule 09.3.1-10](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Remote Desktop Session Host (formerly Terminal Server)

This section contains recommendations for the Remote Desktop Session Host.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was initially named *Terminal Server* but was renamed by Microsoft to *Remote Desktop Session Host* starting with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates.

Connections

This section contains recommendations for Connections to the Remote Desktop Session Host.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-4826

Asset Manager

C	I	A
123	123	123

Ensure 'Restrict Remote Desktop Services users to a single Remote Desktop Services session' is set to 'Enabled'

Rule

Ensure 'Restrict Remote Desktop Services users to a single Remote Desktop Services session' is set to 'Enabled'.

Description

This policy setting allows you to restrict users to a single Remote Desktop Services session.

Rationale

This setting ensures that users & administrators who Remote Desktop to a server will continue to use the same session - if they disconnect and reconnect, they will go back to the same session they were using before, preventing the creation of a second simultaneous session. This both prevents unnecessary resource usage by having the server host unnecessary additional sessions (which would put extra load on the server) and also ensures a consistency of experience for the user. There is also potential to make a secondary connection to a system with compromised credentials.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Administrative Templates\Windows
Components\Remote Desktop Services\Remote Desktop Session
Host\Connections\Restrict Remote Desktop Services users to a single Remote
Desktop Services session

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was named *Restrict Terminal Services users to a single remote session*, but it was renamed starting with the Windows 7 & Server 2008 R2 Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:fSingleSessionPerUser
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.3.2.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Device and Resource Redirection

This section contains recommendations related to Remote Desktop Session Host Device and Resource Redirection.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-3746

Asset Manager

C	I	A
123	123	123

Ensure 'Do not allow COM port redirection' is set to 'Enabled'

Rule

Ensure 'Do not allow COM port redirection' is set to 'Enabled'.

Description

This policy setting specifies whether to prevent the redirection of data to client COM ports from the remote computer in a Remote Desktop Services session.

Rationale

In a more security-sensitive environment, it is desirable to reduce the possible attack surface. The need for COM port redirection within a Remote Desktop session is very rare, so makes sense to reduce the number of unexpected avenues for data exfiltration and/or malicious code transfer.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Device and Resource Redirection\Do not allow COM port redirection

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Users in a Remote Desktop Services session will not be able to redirect server data to local (client) COM ports.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:fDisableCcm
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.3.3.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4864

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Do not allow drive redirection' is set to 'Enabled'

Rule

Ensure 'Do not allow drive redirection' is set to 'Enabled'.

E01 - Exemption

This rule is not mandatory for systems, for which it can be assured by environmental restrictions, that only dedicated and managed clients with an appropriate security level are able to connect to this system.

Description

This policy setting prevents users from sharing the local drives on their client computers to Remote Desktop Servers that they access. Mapped drives appear in the session folder tree in Windows Explorer in the following format:

```
\\TSCClient\<driveletter>$
```

If local drives are shared, they are left vulnerable to intruders who want to exploit the data that is stored on them.

Rationale

Data could be forwarded from the user's Remote Desktop Services session to the user's local computer without any direct user interaction. Malicious software already present on a compromised server would have direct and stealthy disk access to the user's local computer during the Remote Desktop session.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

```
Computer Configuration\Policies\Administrative Templates\Windows  
Components\Remote Desktop Services\Remote Desktop Session Host\Device and  
Resource Redirection\Do not allow drive redirection
```

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Drive redirection will not be possible. In most situations, traditional network drive mapping to file shares (including administrative shares) performed manually by the connected user will serve as a capable substitute to still allow file transfers when needed.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:fDisableCdm
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.3.3.2

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Added exemption from review feedback. This rule is consistent with the CIS recommendation.

BL968-1291

Asset Manager

C	I	A
123	123	123

Ensure 'Do not allow LPT port redirection' is set to 'Enabled'

Rule

Ensure 'Do not allow LPT port redirection' is set to 'Enabled'.

Description

This policy setting specifies whether to prevent the redirection of data to client LPT ports during a Remote Desktop Services session.

Rationale

In a more security-sensitive environment, it is desirable to reduce the possible attack surface. The need for LPT port redirection within a Remote Desktop session is very rare, so makes sense to reduce the number of unexpected avenues for data exfiltration and/or malicious code transfer.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Device and Resource Redirection\Do not allow LPT port redirection

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Users in a Remote Desktop Services session will not be able to redirect server data to local (client) LPT ports.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:fDisableLPT
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.3.3.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4865

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Do not allow supported Plug and Play device redirection' is set to 'Enabled'

Rule

Ensure 'Do not allow supported Plug and Play device redirection' is set to 'Enabled'.

Description

This policy setting allows you to control the redirection of supported Plug and Play devices, such as Windows Portable Devices, to the remote computer in a Remote Desktop Services session.

Rationale

In a more security-sensitive environment, it is desirable to reduce the possible attack surface. The need for Plug and Play device redirection within a Remote Desktop session is very rare, so makes sense to reduce the number of unexpected avenues for data exfiltration and/or malicious code transfer.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Device and Resource Redirection\Do not allow supported Plug and Play device redirection

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Users in a Remote Desktop Services session will not be able to redirect their supported (local client) Plug and Play devices to the remote computer.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:fDisablePNPRedir
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.3.3.4

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

Security

This section contains recommendations related to Remote Desktop Session Host Security.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-4546

EVAL until 2022-02-28

Asset Manager



Ensure 'Always prompt for password upon connection' is set to 'Enabled'

Rule Ensure 'Always prompt for password upon connection' is set to 'Enabled'.

E01 - Privileged Access Management Solutions

This rule is not mandatory, i.e., the respective setting can be set to `Disabled`, for systems which are **exclusively** managed by Privileged Access Management solutions, such as CyberArk, using automated session establishment hiding account credentials from connecting user.

Description

This policy setting specifies whether Remote Desktop Services always prompts the client computer for a password upon connection. You can use this policy setting to enforce a password prompt for users who log on to Remote Desktop Services, even if they already provided the password in the Remote Desktop Connection client.

Rationale

Users have the option to store both their username and password when they create a new Remote Desktop Connection shortcut. If the server that runs Remote Desktop Services allows users who have used this feature to log on to the server but not enter their password, then it is possible that an attacker who has gained physical access to the user's computer could connect to a Remote Desktop Server through the Remote Desktop Connection shortcut, even though they may not know the user's password.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Security\Always prompt for password upon connection

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In the Microsoft Windows Vista Administrative Templates, this setting was named *Always prompt client for password upon connection*, but it was renamed starting with the Windows Server 2008 (non-R2) Administrative Templates.

Impact:

Users cannot automatically log on to Remote Desktop Services by supplying their passwords in the Remote Desktop Connection client. They will be prompted for a password to log on.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:fPromptForPassword
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.3.9.1

Based on [Siemens Information Security Policy Framework Rule 09.3.1-10](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Rephrased exemption 01 for PAM exemption. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2466

Asset Manager

C	I	A
123	123	123

Ensure 'Require secure RPC communication' is set to 'Enabled'

Rule

Ensure 'Require secure RPC communication' is set to 'Enabled'.

Description

This policy setting allows you to specify whether Remote Desktop Services requires secure Remote Procedure Call (RPC) communication with all clients or allows unsecured communication.

You can use this policy setting to strengthen the security of RPC communication with clients by allowing only authenticated and encrypted requests.

Rationale

Allowing unsecure RPC communication can exposes the server to man in the middle attacks and data disclosure attacks.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Security\Require secure RPC communication

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Remote Desktop Services accepts requests from RPC clients that support secure requests, and does not allow unsecured communication with untrusted clients.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:fEncryptRPCTraffic
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.3.9.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-0436

Asset Manager

C	I	A
123	123	123

Ensure 'Require use of specific security layer for remote (RDP) connections' is set to 'Enabled: SSL'

Rule

Ensure 'Require use of specific security layer for remote (RDP) connections' is set to 'Enabled: SSL'.

Description

This policy setting specifies whether to require the use of a specific security layer to secure communications between clients and RD Session Host servers during Remote Desktop Protocol (RDP) connections.

Note: In spite of this setting being labelled *SSL*, it is actually enforcing Transport Layer Security (TLS) version 1.0, not the older (and less secure) SSL protocol.

Rationale

The native Remote Desktop Protocol (RDP) encryption is now considered a weak protocol, so enforcing the use of stronger Transport Layer Security (TLS) encryption for all RDP communications between clients and RD Session Host servers is preferred.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled: SSL**:

Computer Configuration\Policies\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Security\Require use of specific security layer for remote (RDP) connections

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

TLS 1.0 will be required to authenticate to the RD Session Host server. If TLS is not supported, the connection fails.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\SecurityLayer
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.3.9.3

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-0586

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Require user authentication for remote connections by using Network Level Authentication' is set to 'Enabled'

Rule

Ensure 'Require user authentication for remote connections by using Network Level Authentication' is set to 'Enabled'.

E01 - Privileged Access Management Solutions

This rule is not mandatory, i.e., the respective setting can be set to `Disabled`, for systems which are **exclusively** managed by Privileged Access Management solutions, such as CyberArk, using automated session establishment hiding account credentials from connecting user.

Description

This policy setting allows you to specify whether to require user authentication for remote connections to the RD Session Host server by using Network Level Authentication.

Rationale

Network Level Authentication offers a layer of defense against Denial of Service (DoS) attacks and speeds up the brokering process.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Security\Require user authentication for remote connections by using Network Level Authentication

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In the Microsoft Windows Vista Administrative Templates, this setting was initially named *Require user authentication using RDP 6.0 for remote connections*, but it was renamed starting with the Windows Server 2008 (non-R2) Administrative Templates.

Impact:

Only client computers that support Network Level Authentication can connect to the RD Session Host server.

Note: Some third party two-factor authentication solutions (e.g., RSA Authentication Agent) can be negatively affected by this setting, as Network Level Authentication will expect the user's Windows password, and once successfully authenticated, pass the credential along to the Windows session on the RDP host (to complete the login). If a two-factor agent is present and expecting a different credential at the RDP logon screen, this initial connection may result in a failed logon attempt.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\UserAuthentication
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.3.9.4

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added PAM exemption. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4776

Asset Manager

C	I	A
123	123	123

Ensure 'Set client connection encryption level' is set to 'Enabled: High Level'

Rule

Ensure 'Set client connection encryption level' is set to 'Enabled: High Level'.

Description

This policy setting specifies whether to require the use of a specific encryption level to secure communications between client computers and RD Session Host servers during Remote Desktop Protocol (RDP) connections. This policy only applies when you are using native RDP encryption. However, native RDP encryption (as opposed to SSL encryption) is not recommended. This policy does not apply to SSL encryption.

Rationale

If Remote Desktop client connections that use low level encryption are allowed, it is more likely that an attacker will be able to decrypt any captured Remote Desktop Services network traffic.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled: High Level** :

Computer Configuration\Policies\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Security\Set client connection encryption level

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note:

- The setting **High Level** encrypts data sent from the client to the server and from the server to the client by using strong **128-bit** encryption.
- The setting **Low Level** encrypts only data sent from the client to the server by using **56-bit** encryption.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:MinEncryptionLevel
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.3.9.5

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-0256

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Configure 'Server Authentication Certificate Template'

Rule

Replace the self-signed certificate with a machine certificate from Siemens OneAD domain or from Siemens Server RA.

Description

Self-signed certificates are generally utilized for testing local servers and are not allowed to be used in Siemens network as there is no relation with the identity of the person or organization who issued it.

Two types of certificates can be used to validate the identity of a computer:

- Active Directory Certification Authority machine certificates: They identify the computer using their physical name (e.g., MCHHxxxx.ww002.siemens.net). They are used to identify windows-based clients and servers in the Siemens Active Directory.
- Server RA machine certificates: They identify computers using their logical name (e.g., ts.siemens.net). These certificates are normally used by those servers accessible on the Internet, such as web servers.

Rationale

Self-signed certificates cannot be verified by a trusted Certificate Authority and are not acceptable to secure productive servers at Siemens.

I01 - Configure Certificate via Template Group Policy

Use the Group Policy Object Editor to edit the Local Computer Policy.

To establish the recommended configuration via GP, set the following UI path to **Enabled** :

Computer Configuration\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Security\Server Authentication Certificate Template.

Enter Machine Certificate in Certificate Template Name (or any other template, which includes the appropriate intended purpose in the field Enhanced Key Usage (Server Authentication (1.3.6.1.5.5.7.3.1), IP security IKE intermediate (1.3.6.1.5.5.8.2.2), Client Authentication (1.3.6.1.5.5.7.3.2))).

Note: Machine Certificate is the certificate template name used for Siemens machine certificates.

Note #: The renewed certificate is configured automatically (e.g., after 4.5 to 6 months for a machine certificate) if the auto-enrollment certificate is based on the Windows Server 2003 Enterprise format, which is the case for Siemens.net machine certificates.

I02 - Configure the certificate using PowerShell

```
$path = (Get-WmiObject -class "Win32_TSGeneralSetting" -Namespace  
root\cimv2\terminalservices -Filter  
"TerminalName='RDP-tcp').__path  
Set-WmiInstance -Path $path -argument  
@{SSLCertificateSHA1Hash="<thumbprint>"}
```

Listing: BL968-0256_I02_01.ps1

Replace <thumbprint> with the thumbprint of the new certificate (as shown in the certificate details).

Note: The renewed certificate is not configured automatically (e.g., after 4.5 to 6 months for a machine certificate). Thus, the configuration steps have to be reapplied then.

Impact:

Members in Remote Desktop Users are able to logon remotely in a secure manner. Because of the certificate, they can be sure that the target server is no fake server.

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Update in alignment with Siemens Windows Server 2019 (BL942). Not part of CIS Windows Server 2016.

Session Time Limits

This section contains recommendations related to Remote Desktop Session Host Session Time Limits.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-5191

Asset Manager



Ensure 'Set time limit for active but idle Remote Desktop Services sessions' is set to 'Enabled: 12 hours or less'

Rule Ensure 'Set time limit for active but idle Remote Desktop Services sessions' is set to 'Enabled: 12 hours or less'

Description

This policy setting allows you to specify the maximum amount of time that an active Remote Desktop Services session can be idle (without user input) before it is automatically disconnected.

Rationale

This setting helps to prevent active Remote Desktop sessions from tying up the computer for long periods of time while not in use, preventing computing resources from being consumed by large numbers of inactive sessions. In addition, old, forgotten Remote Desktop sessions that are still active can cause password lockouts if the user's password has changed but the old session is still running. For systems that limit the number of connected users (e.g., servers in the default Administrative mode - 2 sessions only), other users' old but still active sessions can prevent another user from connecting, resulting in an effective denial of service.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled: 12 hours or less`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Session Time Limits\Set time limit for active but idle Remote Desktop Services sessions

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was named *Set time limit for active but idle Terminal Services sessions*, but it was renamed starting with the Windows 7 & Server 2008 R2 Administrative Templates.

Impact:

Remote Desktop Services will automatically disconnect active but idle sessions after the specified amount of time. The user receives a warning two minutes before the session disconnects, which allows the user to press a key or move the mouse to keep the session active. If you have a console session, idle session time limits do not apply.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:MaxIdleTime
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.3.10.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3211

Asset Manager

C	I	A
123	123	123

Ensure 'Set time limit for disconnected sessions' is set to 'Enabled: 18 hours or less'

Rule

Ensure 'Set time limit for disconnected sessions' is set to 'Enabled: 18 hours or less'.

Description

This policy setting allows you to configure a time limit for disconnected Remote Desktop Services sessions.

Rationale

This setting helps to prevent active Remote Desktop sessions from tying up the computer for long periods of time while not in use, preventing computing resources from being consumed by large numbers of disconnected but still active sessions. In addition, old, forgotten Remote Desktop sessions that are still active can cause password lockouts if the user's password has changed but the old session is still running. For systems that limit the number of connected users (e.g., servers in the default Administrative mode - 2 sessions only), other users' old but still active sessions can prevent another user from connecting, resulting in an effective denial of service. This setting is important to ensure a disconnected session is properly terminated.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled: 18 hours or less** :

Computer Configuration\Policies\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Session Time Limits\Set time limit for disconnected sessions

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Disconnected Remote Desktop sessions are deleted from the server after the defined period of time. If you have a console session, disconnected session time limits do not apply.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:MaxDisconnectionTime
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.3.10.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Temporary folders

This section contains recommendations related to Remote Desktop Session Host Session Temporary folders.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-1416

Asset Manager



Ensure 'Do not delete temp folders upon exit' is set to 'Disabled'

Rule

Ensure 'Do not delete temp folders upon exit' is set to 'Disabled'.

Description

This policy setting specifies whether Remote Desktop Services retains a user's per-session temporary folders at logoff.

Rationale

Sensitive information could be contained inside the temporary folders and visible to other administrators that log into the system.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Remote Desktop Services\Remote Desktop Session Host\Temporary
Folders\Do not delete temp folders upon exit

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was named *Do not delete temp folder upon exit*, but it was renamed starting with the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services>DeleteTempDirsOnExit
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.3.11.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-1417

Asset Manager

C	I	A
123	123	123

Ensure 'Do not use temporary folders per session' is set to 'Disabled'

Rule

Ensure 'Do not use temporary folders per session' is set to 'Disabled'.

Description

By default, Remote Desktop Services creates a separate temporary folder on the RD Session Host server for each active session that a user maintains on the RD Session Host server. The temporary folder is created on the RD Session Host server in a Temp folder under the user's profile folder and is named with the `sessionId`. This temporary folder is used to store individual temporary files.

To reclaim disk space, the temporary folder is deleted when the user logs off from a session.

Rationale

Disabling this setting keeps the cached data independent for each session, both reducing the chance of problems from shared cached data between sessions, and keeping possibly sensitive data separate to each user session.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Remote Desktop Services\Remote Desktop Session Host\Temporary
Folders\Do not use temporary folders per session

Note: This Group Policy path is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:PerSessionTempDir
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.59.3.11.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

RSS Feeds

This section contains recommendations related to RSS feeds.

This Group Policy section is provided by the Group Policy template `InetRes.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-1971

Asset Manager



Ensure 'Prevent downloading of enclosures' is set to 'Enabled'

Rule

Ensure 'Prevent downloading of enclosures' is set to 'Enabled'.

Description

This policy setting prevents the user from having enclosures (file attachments) downloaded from an RSS feed to the user's computer.

Rationale

Allowing attachments to be downloaded through the RSS feed can introduce files that could have malicious intent.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Administrative Templates\Windows Components\RSS Feeds\Prevent downloading of enclosures

Note: This Group Policy path is provided by the Group Policy template `InetRes.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was named *Turn off downloading of enclosures* , but it was renamed starting with the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

Impact:

Users cannot set the Feed Sync Engine to download an enclosure through the Feed property page. Developers cannot change the download setting through feed APIs.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Internet Explorer\Feeds:DisableEnclosureDownload
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.60.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Search

This section contains recommendations for Search settings.

This Group Policy section is provided by the Group Policy template `Search.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-5781

Asset Manager



Configure 'Allow Cortana'

Rule

Ensure 'Allow Cortana' is set to 'Disabled'.

Description

Cortana is Microsoft's personal assistant software. It helps you to achieve some tasks, such as setting reminders or answering questions.

Rationale

In order to work properly and provide personalized experiences and relevant suggestions, Cortana needs to gather personal information of you (e.g., your hobbies, the apps you use, your search history). Most of this information is sent back to Microsoft to be processed and might include confidential or strictly confidential information.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Search\Allow Cortana

Impact:

Cortana will be turned off. Users will still be able to use search to find things on the device and on the Internet.

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4891

Asset Manager

C	I	A
123	123	123

Configure 'Allow Cortana above lock screen'

Rule

Ensure 'Allow Cortana above lock screen' is set to 'Disabled'.

Description

Cortana is Microsoft's personal assistant software, similar to Siri on Apple devices. It helps you to achieve some tasks, such as setting reminders or answering questions.

This policy setting determines whether or not the user can interact with Cortana using speech while the system is locked.

Rationale

In order to work properly and provide personalized experiences and relevant suggestions, Cortana needs to gather personal information of you (e.g., your hobbies, the apps you use, your search history). Most of this information is sent back to Microsoft to be processed and might include confidential or strictly confidential information.

Access to any computer resource should not be allowed when the device is locked.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Administrative Templates\Windows
Components\Search\Allow Cortana above lock screen

Impact:

The system will need to be unlocked by the user to interact with Cortana using speech.

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1376

Asset Manager

C	I	A
123	123	123

Ensure 'Allow indexing of encrypted files' is set to 'Disabled'

Rule

Ensure 'Allow indexing of encrypted files' is set to 'Disabled'.

Description

This policy setting controls whether encrypted items are allowed to be indexed. When this setting is changed, the index is rebuilt completely. Full volume encryption (such as BitLocker Drive Encryption or a non-Microsoft solution) must be used for the location of the index to maintain security for encrypted files.

Rationale

Indexing and allowing users to search encrypted files could potentially reveal confidential data stored within the encrypted files.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Search\Allow indexing of encrypted files

Note: This Group Policy path is provided by the Group Policy template `Search.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Windows  
Search:AllowIndexingEncryptedStoresOrItems
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.61.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-2046

Asset Manager

C	I	A
123	123	123

Configure 'Allow search and Cortana to use location'

Rule

Ensure 'Allow search and Cortana to use location' is set to 'Disabled'.

Description

This policy setting specifies whether search and Cortana can provide location aware search and Cortana results.

Rationale

In an Enterprise having Cortana and Search having access to location is unnecessary. Organizations may not want this information shared out.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Administrative Templates\Windows
Components\Search\Allow search and Cortana to use location

Note: This Group Policy path does not exist by default. An updated Group Policy template (Search.admx/adml) is required - it is included with the Microsoft Windows 10 Administrative Templates.

Impact:

Search and Cortana will not have access to location information.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Store

This section contains rules related to the Windows Store.

BL968-2286

Asset Manager

C	I	A
123	123	123

Configure 'Disable all apps from Windows Store'

Rule

Ensure 'Disable all apps from Microsoft Store' is set to 'Enabled'.

Description

This setting configures the launch of all apps from the Microsoft Store that came pre-installed or were downloaded.

Rationale

The Store service is a retail outlet built into Windows, primarily for consumer use. In an enterprise environment the IT department should be managing the installation of all applications to reduce the risk of the installation of vulnerable software.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

Computer Configuration\Policies\Administrative Templates\Windows
Components\Store\Disable all apps from Windows Store

Impact:

All apps from the Microsoft Store that came pre-installed or were downloaded are prevented from launching. Existing Microsoft Store apps will not be updated. Microsoft Store is disabled.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1641

Asset Manager

C	I	A
123	123	123

Configure 'Turn off Automatic Download and Install of updates'

Rule

Ensure 'Turn off Automatic Download and Install of updates' is set to 'Disabled'.

Description

This setting enables or disables the automatic download and installation of Windows Store app updates.

- If you enable this setting, the automatic download and installation of app updates is turned off.
- If you disable this setting, the automatic download and installation of app updates is turned on.

Note: This rule has no effect if the rule [BL968-2286 Configure 'Disable all apps from Windows Store'](#) is set to Enabled.

Rationale

Keeping your system properly patched can help protect against zero-day attacks.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled:

Computer Configuration\Policies\Administrative Templates\Windows Components\Store\Turn off Automatic Download and Install of updates

Impact:

Windows Store automatically does not download and install updates for Windows Store apps. This is the default configuration.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1941

Asset Manager

C	I	A
123	123	123

Configure 'Turn off the offer to update to the latest version of Windows'

Rule

Ensure 'Turn off the offer to update to the latest version of Windows' is set to 'Enabled'.

Description

Enables or disables the Windows Store offer to update to the latest version of Windows.

Rationale

Unplanned OS upgrades can lead to more preventable support calls. The IT department should be managing and approving all updates.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Store\Turn off the offer to update to the latest version of Windows

Impact:

The Windows Store application will not offer updates to the latest version of Windows.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1161

Asset Manager

C	I	A
123	123	123

Configure 'Turn off the Store application'

Rule

Ensure 'Turn off the Store application' is set to 'Enabled'.

Description

This setting denies or allows access to the Store application.

Rationale

Allowing to install not or not sufficiently proved 3rd party applications can lead to missed patches and potential zero-day attacks.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Store\Turn off the Store application

Impact:

Access to the Windows Store application is denied.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Software Protection Platform

This section contains recommendations related to the Software Protection Platform.

This Group Policy section is provided by the Group Policy template `AVSValidationGP.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

BL968-4866

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Turn off KMS Client Online AVS Validation' is set to 'Enabled'

Rule

Ensure 'Turn off KMS Client Online AVS Validation' is set to 'Enabled'.

Description

The Key Management Service (KMS) is a Microsoft license activation method that entails setting up a local server to store the software licenses. The KMS server itself needs to connect to Microsoft to activate the KMS service, but subsequent on-network clients can activate Microsoft Windows OS and/or their Microsoft Office via the KMS server instead of connecting directly to Microsoft. This policy setting lets you opt-out of sending KMS client activation data to Microsoft automatically.

Rationale

Even though the KMS licensing method does not *require* KMS clients to connect to Microsoft, they still send KMS client activation state data to Microsoft automatically. Preventing this information from being sent can help reduce privacy concerns in high security environments.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Software Protection Platform\Turn off KMS Client Online AVS
Validation

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `AVSValidationGP.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

Impact:

The computer is prevented from sending data to Microsoft regarding its KMS client activation state.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\CurrentVersion\Software Protection  
Platform:NoGenTicket
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.66.1

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

Windows Defender

This section contains recommendations related to Windows Defender Antivirus.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was originally named *Windows Defender* but was renamed by Microsoft to *Windows Defender* starting with the Microsoft Windows 10 Release 1703 Administrative Templates.

MAPS

This section contains recommendations related to Microsoft Active Protection Service (MAPS).

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

BL968-4870

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Ensure 'Configure local setting override for reporting to Microsoft MAPS' is set to 'Disabled'

Rule

Ensure 'Configure local setting override for reporting to Microsoft MAPS' is set to 'Disabled'.

Description

This policy setting configures a local override for the configuration to join Microsoft Active Protection Service (MAPS), which Microsoft has now renamed to "Windows Defender Antivirus Cloud Protection Service". This setting can only be set by Group Policy.

Rationale

The decision on whether or not to participate in Microsoft MAPS / Windows Defender Antivirus Cloud Protection Service for malicious software reporting should be made centrally in an enterprise managed environment, so that all computers within it behave consistently in that regard. Configuring this setting to Disabled ensures that the decision remains centrally managed.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled:

Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Defender\MAPS\Configure local setting override for reporting to Microsoft MAPS

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template WindowsDefender.admx/adml that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows  
Defender\Spynet:LocalSettingOverrideSpynetReporting
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.77.3.1

[Based on Siemens Information Security Policy Framework Rule 07.1.2-01](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-06](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-07](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-08](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-11](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-16](#)

[Based on Siemens Information Security Policy Framework Rule 13.2.4-01](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-1051

Asset Manager

C	I	A
123	123	123

Ensure 'Join Microsoft MAPS' is set to 'Disabled'

Rule

Ensure 'Join Microsoft MAPS' is set to 'Disabled'.

Description

This policy setting allows you to join Microsoft Active Protection Service (MAPS), which Microsoft has now renamed to "Windows Defender Antivirus Cloud Protection Service". Microsoft MAPS / Windows Defender Antivirus Cloud Protection Service is the online community that helps you choose how to respond to potential threats. The community also helps stop the spread of new malicious software infections. You can choose to send basic or additional information about detected software. Additional information helps Microsoft create new definitions and help it to protect your computer.

Possible options are:

- (0x0) Disabled (default)
- (0x1) Basic membership
- (0x2) Advanced membership

Basic membership will send basic information to Microsoft about software that has been detected including where the software came from the actions that you apply or that are applied automatically and whether the actions were successful.

Advanced membership in addition to basic information will send more information to Microsoft about malicious software spyware and potentially unwanted software including the location of the software file names how the software operates and how it has impacted your computer.

Rationale

The information that would be sent can include things like location of detected items on your computer if harmful software was removed. The information would be automatically collected and sent. In some instances, personal information might unintentionally be sent to Microsoft. However, Microsoft states that it will not use this information to identify you or contact you.

For privacy reasons in high security environments, it is best to prevent these data submissions altogether.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows Defender\MAPS\Join Microsoft MAPS

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template WindowsDefender.admx/adml that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is in effect when the following registry value does not exist, or when it exists with a value of 0:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Spynet:SpynetReporting
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.77.3.2

[Based on Siemens Information Security Policy Framework Rule 07.1.2-01](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-06](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-07](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-08](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-11](#)

[Based on Siemens Information Security Policy Framework Rule 08.2.3-16](#)

[Based on Siemens Information Security Policy Framework Rule 13.2.4-01](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Real-time Protection

This section contains settings related to Real-time Protection.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

BL968-0541

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Scan all downloaded files and attachments' is set to 'Enabled'

Rule

Ensure 'Scan all downloaded files and attachments' is set to 'Enabled'.

Description

This policy setting turns on scanning of all downloaded files and attachments.

Rationale

Setting this policy ensures that all downloaded files and attachments are processed by the Windows Defender engine.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

`Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Defender\Real-time Protection\Scan all downloaded files and attachments.`

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 16.1.6-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

[Based on Siemens Information Security Policy Framework Rule 12.2.1-01](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).

BL968-4871

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Turn on behavior monitoring' is set to 'Enabled'

Rule

Ensure 'Turn on behavior monitoring' is set to 'Enabled'.

Description

This policy setting allows you to configure behavior monitoring for Windows Defender.

Rationale

When running an antivirus solution such as Windows Defender, it is important to ensure that it is configured to heuristically monitor in real-time for suspicious and known malicious activity.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows Defender\Real-Time Protection\Turn on behavior monitoring

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template WindowsDefender.admx/adml that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Impact:

None - this is the default configuration.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Real-Time  
Protection:DisableBehaviorMonitoring
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.77.7.1

Based on Siemens Information Security Policy Framework Rule 16.1.6-01

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Based on Siemens Information Security Policy Framework Rule 12.2.1-01

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

Reporting

This section contains settings related to Windows Defender Reporting.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

BL968-3616

Asset Manager

C	I	A
123	123	123

Ensure 'Configure Watson events' is set to 'Disabled'

Rule

Ensure 'Configure Watson events' is set to 'Disabled'.

Description

This policy setting allows you to configure whether or not Watson events are sent.

Rationale

Watson events are the reports that get sent to Microsoft when a program or service crashes or fails, including the possibility of automatic submission. Preventing this information from being sent can help reduce privacy concerns.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows Defender\Reporting\Configure Watson events

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Impact:

Watson events will not be sent to Microsoft automatically when a program or service crashes or fails.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Reporting:DisableGenericRePorts
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.77.9.1

Based on Siemens Information Security Policy Framework Rule 07.1.2-01

Based on Siemens Information Security Policy Framework Rule 08.2.3-06

Based on Siemens Information Security Policy Framework Rule 08.2.3-07

Based on Siemens Information Security Policy Framework Rule 08.2.3-08

Based on Siemens Information Security Policy Framework Rule 08.2.3-11

Based on Siemens Information Security Policy Framework Rule 08.2.3-16

Based on Siemens Information Security Policy Framework Rule 13.2.4-01

Based on Siemens Information Security Policy Framework Rule 13.2.4-02

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Scan

This section contains settings related to Windows Defender scanning.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

BL968-0616

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Check for the latest virus and spyware definitions before running a scheduled scan' is set to 'Enabled'

Rule

Ensure 'Check for the latest virus and spyware definitions before running a scheduled scan' is set to 'Enabled'.

Description

This policy enabled the check for new antivirus pattern updates before running a scheduled scan.

Rationale

As malware may spread very rapidly, the latest definitions data should be used when running a scan.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Defender\Scan\Check for the latest virus and spyware definitions before running a scheduled scan.

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 16.1.6-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

[Based on Siemens Information Security Policy Framework Rule 12.2.1-01](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).
Changed during review: Aligned GPO UI path to Windows Server 2016 v1607.

BL968-0746

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Scan archive files' is set to 'Enabled'

Rule

Ensure 'Scan archive files' is set to 'Enabled'.

Description

This policy enables scanning of archive files.

Rationale

Content of archives should be processed by the Windows Defender antivirus engine as files within the archive may contain malware.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows Defender\Scan\Scan archive files.

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 16.1.6-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

[Based on Siemens Information Security Policy Framework Rule 12.2.1-01](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Rule has been copied from Siemens Windows 10 (BL696).

BL968-4872

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Scan removable drives' is set to 'Enabled'

Rule

Ensure 'Scan removable drives' is set to 'Enabled'.

Description

This policy setting allows you to manage whether or not to scan for malicious software and unwanted software in the contents of removable drives, such as USB flash drives, when running a full scan.

Rationale

It is important to ensure that any present removable drives are always included in any type of scan, as removable drives are more likely to contain malicious software brought into the enterprise managed environment from an external, unmanaged computer.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows Defender\Scan\Scan removable drives

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template WindowsDefender.admx/adml that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Impact:

Removable drives will be scanned during any type of scan by Windows Defender Antivirus.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Scan:DisableRemovableDriveScanning
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.77.10.1

Based on Siemens Information Security Policy Framework Rule 16.1.6-01

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Based on Siemens Information Security Policy Framework Rule 12.2.1-01

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-4873

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Turn on e-mail scanning' is set to 'Enabled'

Rule

Ensure 'Turn on e-mail scanning' is set to 'Enabled'.

Description

This policy setting allows you to configure e-mail scanning. When e-mail scanning is enabled, the engine will parse the mailbox and mail files, according to their specific format, in order to analyze the mail bodies and attachments. Several e-mail formats are currently supported, for example: pst (Outlook), dbx, mbx, mime (Outlook Express), binhex (Mac).

Rationale

Incoming e-mails should be scanned by an antivirus solution such as Windows Defender, as email attachments are a commonly used attack vector to infiltrate computers with malicious software.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows Defender\Scan\Turn on e-mail scanning

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Impact:

E-mail scanning by Windows Defender will be enabled.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Scan:DisableEmailScanning
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.77.10.2

Based on Siemens Information Security Policy Framework Rule 16.1.6-01

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Based on Siemens Information Security Policy Framework Rule 12.2.1-01

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-4869

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure Windows Defender as Fallback

Rule Ensure 'Turn off Windows Defender' is set to 'Not configured'.

Note: This configuration does not mean, that the primary virus scanner will become obsolete - instead, this configuration allows a convenient fallback solution in case the primary virus scanner runs into problems (e.g., no pattern update anymore).

E01 - Servers for which the Siemens VCC does not provide a solution

If [Siemens Virus Competence Center](#) does not provide an antivirus solution for specific servers, the use of Windows Defender is allowed.

In case Windows Defender is used as the primary AV solution, the setting can be configured to the value 'Disabled'.

Description

This policy setting configures the behavior of Windows Defender.

If the setting is configured to 'Enabled', Windows Defender will be turned off.

If the setting is configured to 'Disabled', Windows Defender will be turned on and the computers will be scanned by Windows Defender for malware and other potentially unwanted software.

If this policy setting is set to 'Not configured', Windows will internally manage Windows Defender. If another antivirus program is installed, Windows automatically disables Windows Defender. If the other antivirus program will be unavailable, uninstalled or if it does not receive any antivirus pattern anymore, Windows Defender will take over the role and scan the computer for malware and other potentially unwanted software.

Rationale

Setting this policy setting to 'Not configured' ensures that Windows Defender Antivirus takes over in cases where the central virus protection from Siemens VCC fails for whatever reasons.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Not configured`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows Defender\Turn off Windows Defender

Note: This Group Policy path is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was initially named *Turn off Windows Defender*, but it was renamed starting with the Windows 10 Release 1703 Administrative Templates.

Impact:

Windows Defender will become active in case the primary virus scanner runs into problems (e.g., no pattern update anymore).

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender:DisableAntiSpyware
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.77.15

[Based on Siemens Information Security Policy Framework Rule 16.1.6-01](#)

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

[Based on Siemens Information Security Policy Framework Rule 12.2.1-01](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is not consistent with the CIS recommendation as we use Windows Defender AV only as Fallback; added an exemption in case WDAV must be used as primary AV product.

Windows Defender SmartScreen

This section contains Windows Defender SmartScreen settings.

This Group Policy section is provided by the Group Policy template `SmartScreen.admx/adml` that is included with the Microsoft Windows 10 Release 1703 Administrative Templates (or newer).

Explorer

This section contains recommendations for Explorer-related Windows Defender SmartScreen settings.

The Group Policy settings contained within this section are provided by the Group Policy template `WindowsExplorer.admx/adml` that is included with the Microsoft Windows 10 Release 1703 Administrative Templates (or newer).

BL968-4877

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Explorer: Configure Windows SmartScreen' is set to 'Disabled'

Rule

Ensure 'Explorer: Configure Windows SmartScreen' is set to 'Disabled'.

Description

This policy setting allows you to manage the behavior of Windows SmartScreen. Windows SmartScreen helps keep PCs safer by warning users before running unrecognized programs downloaded from the Internet. Some information is sent to Microsoft about files and programs run on PCs with this feature enabled.

Rationale

Windows SmartScreen helps keep PCs safer by warning users before running unrecognized programs downloaded from the Internet. However, due to the fact that some information is sent to Microsoft about files and programs run on PCs some organizations may prefer to disable it.

Due to currently unresolved privacy issues and the fact that the ultimate decision is left to the user, Windows SmartScreen has to be disabled.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\File Explorer\Configure Windows SmartScreen

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `WindowsExplorer.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Note #2: In older Microsoft Windows Administrative Templates, this setting was initially named *Configure Windows SmartScreen*, but it was renamed starting with the Windows 10 Release 1703 Administrative Templates.

Impact:

Users are allowed to run unrecognized programs downloaded from the Internet.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry locations:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:EnableSmartScreen
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.80.1.1

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Modified GPO path to comply with 1607. This rule is not consistent with the CIS recommendation. Aligned with Siemens Windows 10 (BL696).

Windows Hello for Business

This section contains rules related to Windows Hello.

BL968-0005

Asset Manager

C	I	A
123	123	123

Configure 'Use Windows Hello for Business'

Rule

Ensure 'Use Windows Hello for Business' is set to 'Disabled'.

Description

Windows Hello is Microsoft's technology to provide biometric authentication. It allows users to use fingerprint or facial recognition to log in to the computer.

Rationale

A vulnerability in a biometric hardware device, such as the camera or the fingerprint reader, or in the hardware driver of that device might allow an attacker to gain access to a computer.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows Hello for Business\Use Windows Hello for Business

Impact:

The server does not provide alternative logon methods using Windows Hello for Business for any user.

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Windows Ink Workspace

This section contains recommendations related to the Windows Ink Workspace.

This Group Policy section is provided by the Group Policy template `WindowsInkWorkspace.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

BL968-2306

Asset Manager



Ensure 'Allow suggested apps in Windows Ink Workspace' is set to 'Disabled'

Rule

Ensure 'Allow suggested apps in Windows Ink Workspace' is set to 'Disabled'.

Description

This policy setting determines whether suggested apps in Windows Ink Workspace are allowed.

Rationale

This Microsoft feature is designed to collect data and suggest apps based on that data collected. Disabling this setting will help ensure your data is not shared with any third party.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows Ink Workspace\Allow suggested apps in Windows Ink Workspace

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `WindowsInkWorkspace.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

The suggested apps in Windows Ink Workspace will not be allowed.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsInkWorkspace:AllowSuggestedAppsInWindowsInkWorkspa  
ce
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.84.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4511

Asset Manager

C	I	A
123	123	123

Ensure 'Allow Windows Ink Workspace' is set to 'Disabled'

Rule

Ensure 'Allow Windows Ink Workspace' is set to 'Disabled'.

Description

This policy setting determines whether Windows Ink items are allowed above the lock screen.

Rationale

Allowing any apps to be accessed while system is locked is not recommended. If this feature is permitted, it should only be accessible once a user authenticates with the proper credentials.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows Ink Workspace\Allow Windows Ink Workspace

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template WindowsInkWorkspace.admx/adml that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows Ink Workspace will not be permitted above the lock screen.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsInkWorkspace:AllowWindowsInkWorkspace
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.84.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent, but strengthened, with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Windows Installer

This section contains recommendations related to Windows Installer.

This Group Policy section is provided by the Group Policy template `MSI.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-3761

Asset Manager



Ensure 'Allow user control over installs' is set to 'Disabled'

Rule

Ensure 'Allow user control over installs' is set to 'Disabled'.

Description

This setting controls whether users are permitted to change installation options that typically are available only to system administrators. The security features of Windows Installer normally prevent users from changing installation options that are typically reserved for system administrators, such as specifying the directory to which files are installed. If Windows Installer detects that an installation package has permitted the user to change a protected option, it stops the installation and displays a message. These security features operate only when the installation program is running in a privileged security context in which it has access to directories denied to the user.

Rationale

In an enterprise managed environment, only IT staff with administrative rights should be installing or changing software on a system. Allowing users the ability to have any control over installs can risk unapproved software from being installed or removed from a system, which could cause the system to become vulnerable to compromise.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows Installer\Allow user control over installs

Note: This Group Policy path is provided by the Group Policy template `MSI.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was named *Enable user control over installs*, but it was renamed starting with the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Installer:EnableUserControl
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.85.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4878

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Computer Configuration: Always install with elevated privileges' is set to 'Disabled'

Rule

Ensure 'Computer Configuration: Always install with elevated privileges' is set to 'Disabled'.

Description

This setting controls whether or not Windows Installer should use system permissions when it installs any program on the system.

Note: This setting appears both in the Computer Configuration and User Configuration folders. To make this setting effective, you must enable the setting in both folders.

Caution: If enabled, skilled users can take advantage of the permissions this setting grants to change their privileges and gain permanent access to restricted files and folders. Note that the User Configuration version of this setting is not guaranteed to be secure.

Rationale

Users with limited privileges can exploit this feature by creating a Windows Installer installation package that creates a new local account that belongs to the local built-in Administrators group, adds their current account to the local built-in Administrators group, installs malicious software, or performs other unauthorized activities.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows Installer\Always install with elevated privileges

Note: This Group Policy path is provided by the Group Policy template MSI.admx/adml that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Installer:AlwaysInstallElevated
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.85.2

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

BL968-5066

Asset Manager

C	I	A
123	123	123

Ensure 'Prevent Internet Explorer security prompt for Windows Installer scripts' is set to 'Disabled'

Rule

Ensure 'Prevent Internet Explorer security prompt for Windows Installer scripts' is set to 'Disabled'.

Description

This policy setting controls whether Web-based programs are allowed to install software on the computer without notifying the user.

Rationale

Suppressing the system warning can pose a security risk and increase the attack surface on the system.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled` :

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows Installer\Prevent Internet Explorer security prompt for
Windows Installer scripts

Note: This Group Policy path is provided by the Group Policy template `MSI.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was initially named *Disable IE security prompt for Windows Installer scripts* , but it was renamed starting with the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Installer:SafeForScripting
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.85.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Windows Logon Options

This section contains recommendations related to Windows Logon Options.

This Group Policy section is provided by the Group Policy template `WinLogon.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-3651

Asset Manager



Ensure 'Sign-in last interactive user automatically after a system-initiated restart' is set to 'Disabled'

Rule

Ensure 'Sign-in last interactive user automatically after a system-initiated restart' is set to 'Disabled'.

Description

This policy setting controls whether a device will automatically sign-in the last interactive user after Windows Update restarts the system.

Rationale

Disabling this feature will prevent the caching of user's credentials and unauthorized use of the device, and also ensure the user is aware of the restart.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Logon Options\Sign-in last interactive user automatically after a system-initiated restart

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `WinLogon.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Note #2: This setting was renamed to `Sign-in and lock last interactive user automatically after a restart` starting with the Windows 10 Release 1903 Administrative Templates.

Impact:

The device does not store the user's credentials for automatic sign-in after a Windows Update restart. The users' lock screen apps are not restarted after the system restarts. The user is required to present the logon credentials in order to proceed after restart.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.

This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:DisableAutomaticRestartSign  
On
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.86.1

[Based on Siemens Information Security Policy Framework Rule 09.1.1-07](#)

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Windows PowerShell

This section contains recommendations related to Windows PowerShell.

This Group Policy section is provided by the Group Policy template `PowerShellExecutionPolicy.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

BL968-3516

Asset Manager



Ensure 'Turn on PowerShell Script Block Logging' is set to 'Disabled'

Rule

Ensure 'Turn on PowerShell Script Block Logging' is set to 'Disabled'.

E01 - Exemption

If *PowerShell Script Block Logging* is mandatorily required to detect threats based on *Advanced Threat Detection* capabilities and up-to-date *Threat Intelligence*, then the setting 'Turn on PowerShell Script Block Logging' can be set to 'Enabled'. If required, the option 'Log script block invocation start / stop events' can be selected as well.

E02 - Exemption

If *PowerShell Script Block Logging* is required for debugging purposes, then the setting 'Turn on PowerShell Script Block Logging' can be set to 'Enabled' only for a **limited** period of time. If required, the option 'Log script block invocation start / stop events' can be selected as well.

Users must be distinctly aware that typed in commands, including passwords, might be stored in clear-text in log files during that time. It is also advisable to change the passwords after debugging has been ended to avoid misuse of logged passwords.

Description

This policy setting enables logging of all PowerShell script input to the Microsoft-Windows-PowerShell/Operational event log.

Note: In Microsoft's own hardening guidance, they recommend the opposite value, `Enabled`, because having this data logged improves investigations of PowerShell attack incidents. However, the default ACL on the PowerShell Operational log allows Interactive User (i.e., *any* logged on user) to read it, and therefore possibly expose passwords or other sensitive information to unauthorized users. If Microsoft locks down the default ACL on that log in the future (e.g., to restrict it only to Administrators), then we will revisit this recommendation in a future release.

Rationale

There are potential risks of capturing passwords in the PowerShell logs. This setting should only be needed for debugging purposes, and not in normal operation, it is important to ensure this is set to Disabled.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows PowerShell\Turn on PowerShell Script Block Logging

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template PowerShellExecutionPolicy.admx/adml that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

Impact:

Logging of PowerShell script input is disabled.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging:EnableScriptBlockLo  
gging
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.95.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-2071

Asset Manager

C	I	A
123	123	123

Ensure 'Turn on PowerShell Transcription' is set to 'Disabled'

Rule

Ensure 'Turn on PowerShell Transcription' is set to 'Disabled'.

E01 - Exemption

If *PowerShell Transcription* is mandatorily required to detect threats based on *Advanced Threat Detection* capabilities and up-to-date *Threat Intelligence*, then the setting 'Turn on PowerShell Transcription' can be set to 'Enabled'. If required, the option 'Include invocation headers' can be selected as well.

E02 - Exemption

If *PowerShell Transcription* is required for debugging purposes, then the setting 'Turn on PowerShell Script Block Logging' can be set to 'Enabled' only for a **limited** period of time. If required, the option 'Include invocation headers' can be selected as well.

Users must be distinctly aware that typed in commands, including passwords, might be stored in clear-text in log files during that time. It is also advisable to change the passwords after debugging has been ended to avoid misuse of logged passwords.

Description

This Policy setting lets you capture the input and output of Windows PowerShell commands into text-based transcripts.

Rationale

If this setting is enabled there is a risk that passwords could get stored in plain text in the PowerShell_transcript output file.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Windows PowerShell\Turn on PowerShell Transcription

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template PowerShellExecutionPolicy.admx/adml that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell\Transcription:EnableTranscripting
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.95.2

Version History (Latest Entry)

v2.0 (2021-10-08): revised

This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0936

Asset Manager

C	I	A
123	123	123

Configure 'PowerShell: Turn on Script Execution'

Rule Ensure 'Turn on Script Execution' is set to 'Enabled:' -> 'Execution Policy' is set to 'Allow local scripts and remote signed scripts'.

Note: The more restrictive setting 'Allow only signed scripts' also means compliance to this rule.

Description

Microsoft *PowerShell* is a platform and scripting language used to perform operational and administrative tasks. Almost every feature or configuration item of a Windows operating system can be configured with a PowerShell cmdlet.

Microsoft introduced an extra layer of security with the *Execution Policy* option. This policy defines under which circumstances a PowerShell script can be executed:

- *Allow only signed scripts (AllSigned)*: Only permits running scripts that are signed by a trusted publisher, even locally created scripts. It prevents, for example, the execution of unsigned malicious scripts downloaded from Internet. However, this setting might prevent the execution of legitimate unsigned scripts (e.g., provided with commercial software products).
- *Allow local scripts and remote signed scripts (RemoteSigned)*: Permits running all PowerShell scripts created locally, but only permits running downloaded scripts from the Internet or any other remote location which are signed by a trusted publisher.

Rationale

Attackers might change an unsigned *PowerShell* script on a network storage, and the administrator would not notice change when the script will be executed the next time. This script could connect to a malicious website (Command and Control Server) to download and execute additional malicious software.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following Group Policy setting to `Enabled`
-> `Set Execution Policy to Allow local scripts and remote signed scripts`

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows PowerShell\Turn on Script Execution

Impact:

- Local scripts are allowed to run,
- Unsigned scripts downloaded scripts from the Internet or any other remote location are not allowed to run,

- Scripts that originate from the Internet or any other remote location must be signed by a trusted publisher.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added note for compliance of more restrictive setting. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Windows Remote Management (WinRM)

This section contains recommendations related to Windows Remote Management (WinRM).

This Group Policy section is provided by the Group Policy template `WindowsRemoteManagement.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

WinRM Client

This section contains recommendations related to the Windows Remote Management (WinRM) client.

This Group Policy section is provided by the Group Policy template `WindowsRemoteManagement.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-5106

Asset Manager



Ensure 'WinRM Client: Allow Basic authentication' is set to 'Disabled'

Rule

Ensure 'WinRM Client: Allow Basic authentication' is set to 'Disabled'.

Description

This policy setting allows you to manage whether the Windows Remote Management (WinRM) client uses Basic authentication.

Rationale

Basic authentication is less robust than other authentication methods available in WinRM because credentials including passwords are transmitted in plain text. An attacker who is able to capture packets on the network where WinRM is running may be able to determine the credentials used for accessing remote hosts via WinRM.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Client\Allow Basic authentication

Note: This Group Policy path is provided by the Group Policy template `WindowsRemoteManagement.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Client:AllowBasic
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.97.1.1

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3596

Asset Manager

C	I	A
123	123	123

Ensure 'WinRM Client: Allow unencrypted traffic' is set to 'Disabled'

Rule

Ensure 'WinRM Client: Allow unencrypted traffic' is set to 'Disabled'.

Description

This policy setting allows you to manage whether the Windows Remote Management (WinRM) client sends and receives unencrypted messages over the network.

Rationale

Encrypting WinRM network traffic reduces the risk of an attacker viewing or modifying WinRM messages as they transit the network.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Client\Allow unencrypted traffic

Note: This Group Policy path is provided by the Group Policy template WindowsRemoteManagement.admx/adml that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Client:AllowUnencryptedTraffic
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.97.1.2

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3921

Asset Manager

C	I	A
123	123	123

Ensure 'WinRM Client: Disallow Digest authentication' is set to 'Enabled'

Rule

Ensure 'WinRM Client: Disallow Digest authentication' is set to 'Enabled'.

Description

This policy setting allows you to manage whether the Windows Remote Management (WinRM) client will not use Digest authentication.

Rationale

Digest authentication is less robust than other authentication methods available in WinRM, an attacker who is able to capture packets on the network where WinRM is running may be able to determine the credentials used for accessing remote hosts via WinRM.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Client\Disallow Digest authentication

Note: This Group Policy path is provided by the Group Policy template `WindowsRemoteManagement.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

The WinRM client will not use Digest authentication.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Client:AllowDigest
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.97.1.3

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-0911

Asset Manager

C	I	A
1	1	1
2	2	2
3	3	3

Configure 'WinRM Client: Allow CredSSP authentication'

Rule

Ensure 'WinRM Client: Allow CredSSP authentication' is set to 'Disabled'.

Description

CredSSP is an outdated authentication protocol of Windows Server 2003 and Windows XP. Several vulnerabilities are known that an attacker might exploit to get access to confidential data.

Rationale

With CredSSP the user's credentials are sent in clear-text to a remote computer which will store those credentials locally. If the remote computer will be compromised the attacker gains access to these clear-text credentials.

Kerberos has to be used instead of CredSSP, because Kerberos uses encrypted tickets instead of credentials. With that it is ensured that credentials will not be stored locally.

More information can be found here: [PowerShell Magazine: Accidental Sabotage: Beware of CredSSP](#).

I01 - Implementation Example

To establish the recommended configuration via GP, set the following Group Policy setting to Disabled:

```
Computer Configuration\Policies\Administrative Templates\Windows  
Components\Windows Remote Management (WinRM)\WinRM Client\Allow CredSSP  
authentication
```

Impact:

The WinRM client sends or receives only Kerberos authentication messages over the network. This is the default configuration.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

WinRM Service

This section contains recommendations related to the Windows Remote Management (WinRM) service.

This Group Policy section is provided by the Group Policy template `WindowsRemoteManagement.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-2931

Asset Manager

C	I	A
123	123	123

Ensure 'WinRM Service: Allow Basic authentication' is set to 'Disabled'

Rule

Ensure 'WinRM Service: Allow Basic authentication' is set to 'Disabled'.

Description

This policy setting allows you to manage whether the Windows Remote Management (WinRM) service accepts Basic authentication from a remote client.

The recommended state for this setting is: `Disabled`.

Rationale

Basic authentication is less robust than other authentication methods available in WinRM because credentials including passwords are transmitted in plain text. An attacker who is able to capture packets on the network where WinRM is running may be able to determine the credentials used for accessing remote hosts via WinRM.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Service\Allow Basic authentication

Note: This Group Policy path is provided by the Group Policy template `WindowsRemoteManagement.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Service:AllowBasic
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.97.2.1

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Added 'Policies' to the UI path in the Implementation.

BL968-2596

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'WinRM Service: Allow remote server management through WinRM' is set to 'Disabled'

Rule

Ensure 'WinRM Service: Allow remote server management through WinRM' is set to 'Disabled'.

E01 - High Security Zone

The use of 'Windows Remote Shell Access (WinRM)' in a 'High Security Zone' as defined in [Secure Network Topologies - Network Zone Types -> Chapter 3.2.7](#) is allowed.

E02 - Encrypted and ingress filter

This rule is not mandatory, if both of the following requirements are satisfied:

- All WinRM traffic is encrypted, e.g., by using HTTPs according [BL968-3126](#) or by using encrypted channel such as IPsec,
- Incoming connections are IP-based filtered to dedicated hosts mandatorily requiring WinRM access, such as Ansible-Tower systems, preferably by using the host's firewall according [BL968-3486](#), [BL968-1741](#) and [BL968-2696](#), or by using dedicated, external environment firewall appliance as mentioned in those rule's exemptions.

Description

This policy setting allows you to manage whether the Windows Remote Management (WinRM) service automatically listens on the network for requests on the HTTP transport over the default HTTP port.

Rationale

Any feature is a potential avenue of attack, those that enable inbound network connections are particularly risky. Only enable the use of the Windows Remote Management (WinRM) service on trusted networks and when feasible employ additional controls such as IPsec.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled:

Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Service\Allow remote server management through WinRM

Note: This Group Policy path is provided by the Group Policy template WindowsRemoteManagement.admx/adml that is included with all versions of the Microsoft Windows Administrative Templates.

Note #2: In older Microsoft Windows Administrative Templates, this setting was initially named *Allow automatic configuration of listeners*, but it was renamed starting with the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Service:AllowAutoConfig
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.97.2.2

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Combined exemption 02 and 03. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Added 'Policies' to the UI path in the Implementation.

BL968-3126

Asset Manager

C	I	A
123	123	123

Ensure 'WinRM Service: Allow unencrypted traffic' is set to 'Disabled'

Rule

Ensure 'WinRM Service: Allow unencrypted traffic' is set to 'Disabled'.

Description

This policy setting allows you to manage whether the Windows Remote Management (WinRM) service sends and receives unencrypted messages over the network.

Rationale

Encrypting WinRM network traffic reduces the risk of an attacker viewing or modifying WinRM messages as they transit the network.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Disabled :

Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Service\Allow unencrypted traffic

Note: This Group Policy path is provided by the Group Policy template WindowsRemoteManagement.admx/adml that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Service:AllowUnencryptedTraffic
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.97.2.3

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5411

Asset Manager

C	I	A
123	123	123

Ensure 'WinRM Service: Disallow WinRM from storing RunAs credentials' is set to 'Enabled'

Rule

Ensure 'Disallow WinRM from storing RunAs credentials' is set to 'Enabled'.

Description

This policy setting allows you to manage whether the Windows Remote Management (WinRM) service will allow RunAs credentials to be stored for any plug-ins.

Note: If you enable and then disable this policy setting, any values that were previously configured for RunAsPassword will need to be reset.

Rationale

Although the ability to store RunAs credentials is a convenient feature it increases the risk of account compromise slightly. For example, if you forget to lock your desktop before leaving it unattended for a few minutes another person could access not only the desktop of your computer but also any hosts you manage via WinRM with cached RunAs credentials.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Remote Management (WinRM)\WinRM Service\Disallow WinRM from storing RunAs credentials

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template WindowsRemoteManagement.admx/adml that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

The WinRM service will not allow the RunAsUser or RunAsPassword configuration values to be set for any plug-ins. If a plug-in has already set the RunAsUser and RunAsPassword configuration values, the RunAsPassword configuration value will be erased from the credential store on the computer.

If this setting is later Disabled again, any values that were previously configured for RunAsPassword will need to be reset.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Service:DisableRunAs
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.97.2.4

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Windows Remote Shell

This section contains settings related to Windows Remote Shell (WinRS).

This Group Policy section is provided by the Group Policy template `WindowsRemoteShell1.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-3514

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Allow Remote Shell Access' is set to 'Disabled'

Rule

Ensure 'Allow Remote Shell Access' is set to 'Disabled'.

E01 - High Security Zone

The use of 'Windows Remote Shell Access (WinRM)' in a 'High Security Zone' as defined in [Secure Network Topologies - Network Zone Types -> Chapter 3.2.7](#) is allowed.

E02 - Encrypted and ingress filter

This rule is not mandatory, if both of the following requirements are satisfied:

- All WinRM traffic is encrypted, e.g., by using HTTPs according [BL968-3126](#) or by using encrypted channel such as IPsec,
- Incoming connections are IP-based filtered to dedicated hosts mandatorily requiring WinRM access, such as Ansible-Tower systems, preferably by using the host's firewall according [BL968-3486](#), [BL968-1741](#) and [BL968-2696](#), or by using dedicated, external environment firewall appliance as mentioned in those rule's exemptions.

Description

This policy setting allows you to manage configuration of remote access to all supported shells to execute scripts and commands.

Note: The GPME help text for this setting is incorrectly worded, implying that configuring it to `Enabled` will reject new Remote Shell connections, and setting it to `Disabled` will allow Remote Shell connections. The opposite is true (and is consistent with the title of the setting). This is a wording mistake by Microsoft in the Administrative Template.

Rationale

This feature is a potential avenue of attack because it enables all kind of administrative shell access.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

Computer Configuration\Policies\Administrative Templates\Windows
Components\Windows Remote Shell\Allow Remote Shell Access

Note: This Group Policy path is provided by the Group Policy template
WindowsRemoteShell.admx/adml that is included with all versions of the Microsoft Windows
Administrative Templates.

Impact:

New Remote Shell connections are not allowed and are rejected by the server.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Service\WinRS:AllowRemoteShellAccess
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 18.9.98.1

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Combined exemption 02 and 03. This rule is consistent with the CIS recommendation. Aligned with
Siemens Windows Server 2019 (BL942).

Administrative Templates (User)

This section contains user-based recommendations from Group Policy Administrative Templates (ADMX).

Control Panel

This section contains recommendations for Control Panel settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Personalization (formerly Desktop Themes)

This section contains recommendations for personalization settings.

This Group Policy section is provided by the Group Policy template `ControlPanelDisplay.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was initially named *Desktop Themes* but was renamed by Microsoft to *Personalization* starting with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates.

BL968-1011

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Enable screen saver' is set to 'Enabled'

Rule Ensure 'Enable screen saver' is set to 'Enabled'.

E01 - Privileged Access Management Solutions

This rule is not mandatory, i.e., the respective setting can be set to `Disabled`, for users which are **exclusively** managed and used by Privileged Access Management solutions, such as CyberArk, using automated session establishment hiding account credentials from connecting user.

Description

This policy setting enables/disables the use of desktop screen savers.

Rationale

If a user forgets to lock their computer when they walk away, it is possible that a passerby will hijack it. Configuring a timed screen saver with password lock will help to protect against these hijacks.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled** :

User Configuration\Policies\Administrative Templates\Control
Panel\Personalization\Enable screen saver

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template ControlPanelDisplay.admx/adml that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

Impact:

A screen saver is enabled on user objects.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\[USER SID]\Software\Policies\Microsoft\Windows\Control Panel\Desktop:ScreenSaveActive
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 19.1.3.1

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added PAM exemption. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-3326

Asset Manager

C	I	A
123	123	123

Ensure 'Password protect the screen saver' is set to 'Enabled'

Rule

Ensure 'Password protect the screen saver' is set to 'Enabled'.

Description

This setting determines whether screen savers used on the computer are password protected.

Rationale

If a user forgets to lock their computer when they walk away, it is possible that a passerby will hijack it. Configuring a timed screen saver with password lock will help to protect against these hijacks.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled` :

User Configuration\Policies\Administrative Templates\Control
Panel\Personalization>Password protect the screen saver

Note: This Group Policy path is provided by the Group Policy template `ControlPanelDisplay.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

All screen savers are password protected. The "Password protected" checkbox on the Screen Saver dialog in the Personalization or Display Control Panel will be disabled, preventing users from changing the password protection setting.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\[USER_SID]\Software\Policies\Microsoft\Windows\Control Panel\Desktop:ScreenSaverIsSecure
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 19.1.3.3

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-4456

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Screen saver timeout' is set to 'Enabled: 900 seconds or fewer, but not 0'

Rule

Ensure 'Screen saver timeout' is set to 'Enabled: 900 seconds or fewer, but not 0'.

E01 - Privileged Access Management Solutions

This rule is not mandatory, i.e., the respective setting can be set to 0, for users which are **exclusively** managed and used by Privileged Access Management solutions, such as CyberArk, using automated session establishment hiding account credentials from connecting user.

Description

This setting specifies how much user idle time must elapse before the screen saver is launched.

Note: This setting has no effect under the following circumstances:

- The wait time is set to zero.
- The "Enable Screen Saver" setting is disabled.
- A valid screen existing saver is not selected manually or via the "Screen saver executable name" setting

Rationale

If a user forgets to lock their computer when they walk away, it is possible that a passerby will hijack it. Configuring a timed screen saver with password lock will help to protect against these hijacks.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to **Enabled: 900 or fewer, but not 0**:

User Configuration\Policies\Administrative Templates\Control Panel\Personalization\Screen saver timeout

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template ControlPanelDisplay.admx/adml that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

Note: This setting applies only to users objects, regardless on which machine the user logs on. A screen saver should also be enabled on machine objects. For more information see: [BL968-5071 Ensure 'Interactive logon: Machine inactivity limit' is set to '900 or fewer second\(s\), but not 0'](#).

Impact:

The screen saver will automatically activate when the computer has been left unattended for the amount of time specified, and the users will not be able to change the timeout value.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\[USER_SID]\Software\Policies\Microsoft\Windows\Control Panel\Desktop:ScreenSaveTimeout
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 19.1.3.4

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added PAM exemption. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Start Menu and Taskbar

This section contains recommendations for Start Menu and Taskbar settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Notifications

This section contains recommendations for Notification settings.

This Group Policy section is provided by the Group Policy template `WPN.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

BL968-1936

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off toast notifications on the lock screen' is set to 'Enabled'

Rule Ensure 'Turn off toast notifications on the lock screen' is set to 'Enabled'.

Description

This policy setting turns off toast notifications on the lock screen.

Rationale

While this feature can be handy for users, applications that provide toast notifications might display sensitive personal or business data while the device is left unattended.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

User Configuration\Policies\Administrative Templates\Start Menu and Taskbar\Notifications\Turn off toast notifications on the lock screen

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `WPN.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

Impact:

Applications will not be able to raise toast notifications on the lock screen.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_USERS\[USER  
SID]\Software\Policies\Microsoft\Windows\CurrentVersion\PushNotifications;NoToastApplicationNotification  
OnLockScreen
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 19.5.1.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

System

This section contains recommendations for System settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Internet Communication Management

This section contains recommendations related to Internet Communication Management.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Internet Communication settings

This section contains recommendations related to Internet Communication settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-3506

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off Help Experience Improvement Program' is set to 'Enabled'

Rule

Ensure 'Turn off Help Experience Improvement Program' is set to 'Enabled'.

Description

This policy setting specifies whether users can participate in the Help Experience Improvement program. The Help Experience Improvement program collects information about how customers use Windows Help so that Microsoft can improve it.

Rationale

Large enterprise managed environments may not want to have information collected by Microsoft from managed client computers.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

User Configuration\Policies\Administrative Templates\System\Internet Communication Management\Internet Communication Settings\Turn off Help Experience Improvement Program

Note: This Group Policy path is provided by the Group Policy template `HelpAndSupport.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Users cannot participate in the Help Experience Improvement program.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\[USER SID]\Software\Policies\Microsoft\Assistance\Client\1.0:NoImplicitFeedback
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 19.6.6.1.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Windows Components

This section contains recommendations for Windows Component settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Attachment Manager

This section contains recommendations related to Attachment Manager.

This Group Policy section is provided by the Group Policy template `AttachmentManager.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-2421

Asset Manager

C	I	A
123	123	123

Ensure 'Do not preserve zone information in file attachments' is set to 'Disabled'

Rule

Ensure 'Do not preserve zone information in file attachments' is set to 'Disabled'.

Description

This policy setting allows you to manage whether Windows marks file attachments with information about their zone of origin (such as restricted, Internet, Intranet, local). This requires NTFS in order to function correctly, and will fail without notice on FAT32. By not preserving the zone information, Windows cannot make proper risk assessments.

Note: The Attachment Manager feature warns users when opening or executing files which are marked as being from an untrusted source, unless/until the file's zone information has been removed via the "Unblock" button on the file's properties or via a separate tool such as [Microsoft Sysinternals Streams](#). .

Rationale

A file that is downloaded from a computer in the Internet or Restricted Sites zone may be moved to a location that makes it appear safe, like an Intranet file share, and executed by an unsuspecting user. The Attachment Manager feature will warn users when opening or executing files which are marked as being from an untrusted source, unless/until the file's zone information has been removed.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled` :

User Configuration\Policies\Administrative Templates\Windows Components\Attachment Manager\Do not preserve zone information in file attachments

Note: This Group Policy path is provided by the Group Policy template AttachmentManager.admx/adml that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\[USER_SID]\Software\Microsoft\Windows\CurrentVersion\Policies\Attachments:SaveZoneInformation
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 19.7.4.1

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

BL968-4885

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Notify antivirus programs when opening attachments' is set to 'Enabled'

Rule

Ensure 'Notify antivirus programs when opening attachments' is set to 'Enabled'.

Description

This policy setting manages the behavior for notifying registered antivirus programs. If multiple programs are registered, they will all be notified.

Note: An updated antivirus program must be installed for this policy setting to function properly.

Rationale

Antivirus programs that do not perform on-access checks may not be able to scan downloaded files.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

User Configuration\Policies\Administrative Templates\Windows Components\Attachment Manager\Notify antivirus programs when opening attachments

Note: This Group Policy path is provided by the Group Policy template `AttachmentManager.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Windows tells the registered antivirus program(s) to scan the file when a user opens a file attachment. If the antivirus program fails, the attachment is blocked from being opened.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\[USER SID]\Software\Microsoft\Windows\CurrentVersion\Policies\Attachments:ScanWithAntiVirus
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 19.7.4.2

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Cloud Content

This section contains recommendations for Cloud Content.

This Group Policy section is provided by the Group Policy template `CloudContent.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

BL968-2206

Asset Manager

C	I	A
123	123	123

Ensure 'Configure Windows spotlight on lock screen' is set to 'Disabled'

Rule

Ensure 'Configure Windows spotlight on lock screen' is set to 'Disabled'.

Description

This policy setting lets you configure Windows Spotlight on the lock screen.

Note: [Per Microsoft TechNet](#) , this policy setting only applies to Windows 10 Enterprise and Windows 10 Education editions.

Rationale

Enabling this setting will help ensure your data is not shared with any third party. The Windows Spotlight feature collects data and uses that data to display suggested apps as well as images from the Internet.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled` :

User Configuration\Policies\Administrative Templates\Windows Components\Cloud Content\Configure Windows spotlight on lock screen

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `CloudContent.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows Spotlight will be turned off and users will no longer be able to select it as their lock screen.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\[USER_SID]\Software\Policies\Microsoft\Windows\CloudContent:ConfigureWindowsSpotlight
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 19.7.7.1

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-5581

Asset Manager

C	I	A
123	123	123

Ensure 'Do not suggest third-party content in Windows spotlight' is set to 'Enabled'

Rule

Ensure 'Do not suggest third-party content in Windows spotlight' is set to 'Enabled'.

Description

This policy setting determines whether Windows will suggest apps and content from third-party software publishers.

Rationale

Enabling this setting will help ensure your data is not shared with any third party. The Windows Spotlight feature collects data and uses that data to display suggested apps as well as images from the Internet.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

User Configuration\Policies\Administrative Templates\Windows Components\Cloud Content\Do not suggest third-party content in Windows spotlight

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template `CloudContent.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows Spotlight on lock screen, Windows tips, Microsoft consumer features and other related features will no longer suggest apps and content from third-party software publishers. Users may still see suggestions and tips to make them more productive with Microsoft features and apps.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\[USER_SID]\Software\Policies\Microsoft\Windows\CloudContent:DisableThirdPartySuggestions
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 19.7.7.2

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

BL968-3666

Asset Manager

C	I	A
123	123	123

Ensure 'Turn off all Windows spotlight features' is set to 'Enabled'

Rule

Ensure 'Turn off all Windows spotlight features' is set to 'Enabled'.

Description

This policy setting lets you turn off all Windows Spotlight features at once.

Note: [Per Microsoft TechNet](#) , this policy setting only applies to Windows 10 Enterprise and Windows 10 Education editions.

Rationale

Enabling this setting will help ensure your data is not shared with any third party. The Windows Spotlight feature collects data and uses that data to display suggested apps as well as images from the Internet.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to Enabled :

User Configuration\Policies\Administrative Templates\Windows Components\Cloud Content\Turn off all Windows spotlight features

Note: This Group Policy path may not exist by default. It is provided by the Group Policy template CloudContent.admx/adml that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Impact:

Windows Spotlight on lock screen, Windows tips, Microsoft consumer features and other related features will be turned off.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\[USER_SID]\Software\Policies\Microsoft\Windows\CloudContent:DisableWindowsSpotlightFeatures
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 19.7.7.4

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Network Sharing

This section contains recommendations related to Network Sharing.

This Group Policy section is provided by the Group Policy template `Sharing.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-4706

Asset Manager



Ensure 'Prevent users from sharing files within their profile.' is set to 'Enabled'

Rule

Ensure 'Prevent users from sharing files within their profile.' is set to 'Enabled'.

Description

This policy setting determines whether users can share files within their profile. By default, users are allowed to share files within their profile to other users on their network after an administrator opts in the computer. An administrator can opt in the computer by using the sharing wizard to share a file within their profile.

The recommended state for this setting is: `Enabled`.

Rationale

If not properly configured, a user could accidentally share sensitive data with unauthorized users. In an enterprise managed environment, the company should provide a managed location for file sharing, such as a file server or SharePoint, instead of the user sharing files directly from their own user profile.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

User Configuration\Policies\Administrative Templates\Windows Components\Network Sharing\Prevent users from sharing files within their profile.

Note: This Group Policy path is provided by the Group Policy template `Sharing.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Users cannot share files within their profile using the sharing wizard. Also, the sharing wizard cannot create a share at `%root%\Users` and can only be used to create SMB shares on folders.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_USERS\[USER_SID]\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer:NoInplaceSharing
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 19.7.26.1

[Based on Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation.
Aligned with Siemens Windows Server 2019 (BL942).

Windows Installer

This section contains recommendations related to Windows Installer.

This Group Policy section is provided by the Group Policy template `MSI.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-4886

EVAL until 2022-02-28

Asset Manager



Ensure 'User Configuration: Always install with elevated privileges' is set to 'Disabled'

Rule Ensure 'User Configuration: Always install with elevated privileges' is set to 'Disabled'.

Description

This setting controls whether or not Windows Installer should use system permissions when it installs any program on the system.

Note: This setting appears both in the Computer Configuration and User Configuration folders. To make this setting effective, you must enable the setting in both folders.

Caution: If enabled, skilled users can take advantage of the permissions this setting grants to change their privileges and gain permanent access to restricted files and folders. Note that the User Configuration version of this setting is not guaranteed to be secure.

Rationale

Users with limited privileges can exploit this feature by creating a Windows Installer installation package that creates a new local account that belongs to the local built-in Administrators group, adds their current account to the local built-in Administrators group, installs malicious software, or performs other unauthorized activities.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Disabled`:

User Configuration\Policies\Administrative Templates\Windows Components\Windows Installer\Always install with elevated privileges

Note: This Group Policy path is provided by the Group Policy template `MSI.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

None - this is the default behavior.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed.
This group policy setting is backed by the following registry location:

```
HKEY_USERS\[USER_SID]\Software\Policies\Microsoft\Windows\Installer:AlwaysInstallElevated
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 19.7.41.1

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

This rule is consistent with the CIS recommendation.

Windows Media Player

This section contains recommendations related to Windows Media Player.

This Group Policy section is provided by the Group Policy template `WindowsMediaPlayer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Playback

This section contains recommendations related to Windows Media Player playback.

This Group Policy section is provided by the Group Policy template `WindowsMediaPlayer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

BL968-1076

Asset Manager

C	I	A
123	123	123

Ensure 'Prevent Codec Download' is set to 'Enabled'

Rule

Ensure 'Prevent Codec Download' is set to 'Enabled'.

Description

This setting controls whether Windows Media Player is allowed to download additional codecs for decoding media files it does not already understand.

Rationale

This has some potential for risk if a malicious data file is opened in Media Player that requires an additional codec to be installed. If a special codec is required for a necessary job function, then that codec should first be tested to ensure it is legitimate, and it should be supplied by the IT department in the organization.

I01 - Implementation Example

To establish the recommended configuration via GP, set the following UI path to `Enabled`:

User Configuration\Policies\Administrative Templates\Windows Components\Windows Media Player\Playback\Prevent Codec Download

Note: This Group Policy path is provided by the Group Policy template `WindowsMediaPlayer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Impact:

Windows Media Player is prevented from automatically downloading codecs to your computer. In addition, the *Download codecs automatically* check box on the Player tab in the Player is not available.

C01 - Example Check

Navigate to the UI Path articulated in the Implementation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location:

```
HKEY_USERS\[USER_SID]\Software\Policies\Microsoft\WindowsMediaPlayer:PreventCodecDownload
```

Crossreferences

Based on CIS Benchmark 'Microsoft Windows Server 2016 RTM Release 1607' (v1.2): 19.7.45.2.1

Based on [Siemens Information Security Policy Framework Rule 12.1.1-05](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added Check section, no need to set an EVAL flag. This rule is consistent with the CIS recommendation. Aligned with Siemens Windows Server 2019 (BL942).

Group Policy Preferences (GPP)

This section contains rules that might be better applied by Group Policies Preferences (GPP) -> Windows Settings -> Registry rather than by Group Policies.

Audit

BL968-1001

Asset Manager

C	I	A
123	123	123

Configure 'Maximum log size (KB) of PowerShell'

Rule Ensure 'Maximum log size (KB) of PowerShell' is set to 153600 KB or more.

Description

Logfiles of 'Windows applications and services logs' may contain additional information beside the Windows advanced auditing. Increasing the 'maximum log size' of relevant logs ensures that entries will be kept for a reasonable time period.

Rationale

PowerShell is a common tool for attackers to carry out their activities. As of PowerShell Version 5, logging and auditing has been enhanced massively. With this version PowerShell is logging suspicious activities to Microsoft-Windows-PowerShell/Operational log by default. Thus, this log can provide valuable information for incident response analysis.

I01 - Implementation Example

To establish the recommended configuration using GP Preferences, change the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

- Path
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\WINEVT\Channels\Microsoft-Windows-PowerShell\Operational\MaxSize -Type DWORD -Value 0x9600000

To ensure that this setting is permanently updated on the server, ensure that the GP Preference 'Action:' is set to Update.

Impact:

140 MB of storage space is additionally required on the system partition.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1000

Asset Manager

C	I	A
123	123	123

Configure 'Maximum log size (KB) of TerminalServices-LocalSessionManager'

Rule

Ensure 'Maximum log size (KB) of TerminalServices-LocalSessionManager' is set to 5120 KB or more.

Description

Logfiles of 'Windows applications and services logs' may contain additional information beside the Windows advanced auditing. Increasing the 'maximum log size' of relevant logs ensures that entries will be kept for a reasonable time period.

Rationale

This log contains all interactive local logons. It can be used if the file 'security.evtx' has been deleted or overwritten. Thus, this log can provide valuable information for incident response analysis.

I01 - Implementation Example

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

- -Path
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\WINEVT\Channels\Microsoft-Windows-TerminalServices-LocalSessionManager\Operational\MaxSize -Type DWORD -Value 0x500000

To ensure that this setting is permanently updated on the server, ensure that the GP Preference 'Action:' is set to Update.

Impact:

4 MB of storage space is additionally required on the system partition.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Network Services

BL968-0991

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Configure 'Access-based Enumeration'

Rule Ensure 'Access-based Enumeration' is enabled on all non-system and non-administrative shares.

E01 - Exemption

Access-based Enumeration is not mandatory for:

- Administrative shares (e.g., C\$ and Admin\$),
- System shares (e.g., SYSVOL, NETLOGON).

Description

Access-based Enumeration displays only the files and folders that a user has permissions to access. If a user does not have Read (or equivalent) permissions for a folder, Windows hides the folder from the user's view. This feature is active only when viewing files and folders in a shared folder; it is not active when viewing files and folders in the local file system.

Rationale

If Access-based Enumeration (ABE) is not enabled on a shared folder, a user with access to the share can enumerate the names of files and folders even if s/he does not have equivalent NTFS permissions (e.g., Read). Though an attacker can only read file and folder names, it might reveal something about the content. This can be very helpful to an attacker in an early stage of the attack.

I01 - Group Policy Preferences (GPP)

To establish Access-based Enumeration using GPO Preferences, add all shares and enable 'Access-based Enumeration' in 'Sharing' properties.

Computer Configuration\Preferences\Windows Settings\Network Shares

To ensure that this setting is permanently updated on the server, ensure that the GP Preference 'Action:' is set to Update.

I02 - PowerShell

Get all shares and their enumeration mode:

```
Get-SmbShare | Select-Object Name, FolderEnumerationMode
```

Listing: BL968-0991_I02_01.ps1

Enable Access-based Enumeration on a share:

```
Set-SmbShare -Name <name of the share> -FolderEnumerationMode AccessBased
```

Listing: BL968-0991_I02_02.ps1

I03 - Tool

The following `dfsutil` command line enables Access-based Enumeration on a server that has either the 'Distributed File System' role service or 'Distributed File System Tools' feature installed:

```
dfsutil property abde enable \\<namespace_root>
```

Listing: BL968-0991_I03_01.ps1

Impact:

Access-based Enumeration causes a higher CPU load on the server hosting the share. This is due to the necessary filtering of the client requests. In some environments, this impact might be noticeable and cause slow response times for the users (monitor CPU load on the system with and without Access-based Enumeration to verify such an effect is indeed caused by Access-based Enumeration).

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added exemption 01. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0261

Asset Manager

C	I	A
123	123	123

Configure 'Default Share Permissions'

Rule

Ensure that 'Default Share Permissions' are empty.

Description

The default permission (=security descriptor) for a new share is stored in the registry key LanmanServer. To ensure that no uncontrolled default permissions are set on a newly created share, the default value of SrvsvcDefaultShareInfo should be cleared.

Rationale

The share permissions of a newly created share allow 'read access' to 'everyone'. This could offer a surface for an attacker.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GPO Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanmanServer\DefaultSecurity\SrvsvcDefaultShareInfo

-Type Binary

-Value 0x01, 0x00, 0x04, 0x80, 0x1c, 0x00, 0x00, 0x00, 0x2c, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x14, 0x00, 0x00, 0x00, 0x02, 0x00, 0x08, 0x00, 0x00, 0x00, 0x00, 0x01, 0x02, 0x00, 0x00, 0x00, 0x00, 0x00, 0x05, 0x20, 0x00, 0x00, 0x00, 0x20, 0x02, 0x00, 0x00, 0x01, 0x05, 0x00, 0x00, 0x00, 0x00, 0x00, 0x05, 0x15, 0x00, 0x00, 0x00, 0x4d, 0x64, 0x49, 0x2e, 0xfa, 0x4f, 0x0c, 0x2f, 0x07, 0xe5, 0x3b, 0x2b, 0x01, 0x02, 0x00, 0x00.

To ensure that any old setting is replaced on the client, ensure that the GP Preference 'Action:' is set to Replace.

Impact:

The share permission of new shares are empty upon creation. Existing shares are not affected. Permissions can be changed after creation.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-5981

Asset Manager

EVAL until 2022-02-28

C	I	A
123	123	123

Configure 'IPv6 Site-to-Site Static Tunnels'

Rule

Disable all IPv6 tunnel interfaces (Teredo, 6to4, ISATAP).

E01 - Exemption

This rule is not mandatory, if IPv6 is completely disabled due to [BL968-4849 Disable IPv6 \(Ensure TCPIP6 Parameter 'DisabledComponents' is set to '0xff \(255\)'\)](#).

E02 - Exemption

Over IPsec, the usage of ISATAP, 6to4 and Teredo is acceptable:

- The use of IPsec in transport mode and protecting the encapsulated IPv4 packets is required for tunnels.
- Alternatively, IPsec in tunnel mode can be used to transport IPv6 traffic over a non-trusted IPv4 network.

Description

Internet Protocol version 6 (IPv6) is a set of protocols that computers use to exchange information over the Internet and over home and business networks. IPv6 allows for many more IP addresses to be assigned than IPv4. Older networking, hosts and operating systems may not support IPv6 natively.

IPv6 and its components can be enabled or disabled by using the following values:

DisabledComponents	Value
Disable all tunnel interfaces	0x01
Disable 6to4	0x02
Disable ISATAP	0x04
Disable Teredo	0x08
Disable all LAN and PPP interfaces	0x10
Disable all LAN, PPP, and tunnel interfaces	0x11
Prefer IPv4 over IPv6	0xA
Disable IPv6 over all interfaces and prefer IPv4 to IPv6	0xFF

Acceptable values for Siemens servers are

- 0xFF disables IPv6 completely. This is the required setting as long as IPv6 is disabled,
- 0x01 disables all tunnel interfaces. This is the required setting, when IPv6 is enabled.

Rationale

Several tunnel protocols exist for IPv6, but all of them have one or more security issues.

More information can be found here: [IETF: Operational Security Considerations for IPv6 Networks -> 2.7.2. Transition Mechanisms.](#)

Specific information about the vulnerabilities of the IPv6 static-tunnel protocols can be found in the following chapters of the IETF documentation:

- 2.7.2.1 (Site-to-Site Static Tunnels),
- 2.7.2.2 (ISATAP),
- 2.7.2.3 (Teredo),
- 2.7.2.4 (6to4)

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\TCPIP6\Parameters\DisableComponents

-Type DWORD

-Value 0x01

To ensure that this setting is permanently updated on the server, ensure that the GP Preference 'Action:' is set to Update.

Note:

More information about configuring IPv6 with GPOs can be found here: [Microsoft Technet: How to Disable IPv6 through Group Policy](#).

Be aware though that simply turning off the group policy setting in the .ADM template will not "undo" the change once applied. Instead, the opposite setting must be applied to change the registry value to the opposite state.

Impact:

Disabled tunneling protocols cannot be used by clients and servers.

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added exemption 01. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0531

Asset Manager

C	I	A
123	123	123

Configure 'Sharing Wizard'

Rule

Ensure 'Sharing Wizard' is set to 'disabled'.

Description

If you open the 'Sharing' properties using the Windows Explorer, you see two buttons "Share" and "Advanced Sharing". The "Share" button sets filesystem permissions (NTFS). The "Advanced Sharing" button sets share permissions (CIFS).

Rationale

To avoid risky misconfigurations, the "Share" button will be disabled. NTFS permissions can be set using the "Security" properties or applying a script.

I01 - Group Policy Preferences (GPP)

The "Share Wizard" is disabled applying a registry Value. This value is user related, not machine related.

To establish the recommended configuration using GPO Preferences, add the following Registry Item

User Configuration\Preferences\Windows Settings\Registry

-Path:

HKCU:\Software\Microsoft\Windows\CurrentVersion\Explorer\Advanced\SharingWizardOn

-Type: DWORD

-Value: 0

To ensure that this setting is permanently updated on the server, ensure that the GP Preference 'Action:' is set to Update.

Impact:

NTFS permissions cannot be set inside the "Sharing Property".

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0117

Asset Manager

C	I	A
123	123	123

Configure 'SMBv3 protocol encryption'

Rule Enable SMB version 3 (SMBv3) encryption.

Note: This rule only affects the communication if both parties are at least Windows 8 or Windows Server 2012. When you apply this rule, older operating systems, such as Windows 7, can still access the shared folder but encryption will not be applied. To enforce encryption, see [BL968-0118 Do Not Allow Unencrypted SMB Sessions](#).

Note: This rule must be applied even when no folders are being shared.

Description

The version 3 of the Server Message Block protocol (SMBv3) introduced end-to-end encryption of SMB sessions. Windows allows you to configure the encryption for either all shares or only single shares. However, one of the drawbacks is that the communication will only be encrypted if both parties are at least Windows 8 or Windows Server 2012.

Rationale

If the communication is not encrypted, an attacker might capture the network packets of a SMB session and be able to obtain the files being transferred.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters\EncryptData

-Type DWORD

-Value 0x1

To ensure that this setting is permanently updated on the server, ensure that the GP Preference 'Action:' is set to Update.

More information can be found here: [Microsoft Developer: SMB3 Secure Dialect Negotiation](#).

Impact:

Internal SMB communication is always encrypted. Unencrypted SMB communication attempts from partners not supporting SMBv3 will be rejected.

I02 - PowerShell

Run the PowerShell command below with administrative privileges to enable encryption of all SMBv3 sessions:

```
Set-SmbServerConfiguration -EncryptData $true -Confirm:$false
```

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0118

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Do Not Allow Unencrypted SMB Sessions

Rule Set the parameter *RejectUnencryptedAccess* to True.

Note: This rule must be applied even when no folders are being shared.

Description

The version 3 of the Server Message Block protocol (SMBv3) introduced end-to-end encryption of SMB packets. Windows allows you to configure the encryption for either all shares or only single shares. However, one of the drawbacks is that the communication will only be encrypted if both parties are at least Windows 8 or Windows Server 2012.

Windows allows you to reject all SMB communications that do not support encryption with the parameter *RejectUnencryptedAccess*.

Rationale

If the communication is not encrypted, an attacker might capture the network packets of a SMB session and be able to obtain the files being transferred.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters\RejectUnencryptedAccess

-Type DWORD

-Value 0x1

To ensure that this setting is permanently updated on the server, ensure that the GP Preference 'Action:' is set to Update.

More information can be found here: [Microsoft Developer: Encryption in SMB3](#).

Impact:

Internal SMB communication is always encrypted. Unencrypted SMB communication attempts from partners not supporting SMBv3 will be rejected.

I02 - PowerShell

Enable the parameter *RejectUnencryptedAccess* by executing the following PowerShell command with administrative privileges:

```
Set-SmbServerConfiguration -RejectUnencryptedAccess $true -Confirm:$false
```

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Removed exemption. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Operating System

BL968-0641

Asset Manager

C	I	A
123	123	123

Configure 'Additional LSA Protection'

Rule

Enable Enhanced Protection for the LSASS Process.

Description

The Local Security Authority (LSA) is the OS component which ensures secure logons on all Windows computers. Since Windows 8.1 Microsoft has added enhanced security to better protect this critical process.

The enabling of this setting requires that any drivers and plug-ins have a valid Microsoft signature and follow the Microsoft Security Development Lifecycle (SDL) process.

More information can be found here: [Windows IT Pro Center - Configuring Additional LSA Protection](#) .

Note:

In case of driver problems, follow the Microsoft link above to enable the additional auditing mode to identify and eliminate the problems.

Rationale

The enabling of this setting prevents attackers to find user credentials in the memory and protects the LSASS process against code injection.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\LSA\RunAsPPL

-Type DWORD

-Value 0x1

To ensure that this setting is permanently updated on the server, ensure that the GP Preference 'Action:' is set to Update.

Note:

To discover if LSA was started in protected mode when Windows started, search for the following WinInit event in the System log under Windows Logs:

- '12: LSASS.exe was started as a protected process with level: 4'

Impact:

As the protection for the Local Security Authority (LSA) process is in place at Siemens with the release of the 'Security Measure Plan for Microsoft Windows Server 2012 (incl. R2)', no new problems caused by this rule are expected.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Transport Layer Security

This section contains recommendations for configuring TLS protocols and cipher suites.

For security protocols (SSL, TLS), there are 2 registry paths that control a protocol state in the operating system: TLS client and TLS server. If the operating system offers any services (e.g., a web server) it normally acts as the TLS server in that it is serving web content to clients. There are some instances where an operating system service is configured as a 'client'. An example of a server acting as a client can be seen when there is dynamic content generation. The webserver queries a remote database server to return content specific to a user's request. In this configuration, the web server is acting as a TLS client. In cases such as these, the configured TLS server protocol and cipher suite preferences take precedence over the client's.

If 'SSL 3.0' registry keys are not set, the operating system defaults take precedence.

For example, to disable 'SSL 3.0' protocol on the server, you need to set the following registry key to '0':

```
HKLM\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL  
3.0\Server\Enabled
```

To prevent a client from issuing the `Hello` command over that legacy protocol the following registry must be set to '0':

```
HKLM\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL  
3.0\Client\Enabled
```

The fact that the key is named 'Enabled' can be confusing. The setting of the value to either '0' or '1' actually sets the state of the protocol. '0' being disabled and '1' being enabled.

Here are some specifics into how 'Enabled' and 'DisabledByDefault' registry settings work. The following article, [Transport Layer Security \(TLS\) registry settings](#), provides additional information related to controlling these protocols and ciphers.

Using the 'Enabled = 0' registry setting disables the protocol in a way that cannot be overridden by application settings. This is the only robust way to prevent the protocol from being used and no additional settings are required. At the same time, using the 'DisabledByDefault' registry setting only prevents that protocol from issuing the `Hello` command over that protocol when an SSL connection with a server is initiated. This operating system level setting can be overridden by an application which has application specific TLS coding. An example of this can be shown by setting the protocol within a line of code in your .NET 4.5 application:

```
ServicePointManager.SecurityProtocol = SecurityProtocolType.Tls12.
```

This can override the operating system setting if the 'DisabledByDefault' key is present.

'DisabledByDefault' is useful in the case when you want to have some control over the system settings but also allow an application to explicitly specify the protocols they would like to use.

'Enabled' only works strongly in the negative case ('Enabled = 0'). If 'Enabled=1' or is not set, then 'DisabledByDefault' will override in the case where the application takes the system defaults. 'Enabled=1' is also overridden by application specific protocol flags.

Note: Besides verifying the settings on the server itself, you can also scan the allowed protocols and ciphers from a different system.

On a Windows system you could use, e.g., the following Tool: <https://github.com/rbsec/sslsan>.

BL968-0596

Asset Manager

C	I	A
123	123	

Disable 'SSL 2.0' Protocol

Rule Ensure 'SSL 2.0' is set to 'Disabled' in client and server mode.

Note: Although this protocol is disabled by default if the registry key is not present, it is required to set the registry to key to ensure that the protocol will not be activated accidentally.

Description

Transport Layer Security (TLS), and its predecessor Secure Sockets Layer (SSL) are cryptographic protocols which can be used to encrypt data sent between client and server.

Rationale

SSLv2 has turned out to be an insecure protocol for the transmission of sensitive information. All major software and IT vendors disregard usage of SSLv2 and recommend more secure protocols such as the TLS suite. This measure follows the recommendation and disables SSLv2 within the Windows operating system (Schannel) entirely (client and server mode).

Disabling weak protocols will help ensure the confidentiality and integrity of in-transit data.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client\Enabled

-Type DWORD

-Value 0x0

-Path

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL  
\Protocols\SSL 2.0\Server\DisabledByDefault
```

-Type DWORD

-Value 0x1

-Path

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL  
\Protocols\SSL 2.0\Client\DisabledByDefault
```

-Type DWORD

-Value 0x1

To ensure that these settings are permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

Any application that relies on SSLv2 and uses Windows' Schannel implementation will run into problems. Furthermore, any client connecting to the server that relies on SSLv2 will fail.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following commands:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server' -  
Force | Out-Null  
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client' -  
Force | Out-Null  
  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL  
2.0\Server' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL  
2.0\Client' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null  
  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL  
2.0\Server' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL  
2.0\Client' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-0596_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Protocol = "SSL 2.0"
$RgKy = "HKLM:\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\$Protocol\"
ForEach ($scope in "Server", "Client")
{
    $RgKyPth = $RgKy + $scope
    if (((Get-ItemProperty -Path $RgKyPth).DisabledbyDefault -ne 1) -or ((Get-ItemProperty -Path $RgKyPth).Enabled -ne 0))
    {
        "$Protocol $scope not configured correctly"
    }
    else
    {
        "$Protocol $scope configured correctly"
    }
}
```

Listing: BL968-0596_C01_01.ps1

Crossreferences

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added PowerShell Implementation and Check. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-0891

Asset Manager

C	I	A
1	1	
2	2	
3	3	

Disable 'SSL 3.0' Protocol

Rule

Ensure 'SSL 3.0' is set to 'Disabled' in client and server mode.

Description

Transport Layer Security (TLS), and its predecessor Secure Sockets Layer (SSL) are cryptographic protocols which can be used to encrypt data sent between client and server.

Rationale

SSLv3 has turned out to be an insecure protocol for the transmission of sensitive information. Encryption in SSLv3 uses either the RC4 stream cipher or block cipher in CBC mode. In both modes, severe security flaws were detected in the past (e.g., Poodle attack). All major software and IT vendors disregard usage of SSLv3 and recommend more secure protocols such as the TLS suite. This measure follows the recommendation and disables SSLv3 within the Windows operating system (Schannel) entirely (client and server mode).

Disabling weak protocols will help ensure the confidentiality and integrity of in-transit data.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server\DisabledByDefault

-Type DWORD

-Value 0x1

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client\DisabledByDefault\ -Type DWORD

-Value 0x1

To ensure that these settings are permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following commands:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server' -
Force | Out-Null
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client' -
Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL
3.0\Server' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL
3.0\Client' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL
3.0\Server' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL
3.0\Client' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-0891_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Protocol = "SSL 3.0"
$RgKy = "HKLM:\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\$Protocol\"
ForEach ($scope in "Server", "Client")
{
    $RgKyPth = $RgKy + $scope
    if (((Get-ItemProperty -Path $RgKyPth).DisabledbyDefault -ne 1) -or ((Get-ItemProperty -Path
$RgKyPth).Enabled -ne 0))
    {
        "$Protocol $scope not configured correctly"
    }
    else
    {
        "$Protocol $scope configured correctly"
    }
}
```

Listing: BL968-0891_C01_01.ps1

Crossreferences

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added PowerShell Implementation and Check. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-0312

Asset Manager

C	I	A
1	2	3
1	2	3

Disable 'TLS 1.0' Protocol

Rule

Ensure 'TLS 1.0' is set to 'Disabled' in client and server mode.

Description

TLS 1.0 is a direct further development of SSL 3.0 and is specified in [RFC2246]. Furthermore, the TLS protocol is available in the versions TLS 1.1 and TLS 1.2 which are specified in [RFC4346] and [RFC5246].

Secure Channel (Schannel) is primarily used for Internet applications that require secure Hypertext Transfer Protocol (HTTP) communications.

Note: Currently, the TLS 1.3 RFC has been formally approved, but TLS 1.3 should not be used before fully supported by Microsoft. Hence, there are no recommendations for TLS 1.3 yet.

Detailed information on implementing TLS 1.3 can be found here: [Microsoft Research - Implementing and Proving the TLS 1.3 Record Layer](#).

Rationale

Disabling weak protocols will help ensure the confidentiality and integrity of in-transit data.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server\DisabledByDefault

-Type DWORD

-Value 0x1

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client\DisabledByDefault

-Type DWORD

-Value 0x1

To ensure that these settings are permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

Any application that relies on TLS 1.0 and uses Windows Schannel implementation will fail.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following commands:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server' -
Force | Out-Null
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client' -
Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.0\Server' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.0\Client' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.0\Server' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.0\Client' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-0312_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Protocol = "TLS 1.0"
$RgKy = "HKLM:\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\$Protocol\"
ForEach ($scope in "Server", "Client")
{
    $RgKyPth = $RgKy + $scope
    if (((Get-ItemProperty -Path $RgKyPth).DisabledbyDefault -ne 1) -or ((Get-ItemProperty -Path
$RgKyPth).Enabled -ne 0))
    {
        "$Protocol $scope not configured correctly"
    }
    else
    {
        "$Protocol $scope configured correctly"
    }
}
```

Listing: BL968-0312_C01_01.ps1

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added PowerShell Implementation and Check. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-0313

Asset Manager

C	I	A
1	2	3
1	2	3

Disable 'TLS 1.1' Protocol

Rule

Ensure 'TLS 1.1' is set to 'Disabled' in client and server mode.

Description

TLS 1.1 is a direct further development of TLS 1.0 and is specified in [RFC4346]. Furthermore, the TLS protocol is available in the versions TLS 1.2 and TLS 1.3 which are specified in [RFC5246] and [RFC8446].

Secure Channel (Schannel) is primarily used for Internet applications that require secure Hypertext Transfer Protocol (HTTP) communications.

Note: Currently, the TLS 1.3 RFC has been formally approved, but TLS 1.3 should not be used before fully supported by Microsoft. Hence, there are no recommendations for TLS 1.3 yet.

Detailed information on implementing TLS 1.3 can be found here: [Microsoft Research - Implementing and Proving the TLS 1.3 Record Layer](#).

Rationale

Disabling weak protocols will help ensure the confidentiality and integrity of in-transit data.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Server\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Client\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Server\DisabledByDefault

-Type DWORD

-Value 0x1

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Client\DisabledByDefault

-Type DWORD

-Value 0x1

To ensure that these settings are permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, as this has been requested in the Server as well as in the IIS Measure Plans for quite some time.

Any application that relies on TLS 1.1 and uses Windows Schannel implementation will fail.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following command:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Server' -
Force | Out-Null
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Client' -
Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.1\Server' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.1\Client' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.1\Server' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.1\Client' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-0313_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Protocol = "TLS 1.1"
$RgKy = "HKLM:\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\$Protocol\"
ForEach ($scope in "Server", "Client")
{
    $RgKyPth = $RgKy + $scope
    if (((Get-ItemProperty -Path $RgKyPth).DisabledbyDefault -ne 1) -or ((Get-ItemProperty -Path
$RgKyPth).Enabled -ne 0))
    {
        "$Protocol $scope not configured correctly"
    }
    else
    {
        "$Protocol $scope configured correctly"
    }
}
```

Listing: BL968-0313_C01_01.ps1

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added PowerShell Implementation and Check. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-0314

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	

Enable 'TLS 1.2' Protocol

Rule

Ensure 'TLS 1.2' is set to 'Enabled' in client and server mode.

Description

TLS 1.2 is a recent and mature protocol for protecting the confidentiality and integrity of HTTP traffic. Enabling TLS 1.2 is recommended. This protocol is enabled by default if the registry key is not present. As with any registry changes, a reboot is required for changes to take effect.

Rationale

Enabling strong protocols will help ensure the confidentiality and integrity of in-transit data.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Server\Enabled

-Type DWORD

-Value 0x1

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Client\Enabled

-Type DWORD

-Value 0x1

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Server\DisabledByDefault

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Client\DisabledByDefault

-Type DWORD

-Value 0x0

To ensure that these settings are permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To enable using PowerShell enter the following command:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Server' -
Force | Out-Null
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Client' -
Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.2\Server' -name 'Enabled' -value '1' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.2\Client' -name 'Enabled' -value '1' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.2\Server' -name 'DisabledByDefault' -value '0' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.2\Client' -name 'DisabledByDefault' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-0314_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Protocol = "TLS 1.2"
$RgKy = "HKLM:\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\$Protocol\"
ForEach ($scope in "Server", "Client")
{
    $RgKyPth = $RgKy + $scope
    if (((Get-ItemProperty -Path $RgKyPth).DisabledbyDefault -ne 0) -or ((Get-ItemProperty -Path
$RgKyPth).Enabled -ne 1))
    {
        "$Protocol $scope not configured correctly"
    }
    else
    {
        "$Protocol $scope configured correctly"
    }
}
```

Listing: BL968-0314_C01_01.ps1

Crossreferences

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-0315

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	

Disable 'NULL' Cipher Suites

Rule

Ensure 'NULL' Cipher Suites are disabled.

Description

The NULL cipher does not provide data confidentiality or integrity. It is recommended that the NULL cipher be disabled.

Rationale

The usage of null cipher suites would effectively lead to clear-text communication. By disabling the NULL cipher, there is a better chance of maintaining data confidentiality and integrity.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\NULL\Enabled

-Type DWORD

-Value 0x0

To ensure that this setting is permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following commands:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\NULL' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\NULL'
-name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-0315_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Ciphers = @('NULL')
ForEach ($Cipher in $Ciphers)
{
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\$Cipher"
    $RegValue = "Enabled"
    $ExpValue = 0
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -eq ($ExpValue))
    {
        "Registry value '$RegValue' for cipher '$Cipher' correctly set to '$ExpValue'."
    }
    else
    {
        "Registry value '$RegValue' for cipher '$Cipher' not correctly set to '$ExpValue' but to '$result'."
    }
}
```

Listing: BL968-0315_C01_01.ps1

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-3906

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	

Disable 'DES' Cipher Suites

Rule

Ensure 'DES 56/56' Cipher Suites are disabled.

Description

The Data Encryption Standard (DES) is a symmetric-key algorithm for the encryption of electronic data. DES is a weak symmetric-key cipher and must therefore be disabled.

Rationale

It is fundamentally inadequate, because its 56-bit key is too short. By disabling DES, there is a better chance of maintaining data confidentiality and integrity.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\DES 56/56\Enabled

-Type DWORD

-Value 0x0

To ensure that this setting is permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following command:

```
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('DES 56/56')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\DES  
56/56' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-3906_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Ciphers = @('DES 56/56')
ForEach ($Cipher in $Ciphers)
{
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\$Cipher"
    $RegValue = "Enabled"
    $ExpValue = 0
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -eq ($ExpValue))
    {
        "Registry value '$RegValue' for cipher '$Cipher' correctly set to '$ExpValue'."
    }
    else
    {
        "Registry value '$RegValue' for cipher '$Cipher' not correctly set to '$ExpValue' but to '$result'."
    }
}
```

Listing: BL968-3906_C01_01.ps1

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-0821

Asset Manager

C	I	A
123	123	

Disable 'RC2' Cipher Suites

Rule

Ensure 'RC2 40/128', 'RC2 56/128', and 'RC2 128/128' Cipher Suites are disabled.

Description

RC2 is a stream cipher that has known practical attacks. It is recommended that RC2 be disabled.

Rationale

Use of RC2 in TLS and SSL could allow an attacker to perform man-in-the-middle attacks and recover plaintext from encrypted sessions.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC2 40/128\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC2 56/128\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC2 128/128\Enabled

-Type DWORD

-Value 0x0

To ensure that this setting is permanently updated on the server, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable RC2 40/128, RC2 56/128, and RC2 128/128 using PowerShell enter the following commands:

```
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('RC2 40/128')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC2  
40/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null  
  
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('RC2 56/128')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC2  
56/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null  
  
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('RC2 128/128')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC2  
128/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-0821_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Ciphers = @('RC2 40/128', 'RC2 56/128', 'RC2 128/128')  
ForEach ($Cipher in $Ciphers)  
{  
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\${Cipher}"  
    $RegValue = "Enabled"  
    $ExpValue = 0  
    $result = (Get-ItemProperty -Path $RegKey).$RegValue  
    if (($result) -eq ($ExpValue))  
    {  
        "Registry value '$RegValue' for cipher '$Cipher' correctly set to '$ExpValue'."  
    }  
    else  
    {  
        "Registry value '$RegValue' for cipher '$Cipher' not correctly set to '$ExpValue' but to '$result'."  
    }  
}
```

Listing: BL968-0821_C01_01.ps1

Crossreferences

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added PowerShell Implementation and Check. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-0131

Asset Manager

C	I	A
123	123	

Disable 'RC4' Cipher Suites

Rule Ensure 'RC4 40/128', 'RC4 56/128', 'RC4 64/128', and 'RC4 128/128' Cipher Suites are disabled.

Description

RC4 is a stream cipher that has known practical attacks. It is recommended that RC4 be disabled.

Rationale

Use of RC4 in TLS and SSL could allow an attacker to perform man-in-the-middle attacks and recover plaintext from encrypted sessions.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4 40/128\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4 56/128\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4 64/128\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4 128/128\Enabled

-Type DWORD

-Value 0x0

To ensure that these settings are permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable RC4 40/128, RC4 56/128, RC4 64/128 and RC4 128/128 using PowerShell enter the following commands:

```
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',
$true).CreateSubKey('RC4 40/128')
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4
40/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',
$true).CreateSubKey('RC4 56/128')
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4
56/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',
$true).CreateSubKey('RC4 64/128')
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4
64/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',
$true).CreateSubKey('RC4 128/128')
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4
128/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-0131_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Ciphers = @('RC4 40/128', 'RC4 56/128', 'RC4 64/128', 'RC4 128/128')
ForEach ($Cipher in $Ciphers)
{
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\$Cipher"
    $RegValue = "Enabled"
    $ExpValue = 0
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -eq ($ExpValue))
    {
        "Registry value '$RegValue' for cipher '$Cipher' correctly set to '$ExpValue'."
    }
    else
    {
        "Registry value '$RegValue' for cipher '$Cipher' not correctly set to '$ExpValue' but to '$result'."
    }
}
```

Listing: BL968-0131_C01_01.ps1

Crossreferences

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added PowerShell Implementation and Check. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-0317

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	

Disable 'Triple DES' Cipher Suites

Rule

Ensure 'Triple DES 168' Cipher Suites are disabled.

Description

Triple DES (Triple Data Encryption Algorithm) relies on a series of three DES keys and appears to offer 168 bit key length of protection, but due to the ability for attackers to generate three dimensional lookup tables that have all combinations of the first and third key available in the realm of potential 56 bit key length combinations, something known as the meet-in-the-middle vulnerability arises which reduces the mathematical complexity of cracking the keys exponentially and significantly. 3DES key strength provides only 112 bits of protection.

Rationale

Security institutions (e.g., the German BSI) clearly recommend migrating away from it because Triple DES does not fulfill the requirement of 128 bit symmetric key size equivalent. 3DES vulnerabilities are, e.g., collision attacks like `sweet32` and `meet-in-the-middle` attack.

Although the 'Triple DES 168' keying option '3TDEA' is considered to be secure, 'Triple DES 168' has to be disabled completely. In Windows operating systems you can only enable or disable 'Triple DES 168' but not differentiate between specific keying options.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\Triple DES 168\Enabled

-Type DWORD

-Value 0x0

To ensure that this setting is permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable Triple DES 168 using PowerShell enter the following command:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\Triple DES 168' -  
Force | Out-Null  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\Triple  
DES 168' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-0317_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following command:

```
$Ciphers = @('Triple DES 168')  
ForEach ($Cipher in $Ciphers)  
{  
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\${Cipher}"  
    $RegValue = "Enabled"  
    $ExpValue = 0  
    $result = (Get-ItemProperty -Path $RegKey).$RegValue  
    if (($result) -eq ($ExpValue))  
    {  
        "Registry value '$RegValue' for cipher '$Cipher' correctly set to '$ExpValue'."  
    }  
    else  
    {  
        "Registry value '$RegValue' for cipher '$Cipher' not correctly set to '$ExpValue' but to '$result'."  
    }  
}
```

Listing: BL968-0317_C01_01.ps1

Crossreferences

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-0318

EVAL until 2022-02-28

Asset Manager

C	I	A
1	2	3
2	1	2
3	3	1

Enable 'AES 128/128' Cipher Suites

Rule

Ensure 'AES 128/128' Cipher Suites are enabled.

Description

AES (acronym of Advanced Encryption Standard) is a symmetric encryption algorithm. The algorithm was developed by two Belgian cryptographer Joan Daemen and Vincent Rijmen. AES was designed to be efficient in both hardware and software, and supports a block length of 128 bits and key lengths of 128, 192, and 256 bits.

Rationale

Enabling this cipher will help ensure the confidentiality and integrity of data in transit.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AES 128/128\Enabled

-Type DWORD

-Value 0x1

To ensure that this setting is permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To enable using PowerShell enter the following command:

```
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('AES 128/128')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AES  
128/128' -name 'Enabled' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-0318_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Ciphers = @('AES 128/128')
ForEach ($Cipher in $Ciphers)
{
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\$Cipher"
    $RegValue = "Enabled"
    $ExpValue = 1
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -eq ($ExpValue))
    {
        "Registry value '$RegValue' for cipher '$Cipher' correctly set to '$ExpValue'."
    }
    else
    {
        "Registry value '$RegValue' for cipher '$Cipher' not correctly set to '$ExpValue' but to '$result'."
    }
}
```

Listing: BL968-0318_C01_01.ps1

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-0319

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	

Enable 'AES 256/256' Cipher Suites

Rule

Ensure 'AES 256/256' Cipher Suites are enabled.

Description

AES 256/256 is the most recent and mature cipher suite for protecting the confidentiality and integrity of HTTP traffic. Enabling AES 256/256 is recommended.

Rationale

Enabling this cipher will help ensure the confidentiality and integrity of data in transit.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AES 256/256\Enabled

-Type DWORD

-Value 0x1

To ensure that this setting is permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To enable using PowerShell enter the following command:

```
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('AES 256/256')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AES  
256/256' -name 'Enabled' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-0319_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following command:

```
$Ciphers = @('AES 256/256')
ForEach ($Cipher in $Ciphers)
{
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\$Cipher"
    $RegValue = "Enabled"
    $ExpValue = 1
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -eq ($ExpValue))
    {
        "Registry value '$RegValue' for cipher '$Cipher' correctly set to '$ExpValue'."
    }
    else
    {
        "Registry value '$RegValue' for cipher '$Cipher' not correctly set to '$ExpValue' but to '$result'."
    }
}
```

Listing: BL968-0319_C01_01.ps1

Crossreferences

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-0320

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	

Disable 'MD5' Hashing Algorithm

Rule

Ensure 'MD5' Hashing Algorithm is disabled.

Description

This hash algorithm is not considered secure anymore. Disabling it is recommended.

Rationale

The MD5 algorithm is reported prone to a hash collision weakness. This weakness reportedly allows attackers to create multiple, differing input sources that, when the MD5 algorithm is used, result in the same MD5-Hash output.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\MD5\Enabled

-Type DWORD

-Value 0x0

To ensure that this setting is permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following command:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\MD5' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\MD5' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-0320_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Hashes = @('MD5')
ForEach ($Hash in $Hashes)
{
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\$Hash"
    $RegValue = "Enabled"
    $ExpValue = 0
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -eq ($ExpValue))
    {
        "Registry value '$RegValue' for hash '$Hash' correctly set to '$ExpValue'."
    }
    else
    {
        "Registry value '$RegValue' for hash '$Hash' not correctly set to '$ExpValue' but to '$result'."
    }
}
```

Listing: BL968-0320_C01_01.ps1

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-0323

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	

Disable 'SHA-1' Hashing Algorithm

Rule

Ensure 'SHA-1' Hashing Algorithm is disabled.

Description

The term "Secure Hash Algorithms" describes a group of standardized cryptographic hash functions which are used to calculate a unique checksum for any digital data. These checksums play an important part in TLS/SSL encryption and are used as unique identifier within a server certificate.

Note: Contrary to information on many Microsoft websites there are more values available under the registry key Hashes besides MD5 and SHA. The additional values are SHA256, SHA384, and SHA512. Therefore, disabling the value SHA will only disable the SHA-1 hash algorithm, but not the newer more secure SHA algorithms.

Rationale

The SHA-1 algorithm is reported prone to a hash collision weakness. In 2017, it was performed a collision attack against SHA-1, publishing two dissimilar PDF files which produced the same SHA-1 hash.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\SHA\Enabled

-Type DWORD

-Value 0x0

To ensure that this setting is permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following command:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\SHA' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\SHA' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-0323_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following command:

```
$Hashes = @('SHA')
ForEach ($Hash in $Hashes)
{
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\$Hash"
    $RegValue = "Enabled"
    $ExpValue = 0
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -eq ($ExpValue))
    {
        "Registry value '$RegValue' for hash '$Hash' correctly set to '$ExpValue'."
    }
    else
    {
        "Registry value '$RegValue' for hash '$Hash' not correctly set to '$ExpValue' but to '$result'."
    }
}
```

Listing: BL968-0323_C01_01.ps1

Crossreferences

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-0484

Asset Manager

C	I	A
123	123	

Ensure sufficient 'Modulus Size in the DHE Key Exchange'

Rule Ensure the modulus size of Diffie-Hellman Ephemeral (DHE) is set to 2048 bit or higher.

Note: A bit size higher than 2048 bits for DHE should be evaluated carefully as this may impose performance issues.

Description

Ephemeral Diffie-Hellman (DHE in the context of TLS) differs from the static Diffie-Hellman (DH) in the way that static Diffie-Hellman key exchange always use the same Diffie-Hellman private keys. So, each time the same parties do a DH key exchange, they end up with the same shared secret.

When a key exchange uses Ephemeral Diffie-Hellman a temporary DH key is generated for every connection and thus the same key is never used twice. This enables *Perfect Forward Secrecy* (PFS), which means that if the long-term private key of the server gets leaked, past communication is still secure.

By default, the modulus size of Diffie-Hellman Ephemeral (DHE) is set to 1024 bit.

Rationale

In 2015, a group of researchers published a paper, describing weaknesses in Diffie- Hellmann key exchange when using a modulus size up to 1024 bit. This vulnerability is known as the Logjam attack (see here [https://en.wikipedia.org/wiki/Logjam_\(computer_security\)](https://en.wikipedia.org/wiki/Logjam_(computer_security))).

The improper configuration of DHE key exchange could allow an attacker to perform man-in-the-middle attacks and recover plaintext from encrypted sessions.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL
\KeyExchangeAlgorithms\Diffie-Hellman\ServerMinKeyBitLength

-Type DWORD

-Value 0x800

To ensure that this setting is permanently updated on the server, ensure that the GP Preference 'Action:' is set to Update.

Possible values for ServerMinKeyBitLength:

Modulus size (Dec)	Modulus Size (Hex)
1024	default
2048	0x800
3072	0xC00
4096	0x1000

More information can be found here: [Microsoft Security Advisory 3174644](#).

Note:

For Windows Versions before Windows 10 and Windows Server 2016 make sure that Microsoft Advisory 3174644 [Microsoft security advisory: Updated support for Diffie-Hellman Key Exchange](#) already has been implemented.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To set the modulus size of Diffie-Hellman Ephemeral to 2048 bits using PowerShell enter the following command:

```
New-Item
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\KeyExchangeAlgorithms\Diffie-Hellman'
-Force | Out-Null
New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\KeyExchangeAlgorithms\Diffie-Hellman'
-name 'ServerMinKeyBitLength' -value '0x00000800' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL968-0484_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following command:

```
$KEAs = @('Diffie-Hellman')
ForEach ($KEA in $KEAs)
{
    $RegKey =
    "HKLM:System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\KeyExchangeAlgorithms\$KEA"
    $RegValue = "ServerMinKeyBitLength"
    $ExpValue = 2048
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -ge ($ExpValue))
    {
        "Registry value '$RegValue' for modulus size of '$KEA' (DHE) correctly set to '$result'."
    }
    else
    {
        "Registry value '$RegValue' for modulus size of '$KEA' (DHE) not correctly set to '$result' but to '$result'."
    }
}
```

Listing: BL968-0484_C01_01.ps1

Crossreferences

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Added PowerShell Implementation and Check. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115).

BL968-0325

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	

Configure TLS Cipher Suite Ordering

Rule

Ensure TLS Cipher Suite ordering is ordered from strongest to weakest Cipher Suite. Use the following order and thus, enabled cipher suites:

- TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384
- TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
- TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256
- TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
- TLS_DHE_RSA_WITH_AES_256_GCM_SHA384
- TLS_DHE_RSA_WITH_AES_128_GCM_SHA256

Note: From the list of currently supported and by default enabled cipher suites in Windows Server 2016, only the above listed cipher suites are allowed.

E01 - Exemption

The TLS Cipher Suite ordering can be changed, if business needs are requiring this. In this case, the reasons for the change have to be documented accordingly.

Note: Avoid cipher suites that do not provide Perfect Forward Secrecy or use weak hashing function, use them only if you need to support backwards compatibility and in the bottom of the order preference list.

Description

Cipher suites are a named combination of authentication, encryption, message authentication code, and key exchange algorithms used for the security settings of a network connection using TLS protocol. Clients send a cipher list and a list of ciphers that it supports in order of preference to a server. The server then replies with the cipher suite that it selects from the client cipher suite list.

Cipher suites should be ordered from strongest to weakest in order to ensure that the more secure configuration is used for encryption between the server and client.

- TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384
- TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
- TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256
- TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
- TLS_DHE_RSA_WITH_AES_256_GCM_SHA384
- TLS_DHE_RSA_WITH_AES_128_GCM_SHA256

Note: From the list of currently supported and by default enabled cipher suites in Windows Server 2016, only the above listed cipher suites are allowed. The following cipher suites are disallowed with appropriately given reason:

- Disallowed due to deprecated and vulnerable CBC padding mode used in AES-encryption:
 - TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384
 - TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256
 - TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384
 - TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256
 - TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA
 - TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA
 - TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA
 - TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA
 - TLS_RSA_WITH_AES_256_CBC_SHA256
 - TLS_RSA_WITH_AES_128_CBC_SHA256
- Disallowed due to lack of perfect forward secrecy (PFS):
 - TLS_RSA_WITH_AES_256_GCM_SHA384
 - TLS_RSA_WITH_AES_128_GCM_SHA256
- Disallowed due to NULL encryption and lack of perfect forward secrecy (PFS):
 - TLS_RSA_WITH_NULL_SHA256
- Disallowed due to deprecated CBC padding mode for AES encryption, lack of perfect forward secrecy (PFS), deprecated 3DES or NULL encryption and deprecated SHA-1 message authentication method:
 - TLS_RSA_WITH_AES_256_CBC_SHA
 - TLS_RSA_WITH_AES_128_CBC_SHA
 - TLS_RSA_WITH_3DES_EDE_CBC_SHA
 - TLS_RSA_WITH_NULL_SHA

Rationale

A weak cipher defines an encryption/decryption algorithm that uses a key of insufficient length. Using a key with insufficient length could cause an attack where the encryption scheme could be broken.

I01 - Group Policy Implementation Example

To establish the recommended configuration via Group Policy, set the following UI path to

Computer Configuration\Policies\Administrative Templates\Network\SSL
Configuration Settings\SSL Cipher Suite Order

Enabled:TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256,TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256,TLS_DHE_RSA_WITH_AES_256_GCM_SHA384,TLS_DHE_RSA_WITH_AES_128_GCM_SHA256

This group policy setting is backed by the following registry:

HKLM\System\CurrentControlSet\Control\Cryptography\Configuration\Local\SSL\00010002:Functions

A reboot of the operating systems is required for these changes to be reflected.

Note: Please be aware, that you need to use a correct syntax for this setting - this means that every Cipher suite must be delimited by comma only (without spaces), that the exact name of the Cipher suite must be used and that the length of the complete string does not exceed 1,023 characters.

Impact:

Cipher ordering is important to ensure that the most secure ciphers are listed first and will be applied over weaker ciphers when possible.

I02 - PowerShell Implementation Example

To configure TLS cipher suite order using PowerShell enter the following commands:

```
New-Item 'HKLM:\SOFTWARE\Policies\Microsoft\Cryptography\Configuration\SSL\00010002' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SOFTWARE\Policies\Microsoft\Cryptography\Configuration\SSL\00010002' -name
'Functions' -value
'TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_ECDSA_WITH_AES_
128_GCM_SHA256,TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256,TLS_DHE_RSA_WITH_AES_256_GCM_SHA384,TLS_DHE_RSA_WIT
H_AES_128_GCM_SHA256' -PropertyType 'String' -Force | Out-Null
```

Listing: BL968-0325_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

Impact:

Cipher ordering is important to ensure that the most secure ciphers are listed first and will be applied over weaker ciphers when possible.

C01 - PowerShell Check Example

To verify using PowerShell enter the following command:

```
$RegKey = "HKLM:\SOFTWARE\Policies\Microsoft\Cryptography\Configuration\SSL\00010002"
$RegValue = "Functions"
$ExpValue =
"TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_ECDSA_WITH_AES_
128_GCM_SHA256,TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256,TLS_DHE_RSA_WITH_AES_256_GCM_SHA384,TLS_DHE_RSA_WIT
H_AES_128_GCM_SHA256"
$result = (Get-ItemProperty -Path $RegKey).$RegValue
if (($result) -eq ($ExpValue))
{
    "Registry value '$RegValue' for TLS Cipher Suite Ordering correctly set to '$ExpValue'."
} else {
    "Registry value '$RegValue' for TLS Cipher Suite Ordering not correctly set to '$ExpValue' but to
'$result'."
}
```

Listing: BL968-0325_C01_01.ps1

Crossreferences

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): created (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens IIS 10 (BL115). Changed during review: Added 'Policies' to the UI path in the Implementation.

Rules not based on Group Policy Objects or Preferences (GPOs, GPPs)

3rd Party Tools

BL968-0322

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Enable the Corporate Scan Service Agent

Rule Enable the *Corporate Scan Service* Agent for every system (clients and servers) connected to and/or operated within the [Siemens Corporate Network](#).

Note: To address found vulnerabilities, the IT system must be registered correctly in the respective corporate repositories and the data must be kept up-to-date.

E01 - System operated in a network environment isolated from the Siemens network

This rule is not mandatory, if the system is operated in a network environment isolated from the [Siemens Corporate Network](#), where the Corporate Scan Service Agent Endpoint is not reachable.

Description

The *Vulnerability Scanning* team provides the *Corporate Scan Service* to analyze Siemens IT systems connected to the Intranet or to the Internet looking for known vulnerabilities. To that end, the *Corporate Scan Service* uses a software agent on each IT systems to provide better and more accurate results than a normal network scan.

After installation, the software agent connects to the central scanning application, scans regularly the server for known vulnerabilities, and reports back the scan results.

Rationale

It is essential that the *Corporate Scan Service* has the possibility to scan regularly all Windows servers for known vulnerabilities which will be reported to the asset manager of the server giving him or her the ability to fix this vulnerability.

I01 - Implementation Example

The installation instructions for the respective *Corporate Scan Service* Agent can be found at [Siemens-Intranet: IPINsplus Home](#), which is in the responsibility of the *Vulnerability Scanning* team.

Any questions regarding the *Corporate Scan Service* software agent shall be sent to the *Vulnerability Scanning* team via the email support.ipinsplus@siemens.com.

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Rephrased exemption to clarify standalone systems with Siemens Corporate Network access. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0066

Asset Manager

C	I	A
123	123	123

Enable an Endpoint Detection and Response Agent

Rule Enable an *Endpoint Detection and Response* Agent for every system (clients and servers) connected to and/or operated within the [Siemens Corporate Network](#):

- **Default agent for all systems (which do not have specific legal, regulatory or security requirements):**
For all systems **which do not have specific legal, regulatory or security requirements** , the cloud based *CrowdStrike* agent shall be installed.
- **For systems with specific legal, regulatory or security requirements:**
For systems that have a legal, regulatory or security requirement not to have a cloud-based agent installed and where data cannot be processed by a third-party, the *Carbon Black* agent shall be installed instead of the *CrowdStrike* agent.
The approved environments in scope for the installation of the *Carbon Black* agent can be found at *Siemens Intranet: Endpoint Detection and Response* [4].

Description

Advanced persistent threats and customized targeted malware attack toolkits are intentionally bypassing traditional signature-based antivirus solutions. *Endpoint Detection and Response* solutions supplement traditional signature-based technologies for richer behavior-based anomaly detection and visibility across endpoints. *Endpoint Detection and Response* tools offer greater visibility into endpoint data that is relevant for detecting and mitigating advanced threats, limiting sensitive data loss, and reducing the risk of devastating data breaches occurring on endpoints.

Rationale

The *Endpoint Detection and Response* (EDR) agent at Siemens allows our Cyber Defense Centers (CDC) to continuously detect threats on all Siemens endpoints (e.g., clients, servers) based on advanced threat detection capabilities and up-to-date threat intelligence. The standard solutions and concepts of the Cyber Defense Center (CDC) for threat detection & analysis on hosts (endpoints) shall be used in any endpoint connected to the Siemens Intranet. If an incident is detected in an endpoint through the EDR agent, the normal security incident handling process is followed.

I01 - Implementation Example

The installation instructions for the respective *Endpoint Detection and Response* Agent can be found at *Siemens Intranet: Endpoint Detection and Response* [4], which is in the responsibility of the Cyber Defense Center (CDC).

Any questions regarding the *Endpoint Detection and Response* agents shall be sent to the Cyber Defense Center (CDC) via the email endpoint-detection.infosec@siemens.com.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 09.4.2-02

Based on Siemens Information Security Policy Framework Rule 12.2.1-01

Based on Siemens Information Security Policy Framework Rule 12.4.1-01

Based on Siemens Information Security Policy Framework Rule 12.4.1-03

Based on Siemens Information Security Policy Framework Rule 12.6.1-01

Based on Siemens Information Security Policy Framework Rule 12.6.1-02

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0422

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Install a Virus Scanner

Rule Enable a virus scanner which complies with the following:

- The virus scanner must be activated at all times,
- The virus signatures and the scanner itself must be kept up-to-date,
- All files must be scanned "on-access".

Note: If an exception to this rule is required, try to solve this issue by excluding specific directories from "on-access" scan and scan these directories in regular intervals instead.

E01 - Servers for which the Siemens VCC does not provide a solution

If [Siemens Virus Competence Center](#) does not provide an antivirus solution for specific servers, the use of Windows Defender is allowed. However, you must implement all rules laid down in the chapter "Windows Defender" of this Security Measure Plan concerning Windows Defender.

Description

The numbers of new viruses and backdoors for Microsoft products are still on high level. Virus scanners close the gap between public awareness of a security vulnerability and patch management applying a security patch. Current antivirus solutions include heuristics that even attempt to detect zero-day attacks.

The Siemens VCC provides the central virus protection support in terms of a basic service to all Siemens Units for operational concepts, distribution, installation and maintenance of the necessary tools as well as for necessary information and alerts.

Rationale

If an attacker is able to execute malware on a system, he or she might take over control of the system.

I01 - Implementation Example

All settings are configured automatically by your service provider.

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942); simplified *Exemption* and *Implementation* as the required settings are now part of separate rules.

Accounts and Permissions

BL968-0771

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Kerberos Delegation

Rule Do not use Kerberos delegation.

Note: Any exception from this rule requires the approval by the [Chief Cybersecurity Officer, CCSO](#) for OneAD (IT Infrastructure).

E01 - Domain Controller

The computer account of a (writable) Domain Controller requires and may be configured to use unconstrained delegation.

E02 - Constrained Delegation

If Kerberos delegation is mandatorily required in server's application scenario, only use Kerberos constrained delegation with a restrictive and minimized list of resources/services that are allowed to be accessed.

Additionally, extensive security monitoring and secure operating in an isolated and protected network setup is required.

Description

Kerberos delegation enables an application or service to re-use a user's Kerberos ticket for accessing further network sources. For example, this might be useful when a user is accessing with his or her account to a web server and the web service has further to read or write information on a database server depending on the specific user rights. Without delegation the web service could only use its own unspecific rights for each user.

Using Constrained delegation limits delegated access to specific service types. It might even be possible to use other protocols than Kerberos. Using Unconstrained delegation allows delegated access to any service using Kerberos.

Rationale

A hostile service or application can take the credentials of a logged-on user to access further network resources.

If an attacker brings a server with enabled unconstrained delegation under his or her control, the attacker can use the TGT tickets of each user connecting to the server. The TGT ticket allows the attacker to get access to any resource with the user's permissions.

Constrained delegation limits the access to the specified service type(s) and should be preferred to unconstrained delegation.

Discovering all domain computers with enabled delegation is a one-liner in PowerShell. Attackers might try to compromise these specific computers to get delegated access to user tickets and to use them for further malicious actions.

I01 - Disable Delegation

1. Go to a computer account in 'Users and Computers',
2. Select 'Properties',
3. Select 'Delegation',
4. Select 'Do not trust this computer for delegation' to disable'.

I02 - Enable Constrained Delegation

1. Go to a computer account in 'Users and Computers',
2. Select 'Properties',
3. Select 'Delegation',
4. Select 'Trust this computer for delegation to specified services only',
 - Select 'Kerberos only' if you do not want to allow protocol transition,
 - Select 'Use any authentication protocol' if you want to allow protocol transition, Add only the services to which the delegation is allowed.

Impact:

Servers with Kerberos Delegation become a target for attackers.

I03 - Enable Unconstrained Delegation

1. Go to a computer account in 'Users and Computers',
2. Select 'Properties',
3. Select 'Delegation',
4. Select 'Trust this computer for delegation to any service (Kerberos only)'.

Impact:

Servers with Kerberos Delegation, especially Unconstrained Kerberos Delegation, become a prime target for attackers.

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Added Note to the Rule. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0004

Asset Manager

C	I	A
123	123	123

Reset Password of kbrtgt Account Regularly (DC only)

Rule

Reset the password of

- the *krbtgt* account for writable Domain Controllers,
- the *krbtgt_####* accounts for each Read-Only Domain Controller,

at least every 90 days.

Description

Kerberos authentication is achieved by the use of tickets enciphered with a symmetric key derived from the password of the server or service to which access is requested. To request such a session ticket, a special ticket, called the *Ticket Granting Ticket* (TGT) must be presented to the Kerberos service. The TGT is enciphered with a key derived from the password of the *krbtgt* account, which is known only by the Kerberos service.

Every *krbtgt* account is a special account existing once in each domain. Although disabled, the account has, like any other account, the last two passwords stored in the Active Directory database. Its passwords can be obtained by an attacker during a domain compromise and allows to gain privileges associated with any account (including domain administrator).

A *Read-Only Domain Controller* (RODC) uses a different *krbtgt* account and password than the *Key Distribution Center* (KDC) on a writable domain controller uses when it signs or encrypts *ticket granting ticket* (TGT) requests. This provides cryptographic isolation between KDCs in different branches, which prevents a compromised RODC from issuing service tickets to resources in other branches or a hub site. The *krbtgt* account for RODCs follows the name standard *krbtgt_#####* (where # is a number greater than 32737).

Rationale

A stolen *krbtgt* account password can wreak havoc on the whole Siemens network because it can be used to impersonate authentication throughout the organization thereby giving an attacker access to sensitive data.

One way to help mitigate the risk of a bad actor using a compromised *krbtgt* key to forge user tickets is by periodically resetting the *krbtgt* account password. Resetting this password on a regular basis reduces the useful lifetime of *krbtgt* keys, in case one or more of them is compromised.

I01 - Writable DCs

Microsoft provides a detailed description of the *krbtgt* reset password process and a PowerShell script that carries all required steps to successfully reset the *krbtgt* password.

More information can be found here: [Microsoft Security - KRBtgt Account Password Reset Scripts now available for customers](#).

Note: Perform the password reset twice within 24 hours to ensure there is no password history maintained.

I02 - Read Only DCs

The *krbtgt_####* account of a Read-Only Domain Controller has to be changed manually:

Go to Administrative Tools -> Active Directory Users and Computers on a centrally located Domain Controller. For every *krbtgt_####* account:

- Select the *krbtgt_####* account,
- Reset the password of the *krbtgt_####* account.

Note: Perform the password reset twice within 24 hours to ensure there is no password history maintained.

Impact:

To avoid any operational issues the second password reset should be initiated earliest after all writable DCs in the domain have replicated the keys derived from the new password. It is also advisable to wait for 10 hours (the default value for the Maximum lifetime for user ticket) to avoid authentication failures caused by old TGTs.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0177

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Permissions on Shared Folders

Rule Ensure no local folders are shared.

If it is inevitable to share a folder, then the following requirements have to be implemented:

- Grant permissions to shared folders temporarily,
- Assign Write or Read permissions to specific users or dedicated groups. Never assign these two permissions to very general groups, such as Domain Users, Authenticated Users, Everyone, or siemens.net\Forest Users,
- Apply the need-to-know principle when setting access permissions to shared folders,
- Regularly examine if the permissions of a shared folder are properly assigned.

Note: Windows grants access to shared folders by taking into consideration the *effective permissions*, that is, share permissions and the NTFS permissions. Thus, it is sufficient to only adjust either the NTFS or the share permissions.

E01 - Shares automatically created by the system or applications

This rule does not apply to those shares which are automatically created by the system or applications (e.g., IPC\$, print\$, DFS-Root).

Description

When sharing a folder with Microsoft Windows built-in tools, Windows uses two types of permissions to determine whether the user has the right permissions:

- NTFS permissions: Permissions applicable to files and folders (local or shared),
- Share permissions: Permissions applicable to shared folders (e.g., who can control access to the share itself (who is allowed to connect to/mount the share)).

To determine the **effective permissions** on a shared folder, Windows combines the two types of permissions and the more restrictive applies. For example, if a user has *Modify* NTFS permissions but only *Read* Share permissions, the user will only have *Read* permission.

Rationale

If a user gives too much permission on a shared folder, company proprietary information might become accessible by users which shall not have access to. For example, when the user assigns *Read* permission to the built-in group *Everyone*.

By default, *Sharing Wizard* assigns *Full Control* Share permissions to the built-in group *Everyone* and *Advance Sharing* assigns *Read* permissions to *Everyone*.

I01 - Implementation Example

Execute regularly the following PowerShell script with administrative privileges, for example by setting up a scheduled task, to remove the Share permissions assigned to general groups:

```
$groups = "Everyone", "NT AUTHORITY\Authenticated Users", "Domain Users", "BUILTIN\Users"
$shares = Get-SmbShare -Special $false
ForEach ($share in $shares) {
    $users = Get-SmbShareAccess -Name $share.Name
    ForEach ($user in $users) {
        if ($groups -contains $user.AccountName) {
            Revoke-SmbShareAccess -Name $share.Name -AccountName $user.AccountName
        }
    }
}
```

Listing: BL968-0177_I01_01.ps1

Note: Add as many groups as deemed necessary in the variable *groups*. You can also adjust the permissions manually:

1. Open Windows Explorer and navigate to the folder to share,
2. Right-click the folder, point to *Share with*, and click *Specific people...*,
3. Select *Find people...* from the drop-down list, search the user you want to share the folder with, and click *Share*,
4. Right-click the folder, and click *Properties*,
5. Assign the necessary Share permissions (*Sharing* tab) and NTFS permissions (*Security* tab) the user needs.

C01 - Obtain a list of non-admin shared folders

Execute the PowerShell command with administrative privileges to obtain a list of non-admin shared folders:

```
Get-SmbShare -Special $false
```

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed during review: Rephrased rule text. Rephrased exemption 01. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0271

Asset Manager

C	I	A
123	123	123

Special Protection of High-Value Accounts

Rule Enable special protection of high-value accounts.

Description

After obtaining an initial foothold, attackers often go after high-value accounts. These accounts include accounts that are used for managing DCs or other critical systems. To make it harder for an attacker to compromise such an account and make detection easier, first it has to be determined which accounts are high-value in an environment. Then special protection steps can be taken.

- Only Kerberos authentication can be used (no NTLM, WDigest, or CredSSP),
- Delegation (forwarding) of credentials is not allowed,
- Cached logons are not possible (cached password verifiers are not stored).

Note: It does not make sense to add accounts for services and computers to the Protected Users group as this group does not provide local protection due to the fact that the password or certificate is always available on the host.

Note #2: Account credentials can still be lost in other ways, e.g., by using them for interactive logon to a compromised system. Restricted Admin Mode for RDP can help in such a scenario.

Rationale

Domains running in Windows Server 2012 R2 domain functional level offer a new security group **Protected Users**. Accounts in this group are better protected against credential theft (including so called Pass-the-Hash attacks). To achieve this, certain restrictions apply:

- Only Kerberos authentication can be used (no NTLM, WDigest, or CredSSP),
- Delegation of credentials [BL968-0771 Kerberos Delegation](#) is not allowed,
- Cached logons are not possible (cached password verifiers are not stored),
- A specific auditing of High-Value accounts is introduced. More information can be found here: [BL968-0516 Configure 'Auditing Privileged Group Members Logons'](#).

I01 - Implementation Example

1. Determine which groups/accounts are high-value in your environment and follow best practices for high-value accounts:
 - Keep the number of high-value accounts to a minimum. Especially, keep the membership (either direct or indirect/nested) in high-value groups to a minimum. Generally, all high-value groups should have less than 20 members. Beyond that, the Enterprise Admins and Schema Admins groups should generally be empty and contain accounts only temporarily when needed for a specific task.
 - Follow the principle of least privilege: Do not use a high-value account for a task that can

be done by a lower-value account. For example, do not use an Enterprise Administrators or Domain Administrators account to troubleshoot an issue if it can be examined using a local Administrator or even regular user account.

- Use dedicated accounts only, do not use a high-value account as your regular user account.
- Password requirements must be implemented.
- An owner must be defined.
- Extended monitoring of account activity that produces alerts in timely fashion in case of abuse has to be performed.

2. Collect all high-value domain accounts. Discuss with your domain provider adding the accounts to Protected Users domain group.

Impact:

New members of the group "Protected users" might show a changed behavior, e.g., NTLMv2 logon is no longer available.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-1066

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Use Domain User Accounts

Rule

Only use domain user accounts and disable all local user accounts.

E01 - Additional user accounts

Specific local user accounts are permitted, if there is an unavoidable reason due to for instance, commercial software products requiring local user accounts. However, when a local user account is required, the following actions must be taken:

1. The purpose of the local account must be documented in the account description section,
2. The owner or responsible for the local account must be identified in the account description section.

E02 - Additional administrator account

A dedicated local administrator account different than the built-in administrator is allowed to ensure access to the server in case network connection to a Domain Controller is not possible. The usage for other administrative or operational purposes is not allowed.

E03 - Privileged Access Management Solutions

Additional local user accounts with administrative privileges are permitted for user accounts which are **exclusively** managed and used by Privileged Access Management solutions, such as CyberArk, using automated session establishment hiding account credentials from connecting user.

Description

Windows domains allow the use of Group Policies to centrally manage different configurations for users and computers. However, these policies only apply to domain users, and not to local user accounts. Siemens Group Policies are defined in such a way that they ensure an adequate level of security for domain user accounts.

Rationale

If the local account policies are not properly defined, an attacker might compromise a local user account taking advantage of the inadequate level of security applied and, for example, obtain the password of the local account. If the user utilizes the same password for his local and domain accounts, the attacker will automatically get access to the domain account.

I01 - Implementation Example

Use the procedure below to disable all local user accounts:

1. Open the *Computer Management* console (compmgmt.msc),

2. In the left pane, expand *Local Users and Groups*, and select *Users*,
3. In the right pane, right-click all local users accounts (one by one), and click *Properties*,
4. For each user, select the check box *Account is disabled* to disable the account.

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942). Changed during review: Added exemption E03 for PAM solutions.

BL968-0416

Asset Manager

C	I	A
123	123	123

Users allowed for Remote Desktop

Rule

Restrict Remote Desktop access to the server to a defined set of users.

E01 - Exemption

This rule is not mandatory, if the role 'Remote Desktop Services' is disabled.

Description

The Remote Desktop Users group on the server controls who can connect via Remote Desktop to the server. Note that members of the local Administrators group are by default allowed to access the server, whether or not they are included in the Remote Desktop Users group.

Rationale

To prevent unauthorized access, Remote Desktop connections to a server have to be restricted to the users who require this access for their work responsibilities.

Note: Keep Remote Desktop access disabled if not required.

I01 - Implementation Example

Add users allowed for Remote Desktop access to Remote Desktop Users group

Start -> Run `lusrmgr.msc` -> Groups -> Remote Desktop Users

Note: Assign Write or Read permissions to specific users or dedicated groups. Never assign these two permissions to very general groups, such as Domain Users, Authenticated Users, Everyone, or `siemens.net\Forest Users`.

Impact:

Members in Remote Desktop Users are granted the right to logon remotely.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Active Directory

BL968-0049

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Domain Controller Hardening

Rule

Ensure that servers owning the role 'Active Directory Domain Services' are hardened accordingly.

Description

Domain Controllers are the heart of a Microsoft Active Directory domain. As their security hardening has relevance for the whole Microsoft environment at Siemens, specific hardening rules have to be applied on servers owning the role 'Active Directory Domain Services'. Just to name a few specific Domain Controller related topics:

- DNS Configuration,
- DC Built-in Administrator Account,
- Fine-Grained Password Policies,
- Dedicated System Management.

Rationale

If an attacker is able to compromise a DC, access to all accounts can be gained. For this reason, DCs are high-value targets for an attacker, and have to be protected accordingly.

I01 - Implementation Example

Before building up a Domain Controller in Siemens' Active Directory, you need to get in contact with the OneAD team to clarify the current hardening requirements for a Domain Controller. OneAD's service website can be found here <https://intranet.siemens.com/onead>.

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Aligned implementation. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Audit

BL968-0516

Asset Manager

C	I	A
123	123	123

Configure 'Auditing Privileged Group Members Logons'

Rule

Enable auditing of privileged group members logons.

Description

Windows Server 2012 and above come with a feature allowing the audit of logons of privileged group members (so called Special Groups Feature).

More information can be found here: [Microsoft Security Blog: Special Groups Audit](#).

There are two prerequisites for using the feature:

- The domain audit policy 'Audit Special Logon' needs to be configured,
- The special groups (=high-value groups) must be configured by adding their SIDs to a registry value.

Rationale

The main advantage of the feature is that it provides a comprehensive event (ID 4964) listing the group memberships at the time of the logon without requiring multi-event and/or multi-server correlation. Thus, for attack detection and incident handling, this feature is very useful.

I01 - Implementation Example

1. Ensure that the rule [BL968-5251 Ensure 'Audit Special Logon' is set to 'Success'](#) has been applied.
2. Build the registry value (if it does not exist, add it as a REG_SZ value)
HKLM\System\CurrentControlSet\Control\Lsa\Audit\SpecialGroups by concatenating the SIDs for
 - the high-value groups determined as per rule [BL968-0271 Special Protection of High-Value Accounts](#)
 - the groups Domain Controllers (SID: S-1-5-21-<domain>-516), Read-only Domain Controllers (SID: S-1-5-21-<domain>-521)

Replace <domain> with the relevant information for your domain to obtain the full SIDs.

If you have additional environment-specific highly privileged groups (e.g., used for system management with Administrator-level access) in your domain, add their SIDs as well.

Additionally, in a Windows domain the following well-known Security identifiers should be set:

S-1-5-32-548;S-1-5-32-544;
S-1-5-32-551;S-1-5-32-550;
S-1-5-32-549;
S-1-5-21-776561741-789336058-725345543-512;
S-1-5-21-776561741-789336058-725345543-516;
S-1-5-21-776561741-789336058-725345543-521;
S-1-5-21-1482476501-261903793-725345543-519;
S-1-5-21-1482476501-261903793-725345543-518

Note: The whole value needs to be put in one line; the breaks are included here for formatting reasons only.

More information about well-known SIDs and the referring group names can be found here: [Windows support: Well-known security identifiers in Windows operating systems](#).

Impact:

Logons of privileged group members will be audited.

Version History (Latest Entry)

v2.0 (2021-10-08): revised

Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

BL968-0486

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Configure 'Audit User Mailbox Attribute' (DC only)

Rule

Enable auditing of modifications to a user's mailbox security attribute.

Description

Windows Audit logs have the capability to record whenever attributes of user objects in the Siemens AD forest are being modified.

There are several prerequisites to monitor a certain attribute:

1. The SACL of the objects and attributes in question need to be adjusted to allow certain audit events to be written to the event log,
2. The domain Advanced Audit policy 'Directory Service Access', and 'Directory Service Changes' need to be configured.

Rationale

Several incidents in the recent past have shown that one of the mailbox attributes of a user object is a very critical property. It needs to be audited to be able to document who had access to a user's email box at any given time.

I01 - Implementation Example

1. Using ADSIedit.msc or a similar tool, modify the SACL for the msExchMailboxSecurityDescriptor attribute in all OUs of an AD domain that contain user accounts:
 - Connect to domain, navigate to root/container,
 - Select properties, switch to Security tab,
 - Click Advanced, switch to Auditing tab,
 - Add Everyone, Switch to Properties tab,
 - Apply onto Descendant User objects,
 - Access: Write msExchMailboxSecurityDescriptor, [X] Successful
2. Check, that the rules concerning Advanced Audit policy 'Directory Service Access' (see [BL968-4586 Ensure 'Audit Directory Service Access' is set to 'Failure' \(DC only\)](#)), and 'Directory Service Changes' (see [BL968-1611 Ensure 'Audit Directory Service Changes' is set to 'Success' \(DC only\)](#)) have been applied.

Notes:

- This rule can only applied on domains with Exchange,
- This rule must be applied only on one DC.

Impact:

Modifications to a user's mailbox security attribute will be audited.

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Specified more precisely in the Implementation which Audit policies need to be configured. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942); linked to corresponding audit rules.

Operating System

BL968-0180

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Check Windows Service Paths

Rule

Verify on a regular basis and after you have installed/updated programs that the executable file paths of all Windows services are properly quoted.

Description

A Windows service is an application that runs in the background and normally for a long period of time. Each Windows service has defined the absolute path of the executable file, plus optional parameters, and switches. Windows internally uses the space character to properly differentiate between the executable file path and the optional parameters and switches when parsing the service command line. Quotation marks are then used to properly identify the path to the executable file (e.g., "C:\Program Files\Program\File.exe"). For example, if a service uses the unquoted executable file path *C:\Program Files\Test 1\Service.exe* within a service path, Windows will sequentially try to execute the following files:

- C:\Program.exe
- C:\Program Files\Test.exe
- C:\Program Files\Test 1\Service.exe

Default Windows services paths are properly quoted by default.

Rationale

Services installed by new software might use insecure absolute unquoted paths, which an attacker could take advantage of by inserting a malicious binary in the path of the affected service and gain elevated privileges to the system.

I01 - Implementation Example

Execute the PowerShell script below with administrative privileges to fix the vulnerable services. You can schedule a task to execute the script every time a user logs in:

```
$quotationregex = '^([^\"]|\\s|\\.exe)(.*)'
$services = Get-WmiObject -Query 'SELECT * FROM Win32_Service'
ForEach ($service in $services) {
    If ($service.PathName -Match '^([^\"]|\\s|\\.exe)' ) {
        $quotedServicePath = $service.PathName -replace $quotationregex, '"$1"$2'
        $registryLocation = "HKLM:\SYSTEM\CurrentControlSet\Services\" + $service.Name
        Try {
            Set-ItemProperty -Path $registryLocation -Name "ImagePath" -Value $quotedServicePath
            $service.PathName = $quotedServicePath
        } Catch {
            Write-Error ("Unable to fix the service: " + $service.Name)
        }
    }
}
```

Listing: BL968-0180_I01_01.ps1

C01 - Checking Windows Service Paths

The PowerShell script below lists all Windows services whose service paths are not properly quoted:

```
[bool] $unquoted_found = $false
$services = Get-WmiObject -Query 'SELECT * FROM Win32_Service'
ForEach ($service in $services) {
    If ($service.PathName -Match '^([^\"]|\\s|\\.exe)' ) {
        "Service name: " + $service.Name
        "Display name: " + $service.DisplayName
        "Path to executable: " + $service.PathName + "`r`n"
        $unquoted_found = $true
    }
}
if (!$unquoted_found) {"Perfect! No unquoted service paths found!"}
```

Listing: BL968-0180_C01_01.ps1

If it does not list any services this means that all services have a correctly quoted path.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Changed script in Implementation and Check section. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942) and Siemens Windows 10 (BL696).

BL968-0002

EVAL until 2022-02-28

Asset Manager

C	I	A
123	123	123

Configure 'DACLS for Windows Services'

Rule

Do not grant the advanced permissions below to non-privileged user accounts, such as *Authenticated Users*, *Everyone*, *Domain Users*, or *Guests*:

- Change template (SERVICE_CHANGE_CONFIG): Change the configuration of a service, for example the startup type.
- Change permissions (WRITE_DAC): Modify the permissions (DACL) associated with the service.
- Take ownership (WRITE_OWNER): Change the owner and group members of the service.

Installation packages provided by local or central service providers need to be checked for correct DACLS before making the package available for installation.

Regularly monitor, for example by setting a scheduled task, the DACLS associated with Windows services to detect non-privileged accounts with the permissions mentioned above.

Description

Microsoft Windows uses the Service Control Manager (SCM) to allow other programs to control and manage services on the local system as well as on remote machines. Each service has a Discretionary Access Control List (DACL) associated, in which the permissions of users and groups are assigned. Examples of permissions which can be assigned to services are: start and stop a service, delete a service, query the status of a service, or change a service's startup type.

By default, the built-in Windows services have properly configured DACL. However, DACL may be modified during the installation of new software or when making changes on the system (e.g., installing patches or service packs).

Rationale

If the DACL of a service is not properly configured, a malicious user might be able to manipulate it and change its configuration. For example, an attacker could change the path to the service executable of a service running with the *LOCAL SYSTEM* account, point it to a malicious file under his or her control, and get elevated privileges of the computer.

I01 - Implementation Example

The procedure below allows you to manually implement this rule or verify the correct execution of the script.

The following PowerShell script lists all services with a wrong DACL associated:


```
ForEach ($service in Get-Service)
{
    $sddl = sc.exe sdshow $service | where { $_ }
    $sd = New-Object System.Security.AccessControl.RawSecurityDescriptor ($sddl)

    ForEach ($acl in $sd.DiscretionaryAcl)
    {
        If ($acl.AceType -eq "AccessAllowed")
        {
            If ("S-1-1-0", "S-1-5-11", "S-1-5-32-545", "S-1-5-32-546" -contains $acl.SecurityIdentifier.Value)
            {
                If ($acl.AccessMask -band 2)
                {
                    $service.Name + ": User account " + $acl.SecurityIdentifier.Value + " has
SERVICE_CHANGE_CONFIG permissions"
                }
                If ($acl.AccessMask -band 262144)
                {
                    $service.Name + ": User account " + $acl.SecurityIdentifier.Value + " has WRITE_DAC
permissions"
                }
                If ($acl.AccessMask -band 524288)
                {
                    $service.Name + ": User account " + $acl.SecurityIdentifier.Value + " has WRITE_OWNER
permissions"
                }
            }
        }
    }
}
```

Listing: BL968-0002_I01_01.ps1

Note: The script only considers the accounts on the list below. Add more user accounts to the script as needed:

- S-1-1-0: Everyone
- S-1-5-11: Authenticated Users
- S-1-5-32-545: (Built-in) Users
- S-1-5-32-546: (Built-in) Guests

For each service found with the previous script, execute the command:

```
sc.exe sdshow "<service_name>"
```

This command returns a line representing a security descriptor, which has the following syntax:

```
D:(string_ace1)...(string_aceN)S:(string_ace1)...(string_aceN)
```

Each (string_ace) object represents an Access Control Entry (ACE) associated with the service. The syntax of this object is:

```
(ace_type;ace_flags;rights_str;obj_guid;inherit_obj_guid;acct_sid)
```

Identify all those ACE objects of the D: part where the acct_sid is AU for Authenticated Users, WD for Everyone, BU for Built-in Users, or BG for Built-in Guests, and the rights_str includes the tuple WD for WRITE_DAC, WO for WRITE_OWNER, or DC for SERVICE_CHANGE_CONFIG.

Remove the corresponding permission, and execute the command below to set a new security descriptor:

```
sc.exe sdset "<service_name>" "<new_security_descriptor>"
```

Example:

1. After executing the script from above, it returns the following message: "wzcsvc: User account S-1-5-11 has SERVICE_CHANGE_CONFIG permissions", which means that the group *Authenticated Users* has the permission SERVICE_CHANGE_CONFIG.
2. Execute the command
`sc.exe sdshow wzcsvc`
to obtain the service descriptor of the service:
D: (A;;;CCDCLCSWRPWPDTLOCRSDRC;;;AU) (A;;;CCLCSWLOCRRRC;;;IU)
S: (AU;FA;SWRPWPDTLOCRSD;;;WD)
3. In the first parenthesis, you can identify the permission SERVICE_CHANGE_CONFIG (DC) assigned to the *Authenticated Users* (AU) group: (A;;;CCDCLCSWRPWPDTLOCRSDRC;;;AU)
4. Remove the *DC* tag from the *rights_str* part, and execute the command below to set the new security descriptor:
`sc.exe sdset wzcsvc "D: (A;;;CCLCSWRPWPDTLOCRSDRC;;;AU)
(A;;;CCLCSWLOCRRRC;;;IU) S: (AU;FA;SWRPWPDTLOCRSD;;;WD) "`

C01 - Checking for wrongly configured services

Execute the PowerShell command `BL968-0118_I01_01.ps1` listed above in the *Implementation* section - if it does not list any services this means that all services are correctly configured.

Crossreferences

Based on Siemens Information Security Policy Framework Rule 12.1.1-05

Version History (Latest Entry)

v2.0 (2021-10-08): modified (EVAL until 2022-02-28)

Aligned implementation. Not part of CIS Windows Server 2016. Aligned with Siemens Windows Server 2019 (BL942).

Definitions

Application

Computer program that performs specific functions for users or other IT/OT applications.

Examples of IT/OT Applications are:

- Database programs, such as SQL Server or Oracle database,
- Web browsers, such as Google Chrome,
- Development tools, such as Visual Studio,
- Office suites, such as Microsoft Office,
- Operating systems, such as Microsoft Windows,
- Software related to manufacturing and industrial control processes.

Asset Manager (AM)

Asset Managers are individuals who hold the overall technical responsibility for [IT Assets](#) (e.g., IT systems, applications, IT services, networks, OT systems, IoT devices). They serve as the primary technical point of contacts for their [IT Assets](#) and are accountable for, among others, their installation, maintenance, and implementation of all security technical requirements.

All [IT Assets](#) shall have an Asset Manager assigned.

Asset Managers can delegate, for example to a Support Organization, the responsibility of the actions associated with the role but the accountability always remains with the Asset Managers, even when the asset is operated by third-parties.

Depending on the type of [IT Asset](#), other names may be used, such as *IT System Manager*, *Application Manager*, *IT Service Manager*, *Cloud Asset Manager*, *Network Manager*, or *IT Operations Manager*.

Chief Cybersecurity Officer, CCSO

Each of the following tasks refers to the respective area of responsibility:

- Implements Cybersecurity governance and guidance
- Represents organizational units in CSB
- Responsible for appointing, empowering and advising dedicated Cybersecurity roles for the organizational units in alignment with the respective CEO
- Implements adequate awareness programs for Cybersecurity within the organization
- Provides regular Cybersecurity status and risk reports to the respective CEO/COO and the GCCSO
- Has a functional reporting line to the GCCSO (where legally possible)
- Defines decentral Cybersecurity requirements and regulations corresponding to the Cybersecurity Framework and provides them to the responsible CEO for enacting
- Regularly measures and re-assesses the maturity level of Cybersecurity in the respective organization based on the pre-defined procedures (e.g. KPIs, PSS Maturity)
- Drives continuous improvement

IT Asset

Type of Corporate Asset. It is any piece of software or hardware within an IT/OT environment.

For the scope of the Siemens Cybersecurity Policy Framework, IT Asset refers to:

- IT Services,
- IT Systems,
- Applications,
- Network Zones,
- OT systems,
- IoT devices.

IT System

It consists of the hardware and software which is needed to manage the computer resources at a low level. It includes the operating system itself as well as all the utility programs and drivers it needs. It also includes OT and IoT devices and their firmware or software.

Examples of IT Systems are:

- Windows or Unix servers,
- Windows or Unix client desktops,
- Multifunctional devices (copy/scan machines),
- Mobile devices, such as smartphones or tablets,
- Network components, such as routers or switches,
- Data storage media,
- Robotic Process Automation (RPA) or business process automation technologies,
- OT devices, such as industrial controllers,
- IoT devices, such as smart sensors.

Privileged Account

Account with Privileged Access Rights on [IT Systems](#) and [Applications](#).

User, Shared User, and Service Accounts are considered Privileged Accounts if they do have privileged access rights on an [IT System](#) or [Application](#).

Service Account

Account not assigned to or used by an individual or group of individuals and which is used by an [IT System](#) or [Application](#) to perform tasks without human-interaction (e.g., account run by a Web Server to query a remote database).

Service Accounts may be considered standard or privileged accounts depending on whether they have privileged or administrative access rights on the IT system or application or not.

Examples are operating system accounts, application accounts, remote login accounts - no matter if they are locally or centrally managed.

Shared User Account

Account used by several individuals rather than a single person.

Shared User Accounts may be considered standard or privileged accounts depending on whether they have privileged access rights on IT systems or applications or not.

Examples are operating system accounts, application accounts, remote login accounts - no matter if they are locally or centrally managed.

Siemens Corporate Network

Internal network zones operated by or on behalf of Siemens in their entirety.

Standard Account

Account without Privileged Access Rights on [IT Systems](#) or [Applications](#).

User, Shared User, and Service Accounts are considered Standard Accounts if they do not have Privileged Access Rights on [IT Systems](#) or [Applications](#).

Glossary

ACP

Abbreviation of Asset Classification and Protection.

Siemens' process to systematically identify critical assets and ensure the development and implementation of adequate protection concepts. More information can be found at <https://intranet.for.siemens.com/cms/056/en/processes/security/Pages/acp.aspx> and at <https://wiki.siemens.com/display/en/ACP>.

Azure AD Identity Protection

Azure AD Identity Protection is a cloud-based security solution from Microsoft that helps Siemens to protect your identity by leveraging automated detection and remediation mechanisms for identity-based risks. These risk events are detected automatically, most in real-time or when you are signing into applications using Azure AD, e.g. Office 365 (e.g. Yammer, SharePoint, or Outlook). After the detection of a risk event, the system will automatically calculate a risk score, based on which it might try to remediate it by requiring multi-factor authentication (MFA) to proof your identity. With Azure AD Identity Protection, the probability of an identity being misused by third parties can be minimized, without manual intervention or additional administration overhead. It enhances a balance between maximum security and usability with automated Multi-Factor Authentication (MFA) when we detect a risk event.

Microsoft Defender for Identity

Microsoft Defender for Identity is a cloud-based security solution that leverages the on-premises Active Directory signals to identify, detect, and investigate advanced threats, compromised identities, and malicious insider actions directed at the organization. It helps to monitor users, entity behavior, and activities with learning-based analytics.

References

[1] Siemens CYS GRS PR *Siemens Information Security Policy Framework*.

<https://sfera.siemens.com/policies>

[2] Siemens ST TO (2019). *Siemens Circular No. 105 "Implementation of Siemens-Internal Regulations in Affiliated Companies"*. <https://srs.siemens.cloud/#/c/ng233c>

[3] CHR (2017). *CHR Circular No. 44/2013, 4th addendum: "Konzernbetriebsvereinbarung über Speicherung Und Auswertungen von Daten über Zugriffe Auf Dateien Im Siemens-Konzern-Netzwerk Und Auf Das Internet/Intranet"*.

https://wse04.siemens.com/content/P0006195/Shared%20Documents/dir2010_2019/2013/HRRS201344_04_KBV_Auswertungen_Daten_Internet_Intranet.pdf

[4] Siemens CYS *Siemens Endpoint Detection and Response (EDR)* .

<https://defense.siemens.com/cdc/edr/>